



# NIST Cybersecurity Framework 2.0

Companion Guide for VMware Cloud Foundation 9.1

June 2026

## Table of Contents

|                                           |    |
|-------------------------------------------|----|
| Disclaimer.....                           | 7  |
| Version.....                              | 8  |
| Introduction.....                         | 8  |
| Third Party Identifiers and Mappings..... | 8  |
| Coverage Levels.....                      | 8  |
| Controls.....                             | 9  |
| Control DE                                | 9  |
| Control DE.AE                             | 11 |
| Control DE.AE-02                          | 16 |
| Control DE.AE-03                          | 20 |
| Control DE.AE-04                          | 24 |
| Control DE.AE-06                          | 28 |
| Control DE.AE-07                          | 32 |
| Control DE.AE-08                          | 34 |
| Control DE.CM                             | 38 |
| Control DE.CM-01                          | 41 |
| Control DE.CM-02                          | 47 |
| Control DE.CM-03                          | 48 |
| Control DE.CM-06                          | 54 |
| Control DE.CM-09                          | 60 |
| Control GV                                | 65 |
| Control GV.OC                             | 67 |
| Control GV.OC-01                          | 68 |
| Control GV.OC-02                          | 69 |
| Control GV.OC-03                          | 70 |
| Control GV.OC-04                          | 71 |
| Control GV.OC-05                          | 72 |
| Control GV.OV                             | 75 |
| Control GV.OV-01                          | 76 |
| Control GV.OV-02                          | 77 |
| Control GV.OV-03                          | 78 |
| Control GV.PO                             | 79 |
| Control GV.PO-01                          | 80 |

|                  |     |
|------------------|-----|
| Control GV.PO-02 | 81  |
| Control GV.RM    | 82  |
| Control GV.RM-01 | 83  |
| Control GV.RM-02 | 84  |
| Control GV.RM-03 | 85  |
| Control GV.RM-04 | 86  |
| Control GV.RM-05 | 87  |
| Control GV.RM-06 | 88  |
| Control GV.RM-07 | 89  |
| Control GV.RR    | 90  |
| Control GV.RR-01 | 91  |
| Control GV.RR-02 | 92  |
| Control GV.RR-03 | 93  |
| Control GV.RR-04 | 94  |
| Control GV.SC    | 95  |
| Control GV.SC-01 | 96  |
| Control GV.SC-02 | 97  |
| Control GV.SC-03 | 98  |
| Control GV.SC-04 | 99  |
| Control GV.SC-05 | 101 |
| Control GV.SC-06 | 102 |
| Control GV.SC-07 | 106 |
| Control GV.SC-08 | 109 |
| Control GV.SC-09 | 113 |
| Control GV.SC-10 | 114 |
| Control ID       | 115 |
| Control ID.AM    | 116 |
| Control ID.AM-01 | 119 |
| Control ID.AM-02 | 123 |
| Control ID.AM-03 | 127 |
| Control ID.AM-04 | 131 |
| Control ID.AM-05 | 132 |
| Control ID.AM-07 | 135 |
| Control ID.AM-08 | 136 |

|                  |     |
|------------------|-----|
| Control ID.IM    | 140 |
| Control ID.IM-01 | 141 |
| Control ID.IM-02 | 145 |
| Control ID.IM-03 | 149 |
| Control ID.IM-04 | 150 |
| Control ID.RA    | 154 |
| Control ID.RA-01 | 155 |
| Control ID.RA-02 | 159 |
| Control ID.RA-03 | 161 |
| Control ID.RA-04 | 163 |
| Control ID.RA-05 | 164 |
| Control ID.RA-06 | 165 |
| Control ID.RA-07 | 166 |
| Control ID.RA-08 | 170 |
| Control ID.RA-09 | 174 |
| Control ID.RA-10 | 178 |
| Control PR       | 179 |
| Control PR.AA    | 180 |
| Control PR.AA-01 | 185 |
| Control PR.AA-02 | 190 |
| Control PR.AA-03 | 191 |
| Control PR.AA-04 | 196 |
| Control PR.AA-05 | 201 |
| Control PR.AA-06 | 206 |
| Control PR.AT    | 207 |
| Control PR.AT-01 | 208 |
| Control PR.AT-02 | 209 |
| Control PR.DS    | 210 |
| Control PR.DS-01 | 216 |
| Control PR.DS-02 | 223 |
| Control PR.DS-10 | 230 |
| Control PR.DS-11 | 236 |
| Control PR.IR    | 242 |
| Control PR.IR-01 | 247 |

|                  |     |
|------------------|-----|
| Control PR.IR-02 | 251 |
| Control PR.IR-03 | 255 |
| Control PR.IR-04 | 259 |
| Control PR.PS    | 265 |
| Control PR.PS-01 | 271 |
| Control PR.PS-02 | 277 |
| Control PR.PS-03 | 281 |
| Control PR.PS-04 | 285 |
| Control PR.PS-05 | 291 |
| Control PR.PS-06 | 297 |
| Control RC       | 298 |
| Control RC.CO    | 303 |
| Control RC.CO-03 | 305 |
| Control RC.CO-04 | 307 |
| Control RC.RP    | 308 |
| Control RC.RP-01 | 312 |
| Control RC.RP-02 | 317 |
| Control RC.RP-03 | 321 |
| Control RC.RP-04 | 324 |
| Control RC.RP-05 | 328 |
| Control RC.RP-06 | 333 |
| Control RS       | 337 |
| Control RS.AN    | 341 |
| Control RS.AN-03 | 345 |
| Control RS.AN-06 | 346 |
| Control RS.AN-07 | 350 |
| Control RS.AN-08 | 353 |
| Control RS.CO    | 354 |
| Control RS.CO-02 | 358 |
| Control RS.CO-03 | 362 |
| Control RS.MA    | 366 |
| Control RS.MA-01 | 370 |
| Control RS.MA-02 | 374 |
| Control RS.MA-03 | 378 |

|                  |     |
|------------------|-----|
| Control RS.MA-04 | 379 |
| Control RS.MA-05 | 383 |
| Control RS.MI    | 387 |
| Control RS.MI-01 | 391 |
| Control RS.MI-02 | 395 |

## Disclaimer

This document is intended to provide general guidance for organizations that are considering Broadcom solutions. The information contained in this document is for educational and informational purposes only. This document is not intended to provide advice and is provided “AS IS.” Broadcom makes no claims, promises, or guarantees about the accuracy, completeness, or adequacy of the information contained herein. Organizations should engage appropriate legal, business, technical, and audit expertise within their specific organization for review of requirements and effectiveness of implementations.

## Version

910-20260612-01

## Introduction

This document describes how VMware Cloud Foundation (VCF) 9.1 and the separately licensed advanced services assessed alongside it, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, and VMware Avi Load Balancer, can support organizations aligning with the NIST Cybersecurity Framework (CSF) 2.0. The CSF organizes cybersecurity outcomes into six core functions (Govern, Identify, Protect, Detect, Respond, and Recover) and is applicable to organizations of all sizes and sectors. Each assessed product is reported separately for every control, with VCF covering the full platform, including its consumption services and Private AI Services capabilities. The responsibility for identifying the organization's risk profile and implementing the framework remains with the organization.

<https://www.nist.gov/cyberframework>

This guidance evolves. Please check the current revision at: <https://bcm.tech/vcf-compliance>

## Third Party Identifiers and Mappings

This document includes regulatory compliance and security control identifiers from external sources as a convenience to end users. This does not constitute endorsement, in either direction.

There is not a one-to-one mapping of product capabilities to third-party controls. A product capability, or set of capabilities, may be applicable to multiple controls. Conversely, a control may be satisfied with the use of multiple capabilities.

Control identifier numbers have been included from the Secure Controls Framework, version 2026.1, under the terms of the Creative Commons Attribution-NoDerivatives 4.0 International Public License. No modifications have been made to the control identifier numbers under the terms of the license.

<https://securecontrolsframework.com/>

## Coverage Levels

Each control entry below carries the framework control text, the SCF control or controls it maps to, and an Aggregate Coverage line showing the strongest position any one of the assessed products holds for that control. Products that meet or contribute to the control follow as subsections, each with its own coverage level and response. Products the control does not apply to are listed together at the end of the entry, with a brief explanation. The coverage levels are:

- **Meets** -- the product directly provides the capability described in the control. No additional organizational process, external product, or human activity is needed beyond configuring the product itself.
- **Contributes** -- the product provides technical capabilities that help satisfy the control, but the control also requires something outside the product to be fully met, such as an organizational process, human activity, or an additional tool.
- **Not Applicable** -- the control does not apply to the product. Physical facility controls, staffing decisions, organizational governance processes, and domains the product does not operate in fall here.
- **Not Supported** -- the control is relevant to the product's domain (infrastructure, networking, security), but the product lacks the specific capability the control requires.
- **Not Assessed** -- the control has not yet been evaluated against the product.



## Controls

### Control DE

> [Withdrawn: Incorporated into PR.DS-01, DE.CM-09] [Withdrawn: Incorporated into ID.RA-09, DE.CM-09] Networks and network services are monitored to find potentially adverse events. The physical environment is monitored to find potentially adverse events. Personnel activity and technology usage are monitored to find potentially adverse events. [Withdrawn: Incorporated into DE.CM-01, DE.CM-09] External service provider activities and services are monitored to find potentially adverse events. [Withdrawn: Incorporated into DE.CM-01, DE.CM-03, DE.CM-06, DE.CM-09] [Withdrawn: Incorporated into ID.RA-01] Computing hardware and software, runtime environments, and their data are monitored to find potentially adverse events. [Withdrawn: Incorporated into ID.AM-03] Potentially adverse events are analyzed to better understand associated activities. Information is correlated from multiple sources. The estimated impact and scope of adverse events are understood. [Withdrawn: Moved to DE.AE-08] Information on adverse events is provided to authorized staff and tools. Cyber threat intelligence and other contextual information are integrated into the analysis. Incidents are declared when adverse events meet the defined incident criteria. [Withdrawn: Incorporated into GV.RR-02] [Withdrawn: Incorporated into DE.AE] [Withdrawn: Incorporated into ID.IM-02] [Withdrawn: Incorporated into DE.AE-06] [Withdrawn: Incorporated into ID.IM, ID.IM-03]

**SCF Controls:** THR-01, THR-02, THR-03, THR-07, THR-09, THR-10

**Aggregate Coverage:** Contributes

#### VMware vDefend (Contributes)

VMware vDefend contributes to this control through its threat intelligence consumption and detection infrastructure. The IDS/IPS engine applies knowledge-based signatures that encode specific patterns corresponding to known attack types, detecting intrusions based on known malicious instruction sequences at distributed and gateway enforcement points within vDefend-protected segments. Threat metadata feeds for Network Detection and Response are distributed and can be refreshed from online sources, or downloaded and applied manually in air-gapped environments through NSX Manager or a workstation connected to the Security Services Platform.

Network Detection and Response (NDR) correlates related detection events into campaigns and organizes them into a chronological timeline for security analyst review and triage. The Campaign view displays total detections and threats identified under Malicious Activity, and Campaign Correlation Rules provide structured visibility into how individual detections relate to broader attack patterns.

Security Intelligence maps detected suspicious events to adversarial tactics and techniques from the MITRE ATT&CK framework, recording the count of each tactic and technique observed during a selected time period. This TTP-level categorization supports the situational awareness the control describes for traffic traversing vDefend-protected segments. The threat visualization canvas aids rapid containment, identification of compromised assets, and adjustment of microsegmentation policies in response to detected activity. The blast radius analysis capability displays which communication paths a threat has affected, helping analysts determine whether an attack targets specific systems or represents a wider campaign.

Security Intelligence also collects related IDS events across the same source and destination hosts to connect relevant events and build a fuller picture of an attack sequence. The vDefend Security Assessment generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows to support protection planning. Security teams investigate individual events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take mitigation actions.

While vDefend delivers technical mechanisms for consuming threat intelligence feeds and mapping observed behavior to adversarial TTPs at the network layer, the broader organizational threat intelligence program, including sourcing intelligence from external providers, integrating with threat sharing platforms, and disseminating findings to other teams and tools, requires complementary processes and tooling outside the product.

### VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to situational awareness of evolving threats at the application delivery layer through its Live Security Threat Intelligence service, which delivers security threat feeds for multiple attack vectors in real time to protect applications from continuously changing threats. The Live Security Threat Intelligence service encompasses four components: an IP Reputation Service, an Application Rules Service, a WAF Signatures Service, and a Bot Management Service. The service is opt-in and must be explicitly enabled through Cloud Services configuration on the Avi Controller.

The IP Reputation Service classifies incoming client IP addresses against a regularly updated database, covering threat categories including botnets, phishing, spam sources, and DoS/DDoS attack sources. The service performs real-time automatic IP Reputation updates and operates across globally distributed Avi Load Balancer Controller clusters.

Administrators attach an IP Reputation database to virtual services, and enforcement actions such as blocking or rate-limiting are applied per classification result.

The Application Rules Service provides rules specifically designed to block attacks on known application vulnerabilities, many of them mapped to CVEs, covering protection for over 5,000 applications including WordPress, Drupal, and Apache. Application Rules are automatically updated on the Avi Controller, and administrators can enable auto-sync to receive Application Rules Database updates automatically when new rules are published.

The WAF Signatures Service allows Avi to receive notifications when new Core Rule Set (CRS) data is available and to automatically download updated WAF CRS rules. This keeps application-layer defenses aligned with current vulnerability intelligence without requiring manual administrator action.

The Bot Management Service delivers a real-time feed for the User-Agent database, a core bot detection component. User Agent Database Sync can be enabled to receive continuous User-Agent updates for threat detection. Traffic is classified into categories including Bad Bot, Dangerous Bot, Good Bot, Human, Unknown, and User-defined Bot, and HTTP security policy rules apply enforcement actions including connection termination for dangerous bot classifications.

When Avi detects security events such as SYN flood or DDoS conditions, its alerting and ControlScript framework supports automated compensating responses. Alert actions can invoke a ControlScript that adds offending client IP addresses to a blocklist IP group attached to a network security policy for rate shaping or blocking. ControlScripts receive alert parameters including attack count, event ID, and alert level, and can execute automated remediation in response to system events rather than requiring manual intervention. The DDoS Policy within the Network Security policy detects and mitigates a range of Layer 4 through Layer 7 network attacks.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control DE.AE

> [Withdrawn: Incorporated into ID.AM-03] Potentially adverse events are analyzed to better understand associated activities. Information is correlated from multiple sources. The estimated impact and scope of adverse events are understood. [Withdrawn: Moved to DE.AE-08] Information on adverse events is provided to authorized staff and tools. Cyber threat intelligence and other contextual information are integrated into the analysis. Incidents are declared when adverse events meet the defined incident criteria. [Withdrawn: Incorporated into DE.AE] [Withdrawn: Incorporated into DE.AE-06]

**SCF Controls:** IRO-01, IRO-02, IRO-02.4, MON-01, MON-01.12, MON-01.8

**Aggregate Coverage:** Meets

### VCF (Meets)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

### **VMware vDefend (Contributes)**

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) contributes to enterprise-wide monitoring controls through a layered set of observability capabilities covering database health, infrastructure compliance, and event-driven alerting.

DSM provides a built-in monitoring framework that tracks database instance health across multiple dimensions. From the Monitoring tab in the DSM UI or the vSphere Client, administrators and authorized users can view real-time and historical metrics for database VMs, including CPU Health, Data Disk Health, System Disk Health, Max Connections, Active Connections, Write Throughput, Read Throughput, Thread Resource Utilization, Slow Queries per Second, InnoDB Buffer Usage, and InnoDB Reads and Writes. The Monitoring page defaults to the last three hours of aggregated metric data, with the time range adjustable through the Time Range Last dropdown. This visibility supports detection of resource contention, performance degradation, and connectivity anomalies at the database layer.

DSM's alert framework provides configurable thresholds for warning and critical conditions on key health indicators. Administrators and users can set separate warning and critical thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters. When thresholds are exceeded, DSM generates typed alerts such as Database Engine Health, Custom Config Health, and Backup Storage Health alerts. DSM monitors database replication status and raises an alert when a secondary database is not replicating data from the primary. DSM also raises an alert when metrics are no longer being received from a cluster, supporting detection of monitoring gaps. Alerts can be activated or deactivated per data service through the "Enable Alerts for DB Alert" setting, providing granular control over which databases are subject to active alerting. For each alert, DSM provides mitigation suggestions to help administrators resolve issues without disrupting database services.

In addition to database-level alerts, DSM generates global infrastructure alerts that surface vCenter integration and infrastructure policy issues. These include `INFRASTRUCTURE_POLICY_VC_ALARMS`, raised when vCenter resource alarms are active; `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, which reflect cluster compliance state;

VCENTER\_CONNECTIVITY, raised when vCenter connectivity fails and triggering troubleshooting steps that include verifying connectivity and checking authentication logs; and LicensingNotUpdated and vCenterBinding API status alerts that surface license and API integration conditions. A Global Alerts page in the DSM UI provides a centralized view of these alerts during and after installation and ongoing operation.

In 9.1, DSM integrates with VCF Operations to extend observability beyond the DSM UI. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state and displays a Data Services View dashboard showing active alerts and inventory items. VCF Operations presents performance data across three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for KPIs including Active Connections, Commits, Rollbacks, and Deadlocks. This integration requires configuring the connection between DSM and VCF Operations before use.

DSM also adds SQL Server as a supported database type, with dedicated monitoring through an integrated InfluxDB instance and Telegraf agents deployed across the provider appliance and SQL Server workload clusters. The monitoring framework supports metrics-based and status-condition-based alerts for SQL Server, covering database engine degradation, non-operational status, and automated or transaction log backup failure conditions.

DSM supports event notification to external systems through a webhook integration. Webhooks transmit alert notifications containing the triggered date, triggered time, triggered user email, task status, previous status, and task type. This allows DSM alerts to feed into centralized monitoring or incident management platforms maintained by the organization. DSM generates plug-in registration logs that administrators can review for vCenter connectivity errors, and DSM's troubleshooting guidance directs administrators to review active vCenter infrastructure alarms and resolve underlying issues identified through the alert system.

Enterprise-wide monitoring requires organizational decisions about monitoring architecture, log aggregation platforms, alerting policies, and operational response procedures that lie outside DSM's scope. DSM provides the data and integration points; the organization must determine how those signals are collected, correlated, and acted upon across the broader environment.

### **VMware Avi Load Balancer (Contributes)**

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER\_HEALTH\_DEGRADED, POOL\_HEALTH\_DEGRADED, and VS\_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.



## Control DE.AE-02

> Potentially adverse events are analyzed to better understand associated activities

**SCF Controls:** IRO-02, IRO-02.4

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.



VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

### **VMware vDefend (Contributes)**

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

#### **VMware Avi Load Balancer (Contributes)**

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER\_HEALTH\_DEGRADED, POOL\_HEALTH\_DEGRADED, and VS\_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

## Control DE.AE-03

> Information is correlated from multiple sources

**SCF Controls:** IRO-02, IRO-02.5, MON-02, MON-02.1

**Aggregate Coverage:** Meets

### VCF (Meets)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

### **VMware vDefend (Contributes)**

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

#### **VMware Avi Load Balancer (Contributes)**

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER\_HEALTH\_DEGRADED, POOL\_HEALTH\_DEGRADED, and VS\_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.



## Control DE.AE-04

> The estimated impact and scope of adverse events are understood

**SCF Controls:** GOV-16, IRO-02, IRO-02.4

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.



VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

### **VMware vDefend (Contributes)**

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

#### **VMware Avi Load Balancer (Contributes)**

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER\_HEALTH\_DEGRADED, POOL\_HEALTH\_DEGRADED, and VS\_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

## Control DE.AE-06

> Information on adverse events is provided to authorized staff and tools [Withdrawn: Incorporated into DE.AE-06]

**SCF Controls:** IRO-02, IRO-02.4, IRO-04, IRO-07, IRO-09, IRO-10, MON-01.12, MON-01.8, MON-02, MON-02.1

**Aggregate Coverage:** Meets

### VCF (Meets)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

### **VMware vDefend (Contributes)**

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

#### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) provides several capabilities that support ongoing event log review. The primary interface for reviewing non-database-related operations is the System Audit Events view, accessible through the System Audit section of the Provider interface. This view records and displays DSM management-plane operations in a structured format, including the Component field (which DSM component performed the operation), Event Type (the type of audited event or operation), Event Details (operation-specific details for the event), Event Time in UTC, Status, and Source. The Source field records either a user identifier (Email ID) for user-initiated events or "System" for events initiated by DSM without user intervention. Administrators can review these events directly in the UI or export them in CSV or XLSX format using the ACTIONS drop-down menu in the System Audit Events view. Exports include all audit events visible to the reviewing user, regardless of how many events appear on a single page, enabling complete off-platform analysis and reporting.

In addition to the System Audit Events view, DSM provides Gateway Audit Logs accessible through the Audit Logs section. Gateway Audit Logs track user read and write operations to DSM data services and infrastructure objects performed in the DSM UI or the DSM Gateway Kubernetes interface. Gateway audit log files are stored on the Provider VM at `/var/log/tdm/provider/audit/` with filenames in the format `gateway-audit-timestamp.log`, and are retained for the last five days on the Provider VM. When a default S3 provider log repository is configured, DSM archives these files periodically to an S3 subpath named "gateway audit," supporting log retention for ongoing and retrospective review. The gateway audit logs contain standard Kubernetes audit events but do not record the content of secrets.

DSM generates a structured set of alerts to support proactive monitoring and help surface conditions that may require investigation. At the infrastructure level, DSM raises an `INFRASTRUCTURE_POLICY_VC_ALARMS` alert when one or more active infrastructure resource alarms are detected in VMware vCenter, and generates alerts for vCenterBinding API status and LicensingNotUpdated conditions. DSM also generates a `VCENTER_CONNECTIVITY` alert when vCenter connectivity fails; troubleshooting steps include verifying vCenter connectivity, checking vCenter authentication logs, and verifying that the service account is not locked. At the database level, DSM provides an Alerts pane in the Monitoring tab where administrators can monitor alerts triggered on databases, covering conditions such as CPU Health, Data Disk Health, System Disk Health, Max Connections, Custom Config Health, and Database Engine Health. Administrators can configure and edit alert threshold values and time limits for warning and critical severities on these conditions, allowing organizations to tune alerting sensitivity to their operational requirements. DSM supports webhook-based alerting for database monitoring events triggered by threshold violations, enabling integration with external notification systems.



Organizations that deploy the VCF Operations integration can extend monitoring visibility. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state, displays active alerts and inventory items on the Data Services View dashboard, and surfaces performance data at three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for database-specific metrics such as Active Connections, Commits, Rollbacks, and Deadlocks.

DSM provides the audit event records, alert generation, export capabilities, log archival, and optional VCF Operations integration needed to support a log review program. The review cadence, escalation thresholds, escalation workflows, and incident management procedures are organizational responsibilities that must be defined and operated separately. Integration with a SIEM or centralized log management platform is also an organizational decision.

### **VMware Avi Load Balancer (Contributes)**

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER\_HEALTH\_DEGRADED, POOL\_HEALTH\_DEGRADED, and VS\_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

## Control DE.AE-07

> Cyber threat intelligence and other contextual information are integrated into the analysis

**SCF Controls:** THR-01, THR-03, THR-10

**Aggregate Coverage:** Contributes

### VMware vDefend (Contributes)

VMware vDefend contributes to this control through its threat intelligence consumption and detection infrastructure. The IDS/IPS engine applies knowledge-based signatures that encode specific patterns corresponding to known attack types, detecting intrusions based on known malicious instruction sequences at distributed and gateway enforcement points within vDefend-protected segments. Threat metadata feeds for Network Detection and Response are distributed and can be refreshed from online sources, or downloaded and applied manually in air-gapped environments through NSX Manager or a workstation connected to the Security Services Platform.

Network Detection and Response (NDR) correlates related detection events into campaigns and organizes them into a chronological timeline for security analyst review and triage. The Campaign view displays total detections and threats identified under Malicious Activity, and Campaign Correlation Rules provide structured visibility into how individual detections relate to broader attack patterns.

Security Intelligence maps detected suspicious events to adversarial tactics and techniques from the MITRE ATT&CK framework, recording the count of each tactic and technique observed during a selected time period. This TTP-level categorization supports the situational awareness the control describes for traffic traversing vDefend-protected segments. The threat visualization canvas aids rapid containment, identification of compromised assets, and adjustment of microsegmentation policies in response to detected activity. The blast radius analysis capability displays which communication paths a threat has affected, helping analysts determine whether an attack targets specific systems or represents a wider campaign.

Security Intelligence also collects related IDS events across the same source and destination hosts to connect relevant events and build a fuller picture of an attack sequence. The vDefend Security Assessment generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows to support protection planning. Security teams investigate individual events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take mitigation actions.

While vDefend delivers technical mechanisms for consuming threat intelligence feeds and mapping observed behavior to adversarial TTPs at the network layer, the broader organizational threat intelligence program, including sourcing intelligence from external providers, integrating with threat sharing platforms, and disseminating findings to other teams and tools, requires complementary processes and tooling outside the product.

### VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to situational awareness of evolving threats at the application delivery layer through its Live Security Threat Intelligence service, which delivers security threat feeds for multiple attack vectors in real time to protect applications from continuously changing threats. The Live Security Threat Intelligence service encompasses four components: an IP Reputation Service, an Application Rules Service, a WAF Signatures Service, and a Bot Management Service. The service is opt-in and must be explicitly enabled through Cloud Services configuration on the Avi Controller.

The IP Reputation Service classifies incoming client IP addresses against a regularly updated database, covering threat categories including botnets, phishing, spam sources, and DoS/DDoS attack sources. The service performs real-time automatic IP Reputation updates and operates across globally distributed Avi Load Balancer Controller clusters. Administrators attach an IP Reputation database to virtual services, and enforcement actions such as blocking or rate-limiting are applied per classification result.

The Application Rules Service provides rules specifically designed to block attacks on known application vulnerabilities, many of them mapped to CVEs, covering protection for over 5,000 applications including WordPress, Drupal, and Apache.



Application Rules are automatically updated on the Avi Controller, and administrators can enable auto-sync to receive Application Rules Database updates automatically when new rules are published.

The WAF Signatures Service allows Avi to receive notifications when new Core Rule Set (CRS) data is available and to automatically download updated WAF CRS rules. This keeps application-layer defenses aligned with current vulnerability intelligence without requiring manual administrator action.

The Bot Management Service delivers a real-time feed for the User-Agent database, a core bot detection component. User Agent Database Sync can be enabled to receive continuous User-Agent updates for threat detection. Traffic is classified into categories including Bad Bot, Dangerous Bot, Good Bot, Human, Unknown, and User-defined Bot, and HTTP security policy rules apply enforcement actions including connection termination for dangerous bot classifications.

When Avi detects security events such as SYN flood or DDoS conditions, its alerting and ControlScript framework supports automated compensating responses. Alert actions can invoke a ControlScript that adds offending client IP addresses to a blocklist IP group attached to a network security policy for rate shaping or blocking. ControlScripts receive alert parameters including attack count, event ID, and alert level, and can execute automated remediation in response to system events rather than requiring manual intervention. The DDoS Policy within the Network Security policy detects and mitigates a range of Layer 4 through Layer 7 network attacks.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control DE.AE-08

> [Withdrawn: Moved to DE.AE-08] Incidents are declared when adverse events meet the defined incident criteria

**SCF Controls:** IRO-02, IRO-02.4

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

### **VMware vDefend (Contributes)**

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

#### **VMware Avi Load Balancer (Contributes)**

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER\_HEALTH\_DEGRADED, POOL\_HEALTH\_DEGRADED, and VS\_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

## Control DE.CM

> [Withdrawn: Incorporated into PR.DS-01, DE.CM-09] [Withdrawn: Incorporated into ID.RA-09, DE.CM-09] Networks and network services are monitored to find potentially adverse events. The physical environment is monitored to find potentially adverse events. Personnel activity and technology usage are monitored to find potentially adverse events. [Withdrawn: Incorporated into DE.CM-01, DE.CM-09] External service provider activities and services are monitored to find potentially adverse events. [Withdrawn: Incorporated into DE.CM-01, DE.CM-03, DE.CM-06, DE.CM-09] [Withdrawn: Incorporated into ID.RA-01] Computing hardware and software, runtime environments, and their data are monitored to find potentially adverse events.

**SCF Controls:** IRO-03, MON-11.3, MON-16, THR-02

**Aggregate Coverage:** Meets

## VCF (Contributes)

VCF provides several capabilities that contribute to anomalous behavior detection and user activity monitoring, though it does not include a dedicated User & Entity Behavior Analytics (UEBA) or User Activity Monitoring (UAM) solution.

VCF Operations includes anomaly detection capabilities that use both dynamic and static thresholds to identify when metrics deviate from normal operating behavior. Dynamic thresholding is enabled by default and uses historical data analysis to establish baselines for each monitored object. The Smart Early Warning feature analyzes the number of applicable metrics that violate the dynamic threshold determining normal operating behavior, triggering alerts when the number of anomalies on an object exceeds a trending threshold. When an anomalous entity is detected, VCF Operations generates an outlier violation alert (vmwAnalyticsOutlierEvent, OID 37002), notifying administrators of unexpected behavior. A Critical threshold violation alert is also generated when anomalous entities are detected.

The Anomalies widget displays detected anomalies for a resource over the past six hours at configurable time intervals, with color-coded criticality indicators. The Anomaly Breakdown widget shows likely root causes for symptoms on a selected resource, helping operators triage issues. The Troubleshooting Workbench includes an Anomalous Metrics card that surfaces metrics exhibiting drastic changes within a selected scope and time window, ranked by degree of change with the most recent anomaly given the highest weighting. Administrators can also examine outlier VMs detected by VCF Operations to identify unexpected behavior and take corrective actions. VCF Operations supports outbound SNMP trap notifications, enabling alert delivery to external SNMP management systems with up to four configurable trap destinations.

For user activity monitoring, VCF Operations provides a User Activity Audit report that offers traceability of user actions including logging in, operations on clusters and nodes, changes to system passwords, certificate activation, and logging out. Each audit event has a detailed view containing information that supports analysis of events in the virtual infrastructure for suspicious user actions or system issues. Event auditing across the VCF platform provides visibility into platform interaction changes and surfaces suspicious access events and policy violations. Administrators should continuously monitor user security aspects to detect security risks early and respond to potential threats. VCF SSO maintains a dedicated audit log that captures user management events, including account creation, modification, deletion, and activation or deactivation, as well as changes to account credentials and profile information. The vSphere Client's Advanced Export feature allows administrators to export tasks performed by a specific user during a specified time range, providing targeted audit data for investigating suspicious activity.

Audit logging extends across VCF components. NSX Manager generates audit log messages that record user operations with fields for UserName, ModuleName, Operation, and Operation status, along with detailed resource change information and timestamps. NSX Manager audit logs also record failed login attempts with username and timestamp information, enabling tracking of access patterns across the environment. VCF Operations for Networks captures audit logs of administrative actions, including CRUD operations and login/logout events.

VCF Operations supports forwarding user activity audit logs to an external syslog server, enabling integration with dedicated SIEM or UEBA platforms for broader correlation and behavioral analysis. VCF Log Management includes content packs that

offer pre-built dashboards, alerts, and queries for VCF components. These content packs support security monitoring use cases such as tracking failed login attempts and privilege escalations.

VCF's built-in anomaly detection is primarily oriented toward infrastructure metrics and operational health rather than user behavior profiling. A dedicated UEBA or UAM solution consuming VCF's audit data would be needed to establish user behavior baselines, detect credential compromise through behavioral deviation, and provide the full scope of analytics this control requires. For organizations requiring deeper behavioral analysis, VMware vDefend extends VCF's monitoring foundation with IDS/IPS, network traffic inspection, and threat intelligence integration.

### **VMware vDefend (Meets)**

VMware vDefend (vDefend) provides IOC detection and visualization mechanisms through its Security Services Platform and Security Intelligence components. The Network Detection and Response (NDR) feature correlates related events into campaigns, organizes threat events within a campaign into a timeline for security analyst triage, and maps threats to the tactics and techniques described in the MITRE ATT&CK framework, giving analysts structured context for identifying signs of compromise.

The Security Services Platform Campaign Blueprint provides an interactive graphical view of correlated security events and key actors for incident investigation. Campaign graph nodes show "IOC for Threat" relationships connecting a specific Indicator of Compromise to a threat, and "Affected by an IOC" relationships identifying workloads affected by a given IOC. IOC Summary panels surface details for File IOC (file score, verdict, SHA hashes, and a View Reports link) and for Malware IOC (impact score, detection details, and malware family details). A workload summary panel within the Blueprint shows the workload's maximum impact score, IP address or UUID, and lists threats in which the workload acts as an attacker or is targeted.

Campaign Correlation Rules calculate an impact score based on detection types, threat severity, and the count of affected workloads, enabling prioritization of IOC-driven investigations. Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to further support response prioritization. The Security Overview Dashboard Threat Event Monitoring displays the number of intrusions detected in each severity category for unique intrusion signatures, giving security teams a current view of network activity.

Security teams can investigate individual threat events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take appropriate mitigation actions. The organizational process of formally defining and managing an IOC program, including sourcing, vetting, and curating IOCs, is a governance activity that vDefend's detection capabilities support but do not replace.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) provides application-layer anomaly detection mechanisms that contribute to meeting this control. The Anomalies Overlay feature, available in Virtual Service Analytics, Service Engine Analytics, and Pool Analytics, flags statistical deviations in traffic metrics as anomaly events when a specific metric deviates from the historical norm by more than four sigma during the anomaly period. Monitored metrics include CPU utilization, bandwidth, disk I/O, server response time, and connection rates. Each anomaly event is identified by entity name, entity type (Virtual Machine, Virtual Service, or Service Engine), and metric value, with a timestamp indicating when the deviation occurred. Anomaly detection operates against a moving-average baseline calculated from recent historical traffic. The Pool Anomalies Overlay also displays prediction interval upper and lower bounds alongside the anomalous value. Administrators can adjust detection granularity by changing the statistics time interval, and can configure alert filter sensitivity to tune the threshold for new alert generation. Note that anomaly recording is disabled when the statistics interval is set to Real Time; a non-real-time statistics interval is required for anomaly capture to function.

The Bot Management module adds a behavioral detection layer focused on credential stuffing and web attack patterns at the application proxy boundary. Bot Management detects malicious bots responsible for online fraud and credential stuffing attacks. The IP Reputation service extends detection by maintaining a database of categorized IP addresses and identifying anomalous traffic patterns, including DoS and DDoS activity and anomalous SYN floods.

For authentication-related anomalous behavior, Avi provides the `AUDIT_COMPLIANCE_EVENT` mechanism to log authentication failures for audit purposes, persisting them via the alerts infrastructure. The Web Application Firewall (WAF) App Log Analytics component captures events whenever a WAF application rule is triggered, recording the type of attack detected. Service Engines generate `DOS_ATTACK` alert events that include attack type, source IP addresses, virtual service UUID and name, and a report timestamp, supporting audit and forensic analysis of detected attacks. Avi also supports DataScripts for custom identification of suspicious traffic and execution of appropriate mitigation actions, enabling organizations to define custom behavioral detection logic beyond the built-in statistical baselines.

Avi monitors over 500 real-time metrics to support DDoS detection and attack visibility. Alerts from any of these mechanisms can be forwarded proactively to email, syslog, SNMP, or custom APIs, enabling integration with a central SIEM or security operations platform. Avi integrates with Splunk via the Avi Load Balancer Splunk Add-on, generating events that serve as an audit trail for user logins, configuration changes, and runtime state changes.

These capabilities operate at the application delivery and load balancing layer. An organization requires a dedicated UEBA or UAM platform to fulfill the full scope of this control, including identity-level behavioral baselines, user session correlation, and cross-system entity analytics that extend beyond application traffic visible to Avi.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control DE.CM-01

> Networks and network services are monitored to find potentially adverse events [Withdrawn: Incorporated into DE.CM-01, DE.CM-09] [Withdrawn: Incorporated into DE.CM-01, DE.CM-03, DE.CM-06, DE.CM-09]

**SCF Controls:** MON-01, MON-01.1, MON-01.3, MON-01.4, MON-01.8

**Aggregate Coverage:** Meets

### VCF (Contributes)

VCF provides enterprise-wide monitoring through integrated tools that span infrastructure health, performance metrics, compliance assessment, log analysis, and alerting.

VCF Operations continuously monitors the operational state of all VCF components to detect conditions that may affect availability or compliance. It collects metrics across compute, storage, and networking resources, and correlates them over time to identify trends that may lead to potential failures. VCF Health, a component of VCF Operations, continuously monitors the operational state of VCF components to verify they are functioning as expected, giving platform operators a single view of operational status. Platform operators can configure alerts, perform log analysis, run infrastructure diagnostics, and review VCF health from a unified interface.

VCF Operations provides continuous compliance management by monitoring infrastructure against industry-standard benchmarks and custom policies. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the monitoring posture to organizational requirements. The platform assesses objects based on selected compliance policies and activates alert definitions associated with the current scorecard, providing ongoing visibility into compliance status. Compliance-related alerts are triggered on objects and displayed through a dedicated compliance alert subtype.

The alerting subsystem in VCF Operations supports the full lifecycle of alert management. Administrators can configure and manage alert definitions to monitor infrastructure events and conditions, including performance metrics, log events, and custom conditions configured through the Management Pack Builder. The Platform Health Alerts page provides a centralized view of all alerts related to overall system health, including alerts from data sources and infrastructure nodes. Health alerts are generated for conditions that affect the health of the environment and require immediate attention. Administrators can create policies to govern how alert definitions are evaluated, including which objects to monitor and what thresholds to apply, and can apply consistent practices to optimize alert behavior across monitored objects.

VCF Operations supports flexible grouping and scheduling to align monitoring with operational realities. Custom groups can be configured with automatic membership criteria to support monitoring strategies and achieve a high level of automation. Maintenance schedules can be assigned to objects undergoing planned downtime to keep monitoring data accurate and avoid false alerts when an object is offline for scheduled maintenance.

VCF Log Management provides centralized log collection and analysis. It ingests logs from VMware vCenter, VMware ESX hosts, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture. The platform provides dashboards and analytics for troubleshooting and security investigation. Log-based alert definitions allow administrators to trigger notifications when specific log patterns appear across monitored systems. Log forwarding to external SIEM or syslog targets is configurable, with support for TLS encryption to protect log data in transit. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols. NSX Manager syslog supports TLS and requires port 6514 for encrypted log transmission.

At the vSphere layer, the alarm infrastructure integrates with events and performance counters to provide real-time alerting. The MetricAlarmExpression data object allows administrators to set alarms on specific performance metrics with configurable monitoring intervals and aggregation functions for processing data points. The vSphere Client provides direct visibility into tasks and events for change tracking and troubleshooting. VCF ships with preconfigured vSphere alarms that are active by default and monitor specific components including the Identity Management Service, Message Bus Configuration Service, ESX Agent Manager, VMware Service Control Agent, vSphere HA host status, and host connection and power state. The vCenter

Management Interface provides appliance-level health visibility through an Overall Health badge that reflects one of five states (Good, Warning, Alert, Critical, or Unknown) across all vCenter components, and notifies administrators of available security patches through Critical or Alert badge indicators when automatic patch checks are enabled.

When VCF Automation is integrated with VCF Operations, the Insights dashboard and Alerts tab provide real-time capacity awareness and alert information for VCF Automation objects, giving IT teams visibility into resource usage across both provisioned workloads and the underlying infrastructure. The VCF Automation Monitor tab surfaces deployment health information sourced from VCF Operations, and deployment cards display Last Request Status information that tracks the most recent operation on each deployment (Create, Update, or Delete) and its outcome (Successful, In Progress, or Failed). The Management Pack Builder allows administrators to set up event definitions for integrated systems, monitoring specific conditions or thresholds and configuring alerts for proactive management. Management Packs extend monitoring to network devices, including sensor monitoring for devices such as switches and routers. Adapters can be installed on VCF Operations nodes to extend monitoring to additional systems and data sources beyond the core VCF components.

The VMware Kubernetes Service (VKS) layer of VCF extends enterprise monitoring to container workloads and Kubernetes infrastructure. VKS clusters support MachineHealthCheck objects for both control plane nodes and worker node deployments; administrators manage these through the VCF CLI `vcf cluster machinehealthcheck` command, which supports configuration of unhealthy-condition definitions, maximum unhealthy thresholds (expressed as an absolute number or a percentage), and label selectors to target specific machines. The VCF CLI `vcf cluster machinehealthcheck node get` and `vcf cluster machinehealthcheck control-plane get` commands retrieve node and control plane health status on demand. VKS cluster health conditions, including the Ready and ControlPlaneReady status indicators, reflect the operational state of each cluster and are accessible via `kubectl` and the VCF CLI. The VCF Automation Provider Management UI includes a Services overview interface that exposes VKS cluster management functions and the health status of all cluster elements, giving platform operators a centralized view of the VKS tier. The Kubernetes API server within VKS clusters exposes diagnostic and health check endpoints (`/healthz`, `/livez`, `/readyz`, `/statusz`, and `/metrics`) that external monitoring systems can scrape to track API server availability and readiness; the `kube-apiserver` also emits the `kubernetes_healthchecks_total` counter and `kubernetes_healthcheck` gauge metric, which report structured health check status for components including `etcd` and `autoregister-completion`. Access to these monitoring endpoints is governed by the built-in Kubernetes `system:monitoring` RBAC group, which grants read access to liveness, readiness, and metrics endpoints while restricting broader cluster access. The Kubernetes Watch API allows monitoring tools to track changes to any API object as a live stream, supporting event-driven monitoring without continuous polling. The Node Problem Detector monitors node health and surfaces node-level problems as Kubernetes events and node conditions that external monitoring systems can consume via the event stream.

For workload-level monitoring within VKS clusters, Prometheus Operator is available as a standard package and defines custom resource definitions to deploy and manage Prometheus and Alertmanager StatefulSets, enabling high-availability alerting configurations. The Prometheus Alertmanager custom resource definition configures alert grouping, inhibition, and routing to external notification systems. The Istio service mesh, also available as a standard package on VKS clusters, provides service-level monitoring alongside its traffic management capabilities. The Dynatrace Operator can be deployed on VKS clusters to automate the deployment, scaling, and maintenance of the Dynatrace monitoring stack. Historical analysis, dashboarding, and alerting on cluster-level metrics require a dedicated monitoring solution configured to scrape the VKS metrics endpoints and subscribe to the Kubernetes event stream. The `vcf cluster support-bundler create` command gathers diagnostic information from Supervisor and VKS clusters when troubleshooting is needed.

At the network layer, NSX provides monitored indicators including node uptime status, deployment status, management and controller connections, tunnel status, PNIC status, and uptime duration. NSX time series APIs allow viewing data such as VPN statistics, including metadata about the number of tunnels configured and how many are up or down at a given time.

VCF Operations also supports self-monitoring through the VCF Operations adapter, which collects internal metrics such as activity success counts. This allows administrators to verify that the monitoring platform itself is functioning correctly. The VCF Operations policy engine monitors conditions and generates events to react to changing states in the orchestrator server or connected technologies. The Adapter Instance monitoring interval is configurable, with intervals as granular as five minutes.

VMware Private AI Services (PAIS) includes a built-in observability stack that supplies monitoring data for AI infrastructure and AI workloads. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the `pais-controller-manager` service, allowing collection by monitoring systems and visualization in observability platforms such as Grafana. Observability is activated by updating the `PAISConfiguration` custom resource with optional sections for Prometheus metrics collection and LLM trace forwarding. The Prometheus runtime can be configured with a specified storage class policy and a configurable metrics retention period, giving administrators control over how long monitoring data is stored. A Prometheus server pod must be in a ready and running state for observability to function.

LLM trace data from PAIS can be forwarded to an OpenTelemetry Collector endpoint over `http/protobuf` or `gRPC`, providing distributed tracing for AI model inference activity. The `observability.llmTraces` configuration governs trace forwarding and works alongside the Prometheus metrics pipeline to produce two signals: metrics for health and performance, and traces for inference-level behavior. PAIS Controller metrics include the Model Endpoint Controller and PAIS Configuration Controller, giving monitoring platforms component-level visibility into PAIS operations.

In 9.1, PAIS adds direct integration with VCF Operations. The `controller-pod-metrics-streaming` setting activates streaming of PAIS controller pod metrics from the Supervisor cluster to VCF Operations, allowing administrators to view PAIS metrics alongside other VCF infrastructure metrics. A Telegraf deployment in the `vmware-system-monitoring` namespace uses a `telegraf-user-config` ConfigMap to manage user-configured monitoring endpoints for PAIS. The VCF Consumption CLI connects to the Supervisor endpoint and enables VI administrators to stream metrics from the PAIS controller pod. DevOps engineers can visualize health and performance metrics for PAIS components running in a VCF Automation namespace using Grafana, and MLOps engineers and application developers can monitor the health, quality, and behavior of AI applications and the models used in agents through the same observability platforms.

PAIS supplies the technical monitoring mechanisms this control requires. Enterprise-wide orchestration of monitoring controls, including alert threshold definition, escalation procedures, and integration with a centralized monitoring or log management platform, remain organizational responsibilities.

### VMware vDefend (Meets)

VMware vDefend (vDefend) supports network security monitoring through multiple integrated capabilities that contribute to enterprise-wide monitoring frameworks.

Security Intelligence, hosted on the Security Services Platform (SSP), provides continuous visibility into network traffic flows across protected workloads. It monitors flows between application pairs, updates the Policy Protection Status for each application to indicate that flows are being monitored, and continuously detects new flows between environment pairs, alerting administrators to unauthorized or unexpected traffic. The Monitor & Plan Overview page presents a consolidated view of pending actions, data collection activity status, network security posture, flow trends, and a summary of suspicious traffic. The Security Intelligence Recommendations monitoring capability checks for changes in the scope of monitored entities every hour when the Monitoring toggle is enabled, allowing administrators to keep policy recommendations current as environments evolve. Segmentation Monitoring provides dedicated views of application and infrastructure flows with configurable time ranges spanning from the last hour to the last month, and displays flows related to detected infrastructure servers in a specified time interval.

The Network Detection and Response (NDR) Sensor checks the status of activated detection features every 15 minutes and updates its configuration accordingly, supporting sustained threat detection coverage. NDR Sensor health status monitoring tracks whether key components, including network traffic capture, file analysis, and data transmission, are operating properly. The NDR Sensor also sends alerts notifying administrators of conditions such as services being down, high CPU, memory, or disk usage, packet drops, or missed heartbeats. NDR provides role-based access control covering triage operations such as viewing detections and campaigns, as well as SIEM configuration management.

The Security Services Platform monitors its own health, with Yellow or Red health status indicators displayed when issues occur in subcomponents. SSP monitoring tracks the status of the flow clustering job that runs every hour and reports suspicious traffic detector execution status after each run, with values such as `SUCCESS`, `NOT_ENOUGH_BASELINE`, and `FAILURE`.

The Security dashboard provides a consolidated view for monitoring and configuring security features across network workloads. In federated deployments, the Global Manager provides centralized event management and monitoring for malicious IP blocking activity across all Local Managers.

vDefend generates Unified Security Logs that VCF Log Management can collect and analyze. These logs cover Distributed Firewall, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering activity. Broader log aggregation and SIEM correlation for enterprise-wide monitoring remain the responsibility of the SIEM and logging infrastructure deployed alongside vDefend.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.

The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) contributes to enterprise-wide monitoring controls through a layered set of observability capabilities covering database health, infrastructure compliance, and event-driven alerting.

DSM provides a built-in monitoring framework that tracks database instance health across multiple dimensions. From the Monitoring tab in the DSM UI or the vSphere Client, administrators and authorized users can view real-time and historical metrics for database VMs, including CPU Health, Data Disk Health, System Disk Health, Max Connections, Active Connections, Write Throughput, Read Throughput, Thread Resource Utilization, Slow Queries per Second, InnoDB Buffer Usage, and InnoDB Reads and Writes. The Monitoring page defaults to the last three hours of aggregated metric data, with the time range adjustable through the Time Range Last dropdown. This visibility supports detection of resource contention, performance degradation, and connectivity anomalies at the database layer.

DSM's alert framework provides configurable thresholds for warning and critical conditions on key health indicators. Administrators and users can set separate warning and critical thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters. When thresholds are exceeded, DSM generates typed alerts such as Database Engine Health, Custom Config Health, and Backup Storage Health alerts. DSM monitors database replication status and raises an alert when a secondary database is not replicating data from the primary. DSM also raises an alert when metrics are no longer being received from a cluster, supporting detection of monitoring gaps. Alerts can be activated or deactivated per data service through the "Enable Alerts for DB Alert" setting, providing granular control over which databases are subject to active alerting. For each alert, DSM provides mitigation suggestions to help administrators resolve issues without disrupting database services.

In addition to database-level alerts, DSM generates global infrastructure alerts that surface vCenter integration and infrastructure policy issues. These include `INFRASTRUCTURE_POLICY_VC_ALARMS`, raised when vCenter resource alarms are active; `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, which reflect cluster compliance state; `VCENTER_CONNECTIVITY`, raised when vCenter connectivity fails and triggering troubleshooting steps that include verifying connectivity and checking authentication logs; and `LicensingNotUpdated` and `vCenterBinding` API status alerts that surface license and API integration conditions. A Global Alerts page in the DSM UI provides a centralized view of these alerts during and after installation and ongoing operation.

In 9.1, DSM integrates with VCF Operations to extend observability beyond the DSM UI. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state and displays a Data Services View dashboard showing active alerts and inventory items. VCF Operations presents performance data across three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for KPIs including Active Connections, Commits, Rollbacks, and Deadlocks. This integration requires configuring the connection between DSM and VCF Operations before use.

DSM also adds SQL Server as a supported database type, with dedicated monitoring through an integrated InfluxDB instance and Telegraf agents deployed across the provider appliance and SQL Server workload clusters. The monitoring framework supports metrics-based and status-condition-based alerts for SQL Server, covering database engine degradation, non-operational status, and automated or transaction log backup failure conditions.

DSM supports event notification to external systems through a webhook integration. Webhooks transmit alert notifications containing the triggered date, triggered time, triggered user email, task status, previous status, and task type. This allows DSM alerts to feed into centralized monitoring or incident management platforms maintained by the organization. DSM generates plug-in registration logs that administrators can review for vCenter connectivity errors, and DSM's troubleshooting guidance directs administrators to review active vCenter infrastructure alarms and resolve underlying issues identified through the alert system.

Enterprise-wide monitoring requires organizational decisions about monitoring architecture, log aggregation platforms, alerting policies, and operational response procedures that lie outside DSM's scope. DSM provides the data and integration points; the organization must determine how those signals are collected, correlated, and acted upon across the broader environment.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) contributes to enterprise-wide monitoring through application-delivery-layer mechanisms built into the Avi Controller and Service Engines.

The Avi Controller monitors Service Engine metrics and sends alarms and notifications to administrators when resource utilization data exceeds defined thresholds. Administrators configure custom thresholds on Service Engine groups through the Resource Events tab in the Avi UI. The Alert feature processes system events and metrics against user-defined rules and generates alerts that trigger configured actions, including sending an email, a syslog message, or an SNMP trap. Alert notifications can be forwarded to remote syslog servers for integration with centralized log management and monitoring platforms.

ControlScripts extend this event-response capability: a ControlScript can alter Avi configuration or communicate to external systems, including through webhook integrations with external monitoring tools, in response to defined system events. This supports dynamic responses including resource scaling or automated notifications based on health scores from monitoring data.

The Avi Controller and Service Engines track health score changes and SSL certificate expiration events. Avi integrates with external monitoring tools such as Prometheus for metrics collection and analysis. User-Defined Metrics allow administrators to define and extract customized telemetry data for specific compliance or reporting needs through the API. Real-time metrics are available via API but deactivate by default after 30 minutes to conserve resources and must be reactivated when sustained real-time visibility is required.

At the data plane, Avi health monitors track the status of backend servers and Service Engines continuously. Service Engine health monitoring records detailed server operational status, including health monitor name, type, last transition timestamps, rise count, fall count, total checks, and total failed checks. Each health monitor can be assigned its own threshold and timeout period for server health validation. Monitors support HTTP, HTTPS, TCP, and UDP health-check protocols with configurable success and failure thresholds, send intervals, and receive timeouts.

In Kubernetes environments managed by the Avi Kubernetes Operator (AKO), the HealthMonitor custom resource definition (CRD) allows users to define custom health monitoring configurations for backend services with fine-grained control over health check parameters. The Avi Multi-Cluster Kubernetes Operator (AMKO) GlobalDeploymentPolicy supports health monitor references for consistent monitoring across multi-cluster deployments. Within VCF Automation, a HealthMonitor custom resource can create monitors for tracking backend pool member status using TCP, PING, and HTTP check types.

## Control DE.CM-02

> The physical environment is monitored to find potentially adverse events

**SCF Controls:** PES-01, PES-03, PES-03.3, PES-05

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control DE.CM-03

> Personnel activity and technology usage are monitored to find potentially adverse events [Withdrawn: Incorporated into DE.CM-01, DE.CM-03, DE.CM-06, DE.CM-09]

**SCF Controls:** MON-01, MON-16, MON-16.1, MON-16.3, NET-18

**Aggregate Coverage:** Meets

### VCF (Meets)

VCF provides enterprise-wide monitoring through integrated tools that span infrastructure health, performance metrics, compliance assessment, log analysis, and alerting.

VCF Operations continuously monitors the operational state of all VCF components to detect conditions that may affect availability or compliance. It collects metrics across compute, storage, and networking resources, and correlates them over time to identify trends that may lead to potential failures. VCF Health, a component of VCF Operations, continuously monitors the operational state of VCF components to verify they are functioning as expected, giving platform operators a single view of operational status. Platform operators can configure alerts, perform log analysis, run infrastructure diagnostics, and review VCF health from a unified interface.

VCF Operations provides continuous compliance management by monitoring infrastructure against industry-standard benchmarks and custom policies. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the monitoring posture to organizational requirements. The platform assesses objects based on selected compliance policies and activates alert definitions associated with the current scorecard, providing ongoing visibility into compliance status. Compliance-related alerts are triggered on objects and displayed through a dedicated compliance alert subtype.

The alerting subsystem in VCF Operations supports the full lifecycle of alert management. Administrators can configure and manage alert definitions to monitor infrastructure events and conditions, including performance metrics, log events, and custom conditions configured through the Management Pack Builder. The Platform Health Alerts page provides a centralized view of all alerts related to overall system health, including alerts from data sources and infrastructure nodes. Health alerts are generated for conditions that affect the health of the environment and require immediate attention. Administrators can create policies to govern how alert definitions are evaluated, including which objects to monitor and what thresholds to apply, and can apply consistent practices to optimize alert behavior across monitored objects.

VCF Operations supports flexible grouping and scheduling to align monitoring with operational realities. Custom groups can be configured with automatic membership criteria to support monitoring strategies and achieve a high level of automation. Maintenance schedules can be assigned to objects undergoing planned downtime to keep monitoring data accurate and avoid false alerts when an object is offline for scheduled maintenance.

VCF Log Management provides centralized log collection and analysis. It ingests logs from VMware vCenter, VMware ESX hosts, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture. The platform provides dashboards and analytics for troubleshooting and security investigation. Log-based alert definitions allow administrators to trigger notifications when specific log patterns appear across monitored systems. Log forwarding to external SIEM or syslog targets is configurable, with support for TLS encryption to protect log data in transit. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols. NSX Manager syslog supports TLS and requires port 6514 for encrypted log transmission.

At the vSphere layer, the alarm infrastructure integrates with events and performance counters to provide real-time alerting. The MetricAlarmExpression data object allows administrators to set alarms on specific performance metrics with configurable monitoring intervals and aggregation functions for processing data points. The vSphere Client provides direct visibility into tasks and events for change tracking and troubleshooting. VCF ships with preconfigured vSphere alarms that are active by default and monitor specific components including the Identity Management Service, Message Bus Configuration Service, ESX Agent Manager, VMware Service Control Agent, vSphere HA host status, and host connection and power state. The vCenter



Management Interface provides appliance-level health visibility through an Overall Health badge that reflects one of five states (Good, Warning, Alert, Critical, or Unknown) across all vCenter components, and notifies administrators of available security patches through Critical or Alert badge indicators when automatic patch checks are enabled.

When VCF Automation is integrated with VCF Operations, the Insights dashboard and Alerts tab provide real-time capacity awareness and alert information for VCF Automation objects, giving IT teams visibility into resource usage across both provisioned workloads and the underlying infrastructure. The VCF Automation Monitor tab surfaces deployment health information sourced from VCF Operations, and deployment cards display Last Request Status information that tracks the most recent operation on each deployment (Create, Update, or Delete) and its outcome (Successful, In Progress, or Failed). The Management Pack Builder allows administrators to set up event definitions for integrated systems, monitoring specific conditions or thresholds and configuring alerts for proactive management. Management Packs extend monitoring to network devices, including sensor monitoring for devices such as switches and routers. Adapters can be installed on VCF Operations nodes to extend monitoring to additional systems and data sources beyond the core VCF components.

The VMware Kubernetes Service (VKS) layer of VCF extends enterprise monitoring to container workloads and Kubernetes infrastructure. VKS clusters support MachineHealthCheck objects for both control plane nodes and worker node deployments; administrators manage these through the VCF CLI `vcf cluster machinehealthcheck` command, which supports configuration of unhealthy-condition definitions, maximum unhealthy thresholds (expressed as an absolute number or a percentage), and label selectors to target specific machines. The VCF CLI `vcf cluster machinehealthcheck node get` and `vcf cluster machinehealthcheck control-plane get` commands retrieve node and control plane health status on demand. VKS cluster health conditions, including the Ready and ControlPlaneReady status indicators, reflect the operational state of each cluster and are accessible via `kubectl` and the VCF CLI. The VCF Automation Provider Management UI includes a Services overview interface that exposes VKS cluster management functions and the health status of all cluster elements, giving platform operators a centralized view of the VKS tier. The Kubernetes API server within VKS clusters exposes diagnostic and health check endpoints (`/healthz`, `/livez`, `/readyz`, `/statusz`, and `/metrics`) that external monitoring systems can scrape to track API server availability and readiness; the `kube-apiserver` also emits the `kubernetes_healthchecks_total` counter and `kubernetes_healthcheck` gauge metric, which report structured health check status for components including `etcd` and `autoregister-completion`. Access to these monitoring endpoints is governed by the built-in Kubernetes system:monitoring RBAC group, which grants read access to liveness, readiness, and metrics endpoints while restricting broader cluster access. The Kubernetes Watch API allows monitoring tools to track changes to any API object as a live stream, supporting event-driven monitoring without continuous polling. The Node Problem Detector monitors node health and surfaces node-level problems as Kubernetes events and node conditions that external monitoring systems can consume via the event stream.

For workload-level monitoring within VKS clusters, Prometheus Operator is available as a standard package and defines custom resource definitions to deploy and manage Prometheus and Alertmanager StatefulSets, enabling high-availability alerting configurations. The Prometheus Alertmanager custom resource definition configures alert grouping, inhibition, and routing to external notification systems. The Istio service mesh, also available as a standard package on VKS clusters, provides service-level monitoring alongside its traffic management capabilities. The Dynatrace Operator can be deployed on VKS clusters to automate the deployment, scaling, and maintenance of the Dynatrace monitoring stack. Historical analysis, dashboarding, and alerting on cluster-level metrics require a dedicated monitoring solution configured to scrape the VKS metrics endpoints and subscribe to the Kubernetes event stream. The `vcf cluster support-bundler create` command gathers diagnostic information from Supervisor and VKS clusters when troubleshooting is needed.

At the network layer, NSX provides monitored indicators including node uptime status, deployment status, management and controller connections, tunnel status, PNIC status, and uptime duration. NSX time series APIs allow viewing data such as VPN statistics, including metadata about the number of tunnels configured and how many are up or down at a given time.

VCF Operations also supports self-monitoring through the VCF Operations adapter, which collects internal metrics such as activity success counts. This allows administrators to verify that the monitoring platform itself is functioning correctly. The VCF Operations policy engine monitors conditions and generates events to react to changing states in the orchestrator server or connected technologies. The Adapter Instance monitoring interval is configurable, with intervals as granular as five minutes.

VMware Private AI Services (PAIS) includes a built-in observability stack that supplies monitoring data for AI infrastructure and AI workloads. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the pais-controller-manager service, allowing collection by monitoring systems and visualization in observability platforms such as Grafana. Observability is activated by updating the PAISConfiguration custom resource with optional sections for Prometheus metrics collection and LLM trace forwarding. The Prometheus runtime can be configured with a specified storage class policy and a configurable metrics retention period, giving administrators control over how long monitoring data is stored. A Prometheus server pod must be in a ready and running state for observability to function.

LLM trace data from PAIS can be forwarded to an OpenTelemetry Collector endpoint over http/protobuf or gRPC, providing distributed tracing for AI model inference activity. The observability.IlmTraces configuration governs trace forwarding and works alongside the Prometheus metrics pipeline to produce two signals: metrics for health and performance, and traces for inference-level behavior. PAIS Controller metrics include the Model Endpoint Controller and PAIS Configuration Controller, giving monitoring platforms component-level visibility into PAIS operations.

In 9.1, PAIS adds direct integration with VCF Operations. The controller-pod-metrics-streaming setting activates streaming of PAIS controller pod metrics from the Supervisor cluster to VCF Operations, allowing administrators to view PAIS metrics alongside other VCF infrastructure metrics. A Telegraf deployment in the vmware-system-monitoring namespace uses a telegraf-user-config ConfigMap to manage user-configured monitoring endpoints for PAIS. The VCF Consumption CLI connects to the Supervisor endpoint and enables VI administrators to stream metrics from the PAIS controller pod. DevOps engineers can visualize health and performance metrics for PAIS components running in a VCF Automation namespace using Grafana, and MLOps engineers and application developers can monitor the health, quality, and behavior of AI applications and the models used in agents through the same observability platforms.

PAIS supplies the technical monitoring mechanisms this control requires. Enterprise-wide orchestration of monitoring controls, including alert threshold definition, escalation procedures, and integration with a centralized monitoring or log management platform, remain organizational responsibilities.

### **VMware vDefend (Contributes)**

VMware vDefend (vDefend) supports network security monitoring through multiple integrated capabilities that contribute to enterprise-wide monitoring frameworks.

Security Intelligence, hosted on the Security Services Platform (SSP), provides continuous visibility into network traffic flows across protected workloads. It monitors flows between application pairs, updates the Policy Protection Status for each application to indicate that flows are being monitored, and continuously detects new flows between environment pairs, alerting administrators to unauthorized or unexpected traffic. The Monitor & Plan Overview page presents a consolidated view of pending actions, data collection activity status, network security posture, flow trends, and a summary of suspicious traffic. The Security Intelligence Recommendations monitoring capability checks for changes in the scope of monitored entities every hour when the Monitoring toggle is enabled, allowing administrators to keep policy recommendations current as environments evolve. Segmentation Monitoring provides dedicated views of application and infrastructure flows with configurable time ranges spanning from the last hour to the last month, and displays flows related to detected infrastructure servers in a specified time interval.

The Network Detection and Response (NDR) Sensor checks the status of activated detection features every 15 minutes and updates its configuration accordingly, supporting sustained threat detection coverage. NDR Sensor health status monitoring tracks whether key components, including network traffic capture, file analysis, and data transmission, are operating properly. The NDR Sensor also sends alerts notifying administrators of conditions such as services being down, high CPU, memory, or disk usage, packet drops, or missed heartbeats. NDR provides role-based access control covering triage operations such as viewing detections and campaigns, as well as SIEM configuration management.

The Security Services Platform monitors its own health, with Yellow or Red health status indicators displayed when issues occur in subcomponents. SSP monitoring tracks the status of the flow clustering job that runs every hour and reports suspicious traffic detector execution status after each run, with values such as SUCCESS, NOT\_ENOUGH\_BASELINE, and FAILURE.

The Security dashboard provides a consolidated view for monitoring and configuring security features across network workloads. In federated deployments, the Global Manager provides centralized event management and monitoring for malicious IP blocking activity across all Local Managers.

vDefend generates Unified Security Logs that VCF Log Management can collect and analyze. These logs cover Distributed Firewall, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering activity. Broader log aggregation and SIEM correlation for enterprise-wide monitoring remain the responsibility of the SIEM and logging infrastructure deployed alongside vDefend.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.

The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) contributes to enterprise-wide monitoring controls through a layered set of observability capabilities covering database health, infrastructure compliance, and event-driven alerting.

DSM provides a built-in monitoring framework that tracks database instance health across multiple dimensions. From the Monitoring tab in the DSM UI or the vSphere Client, administrators and authorized users can view real-time and historical metrics for database VMs, including CPU Health, Data Disk Health, System Disk Health, Max Connections, Active Connections, Write Throughput, Read Throughput, Thread Resource Utilization, Slow Queries per Second, InnoDB Buffer Usage, and InnoDB Reads and Writes. The Monitoring page defaults to the last three hours of aggregated metric data, with the time range adjustable through the Time Range Last dropdown. This visibility supports detection of resource contention, performance degradation, and connectivity anomalies at the database layer.

DSM's alert framework provides configurable thresholds for warning and critical conditions on key health indicators. Administrators and users can set separate warning and critical thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters. When thresholds are exceeded, DSM generates typed alerts such as Database Engine Health, Custom Config Health, and Backup Storage Health alerts. DSM monitors database replication status and raises an alert when a secondary database is not replicating data from the primary. DSM also raises an alert when metrics are no longer being received from a cluster, supporting detection of monitoring gaps. Alerts can be activated or deactivated per data service through the "Enable Alerts for DB Alert" setting, providing granular control over which databases are subject to active alerting. For each alert, DSM provides mitigation suggestions to help administrators resolve issues without disrupting database services.

In addition to database-level alerts, DSM generates global infrastructure alerts that surface vCenter integration and infrastructure policy issues. These include `INFRASTRUCTURE_POLICY_VC_ALARMS`, raised when vCenter resource alarms are active; `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, which reflect cluster compliance state; `VCENTER_CONNECTIVITY`, raised when vCenter connectivity fails and triggering troubleshooting steps that include verifying connectivity and checking authentication logs; and `LicensingNotUpdated` and `vCenterBinding` API status alerts that surface license and API integration conditions. A Global Alerts page in the DSM UI provides a centralized view of these alerts during and after installation and ongoing operation.

In 9.1, DSM integrates with VCF Operations to extend observability beyond the DSM UI. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state and displays a Data Services View dashboard showing active alerts and inventory items. VCF Operations presents performance data across three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for KPIs including Active Connections, Commits, Rollbacks, and Deadlocks. This integration requires configuring the connection between DSM and VCF Operations before use.

DSM also adds SQL Server as a supported database type, with dedicated monitoring through an integrated InfluxDB instance and Telegraf agents deployed across the provider appliance and SQL Server workload clusters. The monitoring framework supports metrics-based and status-condition-based alerts for SQL Server, covering database engine degradation, non-operational status, and automated or transaction log backup failure conditions.

DSM supports event notification to external systems through a webhook integration. Webhooks transmit alert notifications containing the triggered date, triggered time, triggered user email, task status, previous status, and task type. This allows DSM alerts to feed into centralized monitoring or incident management platforms maintained by the organization. DSM generates plug-in registration logs that administrators can review for vCenter connectivity errors, and DSM's troubleshooting guidance directs administrators to review active vCenter infrastructure alarms and resolve underlying issues identified through the alert system.

Enterprise-wide monitoring requires organizational decisions about monitoring architecture, log aggregation platforms, alerting policies, and operational response procedures that lie outside DSM's scope. DSM provides the data and integration points; the organization must determine how those signals are collected, correlated, and acted upon across the broader environment.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) contributes to enterprise-wide monitoring through application-delivery-layer mechanisms built into the Avi Controller and Service Engines.

The Avi Controller monitors Service Engine metrics and sends alarms and notifications to administrators when resource utilization data exceeds defined thresholds. Administrators configure custom thresholds on Service Engine groups through the Resource Events tab in the Avi UI. The Alert feature processes system events and metrics against user-defined rules and generates alerts that trigger configured actions, including sending an email, a syslog message, or an SNMP trap. Alert notifications can be forwarded to remote syslog servers for integration with centralized log management and monitoring platforms.

ControlScripts extend this event-response capability: a ControlScript can alter Avi configuration or communicate to external systems, including through webhook integrations with external monitoring tools, in response to defined system events. This supports dynamic responses including resource scaling or automated notifications based on health scores from monitoring data.

The Avi Controller and Service Engines track health score changes and SSL certificate expiration events. Avi integrates with external monitoring tools such as Prometheus for metrics collection and analysis. User-Defined Metrics allow administrators to define and extract customized telemetry data for specific compliance or reporting needs through the API. Real-time metrics are available via API but deactivate by default after 30 minutes to conserve resources and must be reactivated when sustained real-time visibility is required.

At the data plane, Avi health monitors track the status of backend servers and Service Engines continuously. Service Engine health monitoring records detailed server operational status, including health monitor name, type, last transition timestamps, rise count, fall count, total checks, and total failed checks. Each health monitor can be assigned its own threshold and timeout period for server health validation. Monitors support HTTP, HTTPS, TCP, and UDP health-check protocols with configurable success and failure thresholds, send intervals, and receive timeouts.

In Kubernetes environments managed by the Avi Kubernetes Operator (AKO), the HealthMonitor custom resource definition (CRD) allows users to define custom health monitoring configurations for backend services with fine-grained control over health check parameters. The Avi Multi-Cluster Kubernetes Operator (AMKO) GlobalDeploymentPolicy supports health monitor references for consistent monitoring across multi-cluster deployments. Within VCF Automation, a HealthMonitor custom resource can create monitors for tracking backend pool member status using TCP, PING, and HTTP check types.

## Control DE.CM-06

> External service provider activities and services are monitored to find potentially adverse events [Withdrawn: Incorporated into DE.CM-01, DE.CM-03, DE.CM-06, DE.CM-09]

**SCF Controls:** MON-01, MON-16.2, MON-16.4

**Aggregate Coverage:** Meets

### VCF (Meets)

VCF provides enterprise-wide monitoring through integrated tools that span infrastructure health, performance metrics, compliance assessment, log analysis, and alerting.

VCF Operations continuously monitors the operational state of all VCF components to detect conditions that may affect availability or compliance. It collects metrics across compute, storage, and networking resources, and correlates them over time to identify trends that may lead to potential failures. VCF Health, a component of VCF Operations, continuously monitors the operational state of VCF components to verify they are functioning as expected, giving platform operators a single view of operational status. Platform operators can configure alerts, perform log analysis, run infrastructure diagnostics, and review VCF health from a unified interface.

VCF Operations provides continuous compliance management by monitoring infrastructure against industry-standard benchmarks and custom policies. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the monitoring posture to organizational requirements. The platform assesses objects based on selected compliance policies and activates alert definitions associated with the current scorecard, providing ongoing visibility into compliance status. Compliance-related alerts are triggered on objects and displayed through a dedicated compliance alert subtype.

The alerting subsystem in VCF Operations supports the full lifecycle of alert management. Administrators can configure and manage alert definitions to monitor infrastructure events and conditions, including performance metrics, log events, and custom conditions configured through the Management Pack Builder. The Platform Health Alerts page provides a centralized view of all alerts related to overall system health, including alerts from data sources and infrastructure nodes. Health alerts are generated for conditions that affect the health of the environment and require immediate attention. Administrators can create policies to govern how alert definitions are evaluated, including which objects to monitor and what thresholds to apply, and can apply consistent practices to optimize alert behavior across monitored objects.

VCF Operations supports flexible grouping and scheduling to align monitoring with operational realities. Custom groups can be configured with automatic membership criteria to support monitoring strategies and achieve a high level of automation. Maintenance schedules can be assigned to objects undergoing planned downtime to keep monitoring data accurate and avoid false alerts when an object is offline for scheduled maintenance.

VCF Log Management provides centralized log collection and analysis. It ingests logs from VMware vCenter, VMware ESX hosts, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture. The platform provides dashboards and analytics for troubleshooting and security investigation. Log-based alert definitions allow administrators to trigger notifications when specific log patterns appear across monitored systems. Log forwarding to external SIEM or syslog targets is configurable, with support for TLS encryption to protect log data in transit. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols. NSX Manager syslog supports TLS and requires port 6514 for encrypted log transmission.

At the vSphere layer, the alarm infrastructure integrates with events and performance counters to provide real-time alerting. The MetricAlarmExpression data object allows administrators to set alarms on specific performance metrics with configurable monitoring intervals and aggregation functions for processing data points. The vSphere Client provides direct visibility into tasks and events for change tracking and troubleshooting. VCF ships with preconfigured vSphere alarms that are active by default and monitor specific components including the Identity Management Service, Message Bus Configuration Service, ESX Agent Manager, VMware Service Control Agent, vSphere HA host status, and host connection and power state. The vCenter



Management Interface provides appliance-level health visibility through an Overall Health badge that reflects one of five states (Good, Warning, Alert, Critical, or Unknown) across all vCenter components, and notifies administrators of available security patches through Critical or Alert badge indicators when automatic patch checks are enabled.

When VCF Automation is integrated with VCF Operations, the Insights dashboard and Alerts tab provide real-time capacity awareness and alert information for VCF Automation objects, giving IT teams visibility into resource usage across both provisioned workloads and the underlying infrastructure. The VCF Automation Monitor tab surfaces deployment health information sourced from VCF Operations, and deployment cards display Last Request Status information that tracks the most recent operation on each deployment (Create, Update, or Delete) and its outcome (Successful, In Progress, or Failed). The Management Pack Builder allows administrators to set up event definitions for integrated systems, monitoring specific conditions or thresholds and configuring alerts for proactive management. Management Packs extend monitoring to network devices, including sensor monitoring for devices such as switches and routers. Adapters can be installed on VCF Operations nodes to extend monitoring to additional systems and data sources beyond the core VCF components.

The VMware Kubernetes Service (VKS) layer of VCF extends enterprise monitoring to container workloads and Kubernetes infrastructure. VKS clusters support MachineHealthCheck objects for both control plane nodes and worker node deployments; administrators manage these through the VCF CLI `vcf cluster machinehealthcheck` command, which supports configuration of unhealthy-condition definitions, maximum unhealthy thresholds (expressed as an absolute number or a percentage), and label selectors to target specific machines. The VCF CLI `vcf cluster machinehealthcheck node get` and `vcf cluster machinehealthcheck control-plane get` commands retrieve node and control plane health status on demand. VKS cluster health conditions, including the Ready and ControlPlaneReady status indicators, reflect the operational state of each cluster and are accessible via `kubectl` and the VCF CLI. The VCF Automation Provider Management UI includes a Services overview interface that exposes VKS cluster management functions and the health status of all cluster elements, giving platform operators a centralized view of the VKS tier. The Kubernetes API server within VKS clusters exposes diagnostic and health check endpoints (`/healthz`, `/livez`, `/readyz`, `/statusz`, and `/metrics`) that external monitoring systems can scrape to track API server availability and readiness; the `kube-apiserver` also emits the `kubernetes_healthchecks_total` counter and `kubernetes_healthcheck` gauge metric, which report structured health check status for components including `etcd` and `autoregister-completion`. Access to these monitoring endpoints is governed by the built-in Kubernetes `system:monitoring` RBAC group, which grants read access to liveness, readiness, and metrics endpoints while restricting broader cluster access. The Kubernetes Watch API allows monitoring tools to track changes to any API object as a live stream, supporting event-driven monitoring without continuous polling. The Node Problem Detector monitors node health and surfaces node-level problems as Kubernetes events and node conditions that external monitoring systems can consume via the event stream.

For workload-level monitoring within VKS clusters, Prometheus Operator is available as a standard package and defines custom resource definitions to deploy and manage Prometheus and Alertmanager StatefulSets, enabling high-availability alerting configurations. The Prometheus Alertmanager custom resource definition configures alert grouping, inhibition, and routing to external notification systems. The Istio service mesh, also available as a standard package on VKS clusters, provides service-level monitoring alongside its traffic management capabilities. The Dynatrace Operator can be deployed on VKS clusters to automate the deployment, scaling, and maintenance of the Dynatrace monitoring stack. Historical analysis, dashboarding, and alerting on cluster-level metrics require a dedicated monitoring solution configured to scrape the VKS metrics endpoints and subscribe to the Kubernetes event stream. The `vcf cluster support-bundler create` command gathers diagnostic information from Supervisor and VKS clusters when troubleshooting is needed.

At the network layer, NSX provides monitored indicators including node uptime status, deployment status, management and controller connections, tunnel status, PNIC status, and uptime duration. NSX time series APIs allow viewing data such as VPN statistics, including metadata about the number of tunnels configured and how many are up or down at a given time.

VCF Operations also supports self-monitoring through the VCF Operations adapter, which collects internal metrics such as activity success counts. This allows administrators to verify that the monitoring platform itself is functioning correctly. The VCF Operations policy engine monitors conditions and generates events to react to changing states in the orchestrator server or connected technologies. The Adapter Instance monitoring interval is configurable, with intervals as granular as five minutes.

VMware Private AI Services (PAIS) includes a built-in observability stack that supplies monitoring data for AI infrastructure and AI workloads. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the pais-controller-manager service, allowing collection by monitoring systems and visualization in observability platforms such as Grafana. Observability is activated by updating the PAISConfiguration custom resource with optional sections for Prometheus metrics collection and LLM trace forwarding. The Prometheus runtime can be configured with a specified storage class policy and a configurable metrics retention period, giving administrators control over how long monitoring data is stored. A Prometheus server pod must be in a ready and running state for observability to function.

LLM trace data from PAIS can be forwarded to an OpenTelemetry Collector endpoint over http/protobuf or gRPC, providing distributed tracing for AI model inference activity. The observability.IlmTraces configuration governs trace forwarding and works alongside the Prometheus metrics pipeline to produce two signals: metrics for health and performance, and traces for inference-level behavior. PAIS Controller metrics include the Model Endpoint Controller and PAIS Configuration Controller, giving monitoring platforms component-level visibility into PAIS operations.

In 9.1, PAIS adds direct integration with VCF Operations. The controller-pod-metrics-streaming setting activates streaming of PAIS controller pod metrics from the Supervisor cluster to VCF Operations, allowing administrators to view PAIS metrics alongside other VCF infrastructure metrics. A Telegraf deployment in the vmware-system-monitoring namespace uses a telegraf-user-config ConfigMap to manage user-configured monitoring endpoints for PAIS. The VCF Consumption CLI connects to the Supervisor endpoint and enables VI administrators to stream metrics from the PAIS controller pod. DevOps engineers can visualize health and performance metrics for PAIS components running in a VCF Automation namespace using Grafana, and MLOps engineers and application developers can monitor the health, quality, and behavior of AI applications and the models used in agents through the same observability platforms.

PAIS supplies the technical monitoring mechanisms this control requires. Enterprise-wide orchestration of monitoring controls, including alert threshold definition, escalation procedures, and integration with a centralized monitoring or log management platform, remain organizational responsibilities.

### **VMware vDefend (Contributes)**

VMware vDefend (vDefend) supports network security monitoring through multiple integrated capabilities that contribute to enterprise-wide monitoring frameworks.

Security Intelligence, hosted on the Security Services Platform (SSP), provides continuous visibility into network traffic flows across protected workloads. It monitors flows between application pairs, updates the Policy Protection Status for each application to indicate that flows are being monitored, and continuously detects new flows between environment pairs, alerting administrators to unauthorized or unexpected traffic. The Monitor & Plan Overview page presents a consolidated view of pending actions, data collection activity status, network security posture, flow trends, and a summary of suspicious traffic. The Security Intelligence Recommendations monitoring capability checks for changes in the scope of monitored entities every hour when the Monitoring toggle is enabled, allowing administrators to keep policy recommendations current as environments evolve. Segmentation Monitoring provides dedicated views of application and infrastructure flows with configurable time ranges spanning from the last hour to the last month, and displays flows related to detected infrastructure servers in a specified time interval.

The Network Detection and Response (NDR) Sensor checks the status of activated detection features every 15 minutes and updates its configuration accordingly, supporting sustained threat detection coverage. NDR Sensor health status monitoring tracks whether key components, including network traffic capture, file analysis, and data transmission, are operating properly. The NDR Sensor also sends alerts notifying administrators of conditions such as services being down, high CPU, memory, or disk usage, packet drops, or missed heartbeats. NDR provides role-based access control covering triage operations such as viewing detections and campaigns, as well as SIEM configuration management.

The Security Services Platform monitors its own health, with Yellow or Red health status indicators displayed when issues occur in subcomponents. SSP monitoring tracks the status of the flow clustering job that runs every hour and reports suspicious traffic detector execution status after each run, with values such as SUCCESS, NOT\_ENOUGH\_BASELINE, and FAILURE.



The Security dashboard provides a consolidated view for monitoring and configuring security features across network workloads. In federated deployments, the Global Manager provides centralized event management and monitoring for malicious IP blocking activity across all Local Managers.

vDefend generates Unified Security Logs that VCF Log Management can collect and analyze. These logs cover Distributed Firewall, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering activity. Broader log aggregation and SIEM correlation for enterprise-wide monitoring remain the responsibility of the SIEM and logging infrastructure deployed alongside vDefend.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.

The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) contributes to enterprise-wide monitoring controls through a layered set of observability capabilities covering database health, infrastructure compliance, and event-driven alerting.

DSM provides a built-in monitoring framework that tracks database instance health across multiple dimensions. From the Monitoring tab in the DSM UI or the vSphere Client, administrators and authorized users can view real-time and historical metrics for database VMs, including CPU Health, Data Disk Health, System Disk Health, Max Connections, Active Connections, Write Throughput, Read Throughput, Thread Resource Utilization, Slow Queries per Second, InnoDB Buffer Usage, and InnoDB Reads and Writes. The Monitoring page defaults to the last three hours of aggregated metric data, with the time range adjustable through the Time Range Last dropdown. This visibility supports detection of resource contention, performance degradation, and connectivity anomalies at the database layer.

DSM's alert framework provides configurable thresholds for warning and critical conditions on key health indicators. Administrators and users can set separate warning and critical thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters. When thresholds are exceeded, DSM generates typed alerts such as Database Engine Health, Custom Config Health, and Backup Storage Health alerts. DSM monitors database replication status and raises an alert when a secondary database is not replicating data from the primary. DSM also raises an alert when metrics are no longer being received from a cluster, supporting detection of monitoring gaps. Alerts can be activated or deactivated per data service through the "Enable Alerts for DB Alert" setting, providing granular control over which databases are subject to active alerting. For each alert, DSM provides mitigation suggestions to help administrators resolve issues without disrupting database services.

In addition to database-level alerts, DSM generates global infrastructure alerts that surface vCenter integration and infrastructure policy issues. These include `INFRASTRUCTURE_POLICY_VC_ALARMS`, raised when vCenter resource alarms are active; `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, which reflect cluster compliance state; `VCENTER_CONNECTIVITY`, raised when vCenter connectivity fails and triggering troubleshooting steps that include verifying connectivity and checking authentication logs; and `LicensingNotUpdated` and `vCenterBinding` API status alerts that surface license and API integration conditions. A Global Alerts page in the DSM UI provides a centralized view of these alerts during and after installation and ongoing operation.

In 9.1, DSM integrates with VCF Operations to extend observability beyond the DSM UI. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state and displays a Data Services View dashboard showing active alerts and inventory items. VCF Operations presents performance data across three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for KPIs including Active Connections, Commits, Rollbacks, and Deadlocks. This integration requires configuring the connection between DSM and VCF Operations before use.

DSM also adds SQL Server as a supported database type, with dedicated monitoring through an integrated InfluxDB instance and Telegraf agents deployed across the provider appliance and SQL Server workload clusters. The monitoring framework supports metrics-based and status-condition-based alerts for SQL Server, covering database engine degradation, non-operational status, and automated or transaction log backup failure conditions.

DSM supports event notification to external systems through a webhook integration. Webhooks transmit alert notifications containing the triggered date, triggered time, triggered user email, task status, previous status, and task type. This allows DSM alerts to feed into centralized monitoring or incident management platforms maintained by the organization. DSM generates plug-in registration logs that administrators can review for vCenter connectivity errors, and DSM's troubleshooting guidance directs administrators to review active vCenter infrastructure alarms and resolve underlying issues identified through the alert system.

Enterprise-wide monitoring requires organizational decisions about monitoring architecture, log aggregation platforms, alerting policies, and operational response procedures that lie outside DSM's scope. DSM provides the data and integration points; the organization must determine how those signals are collected, correlated, and acted upon across the broader environment.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) contributes to enterprise-wide monitoring through application-delivery-layer mechanisms built into the Avi Controller and Service Engines.

The Avi Controller monitors Service Engine metrics and sends alarms and notifications to administrators when resource utilization data exceeds defined thresholds. Administrators configure custom thresholds on Service Engine groups through the Resource Events tab in the Avi UI. The Alert feature processes system events and metrics against user-defined rules and generates alerts that trigger configured actions, including sending an email, a syslog message, or an SNMP trap. Alert notifications can be forwarded to remote syslog servers for integration with centralized log management and monitoring platforms.

ControlScripts extend this event-response capability: a ControlScript can alter Avi configuration or communicate to external systems, including through webhook integrations with external monitoring tools, in response to defined system events. This supports dynamic responses including resource scaling or automated notifications based on health scores from monitoring data.

The Avi Controller and Service Engines track health score changes and SSL certificate expiration events. Avi integrates with external monitoring tools such as Prometheus for metrics collection and analysis. User-Defined Metrics allow administrators to define and extract customized telemetry data for specific compliance or reporting needs through the API. Real-time metrics are available via API but deactivate by default after 30 minutes to conserve resources and must be reactivated when sustained real-time visibility is required.

At the data plane, Avi health monitors track the status of backend servers and Service Engines continuously. Service Engine health monitoring records detailed server operational status, including health monitor name, type, last transition timestamps, rise count, fall count, total checks, and total failed checks. Each health monitor can be assigned its own threshold and timeout period for server health validation. Monitors support HTTP, HTTPS, TCP, and UDP health-check protocols with configurable success and failure thresholds, send intervals, and receive timeouts.

In Kubernetes environments managed by the Avi Kubernetes Operator (AKO), the HealthMonitor custom resource definition (CRD) allows users to define custom health monitoring configurations for backend services with fine-grained control over health check parameters. The Avi Multi-Cluster Kubernetes Operator (AMKO) GlobalDeploymentPolicy supports health monitor references for consistent monitoring across multi-cluster deployments. Within VCF Automation, a HealthMonitor custom resource can create monitors for tracking backend pool member status using TCP, PING, and HTTP check types.

## Control DE.CM-09

> [Withdrawn: Incorporated into PR.DS-01, DE.CM-09] [Withdrawn: Incorporated into ID.RA-09, DE.CM-09] [Withdrawn: Incorporated into DE.CM-01, DE.CM-09] [Withdrawn: Incorporated into DE.CM-01, DE.CM-03, DE.CM-06, DE.CM-09]  
Computing hardware and software, runtime environments, and their data are monitored to find potentially adverse events

**SCF Controls:** END-01, END-04, END-06, MON-01, MON-01.7

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides several platform capabilities that support malicious code protection, though organizations must deploy additional tools to achieve full antimalware coverage across endpoints.

At the hypervisor layer, VMware ESX supports Secure Boot and code signing to restrict unauthorized code from executing on hosts. Trusted Platform Module (TPM) support enables boot-time integrity measurement, and VMware vCenter provides APIs to retrieve TPM event logs for validating boot-time measurements or configuring firmware trust with an attestation service. Administrators can verify that hosts have booted in a known good configuration by checking TPM device status and event logs through the vCenter trusted infrastructure API. ESX host TPM modules must be verified as running the latest 2.0 firmware, and if not in use, disabled in the BIOS. Virtual machines can be configured with UEFI firmware for guest operating system boot integrity. Windows guest operating systems support Virtualization Based Security (VBS), which enables Device Guard to help prevent malware from running and Credential Guard to protect credential secrets; these features are configurable through Group Policy on VMs with ESX 6.7 or later compatibility. Virtual machines can also have the Guest Integrity (GI) security device enabled through the VMware Host Client, which is the platform foundation for VMware AppDefense.

The vSphere Security Configuration Guide provides hardening recommendations for ESX hosts, including configuring authentication and authorization settings, disabling unnecessary services, and enabling security features like Secure Boot and TPM. These configuration baselines are industry-standard best practices for host hardening.

vSphere Lifecycle Manager and VCF Operations Configuration Profiles maintain desired-state configuration for ESX hosts. Configuration Drifts in VCF Operations provides a proactive method to monitor configuration changes and identify when vCenter instances and vSphere clusters deviate from their approved baselines. Drift status is updated through a collection cycle that runs every 8 hours. This helps identify when host software or configuration has been modified from its approved state, which can indicate unauthorized changes or tampering.

VCF's networking layer, NSX, supports integration with third-party endpoint protection solutions for virtual machine security. The platform documentation references specific partner integrations including Symantec Endpoint Protection and ESET Antivirus/Security software, which provide anti-malware, intrusion prevention, and firewall capabilities for guest virtual machines. NSX App IDs can be used in conjunction with these third-party solutions for network management and security policy enforcement. Organizations can implement security groups, define security policies, and use NSX's integration with third-party security solutions for virtual machine protection.

NSX Guest Introspection provides an agent-based framework that supports endpoint security within virtual machines. The Guest Introspection Agent must be installed and running in each guest VM, and logged-in users should not have the privilege to remove or stop the agent. This architecture enables third-party security solutions to inspect guest operating system activity without requiring agents to be installed directly on the hypervisor. The security and integrity of the guest operating system must be maintained for these integrations to function correctly.

For container workloads, the VCF CLI supports cosign signature verification for container images through the imgpkg tool, which enables finding and copying cosign signatures. Image pull authentication through imagePullSecrets restricts container image pulls to authenticated private registries. Plugin discovery image signature verification is supported, with configurable public key paths for the cosign verifier. These capabilities help restrict deployment of images that have been tampered with.

VCF Operations supports the deployment and monitoring of agents on endpoint virtual machines, with guest operation privileges required to install agents. Automated software update capabilities in vCenter help keep systems current with security patches, reducing the window of exposure to known malware exploits.

For organizations that deploy VMware vDefend as an add-on to VCF, distributed malware prevention capabilities become available. The NSX Application Platform hosts the Malware Prevention for vDefend feature, which can be deployed from the Local Manager UI in NSX Federation environments. When host clusters are activated for Distributed Malware Prevention, a service virtual machine (SVM) is deployed on each host to perform malware scanning. vDefend also supports IDS/IPS capabilities alongside distributed malware prevention. The DistributedMps runbook is available to verify the health of the Malware Prevention Service pipeline and diagnose issues such as protection not working on a particular VM or certain files not being scanned.

Malware prevention activities generate log data for audit and forensic purposes. The Malware Prevention for vDefend feature writes log files that can be used for troubleshooting and security monitoring, and remote logging can be configured on the malware prevention SVMs for centralized log collection.

VMware Private AI Services (PAIS) includes model validation capabilities that scan machine learning model files for malicious content before they are accepted into a Model Gallery. The validation runs as a sandbox process on Deep Learning VMs and covers integrity verification through hash code checking, malware scanning, serialization attack scanning, and inference behavior testing with NVIDIA Triton Inference Server. Both the malware and serialization checks run as part of the validation workflow required before a model can be uploaded to a Model Gallery and made available to downstream model endpoints, knowledge bases, or AI agents.

Machine learning model files are a category of artifact that traditional endpoint security tools may not inspect. Serialized models in formats such as Python pickle files can carry executable payloads that activate when an application or researcher loads the model. The PAIS Model Gallery intake workflow treats this upload boundary as a security checkpoint, requiring each artifact to pass hash, malware, serialization, and inference behavior tests before it is published for use. PAIS guidance also directs organizations to distribute only models that have been validated internally on a Deep Learning VM rather than pulling artifacts directly from the Internet, where models may contain malicious code or be tuned for malicious behavior. The validation is operated by MLOps engineers, who confirm that onboarded models meet the organization's security, privacy, and technical requirements.

For platform-level malware protection covering virtual machines, VMware ESX hosts, and general workloads running on the PAIS infrastructure, organizations rely on VCF platform controls and, where deployed, VMware vDefend. PAIS adds the specialized scanning layer applied to AI model artifacts at the point of intake, addressing a threat surface that general-purpose antimalware tools do not typically cover.

### **VMware vDefend (Contributes)**

VMware vDefend provides multiple layers of malicious code detection and prevention through its Malware Prevention Service and IDS/IPS capabilities. Together these address the detection aspect of this control directly and contribute to the eradication aspect by restricting malicious code from executing and spreading across the network.

The Malware Prevention Service deploys as a service virtual machine (SVM) on each host in a cluster, with Guest Introspection thin agents installed on each protected guest VM. This architecture separates the detection engine from the protected workload, giving the service visibility into file activity, process execution, and network events from outside the guest. On Linux guests, a File and Network Agent handles file and network traffic introspection. A Host Agent (MUX) component running on ESX hosts supports the Guest Introspection functionality.

The service detects both known and unknown malicious files, including zero-day threats. Supported file categories include Windows executables (.exe, self-extracting), Linux executables (.elf), installer files (.msi), and shortcut files (.lnk), among others. When a file is analyzed, Malware Prevention assigns a verdict and classifies the threat by malware class (virus, trojan horse, worm, adware, ransomware, spyware) and malware family. A single detection event can be associated with multiple malware families and classes. Upon detection, the service can take direct remediation actions, including denying access to

suspicious files or deleting files identified as malicious. An allowlist capability enables administrators to override verdicts for files known to be legitimate, suppressing false positives without disabling broader detection.

Beyond file-based detection, Malware Prevention Service includes fileless malware detection to identify attacks that operate entirely within system memory using existing binaries and in-memory operations such as PowerShell or VBScript, without leaving executable artifacts on disk. The service monitors Indicators of Compromise including process command lines, process hashes, process execution trees, and in-memory executions. In-memory script buffer executions are scored for threat severity and assigned a verdict of malicious or suspicious, with the associated malware family and class displayed on the Malware Prevention Dashboard.

When malware is detected, the service extracts artifacts and in-memory script buffers that security teams can use to define incidents of compromise and create new detection rules for similar future threats. This extends malware coverage as new threat patterns are identified within the environment.

The Malware Prevention Dashboard in Security Services Platform aggregates detection events for malicious files, suspicious files, and uninspected files over configurable time periods. Each unique file is tracked by hash, and events can be filtered by verdict criteria. This centralized visibility allows security teams to identify malware incidents, track detection trends, and coordinate eradication efforts across the virtualized environment.

vDefend IDS/IPS provides signature-based and behavioral intrusion detection and prevention at the distributed firewall level, complementing Malware Prevention with network-layer detection of malware delivery attempts, command-and-control communications, and lateral movement patterns associated with malware infections. IDS/IPS operates at the virtual network interface level, providing visibility into east-west traffic between workloads that perimeter security tools cannot inspect.

While vDefend provides strong detection and file-level remediation capabilities, complete eradication of malicious code from infected guest operating systems typically requires endpoint security agents operating inside the guest. vDefend restricts malware from spreading across the network and blocks or removes detected malicious files, but cleaning an already-infected system requires host-level remediation tooling.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.



The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) contributes to enterprise-wide monitoring controls through a layered set of observability capabilities covering database health, infrastructure compliance, and event-driven alerting.

DSM provides a built-in monitoring framework that tracks database instance health across multiple dimensions. From the Monitoring tab in the DSM UI or the vSphere Client, administrators and authorized users can view real-time and historical metrics for database VMs, including CPU Health, Data Disk Health, System Disk Health, Max Connections, Active Connections, Write Throughput, Read Throughput, Thread Resource Utilization, Slow Queries per Second, InnoDB Buffer Usage, and InnoDB Reads and Writes. The Monitoring page defaults to the last three hours of aggregated metric data, with the time range adjustable through the Time Range Last dropdown. This visibility supports detection of resource contention, performance degradation, and connectivity anomalies at the database layer.

DSM's alert framework provides configurable thresholds for warning and critical conditions on key health indicators. Administrators and users can set separate warning and critical thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters. When thresholds are exceeded, DSM generates typed alerts such as Database Engine Health, Custom Config Health, and Backup Storage Health alerts. DSM monitors database replication status and raises an alert when a secondary database is not replicating data from the primary. DSM also raises an alert when metrics are no longer being received from a cluster, supporting detection of monitoring gaps. Alerts can be activated or deactivated per data service through the "Enable Alerts for DB Alert" setting, providing granular control over which databases are subject to active alerting. For each alert, DSM provides mitigation suggestions to help administrators resolve issues without disrupting database services.

In addition to database-level alerts, DSM generates global infrastructure alerts that surface vCenter integration and infrastructure policy issues. These include `INFRASTRUCTURE_POLICY_VC_ALARMS`, raised when vCenter resource alarms are active; `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, which reflect cluster compliance state; `VCENTER_CONNECTIVITY`, raised when vCenter connectivity fails and triggering troubleshooting steps that include verifying connectivity and checking authentication logs; and `LicensingNotUpdated` and `vCenterBinding API` status alerts that surface license and API integration conditions. A Global Alerts page in the DSM UI provides a centralized view of these alerts during and after installation and ongoing operation.

In 9.1, DSM integrates with VCF Operations to extend observability beyond the DSM UI. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state and displays a Data Services View dashboard showing active alerts and inventory items. VCF Operations presents performance data across three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for KPIs including Active Connections, Commits, Rollbacks, and Deadlocks. This integration requires configuring the connection between DSM and VCF Operations before use.

DSM also adds SQL Server as a supported database type, with dedicated monitoring through an integrated InfluxDB instance and Telegraf agents deployed across the provider appliance and SQL Server workload clusters. The monitoring framework supports metrics-based and status-condition-based alerts for SQL Server, covering database engine degradation, non-operational status, and automated or transaction log backup failure conditions.

DSM supports event notification to external systems through a webhook integration. Webhooks transmit alert notifications containing the triggered date, triggered time, triggered user email, task status, previous status, and task type. This allows DSM alerts to feed into centralized monitoring or incident management platforms maintained by the organization. DSM



generates plug-in registration logs that administrators can review for vCenter connectivity errors, and DSM's troubleshooting guidance directs administrators to review active vCenter infrastructure alarms and resolve underlying issues identified through the alert system.

Enterprise-wide monitoring requires organizational decisions about monitoring architecture, log aggregation platforms, alerting policies, and operational response procedures that lie outside DSM's scope. DSM provides the data and integration points; the organization must determine how those signals are collected, correlated, and acted upon across the broader environment.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer contributes to malicious code protection at the application delivery layer through WAF-based payload inspection, IP Reputation threat intelligence, Application Rules, and Bot Management.

The Avi WAF inspects inbound HTTP/HTTPS request bodies and parameters against signature-based rules, including ModSecurity rules, to detect and block exploit payloads, injection attacks, and known malware delivery patterns. WAF rules are configurable per virtual service and can be tuned to reduce false positives while maintaining coverage of malicious traffic patterns. Configuration is managed through the Avi Controller UI under the WAF Policy section for each virtual service.

The Application Rules service, available through Avi Cloud Console Live Security Threat Intelligence, provides automatically updated WAF rules targeting known vulnerabilities with CVE mappings across more than 5,000 applications, including WordPress, Drupal, and Apache. These rules are pushed automatically to Avi Controllers, reducing the window between vulnerability disclosure and protection.

Avi's IP Reputation service provides a threat intelligence feed that classifies IP addresses known to be infected with malware or identified as contacting malware distribution points (threat category code 6). The service also identifies IP addresses known to distribute malware, shell code, rootkits, worms, or viruses, including Windows exploit IP addresses. An "All threats" classification (threat category code 32) can be applied to block any suspicious IP addresses at the application delivery layer. IP Reputation data is synchronized via Avi Cloud Services and can be referenced in virtual service policies to block malicious source traffic before it reaches protected workloads. This is configured under Administration > External Services > Cloud Services.

Avi Bot Management provides a default System-BotDetectionPolicy that can be bound to virtual services to detect and mitigate malicious bots used in online fraud, credential stuffing, and automated data scraping. Bot Management performs heuristic scanning of User-Agent strings to detect malicious patterns such as SQL injections, marking such requests as bad bot of type web attack. In Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports assigning a BotDetectionPolicy to virtual services via the botPolicyRef parameter, extending bot detection to Kubernetes ingress workloads.

Avi WAF does not include built-in virus or file-content malware scanning. Avi documentation explicitly recommends deploying a dedicated virus and malware scanning tool on the upload directories of protected applications to detect and mitigate malicious uploads, including uploads that may bypass WAF inspection. Malware detection and eradication for workloads running behind Avi is the responsibility of endpoint protection tools deployed on those workloads. Organizations should configure WAF policies, Application Rules, IP Reputation, and Bot Management on Avi virtual services while also deploying dedicated antimalware solutions on application workloads and their supporting infrastructure.

## Control GV

> The organizational mission is understood and informs cybersecurity risk management. Internal and external stakeholders are understood, and their needs and expectations regarding cybersecurity risk management are understood and considered. Legal, regulatory, and contractual requirements regarding cybersecurity - including privacy and civil liberties obligations - are understood and managed. Critical objectives, capabilities, and services that external stakeholders depend on or expect from the organization are understood and communicated. Outcomes, capabilities, and services that the organization depends on are understood and communicated. Risk management objectives are established and agreed to by organizational stakeholders. Risk appetite and risk tolerance statements are established, communicated, and maintained. Cybersecurity risk management activities and outcomes are included in enterprise risk management processes. Strategic direction that describes appropriate risk response options is established and communicated. Lines of communication across the organization are established for cybersecurity risks, including risks from suppliers and other third parties. A standardized method for calculating, documenting, categorizing, and prioritizing cybersecurity risks is established and communicated. Strategic opportunities (i.e., positive risks) are characterized and are included in organizational cybersecurity risk discussions. Organizational leadership is responsible and accountable for cybersecurity risk and fosters a culture that is risk-aware, ethical, and continually improving. Roles, responsibilities, and authorities related to cybersecurity risk management are established, communicated, understood, and enforced. Adequate resources are allocated commensurate with the cybersecurity risk strategy, roles, responsibilities, and policies. Cybersecurity is included in human resources practices. Policy for managing cybersecurity risks is established based on organizational context, cybersecurity strategy, and priorities and is communicated and enforced. Policy for managing cybersecurity risks is reviewed, updated, communicated, and enforced to reflect changes in requirements, threats, technology, and organizational mission. Cybersecurity risk management strategy outcomes are reviewed to inform and adjust strategy and direction. The cybersecurity risk management strategy is reviewed and adjusted to ensure coverage of organizational requirements and risks. Organizational cybersecurity risk management performance is evaluated and reviewed for adjustments needed. A cybersecurity supply chain risk management program, strategy, objectives, policies, and processes are established and agreed to by organizational stakeholders. Cybersecurity roles and responsibilities for suppliers, customers, and partners are established, communicated, and coordinated internally and externally. Cybersecurity supply chain risk management is integrated into cybersecurity and enterprise risk management, risk assessment, and improvement processes. Suppliers are known and prioritized by criticality. Requirements to address cybersecurity risks in supply chains are established, prioritized, and integrated into contracts and other types of agreements with suppliers and other relevant third parties. Planning and due diligence are performed to reduce risks before entering into formal supplier or other third-party relationships. The risks posed by a supplier, their products and services, and other third parties are understood, recorded, prioritized, assessed, responded to, and monitored over the course of the relationship. Relevant suppliers and other third parties are included in incident planning, response, and recovery activities. Supply chain security practices are integrated into cybersecurity and enterprise risk management programs, and their performance is monitored throughout the technology product and service life cycle. Cybersecurity supply chain risk management plans include provisions for activities that occur after the conclusion of a partnership or service agreement. [Withdrawn: Incorporated into GV.RR-02, GV.SC-02] [Withdrawn: Incorporated into GV.OC-05] [Withdrawn: Incorporated into GV.OC-01] [Withdrawn: Incorporated into GV.OC-04, GV.OC-05] [Withdrawn: Incorporated into GV.OC-04] [Withdrawn: Incorporated into GV.PO, GV.PO-01, GV.PO-02] [Withdrawn: Incorporated into GV.OC-02, GV.RR, GV.RR-02] [Withdrawn: Moved to GV.OC-03] [Withdrawn: Moved to GV.RM-04] [Withdrawn: Incorporated into GV.RM-01, GV.RM-06, GV.RR-03] [Withdrawn: Incorporated into GV.RM-02, GV.RM-04] [Withdrawn: Moved into GV.RM-02] [Withdrawn: Incorporated into GV.RM-05, GV.SC-01, GV.SC-06, GV.SC-09, GV.SC-10] [Withdrawn: Incorporated into GV.OC-02, GV.SC-03, GV.SC-04, GV.SC-07, ID.RA-10] [Withdrawn: Moved to GV.SC-05] [Withdrawn: Incorporated into GV.SC-07, ID.RA-10] [Withdrawn: Incorporated into GV.SC-08, ID.IM-02] [Withdrawn: Moved to GV.RR-04] [Withdrawn: Incorporated into GV.RR-02]

**SCF Controls:** GOV-01, GOV-05, PRM-01.1, RSK-01

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control GV.OC

> The organizational mission is understood and informs cybersecurity risk management Internal and external stakeholders are understood, and their needs and expectations regarding cybersecurity risk management are understood and considered Legal, regulatory, and contractual requirements regarding cybersecurity - including privacy and civil liberties obligations - are understood and managed Critical objectives, capabilities, and services that external stakeholders depend on or expect from the organization are understood and communicated Outcomes, capabilities, and services that the organization depends on are understood and communicated [Withdrawn: Incorporated into GV.OC-05] [Withdrawn: Incorporated into GV.OC-01] [Withdrawn: Incorporated into GV.OC-04, GV.OC-05] [Withdrawn: Incorporated into GV.OC-04] [Withdrawn: Incorporated into GV.OC-02, GV.RR, GV.RR-02] [Withdrawn: Moved to GV.OC-03] [Withdrawn: Incorporated into GV.OC-02, GV.SC-03, GV.SC-04, GV.SC-07, ID.RA-10]

**SCF Controls:** AST-01.1, AST-01.2, CPL-01, GOV-08, TPM-05.4

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.OC-01

> The organizational mission is understood and informs cybersecurity risk management [Withdrawn: Incorporated into GV.OC-01]

**SCF Controls:** GOV-08, RSK-01.1, TDA-06.2

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.OC-02

> Internal and external stakeholders are understood, and their needs and expectations regarding cybersecurity risk management are understood and considered [Withdrawn: Incorporated into GV.OC-02, GV.RR, GV.RR-02] [Withdrawn: Incorporated into GV.OC-02, GV.SC-03, GV.SC-04, GV.SC-07, ID.RA-10]

**SCF Controls:** AST-01.2, TPM-05, TPM-05.4

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control GV.OC-03

> Legal, regulatory, and contractual requirements regarding cybersecurity - including privacy and civil liberties obligations - are understood and managed [Withdrawn: Moved to GV.OC-03]

**SCF Controls:** CPL-01, CPL-02, PRI-01, TPM-05, TPM-05.2

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control GV.OC-04

> Critical objectives, capabilities, and services that external stakeholders depend on or expect from the organization are understood and communicated [Withdrawn: Incorporated into GV.OC-04, GV.OC-05] [Withdrawn: Incorporated into GV.OC-04]

**SCF Controls:** BCD-02, GOV-08, PRM-01.1, TPM-02

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.OC-05

> Outcomes, capabilities, and services that the organization depends on are understood and communicated [Withdrawn: Incorporated into GV.OC-05] [Withdrawn: Incorporated into GV.OC-04, GV.OC-05]

**SCF Controls:** BCD-02, TDA-04.2, TPM-02

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides several capabilities that support the identification and documentation of critical technology assets, applications, services, and data within a virtualized infrastructure.

VMware vCenter maintains a real-time inventory of all managed objects, including hosts, VMs, clusters, datastores, and networks, and supports linking multiple vCenter instances for centralized inventory management. The vCenter inventory tracks multiple instances of ClusterComputeResource, ComputeResource, Datacenter, Datastore, DistributedVirtualSwitch, and Folder objects, providing a structured view of all infrastructure components. VCF Operations can export lists of resources, such as powered-off virtual machines, to CSV files for offline documentation and review.

VCF Operations includes a Business Applications feature that allows administrators to group related infrastructure objects and assign business criticality classifications. Each Business Application can be tagged with a criticality level of Critical, Medium, or Low, with Medium as the default. The Object Summary card within VCF Operations displays details including the application's source, application tag, environment, and business criticality rating. This classification capability allows infrastructure teams to maintain a structured view of which applications and their underlying resources are most important to the organization.

VCF Operations Service Discovery automatically detects running services across the environment. Service Discovery displays a list of all supported services that can be discovered and those currently discovered on VMs once configured. It also discovers performance metrics for individual service objects and service type objects, maintaining a catalog of known services and their relationships to underlying infrastructure. This automated discovery reduces manual effort in maintaining an accurate asset inventory.

VCF Operations also provides alert definitions with configurable Impact and Criticality metadata. The Impact setting can be configured to values such as Risk to indicate potential problems, while the Criticality setting can be set to values like Immediate for proper alert prioritization. Alert notifications can be filtered by impact category and criticality level, helping teams classify infrastructure resources by their importance and focus attention on the most important infrastructure components. VCF Operations Insights data tracks resource capacity and can notify project owners of changes affecting their assets.

VCF Automation provides complementary asset identification capabilities through its resource discovery and tagging system. The discovery process automatically identifies machines, storage volumes, networks, load balancers, and security groups for each cloud account region that has been added. Once discovered, these resources can be organized using tags that facilitate search and identification. Tags placed on cloud zones, network profiles, storage profiles, and individual infrastructure resources function as capability tags that define desired capabilities and support governance by expressing capabilities and constraints. Using logical, human-readable tags for storage, network, and infrastructure items is recommended to facilitate search and identification functions.

VCF Automation organizes infrastructure through projects, which link users, catalog items, and IaaS resources to the locations where items are deployed. The Overview tab displays infrastructure and consumption metrics, providing a consolidated view of resource usage. Resource details views support filtering based on attributes such as project membership, enabling administrators to locate and review specific subsets of the infrastructure.

Blueprints in VCF Automation allow users to model complex IT services by visually designing infrastructure components such as VMs, networks, storage, and software components. Resource objects in blueprints represent the infrastructure components and services that are provisioned and managed, providing an architectural record of how assets support business functions.

Together, these inventory, discovery, classification, tagging, and visualization capabilities give operations teams the tools to identify, classify, and document the technology assets that support essential business functions. However, VCF provides the technical tooling for asset identification and classification rather than the organizational processes needed to define which assets are critical to the business mission. Establishing criticality criteria, maintaining asset documentation, and conducting periodic reviews of critical asset designations require organizational processes that operate alongside the platform's capabilities.

### **VMware vDefend (Contributes)**

VMware vDefend contributes to identifying and documenting critical technology assets through the Security Services Platform (SSP) and its Security Intelligence feature, which provide asset inventory, classification, and visualization capabilities oriented toward network security segmentation planning.

Security Services Platform maintains a Platform Inventory of infrastructure assets, collecting status information for each asset including identification of assets that are timed out or out of sync. The inventory view provides filtering by Name and Status to locate specific infrastructure assets and identify their operational state. Tags assigned to each infrastructure asset are displayed for verification of tag assignments.

Security Intelligence gathers infrastructure services and servers from CSV files and discovers additional services and servers based on traffic flows analyzed from ESX hosts. During CSV import, Security Intelligence parses and validates the content format and inventory asset data. Security Intelligence also maps discovered unique assets during segmentation analysis, including workloads, groups, IP addresses, distributed virtual port groups (DVPGs), segments, tiers, infrastructure services, and infrastructure servers.

Security Services Platform identifies and publishes application assets, classifying them as either critical or regular applications. This criticality classification supports the identification of mission-critical technology assets within the environment. The inventory hierarchy spans regions, zones, environments, applications, and tiers, with each level displaying the total number of assets within its scope.

Security Intelligence organizes discovered and imported assets into structured Asset Collections: groups, infrastructure assets, environments (such as Production, Non-Prod, DMZ, PCI, and Development), applications, and application tiers. The Environment Asset Collection maps security zones to the operational contexts that support business functions. Application Asset Collections group workloads that provide enterprise functionalities, linking infrastructure resources to the business services they support. The Infrastructure Asset Collection node covers core networking services that enterprise workloads depend on, including LDAP, DNS, NTP, and DHCP. An Unknown Asset Collection surfaces compute entities that are not in the NSX inventory but are present in the data center and communicating to NSX entities, supporting discovery of assets that should be formally inventoried.

Security Intelligence Workload Classification can be set to "Infrastructure Service" to indicate that a compute entity provides infrastructure services such as DNS, DHCP, LDAP, and Syslog. Inferred infrastructure classifications for compute entities can be reviewed, accepted, or modified through the Monitor & Plan > Security Explorer interface.

These capabilities contribute to the control but do not fully satisfy it. vDefend's asset identification is scoped to network security segmentation planning rather than the enterprise-wide technology asset catalog this control requires. Identifying all critical technology assets, applications, services, and data across an organization requires broader inventory and configuration management capabilities within VCF, such as VCF Operations business application views, VMware vCenter inventory exports, and VCF Automation project tagging, which provide the enterprise-wide asset catalog that vDefend's security-focused inventory complements.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) organizes its protection model around identifying which assets are critical enough to warrant disaster recovery protection. Protection groups are an explicit declaration of critical assets, organizing virtual machines into logical units based on their replication and recovery requirements. Placing a workload in a protection group is a deliberate act of classifying it as essential to business operations.

Inventory mappings document how each protected-site asset (resource pools, folders, networks, datastores) corresponds to recovery-site resources, creating a structured record of the infrastructure that supports critical workloads. Site-wide inventory mappings apply defaults across all protected VMs, while per-VM customizations document specific recovery configurations for workloads with unique requirements.

The Protection and Recovery Configuration Import/Export Tool exports a complete record of the DR asset inventory, including site names, inventory mappings, placeholder datastores, advanced settings, array managers with SRA information, protection groups, and recovery plans. This export provides a structured, portable document of which assets are protected and how they are configured for recovery. The export is produced in XML format, enabling automated processing and retention as a configuration record.

PNR generates and exports reports documenting each run of a recovery plan, each test of a recovery plan, and each test cleanup operation. These reports provide an auditable record of which recovery plans executed and which protected workloads were involved.

PNR tracks site metrics including paired sites, pair names, vCenter addresses, site connectivity status, and counts of protection groups, recovery plans, protected virtual machines, and array managers. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, providing consolidated visibility into the DR infrastructure as a class of managed assets.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.OV

> Cybersecurity risk management strategy outcomes are reviewed to inform and adjust strategy and direction. The cybersecurity risk management strategy is reviewed and adjusted to ensure coverage of organizational requirements and risks. Organizational cybersecurity risk management performance is evaluated and reviewed for adjustments needed.

**SCF Controls:** GOV-01.1, GOV-01.2, GOV-03, GOV-05

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.OV-01

> Cybersecurity risk management strategy outcomes are reviewed to inform and adjust strategy and direction

**SCF Controls:** GOV-01.1, GOV-01.2, GOV-03, GOV-05, GOV-08, PRM-01.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.OV-02

> The cybersecurity risk management strategy is reviewed and adjusted to ensure coverage of organizational requirements and risks

**SCF Controls:** GOV-01.1, GOV-03, RSK-01

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control GV.OV-03

> Organizational cybersecurity risk management performance is evaluated and reviewed for adjustments needed

**SCF Controls:** GOV-01.1, GOV-01.2, GOV-05, RSK-01

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control GV.PO

> Policy for managing cybersecurity risks is established based on organizational context, cybersecurity strategy, and priorities and is communicated and enforced. Policy for managing cybersecurity risks is reviewed, updated, communicated, and enforced to reflect changes in requirements, threats, technology, and organizational mission. [Withdrawn: Incorporated into GV.PO, GV.PO-01, GV.PO-02]

**SCF Controls:** GOV-02, HRS-05.7, HRS-07

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.PO-01

> Policy for managing cybersecurity risks is established based on organizational context, cybersecurity strategy, and priorities and is communicated and enforced [Withdrawn: Incorporated into GV.PO, GV.PO-01, GV.PO-02]

**SCF Controls:** GOV-02, HRS-05.7, HRS-07

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.PO-02

> Policy for managing cybersecurity risks is reviewed, updated, communicated, and enforced to reflect changes in requirements, threats, technology, and organizational mission [Withdrawn: Incorporated into GV.PO, GV.PO-01, GV.PO-02]

**SCF Controls:** GOV-03, HRS-05.7, HRS-07

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.RM

> Risk management objectives are established and agreed to by organizational stakeholders. Risk appetite and risk tolerance statements are established, communicated, and maintained. Cybersecurity risk management activities and outcomes are included in enterprise risk management processes. Strategic direction that describes appropriate risk response options is established and communicated. Lines of communication across the organization are established for cybersecurity risks, including risks from suppliers and other third parties. A standardized method for calculating, documenting, categorizing, and prioritizing cybersecurity risks is established and communicated. Strategic opportunities (i.e., positive risks) are characterized and are included in organizational cybersecurity risk discussions. [Withdrawn: Moved to GV.RM-04] [Withdrawn: Incorporated into GV.RM-01, GV.RM-06, GV.RR-03] [Withdrawn: Incorporated into GV.RM-02, GV.RM-04] [Withdrawn: Moved into GV.RM-02] [Withdrawn: Incorporated into GV.RM-05, GV.SC-01, GV.SC-06, GV.SC-09, GV.SC-10]

**SCF Controls:** GOV-04, PRM-01, PRM-01.1, RSK-01, RSK-01.1, RSK-01.3, RSK-01.5

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.RM-01

> Risk management objectives are established and agreed to by organizational stakeholders [Withdrawn: Incorporated into GV.RM-01, GV.RM-06, GV.RR-03]

**SCF Controls:** GOV-01, GOV-01.1, GOV-05.2, RSK-01

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.RM-02

> Risk appetite and risk tolerance statements are established, communicated, and maintained [Withdrawn: Incorporated into GV.RM-02, GV.RM-04] [Withdrawn: Moved into GV.RM-02]

**SCF Controls:** RSK-01.3, RSK-01.5

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control GV.RM-03

> Cybersecurity risk management activities and outcomes are included in enterprise risk management processes

**SCF Controls:** GOV-01, GOV-01.1, RSK-01

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.RM-04

> Strategic direction that describes appropriate risk response options is established and communicated [Withdrawn: Moved to GV.RM-04] [Withdrawn: Incorporated into GV.RM-02, GV.RM-04]

**SCF Controls:** RSK-01, RSK-01.1, RSK-06, RSK-06.1, RSK-06.2

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control GV.RM-05

> Lines of communication across the organization are established for cybersecurity risks, including risks from suppliers and other third parties [Withdrawn: Incorporated into GV.RM-05, GV.SC-01, GV.SC-06, GV.SC-09, GV.SC-10]

**SCF Controls:** GOV-04, GOV-04.1, HRS-03, TPM-05.4

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.RM-06

> A standardized method for calculating, documenting, categorizing, and prioritizing cybersecurity risks is established and communicated [Withdrawn: Incorporated into GV.RM-01, GV.RM-06, GV.RR-03]

**SCF Controls:** RSK-01, RSK-01.1, RSK-04, RSK-04.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.RM-07

> Strategic opportunities (i.e., positive risks) are characterized and are included in organizational cybersecurity risk discussions

**SCF Controls:** RSK-01.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.RR

> Organizational leadership is responsible and accountable for cybersecurity risk and fosters a culture that is risk-aware, ethical, and continually improving Roles, responsibilities, and authorities related to cybersecurity risk management are established, communicated, understood, and enforced Adequate resources are allocated commensurate with the cybersecurity risk strategy, roles, responsibilities, and policies Cybersecurity is included in human resources practices [Withdrawn: Incorporated into GV.RR-02, GV.SC-02] [Withdrawn: Incorporated into GV.OC-02, GV.RR, GV.RR-02] [Withdrawn: Incorporated into GV.RM-01, GV.RM-06, GV.RR-03] [Withdrawn: Moved to GV.RR-04] [Withdrawn: Incorporated into GV.RR-02]

**SCF Controls:** HRS-03, TPM-05.4

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.RR-01

> Organizational leadership is responsible and accountable for cybersecurity risk and fosters a culture that is risk-aware, ethical, and continually improving

**SCF Controls:** GOV-01, GOV-01.1, GOV-04, GOV-04.1, RSK-01, RSK-01.3, RSK-01.4, RSK-01.5, RSK-12

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.RR-02

> Roles, responsibilities, and authorities related to cybersecurity risk management are established, communicated, understood, and enforced [Withdrawn: Incorporated into GV.RR-02, GV.SC-02] [Withdrawn: Incorporated into GV.OC-02, GV.RR, GV.RR-02] [Withdrawn: Incorporated into GV.RR-02]

**SCF Controls:** GOV-04, HRS-02, HRS-03, TPM-05.4

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control GV.RR-03

> Adequate resources are allocated commensurate with the cybersecurity risk strategy, roles, responsibilities, and policies  
[Withdrawn: Incorporated into GV.RM-01, GV.RM-06, GV.RR-03]

**SCF Controls:** PRM-01, PRM-02, PRM-03

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.RR-04

> Cybersecurity is included in human resources practices [Withdrawn: Moved to GV.RR-04]

**SCF Controls:** HRS-01, HRS-03.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control GV.SC

> A cybersecurity supply chain risk management program, strategy, objectives, policies, and processes are established and agreed to by organizational stakeholders. Cybersecurity roles and responsibilities for suppliers, customers, and partners are established, communicated, and coordinated internally and externally. Cybersecurity supply chain risk management is integrated into cybersecurity and enterprise risk management, risk assessment, and improvement processes. Suppliers are known and prioritized by criticality. Requirements to address cybersecurity risks in supply chains are established, prioritized, and integrated into contracts and other types of agreements with suppliers and other relevant third parties. Planning and due diligence are performed to reduce risks before entering into formal supplier or other third-party relationships. The risks posed by a supplier, their products and services, and other third parties are understood, recorded, prioritized, assessed, responded to, and monitored over the course of the relationship. Relevant suppliers and other third parties are included in incident planning, response, and recovery activities. Supply chain security practices are integrated into cybersecurity and enterprise risk management programs, and their performance is monitored throughout the technology product and service life cycle. Cybersecurity supply chain risk management plans include provisions for activities that occur after the conclusion of a partnership or service agreement. [Withdrawn: Incorporated into GV.RR-02, GV.SC-02] [Withdrawn: Incorporated into GV.RM-05, GV.SC-01, GV.SC-06, GV.SC-09, GV.SC-10] [Withdrawn: Incorporated into GV.OC-02, GV.SC-03, GV.SC-04, GV.SC-07, ID.RA-10] [Withdrawn: Moved to GV.SC-05] [Withdrawn: Incorporated into GV.SC-07, ID.RA-10] [Withdrawn: Incorporated into GV.SC-08, ID.IM-02]

**SCF Controls:** GOV-01, GOV-01.1, GOV-01.2, GOV-05, RSK-01, RSK-09, RSK-09.1, TPM-03

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.SC-01

> A cybersecurity supply chain risk management program, strategy, objectives, policies, and processes are established and agreed to by organizational stakeholders [Withdrawn: Incorporated into GV.RM-05, GV.SC-01, GV.SC-06, GV.SC-09, GV.SC-10]

**SCF Controls:** GOV-01, GOV-01.1, GOV-02, RSK-01, RSK-09

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.SC-02

> Cybersecurity roles and responsibilities for suppliers, customers, and partners are established, communicated, and coordinated internally and externally [Withdrawn: Incorporated into GV.RR-02, GV.SC-02]

**SCF Controls:** TPM-05, TPM-05.2, TPM-05.4

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.SC-03

> Cybersecurity supply chain risk management is integrated into cybersecurity and enterprise risk management, risk assessment, and improvement processes [Withdrawn: Incorporated into GV.OC-02, GV.SC-03, GV.SC-04, GV.SC-07, ID.RA-10]

**SCF Controls:** GOV-01, GOV-01.1, GOV-02, GOV-08, GOV-09, RSK-01, RSK-09

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.SC-04

> Suppliers are known and prioritized by criticality [Withdrawn: Incorporated into GV.OC-02, GV.SC-03, GV.SC-04, GV.SC-07, ID.RA-10]

**SCF Controls:** AST-01, AST-01.1, TPM-01, TPM-01.1, TPM-02

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF contributes to IT Asset Management programs through built-in inventory, discovery, and integration capabilities that provide the technical foundation for asset tracking and governance.

VCF Operations groups discovered objects logically and provides detailed inventory lists across the environment, covering compute, storage, and networking resources. The inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group.

The Service Discovery adapter automatically discovers applications, services, and their associated metrics (CPU, memory) running on managed infrastructure. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be exported in CSV format for use in external asset tracking systems.

For organizations using ServiceNow, VCF provides two integration paths. The Management Pack for ServiceNow in VCF Operations populates the ServiceNow CMDB with discovered resources through the ServiceNow Table API and CMDB Meta API, providing CMDB visibility within VCF Operations. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation provides a structured data source that captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

VCF Automation adds governance through its project model, which controls who can deploy what resources and where those resources are deployed. Projects link users, catalog items, and IaaS resources together. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources.

Tags within VCF Automation express capabilities and constraints that define deployments. Cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

The broader ITAM program responsibilities of establishing asset governance policies, defining ownership lifecycles, and maintaining organizational accountability remain outside VCF's scope.

### VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) organizes inventory assets into a defined hierarchy of region, zone, environment, application, and application tier, classifying them as either critical or regular applications. This hierarchy gives

administrators a structured view of which assets support critical business functions and how they relate to each other within the environment.

Security Explorer's Applications View designates critical applications as high-priority types that receive enhanced security attention and monitoring, providing a focused view of business-critical workloads and their network security posture. The SSP Inventory monitoring function allows administrators to view the infrastructure hierarchy, including regions, zones, and virtual machines, and verify tag assignments for each infrastructure asset.

The SSP Segmentation Monitoring capability tracks application security posture over time and allows administrators to identify and address security risks surfaced through application monitoring. The SSP also identifies vulnerable workloads that could be exploited for lateral movement, supporting assessment of which assets pose elevated risk to critical business functions. Security Intelligence provides Infrastructure, Environment, and Application Monitoring capabilities that further aid in mapping asset relationships and security posture across the environment.

The SSP is a centralized repository that maintains the most current organizational IT assets, including servers, software, and network devices along with their configurations. These capabilities contribute to network-layer asset inventory and dependency mapping but do not replace an enterprise asset management system or provide the full business impact analysis and organizational security assessment processes that a TAAS identification program requires.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.SC-05

> Requirements to address cybersecurity risks in supply chains are established, prioritized, and integrated into contracts and other types of agreements with suppliers and other relevant third parties [Withdrawn: Moved to GV.SC-05]

**SCF Controls:** CPL-01, CPL-01.2, IAO-03.2, PRI-07.1, RSK-01, RSK-09, TPM-05, TPM-05.2

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.SC-06

> Planning and due diligence are performed to reduce risks before entering into formal supplier or other third-party relationships [Withdrawn: Incorporated into GV.RM-05, GV.SC-01, GV.SC-06, GV.SC-09, GV.SC-10]

**SCF Controls:** TPM-01, TPM-02, TPM-03, TPM-03.2, TPM-03.3, TPM-04, TPM-04.1, TPM-04.3, TPM-04.4, TPM-05, TPM-05.2, TPM-05.3, TPM-05.4, TPM-05.5, TPM-05.6, TPM-05.7, TPM-06, TPM-09

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides multiple layers of access control, identity federation, tenant isolation, and monitoring to mitigate risks associated with third-party access to infrastructure assets, applications, services, and data.

VCF SSO integrates with federated identity providers through standards-based protocols, supporting SAML 2.0, OIDC, and AD/LDAP as authentication sources. LDAP-based directory services such as Active Directory are supported for identity management across the platform, including NSX Manager, which supports both Active Directory over LDAP and Open LDAP as identity sources. This allows organizations to extend their existing identity governance to VCF rather than maintaining separate credential stores for third-party users.

Role-based access control enforces least-privilege principles across the platform. VCF local accounts support configurable roles such as superAdmin, and VCF Automation assigns host switch-level permissions through the Cloud Administrator group (Cloudadmin role). The administrators role in VCF Operations is restricted to specific users who need access to objects and actions across the entire environment. For Kubernetes workloads, vSphere Supervisor namespaces support role-based access control with EDIT, VIEW, and OWNER roles that grant specific privileges to users or groups. The Namespace Owner/Edit/View role scopes consumers of a vSphere Namespace to provisioning VKS clusters and vSphere Pods using kubectl, while vSphere Administrator and Supervisor Administrator roles have broader access to cluster and namespace resources. This layered role model restricts third-party access to specific workload boundaries.

VCF Automation implements a provider-and-consumer model that separates the operators of services from the organizations that consume them. Partner services from external vendors are integrated through this model, where providers manage services and organizations consume the resulting business outcomes such as self-service provisioning of Kubernetes clusters, databases, and other resources. Service providers control the publication scope of service instances to selected organizations and decide which roles, rights bundles, and UI plug-ins to include when publishing services. Provider Consumption Organizations offer additional administrative capabilities on top of standard organizations, allowing provider administrators to provision workloads while maintaining separation from consumer tenants. This architectural separation limits third-party visibility and access to only the resources they need to operate.

For third-party application integration, VCF Automation supports dedicated service accounts that automate access for third-party applications. Organizations can generate and issue API access tokens that applications use on their behalf, providing a controlled mechanism for programmatic access rather than requiring shared user credentials. The VCF Operations orchestrator presents an open architecture for plugging in external third-party applications, with integration points managed through the platform rather than through direct infrastructure access.

Tenant isolation is enforced through VCF Automation Organizations, which provide secure infrastructure isolation, quotas, and chargeback across multiple tenants. Within each organization, further isolation exists at the project and namespace levels. IT teams and cloud service providers can monitor resource usage, control permissions, and provide managed services through these organizations while network isolation at the NSX segment level restricts lateral movement between tenants. An Enterprise Admin can share resources with projects in a controlled manner, making objects available for consumption only within designated boundaries. App isolation policies in VCF Automation allow deployments that require on-demand security groups to enforce vDefend firewall rules at the application level. Data-in-transit communications default to TLS encryption for platform services.

VCF Operations monitors resource usage and policy compliance across the environment, providing visibility into third-party activity. VCF Operations supports firewall hardening that restricts network access to internal services, limiting the network



paths available to third-party integrations. Service Discovery identifies permanent listening TCP ports and established UDP connections, and service discovery dashboards provide ongoing visibility into the services operating in the environment. VCF also provides capabilities to discover objects that are not compliant with a security standard, supporting ongoing risk identification for configurations affected by third-party access.

VMware Private AI Services (PAIS) provides technical mechanisms that contribute to mitigating risks associated with third-party access to AI-related assets, services, and data. These mechanisms operate at the trust validation, authentication, authorization, and content approval layers.

#### Trust Establishment for External Integrations

PAIS uses a CA trust bundle to establish secure HTTPS communication with external services and databases. Administrators must import CA trust bundles for the OIDC provider, Private Harbor registry, content management systems used as data sources in Data Indexing and Retrieval, MCP servers providing tools for agents, and the database server when those entities are not supplied at activation. Without an explicitly configured CA trust bundle, PAIS will not establish connections to those services, so third-party integrations require deliberate administrative action rather than automatic open access. PAIS supports updating certificate content for trusted entities through the same trust bundle mechanism, allowing administrators to refresh trust material as provider certificates change.

#### Access Control for Services and Data

PAIS access is controlled through OIDC group-based authorization. User accounts must be members of specified authorized groups (configured via the `authorizedGroups` setting) to access the service, and the `oidc-groups-claim` setting controls which OIDC claim is consulted for group identification in the organization namespace. PAIS requires HTTPS-based communication for OIDC provider integration. SharePoint data sources used as Knowledge Base inputs require user name and password authentication, with support limited to SharePoint On-Premises deployments, so the credential and connectivity posture for that integration is explicit rather than implicit.

#### Harbor Access and Model Storage

The Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. These controls help administrators scope which users and workloads can push to or pull from a registry used by PAIS.

#### Model Validation Before Deployment

Before uploading a model to a PAIS Model Gallery, the platform recommends evaluating the model's performance and safety for the intended business use case, including examining inference requests for malicious behavior and performing hands-on functional tests. PAIS guidance directs administrators to distribute models within the organization that have been validated on a Deep Learning VM rather than models pulled from the Internet, which could contain malicious code or be tuned for malicious behavior. This workflow helps administrators verify third-party or externally sourced models before they become available for production use.

#### VMware vDefend (Contributes)

VMware vDefend contributes to mitigating risks from third-party access to organizational technology assets, applications, services, and data through network-level access controls, threat detection, and security posture reporting. Identity governance, authentication, and administrative access controls are handled by other VCF components (VMware vCenter, VCF SSO). vDefend enforces the network security boundary that constrains what third parties can reach once they have been granted access.

vDefend enforces microsegmentation policies at the vNIC level, allowing administrators to define granular network access rules that restrict third-party workloads or connections to only the specific application tiers and services they require. Context-aware rules allow policies to incorporate workload-level attributes, limiting the network reach of third-party connections to defined sets of addresses, ports, and protocols. In multi-tenant VCF environments, the VPC Isolation with Essential Services

strategy allows enterprise administrators to enforce strict inter-project isolation at the Distributed Firewall level while delegating more granular control to application owners within each project. This architecture is suited to environments where third-party development teams or external service providers operate within shared infrastructure, because Distributed Firewall policy at the project boundary can be set independently of what individual tenants configure inside their own VPCs.

vDefend provides north-south traffic filtering at the perimeter of logical network segments. Enterprise administrators can enforce isolation between projects by denying inter-project communication except for specified infrastructure protocols, adding an enforcement point for controlling inbound and outbound access from external or third-party networks. This policy layer applies regardless of what routing exists at the NSX level, giving security teams a dedicated control plane for third-party network boundaries.

vDefend IDS/IPS monitors east-west and north-south traffic for malicious activity, detecting exploitation attempts that may arise from compromised third-party connections. Signature rules support storing TLS and SSL certificates on disk for forensic analysis and threat investigation. Custom signature sources, including those derived from cybersecurity advisories, can be deployed to address threats specific to proprietary or custom applications that third parties introduce into the environment.

Security Services Platform Security Segmentation capabilities identify risky application protocols, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP, in use across the environment. This flags workloads, including those operated by third parties, that transport data without encryption, and allows administrators to restrict or block them as part of the security baseline. The Security Segmentation Report identifies at-risk workloads across categories including Public Traffic, Obsolete OS, Risky Application Protocols, and Inter VDI Server Connections, providing a structured view of workload-level risk that is directly relevant to understanding the exposure introduced by third-party access. Application monitoring in Security Services Platform surfaces security risks identified across workloads, allowing administrators to take targeted remediation steps against risky or non-compliant third-party workloads.

Security Services Platform certificate management supports importing CA bundles and web proxy certificates to establish trust for external service connections, including those used by the Malware Prevention Service. This controls which external services the platform can reach and provides a configuration point for managing trust relationships with third-party service endpoints.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer provides several mechanisms that allow administrators to restrict where application traffic is processed and where associated data is stored, supporting organizational requirements to control the location of information processing.

Service Engine Group placement controls are the primary mechanism. Administrators can scope Service Engine deployment by host, cluster, or data store by configuring the Host Scope and Data Store settings under Placement Scope for each SE Group at the vCenter level. This confines traffic processing to specific physical infrastructure resources. The Data Store Scope setting in the SE Group Advanced Parameters offers three modes: Local (the Service Engine uses only storage on the physical host, keeping processed data local to that host), Shared (Avi prefers shared storage but allows specific data stores to be included or excluded), and Any (Avi determines the best available storage option).

At the tenant level, Avi's multi-tenancy model provides additional processing location isolation. The behavior depends on tenant context: tenants in Tenant Context provide both control plane isolation and data plane isolation, fully separating application traffic between tenants. Tenants in Provider Context provide control plane isolation only. The `enforce_label_group` setting on a tenant further restricts access to resources tagged with specific label groups, controlling which Service Engines and resources a given tenant can access.

In Kubernetes environments, the Avi Kubernetes Operator (AKO) CRD Operator manages namespace-scoped resources with tenant isolation for multi-tenancy support, extending processing location controls to containerized workloads. The Avi integration with VCF also allows provider administrators to define infrastructure boundaries through regions and organizations in the VCF Automation Provider Management Portal, with region quotas specifying accessible zones and capacity allocation.

The organization is responsible for identifying processing and storage location requirements based on applicable business, regulatory, or contractual obligations, and for configuring the placement and scoping controls accordingly. Avi provides the enforcement mechanisms; defining acceptable locations and verifying that restrictions are correctly applied are organizational responsibilities.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.SC-07

> The risks posed by a supplier, their products and services, and other third parties are understood, recorded, prioritized, assessed, responded to, and monitored over the course of the relationship [Withdrawn: Incorporated into GV.OC-02, GV.SC-03, GV.SC-04, GV.SC-07, ID.RA-10] [Withdrawn: Incorporated into GV.SC-07, ID.RA-10]

**SCF Controls:** TPM-01, TPM-01.1, TPM-02, TPM-03, TPM-03.2, TPM-03.3, TPM-04, TPM-04.1, TPM-08, TPM-09

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides multiple layers of access control, identity federation, tenant isolation, and monitoring to mitigate risks associated with third-party access to infrastructure assets, applications, services, and data.

VCF SSO integrates with federated identity providers through standards-based protocols, supporting SAML 2.0, OIDC, and AD/LDAP as authentication sources. LDAP-based directory services such as Active Directory are supported for identity management across the platform, including NSX Manager, which supports both Active Directory over LDAP and Open LDAP as identity sources. This allows organizations to extend their existing identity governance to VCF rather than maintaining separate credential stores for third-party users.

Role-based access control enforces least-privilege principles across the platform. VCF local accounts support configurable roles such as superAdmin, and VCF Automation assigns host switch-level permissions through the Cloud Administrator group (Cloudadmin role). The administrators role in VCF Operations is restricted to specific users who need access to objects and actions across the entire environment. For Kubernetes workloads, vSphere Supervisor namespaces support role-based access control with EDIT, VIEW, and OWNER roles that grant specific privileges to users or groups. The Namespace Owner/Edit/View role scopes consumers of a vSphere Namespace to provisioning VKS clusters and vSphere Pods using kubectl, while vSphere Administrator and Supervisor Administrator roles have broader access to cluster and namespace resources. This layered role model restricts third-party access to specific workload boundaries.

VCF Automation implements a provider-and-consumer model that separates the operators of services from the organizations that consume them. Partner services from external vendors are integrated through this model, where providers manage services and organizations consume the resulting business outcomes such as self-service provisioning of Kubernetes clusters, databases, and other resources. Service providers control the publication scope of service instances to selected organizations and decide which roles, rights bundles, and UI plug-ins to include when publishing services. Provider Consumption Organizations offer additional administrative capabilities on top of standard organizations, allowing provider administrators to provision workloads while maintaining separation from consumer tenants. This architectural separation limits third-party visibility and access to only the resources they need to operate.

For third-party application integration, VCF Automation supports dedicated service accounts that automate access for third-party applications. Organizations can generate and issue API access tokens that applications use on their behalf, providing a controlled mechanism for programmatic access rather than requiring shared user credentials. The VCF Operations orchestrator presents an open architecture for plugging in external third-party applications, with integration points managed through the platform rather than through direct infrastructure access.

Tenant isolation is enforced through VCF Automation Organizations, which provide secure infrastructure isolation, quotas, and chargeback across multiple tenants. Within each organization, further isolation exists at the project and namespace levels. IT teams and cloud service providers can monitor resource usage, control permissions, and provide managed services through these organizations while network isolation at the NSX segment level restricts lateral movement between tenants. An Enterprise Admin can share resources with projects in a controlled manner, making objects available for consumption only within designated boundaries. App isolation policies in VCF Automation allow deployments that require on-demand security groups to enforce vDefend firewall rules at the application level. Data-in-transit communications default to TLS encryption for platform services.

VCF Operations monitors resource usage and policy compliance across the environment, providing visibility into third-party activity. VCF Operations supports firewall hardening that restricts network access to internal services, limiting the network

paths available to third-party integrations. Service Discovery identifies permanent listening TCP ports and established UDP connections, and service discovery dashboards provide ongoing visibility into the services operating in the environment. VCF also provides capabilities to discover objects that are not compliant with a security standard, supporting ongoing risk identification for configurations affected by third-party access.

VMware Private AI Services (PAIS) provides technical mechanisms that contribute to mitigating risks associated with third-party access to AI-related assets, services, and data. These mechanisms operate at the trust validation, authentication, authorization, and content approval layers.

#### Trust Establishment for External Integrations

PAIS uses a CA trust bundle to establish secure HTTPS communication with external services and databases. Administrators must import CA trust bundles for the OIDC provider, Private Harbor registry, content management systems used as data sources in Data Indexing and Retrieval, MCP servers providing tools for agents, and the database server when those entities are not supplied at activation. Without an explicitly configured CA trust bundle, PAIS will not establish connections to those services, so third-party integrations require deliberate administrative action rather than automatic open access. PAIS supports updating certificate content for trusted entities through the same trust bundle mechanism, allowing administrators to refresh trust material as provider certificates change.

#### Access Control for Services and Data

PAIS access is controlled through OIDC group-based authorization. User accounts must be members of specified authorized groups (configured via the `authorizedGroups` setting) to access the service, and the `oidc-groups-claim` setting controls which OIDC claim is consulted for group identification in the organization namespace. PAIS requires HTTPS-based communication for OIDC provider integration. SharePoint data sources used as Knowledge Base inputs require user name and password authentication, with support limited to SharePoint On-Premises deployments, so the credential and connectivity posture for that integration is explicit rather than implicit.

#### Harbor Access and Model Storage

The Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. These controls help administrators scope which users and workloads can push to or pull from a registry used by PAIS.

#### Model Validation Before Deployment

Before uploading a model to a PAIS Model Gallery, the platform recommends evaluating the model's performance and safety for the intended business use case, including examining inference requests for malicious behavior and performing hands-on functional tests. PAIS guidance directs administrators to distribute models within the organization that have been validated on a Deep Learning VM rather than models pulled from the Internet, which could contain malicious code or be tuned for malicious behavior. This workflow helps administrators verify third-party or externally sourced models before they become available for production use.

#### VMware vDefend (Contributes)

VMware vDefend contributes to mitigating risks from third-party access to organizational technology assets, applications, services, and data through network-level access controls, threat detection, and security posture reporting. Identity governance, authentication, and administrative access controls are handled by other VCF components (VMware vCenter, VCF SSO). vDefend enforces the network security boundary that constrains what third parties can reach once they have been granted access.

vDefend enforces microsegmentation policies at the vNIC level, allowing administrators to define granular network access rules that restrict third-party workloads or connections to only the specific application tiers and services they require. Context-aware rules allow policies to incorporate workload-level attributes, limiting the network reach of third-party connections to defined sets of addresses, ports, and protocols. In multi-tenant VCF environments, the VPC Isolation with Essential Services

strategy allows enterprise administrators to enforce strict inter-project isolation at the Distributed Firewall level while delegating more granular control to application owners within each project. This architecture is suited to environments where third-party development teams or external service providers operate within shared infrastructure, because Distributed Firewall policy at the project boundary can be set independently of what individual tenants configure inside their own VPCs.

vDefend provides north-south traffic filtering at the perimeter of logical network segments. Enterprise administrators can enforce isolation between projects by denying inter-project communication except for specified infrastructure protocols, adding an enforcement point for controlling inbound and outbound access from external or third-party networks. This policy layer applies regardless of what routing exists at the NSX level, giving security teams a dedicated control plane for third-party network boundaries.

vDefend IDS/IPS monitors east-west and north-south traffic for malicious activity, detecting exploitation attempts that may arise from compromised third-party connections. Signature rules support storing TLS and SSL certificates on disk for forensic analysis and threat investigation. Custom signature sources, including those derived from cybersecurity advisories, can be deployed to address threats specific to proprietary or custom applications that third parties introduce into the environment.

Security Services Platform Security Segmentation capabilities identify risky application protocols, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP, in use across the environment. This flags workloads, including those operated by third parties, that transport data without encryption, and allows administrators to restrict or block them as part of the security baseline. The Security Segmentation Report identifies at-risk workloads across categories including Public Traffic, Obsolete OS, Risky Application Protocols, and Inter VDI Server Connections, providing a structured view of workload-level risk that is directly relevant to understanding the exposure introduced by third-party access. Application monitoring in Security Services Platform surfaces security risks identified across workloads, allowing administrators to take targeted remediation steps against risky or non-compliant third-party workloads.

Security Services Platform certificate management supports importing CA bundles and web proxy certificates to establish trust for external service connections, including those used by the Malware Prevention Service. This controls which external services the platform can reach and provides a configuration point for managing trust relationships with third-party service endpoints.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.SC-08

> Relevant suppliers and other third parties are included in incident planning, response, and recovery activities [Withdrawn: Incorporated into GV.SC-08, ID.IM-02]

**SCF Controls:** BCD-01, BCD-01.2, IRO-01, IRO-02, IRO-02.5, TPM-01, TPM-01.1, TPM-02, TPM-09, TPM-10, TPM-11

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations.



HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

#### **VMware vDefend (Contributes)**

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

#### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.



Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

## Control GV.SC-09

> Supply chain security practices are integrated into cybersecurity and enterprise risk management programs, and their performance is monitored throughout the technology product and service life cycle [Withdrawn: Incorporated into GV.RM-05, GV.SC-01, GV.SC-06, GV.SC-09, GV.SC-10]

**SCF Controls:** GOV-01, GOV-01.1, GOV-01.2, GOV-05, PRM-07, RSK-01, RSK-09, RSK-09.1, SEA-07.1, TDA-01.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV.SC-10

> Cybersecurity supply chain risk management plans include provisions for activities that occur after the conclusion of a partnership or service agreement [Withdrawn: Incorporated into GV.RM-05, GV.SC-01, GV.SC-06, GV.SC-09, GV.SC-10]

**SCF Controls:** RSK-09, TPM-01, TPM-05.2, TPM-05.3

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control ID

> Inventories of hardware managed by the organization are maintained Inventories of software, services, and systems managed by the organization are maintained Representations of the organization's authorized network communication and internal and external network data flows are maintained Inventories of services provided by suppliers are maintained Assets are prioritized based on classification, criticality, resources, and impact on the mission [Withdrawn: Incorporated into GV.RR-02, GV.SC-02] Inventories of data and corresponding metadata for designated data types are maintained Systems, hardware, software, services, and data are managed throughout their life cycles Vulnerabilities in assets are identified, validated, and recorded Cyber threat intelligence is received from information sharing forums and sources Internal and external threats to the organization are identified and recorded Potential impacts and likelihoods of threats exploiting vulnerabilities are identified and recorded Threats, vulnerabilities, likelihoods, and impacts are used to understand inherent risk and inform risk response prioritization Risk responses are chosen, prioritized, planned, tracked, and communicated Changes and exceptions are managed, assessed for risk impact, recorded, and tracked Processes for receiving, analyzing, and responding to vulnerability disclosures are established The authenticity and integrity of hardware and software are assessed prior to acquisition and use Critical suppliers are assessed prior to acquisition Improvements are identified from evaluations Improvements are identified from security tests and exercises, including those done in coordination with suppliers and relevant third parties Improvements are identified from execution of operational processes, procedures, and activities Incident response plans and other cybersecurity plans that affect operations are established, communicated, maintained, and improved [Withdrawn: Incorporated into GV.OC-05] [Withdrawn: Incorporated into GV.OC-01] [Withdrawn: Incorporated into GV.OC-04, GV.OC-05] [Withdrawn: Incorporated into GV.OC-04] [Withdrawn: Incorporated into GV.PO, GV.PO-01, GV.PO-02] [Withdrawn: Incorporated into GV.OC-02, GV.RR, GV.RR-02] [Withdrawn: Moved to GV.OC-03] [Withdrawn: Moved to GV.RM-04] [Withdrawn: Incorporated into GV.RM-01, GV.RM-06, GV.RR-03] [Withdrawn: Incorporated into GV.RM-02, GV.RM-04] [Withdrawn: Moved into GV.RM-02] [Withdrawn: Incorporated into GV.RM-05, GV.SC-01, GV.SC-06, GV.SC-09, GV.SC-10] [Withdrawn: Incorporated into GV.OC-02, GV.SC-03, GV.SC-04, GV.SC-07, ID.RA-10] [Withdrawn: Moved to GV.SC-05] [Withdrawn: Incorporated into GV.SC-07, ID.RA-10] [Withdrawn: Incorporated into GV.SC-08, ID.IM-02] [Withdrawn: Incorporated into ID.AM-08, PR.PS-03] [Withdrawn: Incorporated into ID.RA-09, DE.CM-09] [Withdrawn: Incorporated into ID.AM-08, PR.PS-06] [Withdrawn: Incorporated into PR.PS-01, ID.RA-07] [Withdrawn: Incorporated into ID.AM-08] [Withdrawn: Incorporated into ID.IM, ID.IM-03] [Withdrawn: Moved to ID.IM-03] [Withdrawn: Moved to ID.IM-04] [Withdrawn: Incorporated into ID.IM-02, ID.IM-04] [Withdrawn: Incorporated into ID.RA-01, PR.PS-02] [Withdrawn: Incorporated into ID.AM-08, PR.PS-02] [Withdrawn: Incorporated into ID.RA-01] [Withdrawn: Incorporated into ID.AM-03] [Withdrawn: Incorporated into ID.IM-02] [Withdrawn: Moved to ID.RA-08] [Withdrawn: Incorporated into ID.RA-06] [Withdrawn: Incorporated into ID.IM-03, ID.IM-04] [Withdrawn: Incorporated into ID.IM-03]

**SCF Controls:** GOV-01.1, GOV-01.2, RSK-01, RSK-01.1, RSK-03, RSK-03.1, RSK-04, RSK-04.1, RSK-05, RSK-09

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control ID.AM

> Inventories of hardware managed by the organization are maintained Inventories of software, services, and systems managed by the organization are maintained Representations of the organization's authorized network communication and internal and external network data flows are maintained Inventories of services provided by suppliers are maintained Assets are prioritized based on classification, criticality, resources, and impact on the mission [Withdrawn: Incorporated into GV.RR-02, GV.SC-02] Inventories of data and corresponding metadata for designated data types are maintained Systems, hardware, software, services, and data are managed throughout their life cycles [Withdrawn: Incorporated into ID.AM-08, PR.PS-03] [Withdrawn: Incorporated into ID.AM-08, PR.PS-06] [Withdrawn: Incorporated into ID.AM-08] [Withdrawn: Incorporated into ID.AM-08, PR.PS-02] [Withdrawn: Incorporated into ID.AM-03]

**SCF Controls:** AST-01, AST-01.1, AST-01.2, AST-02, AST-03, AST-03.1, HRS-01, HRS-03, HRS-05, HRS-05.1, PES-01, RSK-02, TPM-01, TPM-01.1, TPM-05.4, TPM-06

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF contributes to IT Asset Management programs through built-in inventory, discovery, and integration capabilities that provide the technical foundation for asset tracking and governance.

VCF Operations groups discovered objects logically and provides detailed inventory lists across the environment, covering compute, storage, and networking resources. The inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group.

The Service Discovery adapter automatically discovers applications, services, and their associated metrics (CPU, memory) running on managed infrastructure. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be exported in CSV format for use in external asset tracking systems.

For organizations using ServiceNow, VCF provides two integration paths. The Management Pack for ServiceNow in VCF Operations populates the ServiceNow CMDB with discovered resources through the ServiceNow Table API and CMDB Meta API, providing CMDB visibility within VCF Operations. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation provides a structured data source that captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

VCF Automation adds governance through its project model, which controls who can deploy what resources and where those resources are deployed. Projects link users, catalog items, and IaaS resources together. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources.

Tags within VCF Automation express capabilities and constraints that define deployments. Cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

The broader ITAM program responsibilities of establishing asset governance policies, defining ownership lifecycles, and maintaining organizational accountability remain outside VCF's scope.

### **VMware vDefend (Contributes)**

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

Not applicable for this control: VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control ID.AM-01

> Inventories of hardware managed by the organization are maintained

**SCF Controls:** AST-02, TPM-01.1

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The SimpleClient sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. ResourceAttribute elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to

limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure

state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

### **VMware vDefend (Contributes)**

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator

creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

Not applicable for this control: VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control ID.AM-02

> Inventories of software, services, and systems managed by the organization are maintained

**SCF Controls:** AST-02, TPM-01.1

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The SimpleClient sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. ResourceAttribute elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to

limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure



state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

### **VMware vDefend (Contributes)**

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator

creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

Not applicable for this control: VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control ID.AM-03

> Representations of the organization's authorized network communication and internal and external network data flows are maintained [Withdrawn: Incorporated into ID.AM-03]

**SCF Controls:** AST-04, AST-04.2, DCH-19

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides several capabilities that contribute to maintaining network architecture diagrams and data flow documentation, though the organizational process of creating, maintaining, reviewing, and governing formal diagram artifacts remains a customer responsibility.

VCF Operations for Networks includes an end-to-end interactive network map that displays a detailed model of both physical and virtual devices in the environment, including physical switches, physical firewalls, routers, load balancers, transport nodes, and NSX virtual entities. The Network Map Summary presents a view of the data center that includes these entities along with an alert chart showing alert status across the inventory. Users can scope the view to focus on specific portions of the network. Because the map updates based on data collected from configured sources, it reflects the discovered state of the monitored infrastructure rather than a static diagram, providing a foundation for understanding the current network architecture and validating formal network diagrams.

NSX network connectivity workflows include a built-in topology visualization that correlates user configuration inputs with the resulting network topology, helping administrators understand the architecture before committing changes and reducing the risk of misconfiguration by providing a view of the entire setup. The NSX Manager Network Topology feature allows users to view network connectivity by zooming in to see details about logical entities and their logical paths, along with the services configured on those entities. The NSX Main Dashboard displays the topology of a selected object and how it connects to elements in the network, with a view of related alerts. The vSphere Client provides topology views of compute, storage, and network relationships, displaying logical and physical components such as segments, transport zones, and resource dependencies. The vSphere Distributed Switch topology diagram specifically shows information about the physical adapter connecting virtual adapters to the external network, with filters that default to displaying up to 32 port groups, 32 hosts, and 1,024 virtual machines.

The vSphere Network Inventory Dashboard provides a dedicated topology view of the vSphere network inventory, including information related to vSphere environments, vCenter instances, data centers, distributed vSwitches, distributed port groups, virtual machines, and associated properties and metrics. The Network Configuration Dashboard displays key configuration information including bar charts focused on critical security settings for vSphere distributed switches, providing visibility into the security-relevant configuration state of the network infrastructure.

For data flow analysis, VCF Operations for Networks collects flow data defined by 5-tuple values: source IP address, source port, destination IP address, destination port, and protocol. At the virtual switch level, vSphere Distributed Switches also support NetFlow export, configured with an Observation Domain ID that identifies the switch within the flow collection infrastructure, so flow data can be sent to external collectors for analysis alongside data collected by VCF Operations for Networks. The Access Flow Insight page in Network Operations allows analysis of all flows available in the environment, where each dot in the graph represents multiple flows and users can drill into individual flow details. The Custom Analysis section within Flow Insight provides two-dimensional visualization of flow data on user-selected dimensions to identify outliers in network traffic patterns. Flow metrics display traffic flow data collected from flow-enabled data sources, aggregated to show metrics such as total bytes and traffic rate. Flow analytics can also be run to understand bandwidth and packet rates.

VCF Operations for Networks supports flow-based application discovery, accessible by navigating to Infrastructure Operations, then Analyze, and selecting the Flows tab. This allows administrators to discover applications by analyzing traffic patterns and network flows in the environment, with the ability to modify the scope, naming preference, and duration of the discovery process. The application topology map displays traffic flows between application tiers, internet endpoints, shared services, and other applications, showing how data moves between workload groups. The map shows tier overviews, lists of

members (including VMs, Kubernetes services, and physical IPs), flows between tiers, and the physical IPs and shared services that applications depend on.

VCF Operations for Networks also provides a Security Planning capability that analyzes flows and displays traffic flow patterns and micro-segmentation views. This feature supports security assessment by making it possible to see how traffic moves through the environment, which is directly relevant to documenting sensitive or regulated data flows and assessing the security posture of the network architecture. The platform also provides planning and recommendations for implementing micro-segmentation security, and the micro-segmentation flow analysis interface allows filtering by protection status to view allowed and blocked flows.

VCF Operations for Networks includes a PCI Compliance page that presents a network flow diagram showing data flow paths, firewall placements, connections, and other details associated with the network. This built-in visualization is oriented toward compliance assessment and can supplement organizational network architecture documentation.

For multi-site environments, VCF Operations for Networks supports flow visualization for SDDC-to-SDDC communication through VMware Transit Connect via the VMware Managed Transit Gateway (VTGW), providing visibility into cross-data-center network flows. The Streaming Databus supports cross-data center network flow analysis by grouping query results by source data center, destination data center, and flow type.

Firewall rules can be exported to CSV files using the `run_fw_rule_export` CLI command, producing files that can be transferred via secure copy for integration into formal documentation. VCF also documents its own internal network ports and protocols at [ports.broadcom.com](https://ports.broadcom.com), which provides reference material for documenting the platform's own communication paths.

While VCF provides tools for network topology visualization, flow analysis, application discovery, and security-oriented network views, the control requires a formal organizational process for maintaining network architecture diagrams and data flow diagrams that are kept current and contain sufficient detail for security assessment. VCF's capabilities provide the underlying data and visualization tools that inform these diagrams, but the creation, review, approval, and maintenance lifecycle of the formal documentation is an organizational responsibility.

### **VMware vDefend (Contributes)**

VMware vDefend's Security Intelligence capability, delivered through the Security Services Platform (SSP), provides live network traffic flow visualization and security posture mapping that directly support the creation and maintenance of network architecture diagrams and data flow documentation. While maintaining formal network diagrams is an organizational responsibility, Security Intelligence generates interactive visualizations of network traffic patterns, security group relationships, and Distributed Firewall (DFW) rule coverage that serve as authoritative inputs to those diagrams.

Security Intelligence collects and displays network flow data through a visualization canvas covering groups, computes, destination ports, and Layer 7 application IDs. The visualization displays network traffic flows with color-coded indicators: red-hued dashed lines for unprotected flows, blue-hued solid lines for blocked flows, and green-hued solid lines for allowed flows. The Flow Details dialog shows completed network flows and the firewall rules in effect associated with each flow, linking observed traffic patterns to the policies governing them. Flow data includes the groups flows belong to, services used, Layer 7 application ID, and FQDN information. Network flow data is analyzed within a 15-minute window for near-real-time security status, and administrators can select a time period parameter to examine historical traffic flow data for architecture documentation.

Network traffic flows displayed in Security Intelligence are based on DFW rules in effect and observed traffic during the selected period, covering all traffic matching stateful Layer 4 DFW rules using IPv4 or IPv6. This directly supports the control's requirement that architecture diagrams reflect the current network environment and document how traffic flows through it. The Flow Insights Dashboard categorizes network objects into Rules, Groups, Computes, Destination Ports, and Layer 7 Application IDs, providing a structured multi-dimensional view of the environment's traffic architecture. Security Intelligence also monitors network flows between application pairs and tracks Policy Protection Status to indicate which application communication paths are being monitored.

Security Intelligence generates DFW security policy recommendations for application and environment categories based on analysis of traffic flows over a specified time period. These recommendations, grounded in observed traffic patterns, provide data-driven support for documenting how data flows through the environment and what security controls apply to those flows.

Network Detection and Response (NDR) extends this visibility by collecting and presenting detection events representing security-relevant activity in the network, helping security analysts understand threat patterns and the paths through which activity traverses the environment.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) contributes to network architecture and data flow documentation through its network mapping capabilities, which record the topology between protected and recovery sites and provide programmatic access to that information for inclusion in formal diagrams.

PNR supports site-wide network mappings that define how networks on the protected site correspond to networks on the recovery site. These mappings can specify a different network to use during recovery plan tests, capturing the separate set of data flows that apply during DR exercises. For stretched storage environments, network mappings can be configured manually to override automatic mapping behavior between sites.

The Protection and Recovery Plug-In for the VCF Operations orchestrator provides API workflows that enumerate these mappings programmatically. The Get Network Mappings workflow lists all networks on a local site with existing mappings. The Get Network Mapping Pairs workflow retrieves the full set of mapping pairs for a specified site. The Get Test Network Mapping Pairs workflow lists test network mappings between corresponding objects across the remote site, and can query both protected and recovery sites when both are registered as local, providing a complete picture of the site-to-site network topology. An Add Test Network Mapping to Recovery Plan workflow maps a remote network to a test network within a specific recovery plan. IP customization workflows allow per-mapping customization of IP mapping rules and can remove customization rules from existing mappings.

The Plug-In also supports inventory mapping workflows that span folder mappings, network mappings, resource pool mappings, and test network mappings, providing a unified interface for enumerating all inter-site relationships.

Organizations should incorporate PNR's network mapping data and Plug-In workflow outputs into their formal network architecture diagrams to document DR topology, test network configurations, and the data flows that traverse the replication paths between sites.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) provides application-layer geographic visibility that supports the data flow documentation this control requires. Its Global Server Load Balancing (GSLB) feature maintains an explicit record of where application services are deployed geographically. Geographic information for geolocated services is loaded into the GSLB leader Controller either in bulk or on a location-by-location basis, then converted to geo-DB format and distributed to all DNS Service Engines in the group. GSLB service members can be configured with geolocation data drawn from three sources: the geo-DB, user-configured values, or values inherited from the site. This configuration is a machine-readable registry of which application endpoints are active at which geographic locations. Operators configure geolocation-based load balancing through a Geo Profile, created in the Avi UI at Infrastructure > GSLB > Geo Profile, where a previously created geo-DB file object is selected as the Geo-DB Entries source.

At the application traffic level, Avi maintains geo-DB files that map IP addresses to region, city, latitude, and longitude data. The GSLB geo-DB supports multiple files as input, with a priority mechanism that determines which data takes precedence when multiple sources define a location for the same IP address. Custom geo-DB files can be uploaded to the Avi Controller and consumed by Service Engines for geolocation-based decisions. The Avi Service Engine Geo-DB implementation includes a System-LocationDB-File object stored at /var/lib/avi/geo\_db/admin containing region, city, latitude, and longitude data for IPv4 addresses. Avi Service Engines report geolocation information for client IP addresses, including latitude, longitude, and

geographic location names at the country, region, and city level, and this data appears in traffic logs and troubleshooting checklists.

The DataScript API function `avi.utils.get_geo_from_ip` retrieves geolocation data for a queried IP address, returning autonomous system (AS) number, country code, country name, continent name, continent code, latitude, longitude, region, and city. The DNS DataScript location API similarly returns a table containing validity status, longitude, latitude, location name, and client location tag. These APIs let operators build custom data flow reporting that identifies the geographic origin of application traffic programmatically.

Geolocation-based policies in WAF, the HTTP Policy Set, and Network Security Policy can reference geo-DB data to apply rules based on client geographic origin. Avi WAF Policy allows selection of a Geo Location Mapping Database from a drop-down menu. The HTTP Policy Set supports Geo-DB selection for use in the geolocation algorithm. Together, these capabilities let operators document which geographic regions application services serve and apply enforcement policies based on that geography.

Organizations should use GSLB site configuration and Avi's traffic analytics as inputs to a broader data flow inventory. The full inventory must extend to the compute, storage, and network layers of VCF that Avi's application delivery scope does not cover.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

## Control ID.AM-04

> Inventories of services provided by suppliers are maintained

**SCF Controls:** TPM-01.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control ID.AM-05

> Assets are prioritized based on classification, criticality, resources, and impact on the mission

**SCF Controls:** AST-04.1, BCD-02, DCH-02, TPM-02

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides several capabilities that support the identification and documentation of critical technology assets, applications, services, and data within a virtualized infrastructure.

VMware vCenter maintains a real-time inventory of all managed objects, including hosts, VMs, clusters, datastores, and networks, and supports linking multiple vCenter instances for centralized inventory management. The vCenter inventory tracks multiple instances of ClusterComputeResource, ComputeResource, Datacenter, Datastore, DistributedVirtualSwitch, and Folder objects, providing a structured view of all infrastructure components. VCF Operations can export lists of resources, such as powered-off virtual machines, to CSV files for offline documentation and review.

VCF Operations includes a Business Applications feature that allows administrators to group related infrastructure objects and assign business criticality classifications. Each Business Application can be tagged with a criticality level of Critical, Medium, or Low, with Medium as the default. The Object Summary card within VCF Operations displays details including the application's source, application tag, environment, and business criticality rating. This classification capability allows infrastructure teams to maintain a structured view of which applications and their underlying resources are most important to the organization.

VCF Operations Service Discovery automatically detects running services across the environment. Service Discovery displays a list of all supported services that can be discovered and those currently discovered on VMs once configured. It also discovers performance metrics for individual service objects and service type objects, maintaining a catalog of known services and their relationships to underlying infrastructure. This automated discovery reduces manual effort in maintaining an accurate asset inventory.

VCF Operations also provides alert definitions with configurable Impact and Criticality metadata. The Impact setting can be configured to values such as Risk to indicate potential problems, while the Criticality setting can be set to values like Immediate for proper alert prioritization. Alert notifications can be filtered by impact category and criticality level, helping teams classify infrastructure resources by their importance and focus attention on the most important infrastructure components. VCF Operations Insights data tracks resource capacity and can notify project owners of changes affecting their assets.

VCF Automation provides complementary asset identification capabilities through its resource discovery and tagging system. The discovery process automatically identifies machines, storage volumes, networks, load balancers, and security groups for each cloud account region that has been added. Once discovered, these resources can be organized using tags that facilitate search and identification. Tags placed on cloud zones, network profiles, storage profiles, and individual infrastructure resources function as capability tags that define desired capabilities and support governance by expressing capabilities and constraints. Using logical, human-readable tags for storage, network, and infrastructure items is recommended to facilitate search and identification functions.

VCF Automation organizes infrastructure through projects, which link users, catalog items, and IaaS resources to the locations where items are deployed. The Overview tab displays infrastructure and consumption metrics, providing a consolidated view of resource usage. Resource details views support filtering based on attributes such as project membership, enabling administrators to locate and review specific subsets of the infrastructure.

Blueprints in VCF Automation allow users to model complex IT services by visually designing infrastructure components such as VMs, networks, storage, and software components. Resource objects in blueprints represent the infrastructure components and services that are provisioned and managed, providing an architectural record of how assets support business functions.

Together, these inventory, discovery, classification, tagging, and visualization capabilities give operations teams the tools to identify, classify, and document the technology assets that support essential business functions. However, VCF provides the

technical tooling for asset identification and classification rather than the organizational processes needed to define which assets are critical to the business mission. Establishing criticality criteria, maintaining asset documentation, and conducting periodic reviews of critical asset designations require organizational processes that operate alongside the platform's capabilities.

### **VMware vDefend (Contributes)**

VMware vDefend contributes to identifying and documenting critical technology assets through the Security Services Platform (SSP) and its Security Intelligence feature, which provide asset inventory, classification, and visualization capabilities oriented toward network security segmentation planning.

Security Services Platform maintains a Platform Inventory of infrastructure assets, collecting status information for each asset including identification of assets that are timed out or out of sync. The inventory view provides filtering by Name and Status to locate specific infrastructure assets and identify their operational state. Tags assigned to each infrastructure asset are displayed for verification of tag assignments.

Security Intelligence gathers infrastructure services and servers from CSV files and discovers additional services and servers based on traffic flows analyzed from ESX hosts. During CSV import, Security Intelligence parses and validates the content format and inventory asset data. Security Intelligence also maps discovered unique assets during segmentation analysis, including workloads, groups, IP addresses, distributed virtual port groups (DVPGs), segments, tiers, infrastructure services, and infrastructure servers.

Security Services Platform identifies and publishes application assets, classifying them as either critical or regular applications. This criticality classification supports the identification of mission-critical technology assets within the environment. The inventory hierarchy spans regions, zones, environments, applications, and tiers, with each level displaying the total number of assets within its scope.

Security Intelligence organizes discovered and imported assets into structured Asset Collections: groups, infrastructure assets, environments (such as Production, Non-Prod, DMZ, PCI, and Development), applications, and application tiers. The Environment Asset Collection maps security zones to the operational contexts that support business functions. Application Asset Collections group workloads that provide enterprise functionalities, linking infrastructure resources to the business services they support. The Infrastructure Asset Collection node covers core networking services that enterprise workloads depend on, including LDAP, DNS, NTP, and DHCP. An Unknown Asset Collection surfaces compute entities that are not in the NSX inventory but are present in the data center and communicating to NSX entities, supporting discovery of assets that should be formally inventoried.

Security Intelligence Workload Classification can be set to "Infrastructure Service" to indicate that a compute entity provides infrastructure services such as DNS, DHCP, LDAP, and Syslog. Inferred infrastructure classifications for compute entities can be reviewed, accepted, or modified through the Monitor & Plan > Security Explorer interface.

These capabilities contribute to the control but do not fully satisfy it. vDefend's asset identification is scoped to network security segmentation planning rather than the enterprise-wide technology asset catalog this control requires. Identifying all critical technology assets, applications, services, and data across an organization requires broader inventory and configuration management capabilities within VCF, such as VCF Operations business application views, VMware vCenter inventory exports, and VCF Automation project tagging, which provide the enterprise-wide asset catalog that vDefend's security-focused inventory complements.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) organizes its protection model around identifying which assets are critical enough to warrant disaster recovery protection. Protection groups are an explicit declaration of critical assets, organizing virtual machines into logical units based on their replication and recovery requirements. Placing a workload in a protection group is a deliberate act of classifying it as essential to business operations.

Inventory mappings document how each protected-site asset (resource pools, folders, networks, datastores) corresponds to recovery-site resources, creating a structured record of the infrastructure that supports critical workloads. Site-wide inventory

mappings apply defaults across all protected VMs, while per-VM customizations document specific recovery configurations for workloads with unique requirements.

The Protection and Recovery Configuration Import/Export Tool exports a complete record of the DR asset inventory, including site names, inventory mappings, placeholder datastores, advanced settings, array managers with SRA information, protection groups, and recovery plans. This export provides a structured, portable document of which assets are protected and how they are configured for recovery. The export is produced in XML format, enabling automated processing and retention as a configuration record.

PNR generates and exports reports documenting each run of a recovery plan, each test of a recovery plan, and each test cleanup operation. These reports provide an auditable record of which recovery plans executed and which protected workloads were involved.

PNR tracks site metrics including paired sites, pair names, vCenter addresses, site connectivity status, and counts of protection groups, recovery plans, protected virtual machines, and array managers. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, providing consolidated visibility into the DR infrastructure as a class of managed assets.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control ID.AM-07

> Inventories of data and corresponding metadata for designated data types are maintained

**SCF Controls:** DCH-06, DCH-06.2, DCH-06.3, PRI-05, PRI-05.5

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control ID.AM-08

> Systems, hardware, software, services, and data are managed throughout their life cycles [Withdrawn: Incorporated into ID.AM-08, PR.PS-03] [Withdrawn: Incorporated into ID.AM-08, PR.PS-06] [Withdrawn: Incorporated into ID.AM-08] [Withdrawn: Incorporated into ID.AM-08, PR.PS-02]

**SCF Controls:** AST-01, AST-01.2, DCH-01, DCH-01.1, PRM-07, SEA-07, SEA-07.1

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF contributes to IT Asset Management programs through built-in inventory, discovery, and integration capabilities that provide the technical foundation for asset tracking and governance.

VCF Operations groups discovered objects logically and provides detailed inventory lists across the environment, covering compute, storage, and networking resources. The inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group.

The Service Discovery adapter automatically discovers applications, services, and their associated metrics (CPU, memory) running on managed infrastructure. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be exported in CSV format for use in external asset tracking systems.

For organizations using ServiceNow, VCF provides two integration paths. The Management Pack for ServiceNow in VCF Operations populates the ServiceNow CMDB with discovered resources through the ServiceNow Table API and CMDB Meta API, providing CMDB visibility within VCF Operations. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation provides a structured data source that captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

VCF Automation adds governance through its project model, which controls who can deploy what resources and where those resources are deployed. Projects link users, catalog items, and IaaS resources together. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources.

Tags within VCF Automation express capabilities and constraints that define deployments. Cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

The broader ITAM program responsibilities of establishing asset governance policies, defining ownership lifecycles, and maintaining organizational accountability remain outside VCF's scope.

### VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to data protection controls by providing network-level security mechanisms that protect data in transit and restrict unauthorized network access to systems where data is stored or processed.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level, restricting which workloads can communicate with data stores, databases, and application tiers. By segmenting the data center network into isolated security zones, vDefend limits the blast radius of a compromise and restricts lateral movement toward systems that hold sensitive data. Administrators define granular firewall rules based on workload identity, security tags, and application-level attributes, limiting access to data repositories to authorized services. Identity Firewall extends policy enforcement to user identity, allowing administrators to define access controls based on which authenticated user initiated the connection rather than solely the source workload, strengthening data access controls in environments with user-based authorization requirements. Security policies are defined, propagated, and enforced across Bare Metal servers through the Security Services Platform (SSP), extending microsegmentation protections beyond virtualized workloads to physical infrastructure connected to the environment.

The SSP includes Security Intelligence, which identifies risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP. This visibility allows administrators to detect and remediate unencrypted data flows that could expose sensitive information in transit. Security Intelligence administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment flows. Security Intelligence also enables administrators to generate policy recommendations and deploy them in monitor-before-enforcement mode, allowing observation of traffic patterns before applying restrictive rules. The SSP summary panel displays the number of services that are fully protected, partially protected, or not protected, giving administrators a dashboard view of segmentation coverage gaps across the environment.

IDS/IPS profiles attach to Distributed Firewall and Gateway Firewall rules to inspect east-west and north-south network traffic for signatures and behaviors associated with data theft, command-and-control communication, and exploitation of vulnerabilities in data-handling services. In vDefend, IDS/IPS signature rules support storing TLS/SSL certificates on disk for forensic analysis and threat investigation, providing durable artifacts for post-incident review of potential data exfiltration events.

Malware Prevention profiles attach to DFW and Gateway Firewall rules and can be configured to send files to the cloud for detailed analysis or to process files locally without cloud connectivity, accommodating environments with data-residency or air-gap requirements. Malware Prevention collects file analysis data including file hash submissions and assigns an Analyst UUID to each submission to track its analysis lifecycle. The Malware Prevention dashboard displays trends of malicious, suspicious, and suppressed file events across the data center, and file verdict filtering allows operators to focus on specific verdict categories such as malicious-only views.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to cloud services, providing a built-in data privacy mechanism for environments that enable cloud-assisted threat detection.

These network security controls complement the data-at-rest encryption, backup, replication, and access management capabilities provided by other VCF components. vDefend does not perform data encryption, classification, backup, or recovery itself, but it protects the network paths and access patterns through which data is stored, replicated, and retrieved.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides replication-based data protection for virtual machine workloads across sites. Protection groups allow administrators to organize virtual machines and datastores under consistent snapshot and replication policies at scale, covering both local recovery via vSAN snapshots and cross-site recovery via vSphere Replication or array-based replication. Protection group membership can be modified after creation, and virtual machines can be automatically enrolled for protection using storage tag selection on designated datastores, reducing manual overhead in maintaining protection coverage across a growing environment.

PNR introduces an immutability mode for protection groups that, when enabled, prevents the data protection group from being modified or deleted. This mechanism allows administrators to safeguard protection configurations against inadvertent or unauthorized changes. PNR Health monitoring provides consolidated visibility into data protection service health, operation issues for local and replication snapshots, storage utilization, and protection group membership changes, giving administrators a current view of protection posture across the environment.

Site Recovery Manager (SRM) integrates with vSphere Replication to provide orchestrated failover with configurable recovery point objectives, giving organizations control over acceptable data loss thresholds for protected workloads. PNR supports additional site topologies, including shared recovery site configurations where protected site resources are mapped to isolated datacenters, networks, folders, and datastores on the recovery site. Inventory mappings allow administrators to define resource configurations once and apply them consistently across protection groups.

vSAN Snapshots and Replication is a native, integrated snapshot-based backup capability for virtual machines running on vSAN datastores, managed through the vSphere Client. It provides VM restore and clone operations from existing snapshots, supporting both rapid recovery from operational failures and ransomware recovery scenarios. Test failover operations allow administrators to validate that recovery configurations are functional before an actual recovery event occurs.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) provides several mechanisms that support data protection for managed database instances, covering PostgreSQL, MySQL, and SQL Server databases.

The most direct contribution is DSM's automated backup framework, which administrators can enable on a per-database basis or through data service policies. When configured, DSM performs scheduled full and incremental backups of database content and stores them in S3-compatible object storage at a configurable backup location. Backup retention is configurable (backup-retention-period), and DSM retains backups of deleted databases until the configured retention period expires, supporting recovery from accidental deletion. For point-in-time recovery, DSM restores a backup to a newly created database VM with a user-specified name and datastore location, and can target the most recent timestamp or a specific point in time. DSM archives binary logs in backup storage as part of its backup protection mechanism. Administrators can also initiate manual on-demand backups of primary PostgreSQL databases to safeguard data before high-impact operations or as immediate protection after major changes. For PostgreSQL multi-site deployments, DSM performs a full backup automatically during a promotion event before resuming the regular schedule.

Data service policies give administrators control over backup behavior across all databases governed by a policy. Policies can require that databases have automated backups enabled, allow users to opt in, or disallow automated backups entirely. The allowed-backup-locations setting in the data service policy restricts users to selecting from approved backup locations, reducing the risk of backup misconfiguration. Policies can be enforced across multiple tenants and across different namespaces and namespace labels, supporting consistent data protection posture in multi-tenant deployments. A Compliance tab on data service policies displays compliance reports and allows administrators to expand each policy violation to view the noncompliant database, data service, and namespace, giving administrators visibility into where data protection requirements are not being met. In 9.1, data service policies extend to SQL Server databases in addition to MySQL and PostgreSQL.

DSM implements role-based access control that separates administrative and user-level database access. DSM Admins can create, monitor, and manage all data services in the environment; DSM Users can only manage and monitor the data services they own. This access model limits who can modify backup configurations and policy settings. Infrastructure policies govern which storage resources are available for database VMs, including CPU, memory, storage policies, IP pool, and VM classes, giving administrators control over the storage environment in which data resides.

Control plane recovery requires that a Provider Backup Repo has been configured at installation time. If the Provider VM fails, the restore-provider command restores it to the latest timestamp. In the VCF Automation context, tenants can perform point-in-time restores directly through the VCF Automation UI, broadening restore access to self-service scenarios.

One limitation applies: if an incremental backup in the backup chain is deleted, DSM cannot restore the full data; a successful restore from an incremental chain requires the last full backup and all following incremental backups. Organizations must protect the integrity of the backup chain through access controls on the backup storage.

DSM provides configurable backup, recovery, and policy enforcement mechanisms for managed database instances. The broader data protection program requires organizational decisions about backup schedules, retention periods, backup storage security, and off-site management that DSM does not prescribe on its own.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

## Control ID.IM

> Improvements are identified from evaluations. Improvements are identified from security tests and exercises, including those done in coordination with suppliers and relevant third parties. Improvements are identified from execution of operational processes, procedures, and activities. Incident response plans and other cybersecurity plans that affect operations are established, communicated, maintained, and improved. [Withdrawn: Incorporated into GV.SC-08, ID.IM-02] [Withdrawn: Incorporated into ID.IM, ID.IM-03] [Withdrawn: Moved to ID.IM-03] [Withdrawn: Moved to ID.IM-04] [Withdrawn: Incorporated into ID.IM-02, ID.IM-04] [Withdrawn: Incorporated into ID.IM-02] [Withdrawn: Incorporated into ID.IM-03, ID.IM-04] [Withdrawn: Incorporated into ID.IM-03]

**SCF Controls:** OPS-01, OPS-01.1, RSK-01, RSK-09

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control ID.IM-01

> Improvements are identified from evaluations

**SCF Controls:** CPL-03, CPL-03.2, IAO-02, IAO-02.4, IAO-05, TDA-09, TDA-09.1, TPM-04.1, TPM-08

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides configuration-state review and continuous compliance monitoring capabilities that contribute to regular functional reviews of cybersecurity and data protection controls across the infrastructure stack, though the organizational review process, schedule, and corrective action procedures must be established and maintained outside the platform.

VCF Operations includes a compliance management capability that continuously monitors infrastructure against industry-standard security benchmarks and custom policies. Rather than relying solely on periodic manual reviews, VCF Operations flags configuration drift and policy deviations as they occur, giving auditors and administrators ongoing visibility into the compliance posture of technology assets and services running on the platform. When VCF Operations detects non-compliance with a policy, it can generate alerts or notifications, and depending on the severity, administrators can configure automated remediation actions to bring the object back into compliance. Compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations.

VCF Operations calculates a compliance score for each managed object based on the ratio of compliant objects to total objects assessed by a given benchmark, expressed as a percentage. The most critical violated standard determines the overall compliance score for a given object, making it straightforward to identify which assets need attention first. Compliance score cards display the number of non-compliant objects and the total number of objects affected by each hardening guide. Administrators manage all compliance-related tasks from the Security > Compliance page, where they can discover non-compliant objects, review associated violations, and take remedial action.

To support structured reviews against recognized standards, VCF provides pre-built compliance packs available as native packs from the compliance repository. These include packs aligned with ISO security standards and the DISA Security Technical Implementation Guide (STIG), among others. Organizations can apply these packs to evaluate their VCF deployment against established security baselines, identify gaps, and track remediation progress. The vSphere Security Configuration Guide and the vSAN Security Configuration Guide provide additional hardening guidance and address compliance considerations, and are references for what settings and configurations to verify during a functional review. The NSX Security Configuration Guide provides recommendations for securing NSX components such as NSX nodes, NSX Controllers, and NSX Edge nodes.

Beyond the built-in benchmarks, organizations can create custom compliance benchmarks that codify their own cybersecurity and data protection policies. Custom benchmarks are configured through a multi-step process that includes naming, selecting compliance alerts to monitor, and activating policies. VCF Operations supports up to five custom compliance score cards. Custom benchmarks can be exported from one VCF Operations instance and imported to another, providing consistent policy enforcement across multiple deployments.

At the host layer, VCF Operations Configuration Drifts provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. vSphere Configuration Profiles must be enabled on clusters to view drift status, and the feature applies to deployments running VCF or later. The Configuration Drift dashboard allows administrators to view and monitor drift statuses, detecting when hosts fall out of their desired-state configurations. vSphere Lifecycle Manager can check the compliance of a cluster or host against the desired state and determine whether additional remediation steps are required.

NSX provides its own compliance status reporting. NSX Manager offers a Compliance Status Report accessible from the Monitoring Dashboards that displays the number of affected resources and compliance status. The report identifies non-compliant configurations by non-compliance code, description, compliance standard violated, affected resource name or ID, and resource type. Organizations can use the NSX compliance report to configure their NSX environment to adhere to IT policies and industry standards.



The VMware Kubernetes Service (VKS) layer of VCF extends compliance review capabilities to containerized workloads and the Kubernetes control plane. Pod Security Admission (PSA) is the built-in Kubernetes admission controller that evaluates pod specifications against defined security standards at the point of deployment. PSA operates in three modes: enforce blocks non-compliant pods from running, audit records security violations as audit events without blocking deployment, and warn returns warnings to the caller without blocking. Organizations can configure PSA to enforce a baseline standard cluster-wide while operating the restricted standard in audit and warn modes, producing an ongoing stream of compliance findings about workloads that do not meet the stricter profile without disrupting existing workloads. PSA can be configured per namespace using the podSecurityStandard API, allowing different review stringency to be applied to different teams or workload types. Pods' security contexts should be separately reviewed to identify any privileges or capabilities that exceed what the predefined security standards permit for a given use case.

VKS Cluster Management provides out-of-the-box security policy templates that mirror the Kubernetes Pod Security Standards profiles, including baseline and restricted. The baseline template mitigates common privilege escalation risks while maintaining compatibility with standard containerized workloads. Custom security policy templates extend these defaults, allowing organizations to fine-tune individual security context parameters in support of governance requirements specific to their environment.

For Kubernetes RBAC review, the Kubernetes documentation distributed with VKS notes that the default RBAC rights provided in clusters should be reviewed to identify opportunities for security hardening. Auditors reviewing a VKS deployment should examine ClusterRole and ClusterRoleBinding objects for overly broad permissions as well as namespace-scoped Role and RoleBinding objects for each team or namespace. IAM role trust policies should be scoped to specific service accounts and namespaces to support least-privilege enforcement.

STIGs for VKS system components, including Supervisor and VMware Kubernetes Release (VKr) components, are available through Tanzu STIG Hardening and provide a recognized baseline against which deployed VKS environments can be compared during periodic compliance reviews.

Harbor Registry, available as a standard package on VKS clusters, provides vulnerability scanning, content trust, and policy-based replication to help evaluate the security of the container image supply chain. Harbor's role-based access controls and artifact policies can themselves be audited to confirm that only approved images are accessible to workloads. Within CI/CD pipelines integrated through Harness, the Harness Security Testing Orchestration (STO) capability enforces policy based on CVE data and severity thresholds, and Wiz integrates with the pipeline to authenticate to the artifact registry, pull container images, and perform vulnerability scanning before workloads are promoted to production. Wiz can also be deployed as a service on VKS clusters to continuously monitor the cloud environment and deployed workloads for security risks and compliance deviations.

Third-party policy engines such as Kyverno and OPA Gatekeeper can be deployed on VKS clusters to implement policy-as-code compliance review. These tools evaluate cluster resources against defined policies and can generate compliance reports identifying violations across the cluster, extending the platform's built-in review instrumentation.

For auditors evaluating a VCF environment against this control, the key areas to examine are: whether VCF Operations compliance monitoring is enabled and configured with benchmarks that map to the organization's policies; whether compliance packs appropriate to the organization's regulatory environment have been applied; whether the Configuration Drifts feature is active for vSphere clusters; whether PSA is configured in audit and warn modes on VKS namespaces to produce ongoing compliance findings; whether RBAC bindings across VKS clusters have been reviewed against least-privilege expectations; and whether the compliance dashboard and NSX compliance reports are being reviewed on a regular cadence with findings triaged and remediated.

These capabilities verify that infrastructure configurations match desired baselines and that compliance benchmarks are met, but they do not functionally test whether security controls are actively operating as intended. Organizations should supplement VCF's configuration-state reviews with periodic functional validation such as security assessments or controlled test scenarios. The review schedule, escalation procedures, and corrective action processes are organizational responsibilities that VCF does not enforce on its own.



## VMware vDefend (Contributes)

VMware vDefend contributes to the functional review of cybersecurity controls by providing network security-specific compliance assessment, policy analysis, and segmentation scoring capabilities. While the broader review of all technology assets against organizational policies is handled by VCF Operations and its compliance management features, vDefend provides the network security dimension of that review.

Security Services Platform includes a Security Segmentation score and report generation capability that helps compliance officers meet security audit requirements and demonstrate adherence to network security best practices. This scoring mechanism evaluates the current state of microsegmentation policy enforcement across the environment, providing auditors a quantitative measure of alignment between network security controls and policy objectives. The Security Segmentation Score Breakdown report details total environments and pairs, protection rule actions, and highlights environment pairs that lack inter-environment policies, providing specific visibility into coverage gaps in the microsegmentation posture. The Security Policies window within Security Services Platform displays all firewall rules applied for environment pairs, and administrators can change the action of published environment pair protection rules directly from this view.

The metrics service within Security Services Platform collects key performance indicators and operational data points across vDefend components including Distributed Firewall, Gateway Firewall, IDS/IPS, and TLS Inspection, providing the data foundation for ongoing compliance reviews. Viewing the TLS Inspection dashboard requires Security Services Platform to be deployed with the Metrics feature enabled. Security Services Platform Inventory monitoring allows administrators to view the infrastructure hierarchy including regions, zones, and VMs to verify correct definition, supporting periodic reviews of Technology Assets.

Security Services Platform's Security Intelligence capability provides policy recommendation analysis that compares recommended rules, groups, and services against the current environment to identify gaps between desired and actual security policy. Administrators use the Monitor & Plan interface to review, filter, and manage policy recommendations, identifying where current firewall rules diverge from what traffic analysis suggests is appropriate. Recommendations can be filtered by Status and Ready to Publish state, and scoped to selected groups and VMs. Policy Recommendations can be exported in JSON format with resource\_type, id, and children elements for infrastructure and domain configuration, allowing compliance teams to analyze recommended rule sets outside the platform.

The Security Overview dashboard in Security Services Platform provides summary-level statistics of file inspections, and the platform provides monitoring of current deployment status and platform-related alarms that highlight errors requiring attention. Security Services Platform support bundles collect diagnostic information from all controller and worker nodes in the deployment for troubleshooting and compliance documentation. Security Services Platform also supports assessment of control effectiveness by enabling comparison of the ratio of detected versus prevented events, providing reviewers a quantifiable measure of security control activity relative to observed threats.

Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The dedicated Auditor role is designed for personnel performing compliance and security reviews, allowing compliance teams to access review and assessment capabilities without requiring administrative privileges.

## VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides built-in mechanisms that support regular review of database infrastructure assets for adherence to security, compliance, and resilience policies.

The most direct compliance review mechanism in DSM is the Compliance tab, available on each data service policy detail page. This tab displays compliance reports for data service policies and allows administrators to expand policy violations to identify noncompliant databases, data services, namespaces, and resource configurations. Administrators can use this view to assess which database instances are operating outside defined policy parameters and take corrective action.

Infrastructure policies in DSM create a framework of standards against which deployed database resources are evaluated. Administrators define data service policies that govern resource consumption limits, storage placement, VM class selection,

and IP range assignments. These policies apply to PostgreSQL, MySQL, and SQL Server databases and can be enforced across different tenants to maintain a consistent security and compliance posture. The Infrastructure Policies view in the DSM administrator UI lists all policies in the environment and shows which databases are associated with each policy, providing a consolidated view for compliance assessment.

DSM generates infrastructure policy compliance alerts, including `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, to flag when cluster configurations drift from policy requirements. The monitoring framework also raises metrics-based and status-condition-based alerts to identify critical failure conditions across database engines, including engine degradation, non-operational status, and backup failures for PostgreSQL, MySQL, and SQL Server databases. These alerts provide ongoing visibility into the compliance and resilience state of database resources without requiring manual inspection.

For resilience review specifically, DSM requires that High Availability be activated on VMware vCenter clusters as a prerequisite for infrastructure policy compliance. The resiliency of the DSM Provider Appliance itself is provided through vSphere HA. These requirements are surfaced through the policy compliance alerting mechanism, making infrastructure resilience status an integrated part of policy compliance reporting.

Organizations should supplement DSM's built-in compliance reporting with documented review schedules, assigned review responsibilities, and a process for tracking and remediating identified violations. DSM provides technical visibility into policy adherence for database infrastructure, but the organizational governance processes that constitute a complete functional review program remain the responsibility of the operating organization.

#### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) supports organizational reviews of application-layer security, compliance, and resilience through its built-in reporting capabilities.

The Application Security Report generates audit-ready records of WAF findings, statistics, and overall security posture accessible to both technical teams and executive stakeholders. The report is available as a downloadable PDF, making it suitable for sharing findings with auditors and compliance reviewers. Security teams can use this report to assess whether Avi-managed applications are aligned with organizational security policies and to track posture over time.

The WAF Evaluation Report provides structured recommendations for strengthening an application's security posture, giving reviewers a concrete basis for identifying and remediating configuration gaps across virtual services.

In 9.1, Positive Security configuration has been consolidated under Virtual Service > Positive Security Policy, a change from its prior location within the WAF Policy. This mechanism determines which learned application behaviors are promoted to enforced security rules. Periodic review of the Positive Security Policy is part of maintaining the application security posture across Avi-protected services.

User-Defined Metrics extend Avi's reporting capabilities by allowing administrators to define and extract customized telemetry data required for specific enterprise compliance or reporting needs through API calls. This capability supports integration of Avi-specific application metrics into broader compliance dashboards and review workflows.

Avi's contribution to this control is bounded by its role as an application delivery controller. The review program this control requires, encompassing all technology assets and services across the organization, is an organizational governance responsibility that extends beyond the application-layer reporting and validation capabilities Avi provides.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

## Control ID.IM-02

> Improvements are identified from security tests and exercises, including those done in coordination with suppliers and relevant third parties [Withdrawn: Incorporated into GV.SC-08, ID.IM-02] [Withdrawn: Incorporated into ID.IM-02, ID.IM-04] [Withdrawn: Incorporated into ID.IM-02]

**SCF Controls:** BCD-05, CPL-03, CPL-03.2, IAO-02, IAO-02.4, IAO-05, IRO-13, TDA-09, TDA-09.1, TPM-04.1, TPM-08

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides configuration-state review and continuous compliance monitoring capabilities that contribute to regular functional reviews of cybersecurity and data protection controls across the infrastructure stack, though the organizational review process, schedule, and corrective action procedures must be established and maintained outside the platform.

VCF Operations includes a compliance management capability that continuously monitors infrastructure against industry-standard security benchmarks and custom policies. Rather than relying solely on periodic manual reviews, VCF Operations flags configuration drift and policy deviations as they occur, giving auditors and administrators ongoing visibility into the compliance posture of technology assets and services running on the platform. When VCF Operations detects non-compliance with a policy, it can generate alerts or notifications, and depending on the severity, administrators can configure automated remediation actions to bring the object back into compliance. Compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations.

VCF Operations calculates a compliance score for each managed object based on the ratio of compliant objects to total objects assessed by a given benchmark, expressed as a percentage. The most critical violated standard determines the overall compliance score for a given object, making it straightforward to identify which assets need attention first. Compliance score cards display the number of non-compliant objects and the total number of objects affected by each hardening guide. Administrators manage all compliance-related tasks from the Security > Compliance page, where they can discover non-compliant objects, review associated violations, and take remedial action.

To support structured reviews against recognized standards, VCF provides pre-built compliance packs available as native packs from the compliance repository. These include packs aligned with ISO security standards and the DISA Security Technical Implementation Guide (STIG), among others. Organizations can apply these packs to evaluate their VCF deployment against established security baselines, identify gaps, and track remediation progress. The vSphere Security Configuration Guide and the vSAN Security Configuration Guide provide additional hardening guidance and address compliance considerations, and are references for what settings and configurations to verify during a functional review. The NSX Security Configuration Guide provides recommendations for securing NSX components such as NSX nodes, NSX Controllers, and NSX Edge nodes.

Beyond the built-in benchmarks, organizations can create custom compliance benchmarks that codify their own cybersecurity and data protection policies. Custom benchmarks are configured through a multi-step process that includes naming, selecting compliance alerts to monitor, and activating policies. VCF Operations supports up to five custom compliance score cards. Custom benchmarks can be exported from one VCF Operations instance and imported to another, providing consistent policy enforcement across multiple deployments.

At the host layer, VCF Operations Configuration Drifts provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. vSphere Configuration Profiles must be enabled on clusters to view drift status, and the feature applies to deployments running VCF or later. The Configuration Drift dashboard allows administrators to view and monitor drift statuses, detecting when hosts fall out of their desired-state configurations. vSphere Lifecycle Manager can check the compliance of a cluster or host against the desired state and determine whether additional remediation steps are required.

NSX provides its own compliance status reporting. NSX Manager offers a Compliance Status Report accessible from the Monitoring Dashboards that displays the number of affected resources and compliance status. The report identifies non-compliant configurations by non-compliance code, description, compliance standard violated, affected resource name or ID,

and resource type. Organizations can use the NSX compliance report to configure their NSX environment to adhere to IT policies and industry standards.

The VMware Kubernetes Service (VKS) layer of VCF extends compliance review capabilities to containerized workloads and the Kubernetes control plane. Pod Security Admission (PSA) is the built-in Kubernetes admission controller that evaluates pod specifications against defined security standards at the point of deployment. PSA operates in three modes: enforce blocks non-compliant pods from running, audit records security violations as audit events without blocking deployment, and warn returns warnings to the caller without blocking. Organizations can configure PSA to enforce a baseline standard cluster-wide while operating the restricted standard in audit and warn modes, producing an ongoing stream of compliance findings about workloads that do not meet the stricter profile without disrupting existing workloads. PSA can be configured per namespace using the podSecurityStandard API, allowing different review stringency to be applied to different teams or workload types. Pods' security contexts should be separately reviewed to identify any privileges or capabilities that exceed what the predefined security standards permit for a given use case.

VKS Cluster Management provides out-of-the-box security policy templates that mirror the Kubernetes Pod Security Standards profiles, including baseline and restricted. The baseline template mitigates common privilege escalation risks while maintaining compatibility with standard containerized workloads. Custom security policy templates extend these defaults, allowing organizations to fine-tune individual security context parameters in support of governance requirements specific to their environment.

For Kubernetes RBAC review, the Kubernetes documentation distributed with VKS notes that the default RBAC rights provided in clusters should be reviewed to identify opportunities for security hardening. Auditors reviewing a VKS deployment should examine ClusterRole and ClusterRoleBinding objects for overly broad permissions as well as namespace-scoped Role and RoleBinding objects for each team or namespace. IAM role trust policies should be scoped to specific service accounts and namespaces to support least-privilege enforcement.

STIGs for VKS system components, including Supervisor and VMware Kubernetes Release (VKr) components, are available through Tanzu STIG Hardening and provide a recognized baseline against which deployed VKS environments can be compared during periodic compliance reviews.

Harbor Registry, available as a standard package on VKS clusters, provides vulnerability scanning, content trust, and policy-based replication to help evaluate the security of the container image supply chain. Harbor's role-based access controls and artifact policies can themselves be audited to confirm that only approved images are accessible to workloads. Within CI/CD pipelines integrated through Harness, the Harness Security Testing Orchestration (STO) capability enforces policy based on CVE data and severity thresholds, and Wiz integrates with the pipeline to authenticate to the artifact registry, pull container images, and perform vulnerability scanning before workloads are promoted to production. Wiz can also be deployed as a service on VKS clusters to continuously monitor the cloud environment and deployed workloads for security risks and compliance deviations.

Third-party policy engines such as Kyverno and OPA Gatekeeper can be deployed on VKS clusters to implement policy-as-code compliance review. These tools evaluate cluster resources against defined policies and can generate compliance reports identifying violations across the cluster, extending the platform's built-in review instrumentation.

For auditors evaluating a VCF environment against this control, the key areas to examine are: whether VCF Operations compliance monitoring is enabled and configured with benchmarks that map to the organization's policies; whether compliance packs appropriate to the organization's regulatory environment have been applied; whether the Configuration Drifts feature is active for vSphere clusters; whether PSA is configured in audit and warn modes on VKS namespaces to produce ongoing compliance findings; whether RBAC bindings across VKS clusters have been reviewed against least-privilege expectations; and whether the compliance dashboard and NSX compliance reports are being reviewed on a regular cadence with findings triaged and remediated.

These capabilities verify that infrastructure configurations match desired baselines and that compliance benchmarks are met, but they do not functionally test whether security controls are actively operating as intended. Organizations should supplement VCF's configuration-state reviews with periodic functional validation such as security assessments or controlled

test scenarios. The review schedule, escalation procedures, and corrective action processes are organizational responsibilities that VCF does not enforce on its own.

### **VMware vDefend (Contributes)**

VMware vDefend contributes to the functional review of cybersecurity controls by providing network security-specific compliance assessment, policy analysis, and segmentation scoring capabilities. While the broader review of all technology assets against organizational policies is handled by VCF Operations and its compliance management features, vDefend provides the network security dimension of that review.

Security Services Platform includes a Security Segmentation score and report generation capability that helps compliance officers meet security audit requirements and demonstrate adherence to network security best practices. This scoring mechanism evaluates the current state of microsegmentation policy enforcement across the environment, providing auditors a quantitative measure of alignment between network security controls and policy objectives. The Security Segmentation Score Breakdown report details total environments and pairs, protection rule actions, and highlights environment pairs that lack inter-environment policies, providing specific visibility into coverage gaps in the microsegmentation posture. The Security Policies window within Security Services Platform displays all firewall rules applied for environment pairs, and administrators can change the action of published environment pair protection rules directly from this view.

The metrics service within Security Services Platform collects key performance indicators and operational data points across vDefend components including Distributed Firewall, Gateway Firewall, IDS/IPS, and TLS Inspection, providing the data foundation for ongoing compliance reviews. Viewing the TLS Inspection dashboard requires Security Services Platform to be deployed with the Metrics feature enabled. Security Services Platform Inventory monitoring allows administrators to view the infrastructure hierarchy including regions, zones, and VMs to verify correct definition, supporting periodic reviews of Technology Assets.

Security Services Platform's Security Intelligence capability provides policy recommendation analysis that compares recommended rules, groups, and services against the current environment to identify gaps between desired and actual security policy. Administrators use the Monitor & Plan interface to review, filter, and manage policy recommendations, identifying where current firewall rules diverge from what traffic analysis suggests is appropriate. Recommendations can be filtered by Status and Ready to Publish state, and scoped to selected groups and VMs. Policy Recommendations can be exported in JSON format with resource\_type, id, and children elements for infrastructure and domain configuration, allowing compliance teams to analyze recommended rule sets outside the platform.

The Security Overview dashboard in Security Services Platform provides summary-level statistics of file inspections, and the platform provides monitoring of current deployment status and platform-related alarms that highlight errors requiring attention. Security Services Platform support bundles collect diagnostic information from all controller and worker nodes in the deployment for troubleshooting and compliance documentation. Security Services Platform also supports assessment of control effectiveness by enabling comparison of the ratio of detected versus prevented events, providing reviewers a quantifiable measure of security control activity relative to observed threats.

Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The dedicated Auditor role is designed for personnel performing compliance and security reviews, allowing compliance teams to access review and assessment capabilities without requiring administrative privileges.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) provides built-in mechanisms that support regular review of database infrastructure assets for adherence to security, compliance, and resilience policies.

The most direct compliance review mechanism in DSM is the Compliance tab, available on each data service policy detail page. This tab displays compliance reports for data service policies and allows administrators to expand policy violations to identify noncompliant databases, data services, namespaces, and resource configurations. Administrators can use this view to assess which database instances are operating outside defined policy parameters and take corrective action.

Infrastructure policies in DSM create a framework of standards against which deployed database resources are evaluated. Administrators define data service policies that govern resource consumption limits, storage placement, VM class selection, and IP range assignments. These policies apply to PostgreSQL, MySQL, and SQL Server databases and can be enforced across different tenants to maintain a consistent security and compliance posture. The Infrastructure Policies view in the DSM administrator UI lists all policies in the environment and shows which databases are associated with each policy, providing a consolidated view for compliance assessment.

DSM generates infrastructure policy compliance alerts, including `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, to flag when cluster configurations drift from policy requirements. The monitoring framework also raises metrics-based and status-condition-based alerts to identify critical failure conditions across database engines, including engine degradation, non-operational status, and backup failures for PostgreSQL, MySQL, and SQL Server databases. These alerts provide ongoing visibility into the compliance and resilience state of database resources without requiring manual inspection.

For resilience review specifically, DSM requires that High Availability be activated on VMware vCenter clusters as a prerequisite for infrastructure policy compliance. The resiliency of the DSM Provider Appliance itself is provided through vSphere HA. These requirements are surfaced through the policy compliance alerting mechanism, making infrastructure resilience status an integrated part of policy compliance reporting.

Organizations should supplement DSM's built-in compliance reporting with documented review schedules, assigned review responsibilities, and a process for tracking and remediating identified violations. DSM provides technical visibility into policy adherence for database infrastructure, but the organizational governance processes that constitute a complete functional review program remain the responsibility of the operating organization.

#### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) supports organizational reviews of application-layer security, compliance, and resilience through its built-in reporting capabilities.

The Application Security Report generates audit-ready records of WAF findings, statistics, and overall security posture accessible to both technical teams and executive stakeholders. The report is available as a downloadable PDF, making it suitable for sharing findings with auditors and compliance reviewers. Security teams can use this report to assess whether Avi-managed applications are aligned with organizational security policies and to track posture over time.

The WAF Evaluation Report provides structured recommendations for strengthening an application's security posture, giving reviewers a concrete basis for identifying and remediating configuration gaps across virtual services.

In 9.1, Positive Security configuration has been consolidated under Virtual Service > Positive Security Policy, a change from its prior location within the WAF Policy. This mechanism determines which learned application behaviors are promoted to enforced security rules. Periodic review of the Positive Security Policy is part of maintaining the application security posture across Avi-protected services.

User-Defined Metrics extend Avi's reporting capabilities by allowing administrators to define and extract customized telemetry data required for specific enterprise compliance or reporting needs through API calls. This capability supports integration of Avi-specific application metrics into broader compliance dashboards and review workflows.

Avi's contribution to this control is bounded by its role as an application delivery controller. The review program this control requires, encompassing all technology assets and services across the organization, is an organizational governance responsibility that extends beyond the application-layer reporting and validation capabilities Avi provides.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

### Control ID.IM-03

> Improvements are identified from execution of operational processes, procedures, and activities [Withdrawn: Incorporated into ID.IM, ID.IM-03] [Withdrawn: Moved to ID.IM-03] [Withdrawn: Incorporated into ID.IM-03, ID.IM-04] [Withdrawn: Incorporated into ID.IM-03]

**SCF Controls:** BCD-05, GOV-05, IRO-13

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control ID.IM-04

> Incident response plans and other cybersecurity plans that affect operations are established, communicated, maintained, and improved [Withdrawn: Moved to ID.IM-04] [Withdrawn: Incorporated into ID.IM-02, ID.IM-04] [Withdrawn: Incorporated into ID.IM-03, ID.IM-04]

**SCF Controls:** BCD-01, BCD-06, IRO-04, IRO-04.2

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations.



HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

#### **VMware vDefend (Contributes)**

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

#### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

## Control ID.RA

> Vulnerabilities in assets are identified, validated, and recorded. Cyber threat intelligence is received from information sharing forums and sources. Internal and external threats to the organization are identified and recorded. Potential impacts and likelihoods of threats exploiting vulnerabilities are identified and recorded. Threats, vulnerabilities, likelihoods, and impacts are used to understand inherent risk and inform risk response prioritization. Risk responses are chosen, prioritized, planned, tracked, and communicated. Changes and exceptions are managed, assessed for risk impact, recorded, and tracked. Processes for receiving, analyzing, and responding to vulnerability disclosures are established. The authenticity and integrity of hardware and software are assessed prior to acquisition and use. Critical suppliers are assessed prior to acquisition. [Withdrawn: Incorporated into GV.OC-02, GV.SC-03, GV.SC-04, GV.SC-07, ID.RA-10] [Withdrawn: Incorporated into GV.SC-07, ID.RA-10] [Withdrawn: Incorporated into ID.RA-09, DE.CM-09] [Withdrawn: Incorporated into PR.PS-01, ID.RA-07] [Withdrawn: Incorporated into ID.RA-01, PR.PS-02] [Withdrawn: Incorporated into ID.RA-01] [Withdrawn: Moved to ID.RA-08] [Withdrawn: Incorporated into ID.RA-06]

**SCF Controls:** GOV-01, GOV-01.1, GOV-02, RSK-01, RSK-09

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control ID.RA-01

> Vulnerabilities in assets are identified, validated, and recorded [Withdrawn: Incorporated into ID.RA-01, PR.PS-02]  
[Withdrawn: Incorporated into ID.RA-01]

**SCF Controls:** IAO-01, IAO-02, IAO-05, RSK-04, RSK-04.1, TDA-09, VPM-01, VPM-06

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides integrated vulnerability and patch management capabilities across its infrastructure stack, addressing both the implementation and monitoring aspects of this control.

VCF includes built-in lifecycle management that automates the process of applying updates and patches to software components within the stack. Patch releases provide time-sensitive fixes to security and critical issues and can be applied selectively to individual components without requiring synchronized updates across all VCF components. VCF Operations includes a patch planner that identifies available updates for VCF core components, downloads binaries from online depots (or stages them for offline environments), and orchestrates installation across the stack. Pre-update validation runs health checks and compatibility verification before applying changes. VCF Operations automatically backs up components during the patch process to provide a recovery point in case of failure. For vCenter appliance patching, an LVM snapshot is automatically created before the patching process begins; if patching fails, the orchestrator offers the option to roll back to that snapshot or continue after addressing the underlying issue. Lifecycle management also provides tools for planning updates so that administrators can schedule maintenance windows and coordinate changes with minimal disruption to services.

vSphere Lifecycle Manager (vLCM) manages the desired-state configuration for ESX hosts, including firmware and drivers through Hardware Support Manager (HSM) plugins provided by OEM vendors. vLCM images consist of a base image, vendor add-ons, components, and firmware add-ons that can be independently retrieved and applied to hosts. vLCM scans hosts against the desired image specification, flags deviations, and remediates non-compliant hosts. vSphere Lifecycle Manager also supports Live Patch for applicable updates, enabling patches to be applied to ESX hosts without requiring them to enter maintenance mode. It works with three types of software depots (online, offline, and UMDS) to provide flexibility in how patches are sourced and distributed. Update Manager supports dynamic baselines that automatically adjust their patch data based on specified criteria each time new patches are downloaded, allowing administrators to define patching policies that stay current without manual intervention. The Update Manager PowerCLI module provides cmdlets for downloading software patches, creating and modifying baselines, and scanning and remediating virtual machines and hosts, enabling automation of patching workflows.

For the VMware Kubernetes Service (VKS) and vSphere Supervisor layer, Security Technical Implementation Guides (STIGs) are available for Supervisor and VMware Kubernetes Release (VKr) components through Tanzu STIG Hardening, providing a structured security configuration baseline against which VKS deployments can be assessed and remediated. VKr components and Standard Packages are updated using the VCF CLI ``vcf package installed update`` command, which upgrades a package installation to a newer version and applies new configuration values, giving administrators a structured mechanism for applying package-level updates to components running in the Supervisor environment. VCF building-block services have independent lifecycles, enabling components to be updated individually without affecting the broader environment. The Node Problem Detector can be deployed within VKS clusters to monitor node health and report infrastructure-level problems through configurable detection rules, supporting the monitoring dimension of vulnerability management at the workload tier.

For container workloads running on VKS, Harbor is available as a deployable Standard Package with built-in vulnerability scanning using the Trivy database, which can be configured to use a custom or mirrored repository for air-gapped deployments. Harbor also provides content trust features that support image signing and policy-based replication, giving operations teams mechanisms to detect and restrict deployment of images containing known vulnerabilities. Harbor packages are updated using the ``vcf package installed update harbor`` command. Kubernetes guidance recommends that container images be regularly scanned during creation and in deployment, with known vulnerable software patched before workloads reach the runtime environment. Kubernetes security vulnerabilities are tracked and announced through the Kubernetes Security Response Committee, which maintains an official list of known CVEs and publishes security-related announcements

to the kubernetes-announce mailing list. For CI/CD pipelines running on VCF, Harness CI/CD is available as a Supervisor Service with integrated Security Testing Orchestration (STO) that incorporates the Wiz CLI to automate vulnerability management throughout the pipeline, performing infrastructure-as-code (IaC) and secret detection scans and container image scans against artifacts stored in JFrog Artifactory. Vulnerability scan findings from Wiz are reported to the Harness security dashboard, and Harness STO automatically deduplicates findings and displays them on the vulnerabilities tab of each pipeline execution for review.

VCF Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack, providing detailed descriptions, root cause insights, and actionable remediation steps. The Security Operations dashboard in VCF Operations provides a consolidated view of security posture, helping administrators identify areas requiring attention. VCF Operations compliance management continuously monitors infrastructure for policy violations, highlights risk areas, and provides actionable remediation recommendations. When VCF Operations detects non-compliance with a policy, it can generate alerts or notifications, and depending on the severity of the non-compliance, automated remediation actions can be configured to bring the object back into compliance.

Configuration drift monitoring provides an additional layer of ongoing assurance. VCF Operations provides unified configuration management that supports scheduled drift detection for vCenter and cluster objects. It detects deviations from assigned configuration template values, displays drift results across all configuration templates, and allows administrators to compare changes against desired values. This helps identify unauthorized or unintended changes to the infrastructure that could introduce vulnerabilities.

Patching operations are governed by role-based access controls. Editing remediation settings in vSphere Lifecycle Manager requires specific privileges (`VcIntegrity.lifecycleSettings.Read` and `VcIntegrity.lifecycleSettings.Write`), and image remediation operations require a separate set of API privileges.

Broadcom publishes security advisories (VMSAs) for VCF vulnerabilities and releases patches to address them.

### **VMware vDefend (Contributes)**

VMware vDefend contributes to vulnerability management through network-layer detection, virtual patching, and security posture monitoring capabilities that complement traditional patch management workflows.

vDefend Distributed IDS/IPS provides signature-based detection of vulnerability exploitation attempts across east-west traffic within the data center. When a new vulnerability is disclosed, administrators can deploy custom IDS/IPS signatures to detect and block exploitation attempts before official patches are available, a practice commonly referred to as virtual patching. In 9.1, IDS/IPS event monitoring displays Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by exploits, giving security teams direct visibility into which specific vulnerabilities are being actively targeted in their environment. The IDS/IPS dashboard provides monitoring and analysis of intrusion events, and Security Services Platform collects metrics to monitor IDS/IPS readiness and performance across the environment. Malicious IP reputation feeds, managed centrally through the Global Manager, automatically update threat intelligence so that known attacker infrastructure is blocked without manual intervention.

The Threat Event Monitoring dashboard in Security Services Platform displays the top IPs on which an intrusion was attempted and the top VMs based on Vulnerability Severity criteria. The Threat Event Monitoring tab on the Security Overview dashboard surfaces key insights about the current state of various security issues in the data center, helping security teams understand network activity and prioritize focus areas.

Security Intelligence, a feature within Security Services Platform, provides posture assessment and segmentation monitoring capabilities. Administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment traffic. The Security Posture dashboard presents information that can be used to plan and implement additional security policies. The Security Explorer provides a visual representation of workloads, their traffic flows, and connection status, which helps identify workloads that may be exposed to unpatched vulnerabilities. Security Services Platform also generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and traffic flows, providing the visibility needed to plan subsequent protection stages. The Security

Operator role in Security Services Platform is designated to monitor security systems and respond to security incidents, supporting the operational dimension of vulnerability management monitoring.

vDefend Advanced Threat Prevention extends detection capabilities to include behavioral analysis and sandboxing, identifying malware and exploit attempts that signature-based detection might miss. The Security Overview dashboard in Security Services Platform displays file inspection statistics organized by different ranges of threat score, giving security teams a quantitative view of file-based threats detected in their environment. This provides an additional layer of protection for systems awaiting patches.

These capabilities address the detection and monitoring dimensions of vulnerability management. Patch deployment and software lifecycle management are handled by other VCF components such as VCF Operations and vSphere Lifecycle Manager.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) provides patch management and monitoring capabilities that support an organization's vulnerability management program as it applies to the database services DSM manages.

For patch management, DSM exposes a Maintenance Policy that administrators configure in the vSphere Client. The Maintenance Policy controls when and for how long the platform applies automatic minor software updates to DSM appliances. Configurable settings include the start date (maintenance-policy-start-date), start time in hours and minutes (maintenance-policy-start-time), and duration of the update window (maintenance-policy-duration). The default maintenance window starts each Saturday at 23:59 with a six-hour duration, and administrators should always set a future date and time when configuring the policy. Upgrade operations during the maintenance window may include CVE fixes, bug fixes, and performance improvements. Per-database maintenance windows follow the same structure and can be adjusted during database creation or subsequent operations.

DSM requires that at least one complete chain of software updates for appliances be attempted, irrespective of the configured maintenance window duration. Patch cycles cannot be indefinitely deferred through policy configuration alone. Within the configured maintenance duration, plug-in software updates attempt up to three times with a 10-minute interval between attempts. The maintenance policy can be edited during the 10-minute interval between attempts, which cancels the next scheduled attempt and applies the newly configured policy. Administrators can view available upgrades and the upgrade history through the Version & Upgrade interface, accessible from the vSphere Client under the VMware vCenter Configure tab. The vSphere Administrator role is explicitly responsible for managing DSM VM updates and creating and managing infrastructure policies, which supports assigning patch management responsibilities to designated personnel. Both a vSphere administrator and a DSM user in the admin role can manage plug-in and database template software updates.

The DSM controller manages feature dependencies through status monitoring and automated remediation. When an upgrade requires resolution of VKS release dependencies, the controller automatically resumes the provisioning process after those dependencies are resolved, helping maintain patch state consistency during VCF environment upgrades.

DSM also provides monitoring capabilities that help identify conditions requiring remediation. The Global Alerts page, accessible in both the plug-in UI and the standalone UI, displays non-catastrophic alerts and system status. The Administrator UI Dashboard surfaces the same Global Alerts view for environment-wide visibility. DSM generates alerts for authentication failures, backup and restore corruptions, and certificate errors. The monitoring framework supports metrics-based and status-condition-based alerts covering conditions such as database engine degradation, non-operational status, and backup failure. Administrators and database users can configure alert thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections, each with separate warning and critical thresholds. DSM supports webhook-based alerting for database monitoring events triggered by threshold violations. DSM also provides mitigation suggestions alongside database alerts to help administrators resolve issues without disrupting database services. SQL Server administrators can define maintenance windows for operating system patching of SQL Server instances.

For diagnostics, DSM generates system support bundles containing system logs and diagnostic information, with a configurable retention duration before the system automatically deletes them. The Monitoring tab in the DSM UI displays monitoring data for individual database instances, including an Alerts pane and an Operations view for tracking operations



targeted on database VMs. DSM can also be monitored using VCF Operations for troubleshooting and status visibility, with VCF Operations providing a view of PostgreSQL and MySQL cluster health within the DSM environment.

The overall vulnerability management program, including scanning, prioritization, remediation timelines, and organizational governance, is an organizational responsibility outside DSM's scope. DSM contributes by providing the update scheduling mechanisms and monitoring visibility needed to act on vulnerability management decisions within the scope of the database services it manages.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer provides a structured patch management lifecycle for both the Controller and Service Engine groups, supporting the application delivery layer's contribution to an organizational vulnerability management program. The CLI patch command offers distinct patching modes (Controller Patch, SE Group Patch, Disruptive Patch, and System Patch), giving administrators flexibility to apply patches to specific components or across the entire system without requiring a full upgrade cycle. The documentation recommends applying patches only to the Service Engine groups that require them, based on Service Engine group segmentation. Patch images are uploaded to the Controller and verified for inclusion in the image bundle before any upgrade operation proceeds.

Rollback capability is available for patch releases via CLI. The ``rollbackpatch controller`` command reverts the Controller to the previous patch version, while ``rollbackpatch system`` rolls back the Controller and all Service Engine groups simultaneously. Rollback transitions the system to the version without the specific patch and does not roll back to the previous major version. The Avi for VCF documentation recommends planning a remediation strategy before re-attempting an upgrade following a rollback. On restore operations, the Controller checks for patches applied as part of the restore to maintain version consistency.

For application-layer vulnerability management, Avi Load Balancer supports virtual patching through two complementary mechanisms. The Web Application Firewall (WAF) integrates with Dynamic Application Security Testing (DAST) scanners; the Avi SDK integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning, allowing scan results to be imported and used to identify application vulnerabilities and apply WAF-based protections while permanent code fixes are developed and deployed. The Live Security Threat Intelligence service, available through the Cloud Console, extends virtual patching coverage with an Application Rules service providing rules designed to block attacks on known application vulnerabilities, including many with associated CVEs. These rules cover over 5,000 applications including WordPress, Drupal, and Apache, and are automatically updated through continuous Application Rules Database synchronization, keeping WAF protections current.

An Application Security Report provides a downloadable PDF documenting security findings and pre-check results, supporting vulnerability management reporting and documentation. The alert automation infrastructure supports ControlScripts that alert actions can invoke to automatically add offending client IP addresses to a blocklist attached to a network security policy, enabling automated response to detected threats.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.



## Control ID.RA-02

> Cyber threat intelligence is received from information sharing forums and sources

**SCF Controls:** GOV-07, THR-03

**Aggregate Coverage:** Contributes

### VMware vDefend (Contributes)

VMware vDefend contributes to this control through its threat intelligence consumption and detection infrastructure. The IDS/IPS engine applies knowledge-based signatures that encode specific patterns corresponding to known attack types, detecting intrusions based on known malicious instruction sequences at distributed and gateway enforcement points within vDefend-protected segments. Threat metadata feeds for Network Detection and Response are distributed and can be refreshed from online sources, or downloaded and applied manually in air-gapped environments through NSX Manager or a workstation connected to the Security Services Platform.

Network Detection and Response (NDR) correlates related detection events into campaigns and organizes them into a chronological timeline for security analyst review and triage. The Campaign view displays total detections and threats identified under Malicious Activity, and Campaign Correlation Rules provide structured visibility into how individual detections relate to broader attack patterns.

Security Intelligence maps detected suspicious events to adversarial tactics and techniques from the MITRE ATT&CK framework, recording the count of each tactic and technique observed during a selected time period. This TTP-level categorization supports the situational awareness the control describes for traffic traversing vDefend-protected segments. The threat visualization canvas aids rapid containment, identification of compromised assets, and adjustment of microsegmentation policies in response to detected activity. The blast radius analysis capability displays which communication paths a threat has affected, helping analysts determine whether an attack targets specific systems or represents a wider campaign.

Security Intelligence also collects related IDS events across the same source and destination hosts to connect relevant events and build a fuller picture of an attack sequence. The vDefend Security Assessment generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows to support protection planning. Security teams investigate individual events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take mitigation actions.

While vDefend delivers technical mechanisms for consuming threat intelligence feeds and mapping observed behavior to adversarial TTPs at the network layer, the broader organizational threat intelligence program, including sourcing intelligence from external providers, integrating with threat sharing platforms, and disseminating findings to other teams and tools, requires complementary processes and tooling outside the product.

### VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to situational awareness of evolving threats at the application delivery layer through its Live Security Threat Intelligence service, which delivers security threat feeds for multiple attack vectors in real time to protect applications from continuously changing threats. The Live Security Threat Intelligence service encompasses four components: an IP Reputation Service, an Application Rules Service, a WAF Signatures Service, and a Bot Management Service. The service is opt-in and must be explicitly enabled through Cloud Services configuration on the Avi Controller.

The IP Reputation Service classifies incoming client IP addresses against a regularly updated database, covering threat categories including botnets, phishing, spam sources, and DoS/DDoS attack sources. The service performs real-time automatic IP Reputation updates and operates across globally distributed Avi Load Balancer Controller clusters. Administrators attach an IP Reputation database to virtual services, and enforcement actions such as blocking or rate-limiting are applied per classification result.

The Application Rules Service provides rules specifically designed to block attacks on known application vulnerabilities, many of them mapped to CVEs, covering protection for over 5,000 applications including WordPress, Drupal, and Apache.

Application Rules are automatically updated on the Avi Controller, and administrators can enable auto-sync to receive Application Rules Database updates automatically when new rules are published.

The WAF Signatures Service allows Avi to receive notifications when new Core Rule Set (CRS) data is available and to automatically download updated WAF CRS rules. This keeps application-layer defenses aligned with current vulnerability intelligence without requiring manual administrator action.

The Bot Management Service delivers a real-time feed for the User-Agent database, a core bot detection component. User Agent Database Sync can be enabled to receive continuous User-Agent updates for threat detection. Traffic is classified into categories including Bad Bot, Dangerous Bot, Good Bot, Human, Unknown, and User-defined Bot, and HTTP security policy rules apply enforcement actions including connection termination for dangerous bot classifications.

When Avi detects security events such as SYN flood or DDoS conditions, its alerting and ControlScript framework supports automated compensating responses. Alert actions can invoke a ControlScript that adds offending client IP addresses to a blocklist IP group attached to a network security policy for rate shaping or blocking. ControlScripts receive alert parameters including attack count, event ID, and alert level, and can execute automated remediation in response to system events rather than requiring manual intervention. The DDoS Policy within the Network Security policy detects and mitigates a range of Layer 4 through Layer 7 network attacks.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control ID.RA-03

> Internal and external threats to the organization are identified and recorded

**SCF Controls:** THR-01, THR-02, THR-03, THR-04, THR-05, THR-07, THR-09

**Aggregate Coverage:** Contributes

### VMware vDefend (Contributes)

VMware vDefend contributes to this control through its threat intelligence consumption and detection infrastructure. The IDS/IPS engine applies knowledge-based signatures that encode specific patterns corresponding to known attack types, detecting intrusions based on known malicious instruction sequences at distributed and gateway enforcement points within vDefend-protected segments. Threat metadata feeds for Network Detection and Response are distributed and can be refreshed from online sources, or downloaded and applied manually in air-gapped environments through NSX Manager or a workstation connected to the Security Services Platform.

Network Detection and Response (NDR) correlates related detection events into campaigns and organizes them into a chronological timeline for security analyst review and triage. The Campaign view displays total detections and threats identified under Malicious Activity, and Campaign Correlation Rules provide structured visibility into how individual detections relate to broader attack patterns.

Security Intelligence maps detected suspicious events to adversarial tactics and techniques from the MITRE ATT&CK framework, recording the count of each tactic and technique observed during a selected time period. This TTP-level categorization supports the situational awareness the control describes for traffic traversing vDefend-protected segments. The threat visualization canvas aids rapid containment, identification of compromised assets, and adjustment of microsegmentation policies in response to detected activity. The blast radius analysis capability displays which communication paths a threat has affected, helping analysts determine whether an attack targets specific systems or represents a wider campaign.

Security Intelligence also collects related IDS events across the same source and destination hosts to connect relevant events and build a fuller picture of an attack sequence. The vDefend Security Assessment generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows to support protection planning. Security teams investigate individual events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take mitigation actions.

While vDefend delivers technical mechanisms for consuming threat intelligence feeds and mapping observed behavior to adversarial TTPs at the network layer, the broader organizational threat intelligence program, including sourcing intelligence from external providers, integrating with threat sharing platforms, and disseminating findings to other teams and tools, requires complementary processes and tooling outside the product.

### VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to situational awareness of evolving threats at the application delivery layer through its Live Security Threat Intelligence service, which delivers security threat feeds for multiple attack vectors in real time to protect applications from continuously changing threats. The Live Security Threat Intelligence service encompasses four components: an IP Reputation Service, an Application Rules Service, a WAF Signatures Service, and a Bot Management Service. The service is opt-in and must be explicitly enabled through Cloud Services configuration on the Avi Controller.

The IP Reputation Service classifies incoming client IP addresses against a regularly updated database, covering threat categories including botnets, phishing, spam sources, and DoS/DDoS attack sources. The service performs real-time automatic IP Reputation updates and operates across globally distributed Avi Load Balancer Controller clusters. Administrators attach an IP Reputation database to virtual services, and enforcement actions such as blocking or rate-limiting are applied per classification result.

The Application Rules Service provides rules specifically designed to block attacks on known application vulnerabilities, many of them mapped to CVEs, covering protection for over 5,000 applications including WordPress, Drupal, and Apache.

Application Rules are automatically updated on the Avi Controller, and administrators can enable auto-sync to receive Application Rules Database updates automatically when new rules are published.

The WAF Signatures Service allows Avi to receive notifications when new Core Rule Set (CRS) data is available and to automatically download updated WAF CRS rules. This keeps application-layer defenses aligned with current vulnerability intelligence without requiring manual administrator action.

The Bot Management Service delivers a real-time feed for the User-Agent database, a core bot detection component. User Agent Database Sync can be enabled to receive continuous User-Agent updates for threat detection. Traffic is classified into categories including Bad Bot, Dangerous Bot, Good Bot, Human, Unknown, and User-defined Bot, and HTTP security policy rules apply enforcement actions including connection termination for dangerous bot classifications.

When Avi detects security events such as SYN flood or DDoS conditions, its alerting and ControlScript framework supports automated compensating responses. Alert actions can invoke a ControlScript that adds offending client IP addresses to a blocklist IP group attached to a network security policy for rate shaping or blocking. ControlScripts receive alert parameters including attack count, event ID, and alert level, and can execute automated remediation in response to system events rather than requiring manual intervention. The DDoS Policy within the Network Security policy detects and mitigates a range of Layer 4 through Layer 7 network attacks.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control ID.RA-04

> Potential impacts and likelihoods of threats exploiting vulnerabilities are identified and recorded

**SCF Controls:** THR-09, THR-10

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control ID.RA-05

> Threats, vulnerabilities, likelihoods, and impacts are used to understand inherent risk and inform risk response prioritization

**SCF Controls:** RSK-01.1, RSK-02.1, RSK-04, RSK-05, RSK-06, RSK-06.1, THR-02, THR-09, THR-10

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control ID.RA-06

> Risk responses are chosen, prioritized, planned, tracked, and communicated [Withdrawn: Incorporated into ID.RA-06]

**SCF Controls:** RSK-01.1, RSK-02.1, RSK-05, RSK-06, RSK-06.1, RSK-06.2

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control ID.RA-07

> Changes and exceptions are managed, assessed for risk impact, recorded, and tracked [Withdrawn: Incorporated into PR.PS-01, ID.RA-07]

**SCF Controls:** CHG-01, CHG-02, CHG-02.1, CHG-02.2, CHG-03, CHG-04, GOV-02.1

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides several technical capabilities that support an organization's change management program, though the program itself must be established and governed through organizational policy and process.

VCF Operations is the central lifecycle management engine for the platform. It coordinates updates across the full stack and requires a precheck before applying any update to verify that the environment is ready. Lifecycle management tools within VCF Operations support planning updates so that administrators can schedule maintenance windows and make changes with minimal disruption to services. When updates are available, VCF Operations Fleet Management displays them through its Lifecycle view, where administrators can select a VCF instance and review pending VCF Operations updates.

vSphere Lifecycle Manager (vLCM) provides centralized lifecycle management for ESX hosts, drivers, firmware, and add-on software. vLCM uses desired-state configuration with a single image per cluster to maintain consistency across infrastructure components. Upon remediation, the image is installed on all hosts in the cluster, replacing the older baseline and baseline group approach from Update Manager. vLCM synchronizes to its download sources, including VCF Operations, on a regular and automatic basis. The Update Manager module provides PowerCLI cmdlets for downloading patches, creating and modifying baselines, and scanning and remediating hosts and virtual machines. Together, these components provide a structured, repeatable process for applying changes to the infrastructure.

VCF Operations extends change management support through configuration drift detection and source control integration. The Configuration Drifts feature tracks changes in product configurations over time and compares them against assigned desired values, providing scheduled drift detection for VMware vCenter and cluster objects to proactively detect configuration deviations from the desired state. Configuration Drifts Templates can be integrated with a source control repository (GitHub or GitLab), which enables versioning, auditing, and management of configuration templates. This integration supports change control with reviews and can be incorporated into continuous integration and continuous deployment pipelines for automated testing and validation of configuration changes. VCF Operations orchestrator also supports pushing local change sets to a Git repository, where each change set can consist of one or more modified orchestrator objects, providing a traceable record of automation changes. VCF Operations audit logging tracks each configuration change to the authenticated user who initiated the change or scheduled the job that performed it, allowing data center administrators to determine who changed what and when.

VCF Automation includes workflow capabilities with approval policies that require project administrators to review changes to deployed catalog instances before they take effect. This allows organizations to integrate change approval into their operational workflows. For organizations that use ServiceNow for IT service management, the ServiceNow ITSM Plug-in for VCF Automation integrates deployment lifecycle actions (such as power operations, lease changes, ownership transfers, and deployment edits) with ServiceNow change workflows. This allows VCF operational changes to be routed through an organization's existing ITSM change approval processes. Policy management capabilities within VCF Automation allow Organization Administrators to create, update, and manage policy definitions, providing a governance layer for controlling what changes are permitted within the platform.

NSX Global Manager provides change validation by checking proposed configuration changes against both Global Manager and Local Manager configurations before they are applied, reducing the risk of conflicting or disruptive network changes in federated environments.

Role-based access control across VCF components restricts who can make configuration changes. Audit logging across the platform captures change activity for review, including vDefend firewall audit logs that capture both old and new values for



modified security policies and VCF Operations audit events that record interactions such as configuration modifications, logins, and capability checks.

### **VMware vDefend (Contributes)**

VMware vDefend provides several mechanisms that help prohibit unauthorized changes to network security policy within its domain, contributing to an organization's broader change control process.

The Distributed Firewall (DFW) includes a policy locking feature: when a security policy section is locked, no other user can modify the policy until the lock is released by the user who applied it. This restricts concurrent or unauthorized edits to active firewall policy sections and is configurable per section, allowing administrators to protect policies during change freezes or maintenance windows. Within project-based deployments, Organization Admin ownership of firewall rules prevents project members from accessing firewall rule modifications entirely, providing a role-based structural constraint on who can modify network security policy.

Security Services Platform (SSP) enforces immutability on published security policies: once initial policies have been published through SSP, they cannot be modified from the user interface. This requires administrators to follow a defined workflow for any policy updates rather than directly editing production policies. SSP also surfaces a change-detected indicator in Security Intelligence Policy Recommendations when input entities used to generate prior recommendations change, giving administrators visibility into modifications that could affect security posture.

DFW system-generated rules produced by applying a security strategy cannot be edited individually through the API or UI (except for logging settings and log labels), and new rules cannot be added to those sections. DFW policy numbers cannot be changed after initial creation, providing a stable reference for change tracking and audit purposes.

DFW and Gateway Firewall policy changes follow a realization workflow: after a create, update, or delete operation on a policy or rule, the change must be explicitly realized on the transport nodes where the policy applies. Changes are not propagated to enforcement points without deliberate action, providing an additional checkpoint between policy definition and enforcement.

For IDS/IPS, signature bundle updates can be configured in either automatic or manual mode. Manual mode gives administrators explicit control over which signature bundle versions are deployed to each site, supporting change approval workflows where updates require review before deployment. The Global Signature Management interface records signatures changed globally by users, including excluded signatures, providing an audit trail of signature-level changes.

These capabilities operate within vDefend's network security policy domain. Broader organizational change management processes, approval workflows, and integration with IT Service Management platforms are provided by other components of the VCF stack, such as VCF Automation.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides role-based access controls, audit logging, and operational safeguards that contribute to change management programs for disaster recovery configurations.

PNR separates change authority through role-based access that restricts who can modify DR infrastructure. The Protection and Recovery Appliance Management Interface requires admin credentials to access reconfiguration and service management functions, controlling administrative-level changes to the appliance itself, including hostname changes, certificate changes, and patch application. In VCF Automation deployments, namespace network mappings can only be edited by an Organization Administrator in the VCF Automation Organization UI. Provider Administrators with the system administrator predefined role install PNR in regions, pair regions, and manage organizational access to PNR capabilities through the VCF Automation Provider Management UI. These access controls restrict modification of DR infrastructure to authorized personnel.

PNR logs configuration change events to support traceability. Array Manager reconfiguration events are recorded when a user edits Array Manager properties, capturing changes to storage replication infrastructure. The Appliance Management Interface provides an authenticated path for appliance-level configuration changes, requiring admin credentials for all reconfiguration and service management operations.

Recovery plans in PNR support structured and auditable change to DR workflows. Plans can be edited to modify the recovery site, protection groups, and test network selection, and can be organized into folders and edited from either the protected site or the recovery site. Recovery plan steps run in a specific order that cannot be changed, but custom steps that display messages and run commands can be added to extend the workflow. Array managers can be edited to modify settings such as IP address, user name, and password without rebuilding dependent protection groups.

A configurable setting, `replication.updateVmProtectionOnPlacementChange`, controls whether VM protection is updated automatically when VM placement changes. Setting this to false prevents infrastructure placement operations from triggering protection reconfigurations outside of an intentional change workflow.

### **VMware Data Services Manager (Contributes)**

CHG-02.1 requires mechanisms to prohibit unauthorized changes unless organization-approved change requests have been received. VMware Data Services Manager (DSM) contributes to this control through role-based access controls, policy enforcement, and system-level immutability protections that restrict who can make changes and what changes are permissible.

DSM's access control model scopes configuration authority to specific roles. For databases created in the default namespace, only the database owner can modify compute resource allocations. DSM's internal management login (`dsm_mgmt`) restricts users from accessing or modifying system-level objects in SQL Server, keeping administrative operations within an isolated context. DSM grants the SQL Server cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing rather than full administrative access. For MySQL, DSM revokes the create and update privileges on objects in the `mysql` system schema for database users.

Data service policies provide a framework for defining and enforcing approved configurations across tenants. DSM requires review of policy violations before applying policies to databases, allowing administrators to assess the impact before committing changes. Policy names and the applicable data service cannot be edited after creation for MySQL, PostgreSQL, or SQL Server policies, which limits the scope of post-deployment modifications. If an in-use policy is deleted, associated data services become non-compliant, making the effect of such actions visible.

Infrastructure policies actively used by a database cannot have their existing settings modified, though new compute resources with corresponding parameters can be added. VM classes associated with an infrastructure policy and actively used by a database cannot be edited or deleted. Infrastructure policy names cannot be changed after creation. These immutability constraints collectively reduce the surface area for unauthorized or accidental configuration drift. MySQL on DSM automatically overwrites user changes to non-editable advanced database settings back to their configured defaults, enforcing DSM-managed baseline configurations.

What DSM does not provide is a formal change management workflow with approval gates, ticketing integration, or change advisory board controls. Fully prohibiting unauthorized changes requires organizational processes: a change management policy, defined approval authorities, and integration with change management tooling. DSM's controls support this objective by scoping who can make which changes, but the approval workflow itself must be maintained outside the platform.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer includes several mechanisms that support change management practices for application delivery configurations.

The Avi Controller generates configuration event codes for all changes: `CONFIG_CREATE`, `CONFIG_UPDATE`, and `CONFIG_DELETE`. `CONFIG_UPDATE` events capture the resource name, status, and prior resource data, giving administrators and auditors a traceable record of changes to virtual services, pools, WAF policies, Service Engine Groups, and other Avi-managed objects. These events are accessible via Operations > Events > Config Audit Trail. Administrators can also use the Config Events overlay in Service Engine analytics to correlate traffic behavior changes with specific configuration modifications, identifying whether a shift in traffic was caused by a change to virtual service security settings, pool membership, or other configuration parameters.

Configuration changes made through the web interface, CLI, or REST API are automatically propagated to all Controller cluster members, so all nodes maintain a consistent and current configuration state.

Avi supports infrastructure-as-code tooling for controlled deployment workflows. Terraform integration includes a plan phase that shows administrators what changes will be made to Avi Controller deployment before they are applied, allowing review and approval prior to execution. Ansible can be integrated with CI/CD pipelines to trigger automated, repeatable Avi Controller deployments, supporting consistent and auditable change procedures. In VCF environments, new Avi installations must be performed through VCF Lifecycle Management, adding a structured change governance layer to the deployment lifecycle itself.

The Avi CLI provides a `configure upgrade profile` command for setting parameters that govern Controller and Service Engine upgrade sequencing, and a rollback capability allows reverting to a prior state if a change introduces problems.

Avi Contributes rather than Meets because the control asks whether the organization facilitates a change management program. A program of this kind includes formal approval workflows, change advisory processes, scheduling policies, and governance documentation that Avi does not provide independently. The configuration audit trail and automation integrations support the technical aspects of change traceability, but the governance program itself must be established and operated by the organization.

## Control ID.RA-08

> Processes for receiving, analyzing, and responding to vulnerability disclosures are established [Withdrawn: Moved to ID.RA-08]

**SCF Controls:** THR-01, THR-02, THR-03, VPM-01, VPM-02, VPM-03

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides integrated mechanisms for identifying, tracking, and remediating vulnerabilities across the infrastructure stack. These capabilities span automated detection, compliance monitoring, alert-driven tracking, structured remediation workflows, and lifecycle management tooling.

VCF Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack, providing detailed descriptions, root cause insights, and actionable remediation steps. This capability builds on several legacy diagnostics tools and operational data to deliver integrated issue detection and remediation from a single pane. Diagnostic Findings uses a library of log and property-based diagnostic rules (also called signatures) to identify known issues across the platform, giving operations teams a structured way to discover and resolve problems.

VCF Operations extends vulnerability tracking through compliance management, which detects violations, highlights risk areas, and provides actionable remediation recommendations. When VCF Operations detects non-compliance with a defined policy, it generates alerts or notifications. Depending on the severity, administrators can configure automated remediation actions to bring objects back into compliance without manual intervention. VCF Operations also maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation tied directly to detected conditions. To retrieve remediation recommendations for a specific virtual machine, the system must be connected to a VCF Operations instance with at least one triggered alert for that virtual machine.

Configuration Drifts in VCF Operations provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. Administrators can view and compare configuration drifts and identify settings that have changed over time. VCF Operations audit logging tracks each configuration change to an authenticated user who initiated the change or scheduled the job that performed the change, allowing administrators to determine who changed what and when.

VCF lifecycle management simplifies and automates the process of applying updates and patches to software components within the VCF stack. VCF Operations includes patch planner functionality for updating or patching individual VCF core components in a VCF domain, and provides a Plan Patching capability to create patching plans for desired components. Pre-update validation runs upgrade prechecks to verify readiness before proceeding, identifying issues before the update starts. Update bundle management supports both online and offline depots; the VCF Download Tool and the lcm-bundle-transfer-util command handle bundle download, staging, and repository configuration for environments with limited or no internet connectivity.

On the patching side, Broadcom releases security advisories for critical known vulnerabilities with step-by-step remediation instructions. Patch releases for VCF components provide time-sensitive fixes to security and catastrophic issues that affect business operations. These patches are released between major, minor, and maintenance releases and can be selectively applied based on environmental impact and operational costs.

vSphere Lifecycle Manager (vLCM) manages desired-state configurations for ESX hosts. It can create a desired state that includes a specific version of the ESX host, compatible partner software and firmware components, and add-ons. When hosts deviate from the target specification, cluster remediation applies the desired state to each non-compliant host, with the Coordinator Manager running pre-checks to evaluate how each host is affected and whether additional steps are needed. Patches can be staged to ESX hosts before remediation begins, reducing the time hosts spend in maintenance mode during the remediation window. Remediation can also be initiated manually or scheduled as a regular task to run at a time convenient for operations teams, supporting consistent patch compliance over time. Firmware add-ons can be added, replaced, removed, upgraded, or downgraded as part of the image. The vSphere Automation REST API allows administrators to query

effective global and cluster-specific remediation policies before initiating remediation, supporting a review-before-apply workflow that reduces risk during patching operations.

VCF also provides tooling for managing remediation at scale. VCF PowerCLI supports parallel remediation with a configurable maximum number of concurrent remediations, allowing administrators to remediate multiple hosts simultaneously. Live Patching allows security updates to be applied to ESX hosts without requiring a host reboot. vCenter RDU upgrades perform automatic rollback if the upgrade fails, providing a safety net during update operations. Maintenance releases are scheduled, cumulative updates focused on platform stability and support, providing bug and security fixes, hardware enablement changes, driver updates, guest OS support, and backward-compatible new features with limited scope to minimize operational impact.

For containerized workloads running on vSphere namespaces, VMware Kubernetes Service (VKS) extends vulnerability identification and remediation to the application layer. Harbor Registry, deployable as a standard package on VKS clusters, performs automated vulnerability scanning against container images using the Trivy vulnerability database, which can be configured to point to a custom or mirrored registry. Harbor also supports image signing to establish content trust, giving administrators a mechanism to identify images that have passed security review. Admission controls can be configured to restrict workload deployments to images sourced from a designated Harbor instance where scanning is enforced, helping constrain the image surface to scanned and trusted artifacts.

VKS MachineHealthCheck provides automated remediation of unhealthy cluster nodes. The `remediation.maxInFlight` parameter controls how many concurrent node remediations may proceed simultaneously, and the `triggerIf.unhealthyLessThanOrEqualTo` threshold determines the condition under which remediation activates. The Kubernetes API surfaces a Remediating condition on VKS clusters, giving administrators direct visibility into the status of ongoing node remediation. DISA Security Technical Implementation Guides (STIGs) are available for both Supervisor and VKS cluster releases (VKrs), documenting known configuration weaknesses and providing step-by-step remediation guidance for hardening these deployments. The Kubernetes Security Response Committee tracks upstream Kubernetes vulnerabilities, assigns CVE identifiers, and publishes advisories through the kube-security-announce mailing list and the official Kubernetes CVE list; the committee's policy is to fully disclose vulnerabilities as soon as a user mitigation is available, with timeframes ranging from immediate to a few weeks depending on the complexity of the issue and vendor coordination requirements. Organizations running VKS can subscribe to receive these notifications and coordinate patch deployments accordingly.

CI/CD pipelines deployed on the VCF consumption layer can incorporate Harness CI/CD with Security Testing Orchestration (STO). Harness STO integrates Wiz to perform pre-deployment vulnerability scanning across container image layers and automatically deduplicates findings, presenting each unique vulnerability, CVE, misconfiguration, or exposed secret as a single actionable item on the pipeline execution's vulnerabilities tab.

### **VMware vDefend (Contributes)**

VMware vDefend (vDefend) contributes to vulnerability remediation by providing network-level threat detection and structured response mechanisms that identify, track, and contain exploitation attempts across protected workloads.

vDefend Distributed IDS/IPS continuously monitors east-west traffic for known vulnerability exploits using signature-based detection. In 9.1, IDS/IPS event monitoring displays CVE reference information and Common Vulnerability Scoring System (CVSS) scores for vulnerabilities targeted by detected exploits, enabling security teams to correlate detected traffic with the specific vulnerability being exploited and prioritize response based on severity. Administrators can search the signature database by CVE ID, making it possible to verify detection coverage for a newly disclosed vulnerability and identify which IDS signatures apply before system signature updates are deployed.

Custom signatures extend detection to application-specific and zero-day threats. vDefend IDS/IPS supports custom signatures that can be exported, edited, and re-uploaded to the system. Before publication, the system validates custom signatures and identifies those tagged as Invalid or Warning, preventing deployment of malformed detection rules. Custom IDS/IPS profiles can include custom signatures with assigned severity levels. Administrators can exempt known false positives from inspection when internal applications use protocols that resemble attacks but are not malicious, reducing alert noise without degrading detection coverage.

The Security Services Platform (SSP) provides a structured remediation workflow for detected security events. When vDefend IDS/IPS, Malware Prevention, or Network Detection and Response (NDR) identifies a threat, administrators can apply remediation actions that automatically create Distributed Firewall rules or IDS/IPS policies to block the attack vector. Two remediation strategies are available: Targeted remediation creates surgically scoped rules that address the specific threat with potentially lower effectiveness, while Comprehensive remediation creates broader policies that protect against similar attack patterns with potentially lower safety margins. The Response and Remediation feature in SSP performs automated creation of policy based on user role and permissions. Intelligent Assist automates selection between these strategies and handles creation of the necessary groups, security profiles, rules, and policies. For Malware events, Targeted remediation enables all IDS signatures for the affected workload, and Comprehensive remediation creates Distributed Firewall policies. Remediations detected on the Gateway Firewall are applied on the Distributed Firewall, extending protection to east-west traffic. Applied remediation policies can be verified in NSX Manager at Security > IDS/IPS & Malware Prevention > Emergency Threat Rules.

SSP manages IDS policy lifecycle by extracting all active policies, rules, and security profiles to support multiple concurrent remediations, identify stale policies for cleanup, and suggest additions that avoid conflicts with existing rules. The Security Services Platform also identifies vulnerable workloads that could be exploited for lateral movement, helping administrators understand exposure before a threat can propagate across segments.

Remediations are not automatically applied. Administrators must review and manually apply suggested remediations through the NSX Manager UI, and objects generated during remediation that encounter errors require manual cleanup. This manual review step gives security teams control over which containment actions are deployed.

The Malware Prevention Service can deny access to suspicious files or delete files confirmed as malicious directly on the protected endpoint, providing a remediation path that extends beyond network policy to the file level.

These capabilities complement VCF's infrastructure-level vulnerability and patch management by providing a network security layer that can detect active exploitation and apply containment actions while patches are being evaluated and deployed.

#### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) contributes to the vulnerability remediation process primarily through its software update mechanisms and compliance tracking features. DSM does not provide vulnerability scanning or external CVE tracking; those functions require organizational processes and tools outside the platform.

DSM supports software remediation through update bundles that apply patches to DSM appliances and managed database versions. The DSM controller manages component dependencies through status monitoring and automated remediation, helping maintain a consistent update baseline across the environment. Database engines, including PostgreSQL and MySQL, can be upgraded to new minor and major versions through the DSM interface; upgrade operations during the maintenance window may include CVE fixes, bug fixes, and performance improvements, allowing operators to remediate known vulnerabilities by updating to patched releases.

To support issue identification, DSM surfaces database alerts with mitigation suggestions so that operators can resolve operational issues without disrupting database services. Operators should verify VM status and infrastructure health when resolving alerts to identify underlying causes. The platform can generate and download log bundles that aggregate relevant logs from database VMs to support faster diagnosis when a service faces a problem. Operators can also review active VMware vCenter infrastructure alarms through DSM troubleshooting guidance and resolve the underlying problems causing those alarms.

Data service policies in DSM include a compliance tab that tracks whether deployed databases conform to the policy. When a data service policy is deleted, the associated services are marked as non-compliant, providing visibility into configuration drift. These policies can be enforced across different tenants, supporting consistent configuration standards across the environment.

DSM handles the patching and software update aspects of vulnerability remediation within its own scope and provides monitoring and compliance visibility. The broader requirements of the control, including external vulnerability scanning to identify CVEs in database software, a centralized vulnerability tracking system for prioritization and assignment, and defined

organizational remediation timelines and escalation procedures, must be addressed through organizational processes and tools that operate alongside DSM.

#### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) provides several mechanisms that support an organization's vulnerability identification and remediation processes for application delivery infrastructure.

For application-layer vulnerability identification, Avi's Web Application Firewall (WAF) supports virtual patching through integration with Dynamic Application Security Testing (DAST) tools. Organizations can import scanner results into Avi to identify vulnerable application endpoints. The WAF creates Positive Security rules for each identified vulnerability, restricting requests to known-good parameters without requiring changes to the protected application. This allows organizations to limit exposure to identified vulnerabilities while application-level remediation is underway.

In 9.1, the Avi Cloud Console adds a Live Security Threat Intelligence service, which includes an Application Rules Service providing rules targeting known application vulnerabilities identified by CVE. The service covers over 5,000 applications and automatically synchronizes rule database updates, keeping CVE-based protections current without manual rule management. When the service is temporarily unavailable, Avi Controllers continue to operate using the cached rule database.

For tracking and documentation, the Avi Application Security Report generates a downloadable PDF documenting WAF security findings and pre-check results, supporting both technical review and organizational documentation requirements.

The WAF Recommendation system supports the tuning portion of the vulnerability management process by proposing configuration changes to address false positives, with reasoning and risk assessment accompanying each suggested change. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation. Alert Actions can trigger ControlScripts in response to system events, enabling automated remediation responses to detected conditions in place of manual administrator intervention.

For platform-level vulnerabilities in the Avi Controller and Service Engines, Avi supports patch application and rollback. After upgrading to a new version, old root partitions that may contain packages with known CVEs can be removed to reduce residual exposure. If a patch introduces instability, rollback features allow operators to return the Controller and all Service Engine groups to the prior version via CLI commands (rollback system, rollbackpatch system) or the REST API (POST api/rollback). The REST API also supports non-disruptive SE-group-specific rollback, allowing selective rollback of individual Service Engine groups. Organizations can lock the Avi Controller Linux system to a specific OS version to avoid CVE scanner false positives from inactive, unused package versions.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.



## Control ID.RA-09

> The authenticity and integrity of hardware and software are assessed prior to acquisition and use [Withdrawn: Incorporated into ID.RA-09, DE.CM-09]

**SCF Controls:** AST-15, AST-18, TDA-01, TDA-01.2, TDA-14, TDA-14.1, TDA-14.2

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides multiple integrity verification mechanisms for software and firmware components across the platform stack, spanning hardware trust, software lifecycle management, containerized workload registries, and ongoing drift detection.

At the firmware level, ESX hosts support UEFI Secure Boot and Trusted Platform Module (TPM). Secure Boot verifies that each component loaded during the boot process is digitally signed, restricting execution to authorized firmware and drivers. TPM provides hardware-based measurement of boot-time components, and administrators can retrieve the TPM event log for configuring firmware trust with an attestation service or validating boot-time TPM measurements. vCenter provides programmatic access to host hardware TPM information and endorsement keys through the Trusted Infrastructure API, and supports unsealing secrets bound to endorsement keys to verify reported TPM measurements. The Security Configuration Guide recommends enabling both Secure Boot and TPM as part of ESX host hardening. Virtual machines can also be configured with UEFI Secure Boot to verify the integrity of firmware and bootloader code before execution, and a virtual TPM (vTPM) device can be added to a VM to perform cryptographic operations and attest the VM platform's integrity.

Hardware and firmware compatibility is enforced through certification requirements. Storage I/O controllers, drivers, and firmware versions must be certified and listed in the Broadcom Compatibility Guide. ESX driver and firmware versions should be verified for hardware compatibility, as mismatches can affect performance and stability. The vSAN hardware compatibility health checks verify deployed hardware against the Broadcom Compatibility Guide to identify unsupported or outdated firmware. VCF requires certified software and hardware components, drivers, controllers, and firmware to avoid unexpected data loss and performance issues.

For software integrity during deployment, the VCF Installer downloads and validates binaries after selection to confirm integrity before they are applied to the environment. VCF also requires verification of the server fingerprint for each ESX host during commissioning, with fingerprint confirmation activated before host validation proceeds. All communication between the VCF Installer and ESX hosts is performed over HTTPS, validating identity by comparing the common name of the certificate against the FQDN provided in the deployment wizard. The VCF CLI binary can be verified using a sha256sum.txt checksum file available alongside the CLI download or from the VCF Automation Tenant Portal, providing an integrity check for the tooling used to manage VCF Services consumption.

vSphere Lifecycle Manager manages software component lifecycle through structured payloads that encapsulate groups of components for coordinated management. It validates host compliance against a desired-state software specification, allowing administrators to check whether hosts in a cluster match the intended configuration before applying updates. The Drafts service offers a `validate_Task` method that checks whether a draft software specification is complete and whether there are conflicts between components or unresolved dependencies. The `Invoke-CheckHostSoftwareAsync` PowerCLI cmdlet performs remediation pre-checks on hosts to verify software and hardware compatibility with a desired software specification before remediation proceeds. ESX also enforces software integrity at the package level through the Host Image Profile Acceptance Level: each vSphere Installation Bundle (VIB) has an associated acceptance level, and ESX conducts integrity checks to confirm that only packages meeting the configured acceptance threshold are permitted to install on the host.

At the data layer, vSAN uses end-to-end checksums to verify data integrity, confirming that each copy of a file matches the source. When a checksum mismatch is detected, vSAN automatically repairs the data by overwriting the incorrect copy with the correct data.

For containerized workloads, VKS clusters require internal or trusted CA certificates for local registries, and VKS Cluster Management image registry policies restrict the source registries from which images can be pulled. The VCF CLI `imgpkg` command supports adding CA certificates for registry API validation through the `--registry-ca-cert-path` flag, and `image pull`



secrets authenticate to container registries before pulling images. Harbor, available as a standard package on VMware Kubernetes Service (VKS) clusters, provides vulnerability scanning, content trust, and policy-based replication for software supply chain security. Harbor secures artifacts with policies and role-based access control, allowing platform teams to define which images are trusted and restrict deployment of content that has not been scanned or signed. Kubernetes admission controllers can automatically verify image signatures at deploy time to validate the authenticity and integrity of container images before a workload is permitted to run in a vSphere namespace; organizations can deploy admission webhooks that block unsigned images from being scheduled on VKS cluster namespaces. Kubernetes release artifacts, including the platform Software Bill of Materials (SBOM), can be verified using SHA512 and SHA256 checksums together with sigstore certificate and signature files available from sbom.k8s.io, allowing platform administrators to confirm the integrity of Kubernetes components. Security Technical Implementation Guides (STIGs) for system components, including vSphere Supervisor and VKS Kubernetes releases (VKrs), are available through Tanzu STIG hardening to guide integrity-related configuration of the consumption layer.

Ongoing integrity monitoring is provided through VCF Operations, which runs property-based signature checks every four hours. These checks scan VMware vCenter, ESX, NSX, VCF Operations, vSAN, and VCF Automation to detect configuration drift or unauthorized changes across the SDDC stack. VCF Operations also provides scheduled drift detection for vCenter and cluster objects, enabling proactive detection of configuration deviations from the desired state.

VMware Private AI Services (PAIS) provides a structured validation workflow for ML models that gives the AI platform a technical mechanism for software integrity verification within its scope.

The Model Gallery workflow requires MLOps engineers to validate ML models against the security, privacy, and technical requirements of the organization before those models can be uploaded to a Model Gallery for use by AI application developers. Integrity validation is performed in a Deep Learning VM (DL VM) acting as a sandbox. The process checks the hash code of model files, scans them for malware, scans them for serialization attacks, and tests correct inference behavior using Triton Inference Server before upload. Only models that pass these checks are admitted to the gallery. The Model Gallery itself helps maintain integrity of uploaded models by assigning a unique digest to each revision when the same model is pushed multiple times, which allows administrators to identify specific model versions across re-uploads.

PAIS Model Runtime endpoints reference model container images through the spec.model.ociRef property in the ModelEndpoint specification and support image pull secrets for private OCI registries that require authentication. PAIS requires CA trust bundles to be imported for the Private Harbor registry, for content management systems used as data sources in Data Indexing and Retrieval, and for MCP servers providing tools for agents. These trust bundles allow PAIS to verify the identity of the systems serving model and tool artifacts during pulls and tool invocations.

For agentic workflows that use the Model Context Protocol (MCP), PAIS requires examination and approval of MCP server tool capabilities and parameters before use in agents to confirm suitability against organizational security standards. This extends integrity verification to the tool layer of AI applications built on the platform.

Auditors reviewing a PAIS deployment should look for evidence that the validation workflow is being followed: confirmation that MLOps engineers are performing hash verification, malware scanning, serialization attack scanning, and Triton inference testing before model uploads, that Model Gallery revisions carry unique digests, that CA trust bundles are imported for the Private Harbor registry and MCP servers, and that the MCP tool approval step is documented against the organization's defined security and privacy requirements.

### **VMware vDefend (Contributes)**

VMware vDefend provides integrity controls for its own security component updates through IDS/IPS signature bundle management and Security Services Platform upgrade validation.

vDefend IDS/IPS includes configurable signature bundle update modes. In automatic mode, the system retrieves signature updates through the cloud-hosted vDefend Threat Intelligence Service (vTIS) portal, which notifies administrators when new bundle versions are detected. In manual mode, administrators disable the Auto Update toggle and select a specific signature bundle version for deployment. For air-gapped environments, vDefend IDS/IPS supports offline download and upload of signature bundle files. Signature Bundle Version Management allows administrators to view available versions and set the

active signature set; by default, the latest version is selected for automatic updates. Signature Bundle Realization Status tracks whether updates were successfully applied across transport nodes and Edges, confirming that the selected version is in use. In federated deployments, Local Manager sites can independently select manual bundle versions when Auto Update is disabled. Administrators can also publish validated custom signatures directly to transport nodes and Edges. Both IDS/IPS and Malware Prevention share the Auto Update toggle, so the configured mode applies across both detection features.

Security Services Platform (SSP) performs prechecks of its components, including metrics components, during upgrade validation before proceeding. The SSP upgrade manager handles updates to Workload and Management clusters and the installer VM. The deployment wizard conducts validations before implementing configuration changes to confirm that configurations are correct and compatible. SSP monitors deployment status and raises alarms for errors that require attention during upgrade operations.

These mechanisms operate alongside the broader VCF platform integrity controls, which include upgrade bundle checksum verification through VMware vCenter and cosign-based image signature verification via the VCF CLI.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) supports integrity mechanisms for software updates through certificate-based trust validation for update sources, a controlled staging workflow for applying updates, and signature verification for operator package deployments.

For the Consumption Operator, DSM includes Signature Verification validation as part of the deployment process to confirm package integrity before components are installed. This capability applies when deploying or uninstalling the Data Services Manager Supervisor Service in VCF Automation environments.

DSM supports configuration of private container registries with CA certificate validation for untrusted registries, restricting update package sources to those that can be authenticated against a trusted certificate authority. Administrators manage the trusted root certificates used for these validations through the DSM certificate store, where certificates can be added, updated, or removed. In version 9.1, DSM introduces a "latest" certificate validation mode as the default, which enforces strict cryptographic and KeyUsage validations for all endpoints including the Provider VM and data service clusters. DSM also supports validation of trust bundles for self-signed certificates in image registry connectivity. As part of upgrading to version 9.1, DSM requires that all existing certificates be reviewed and replaced to confirm compliance with updated cryptographic algorithm requirements before the upgrade proceeds.

For platform-level software updates, DSM implements a staged upgrade workflow. Update bundles uploaded to the system progress through a defined status sequence from "available" to "Ready to Install" before installation proceeds. This staged approach provides an explicit review point between update availability and installation. Administrators can check for available upgrades and review upgrade history through the Version and Upgrade interface in the vSphere Client, accessible under the VMware vCenter Configure tab. The DSM plug-in supports a configurable Maintenance Policy that controls when automatic updates are applied, with settings for start date, start time, and duration.

Satisfying this control fully requires organizational processes beyond what DSM provides directly. DSM supports signature verification for operator packages, certificate-based validation of update sources, and controlled staging for applying updates, but the control's Process categorization requires organizations to establish procedures for verifying that update bundles are obtained from authorized VMware sources, maintaining a managed set of trusted CA certificates, and documenting the integrity validation steps applied before updates are approved for installation.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) supports logical integrity assessment of its own application delivery components through several mechanisms in 9.1.

The Avi Controller maintains a checksum and creation timestamp for custom IPAM script files, providing file integrity tracking and an audit trail that can surface unauthorized modifications to scripts managing IP address management (p2551). This is a direct logical integrity mechanism within Avi's own configuration plane.

The Avi Controller provides an Application Security Report, available for download in PDF format, that captures WAF findings and security configuration status in a format accessible to both technical teams and executive stakeholders (p3479). This report gives auditors a structured view of whether the Avi deployment's WAF posture conforms to its expected security baseline and can be used as evidence during periodic integrity assessments.

Avi Load Balancer supports FIPS 140-3 compliance mode, which enforces validated cryptographic modules and stricter handling of cryptographic keys, authentication data, and random number generation (p3001). Deviations from the FIPS 140-3 configuration state can serve as indicators of unauthorized changes to the cryptographic posture.

In Kubernetes environments, the Avi Kubernetes Operator (AKO) performs syntactical validations on Custom Resource Definitions (CRDs) at creation time, verifying configuration correctness and providing status messages that surface configuration deviations from the expected resource state (p83).

The Avi Controller and Service Engines log audit records for certificate validation failures, authentication failures, and SSH session establishment failures, including identification of the initiator and target of failed trusted channel establishment attempts (p4157). These records provide signals that may indicate tampered configurations or certificate substitution.

Physical integrity of the underlying compute infrastructure falls under VCF, which provides hypervisor-level integrity controls including Secure Boot and TPM attestation on VMware ESX hosts. Physical assessment of the hardware on which Avi Controller and Service Engine VMs run is handled at the VCF platform layer, not within Avi itself.

Organizations are responsible for scheduling execution of integrity assessments on a recurring basis and for acting on the results to remediate detected configuration drift. Avi provides the assessment mechanisms; the operational process of scheduling, reviewing, and remediating those assessments remains an organizational responsibility.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

## Control ID.RA-10

> Critical suppliers are assessed prior to acquisition [Withdrawn: Incorporated into GV.OC-02, GV.SC-03, GV.SC-04, GV.SC-07, ID.RA-10] [Withdrawn: Incorporated into GV.SC-07, ID.RA-10]

**SCF Controls:** TPM-01.1, TPM-02, TPM-04.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control PR

> Identities and credentials for authorized users, services, and hardware are managed by the organization. Identities are proofed and bound to credentials based on the context of interactions. Users, services, and hardware are authenticated. Identity assertions are protected, conveyed, and verified. Access permissions, entitlements, and authorizations are defined in a policy, managed, enforced, and reviewed, and incorporate the principles of least privilege and separation of duties. Physical access to assets is managed, monitored, and enforced commensurate with risk. Personnel are provided with awareness and training so that they possess the knowledge and skills to perform general tasks with cybersecurity risks in mind. Individuals in specialized roles are provided with awareness and training so that they possess the knowledge and skills to perform relevant tasks with cybersecurity risks in mind. [Withdrawn: Incorporated into PR.AT-01, PR.AT-02] [Withdrawn: Incorporated into PR.AT-02] The confidentiality, integrity, and availability of data-at-rest are protected. The confidentiality, integrity, and availability of data-in-transit are protected. [Withdrawn: Incorporated into ID.AM-08, PR.PS-03] [Withdrawn: Moved to PR.IR-04] [Withdrawn: Incorporated into PR.DS-01, PR.DS-02, PR.DS-10] [Withdrawn: Incorporated into PR.DS-01, DE.CM-09] [Withdrawn: Incorporated into PR.IR-01] [Withdrawn: Incorporated into ID.RA-09, DE.CM-09] The confidentiality, integrity, and availability of data-in-use are protected. Backups of data are created, protected, maintained, and tested. Configuration management practices are established and applied. Software is maintained, replaced, and removed commensurate with risk. Hardware is maintained, replaced, and removed commensurate with risk. Log records are generated and made available for continuous monitoring. Installation and execution of unauthorized software are prevented. Secure software development practices are integrated, and their performance is monitored throughout the software development life cycle. Networks and environments are protected from unauthorized logical access and usage. The organization's technology assets are protected from environmental threats. Mechanisms are implemented to achieve resilience requirements in normal and adverse situations. Adequate resource capacity to ensure availability is maintained. [Withdrawn: Incorporated into PR.AA-01, PR.AA-05] [Withdrawn: Moved to PR.AA-06] [Withdrawn: Incorporated into PR.AA-03, PR.AA-05, PR.IR-01] [Withdrawn: Moved to PR.AA-05] [Withdrawn: Moved to PR.AA-02] [Withdrawn: Moved to PR.AA-03] [Withdrawn: Incorporated into PR.PS-01] [Withdrawn: Incorporated into ID.AM-08, PR.PS-06] [Withdrawn: Incorporated into PR.PS-01, ID.RA-07] [Withdrawn: Moved to PR.DS-11] [Withdrawn: Moved to PR.IR-02] [Withdrawn: Incorporated into ID.AM-08] [Withdrawn: Incorporated into ID.IM, ID.IM-03] [Withdrawn: Moved to ID.IM-03] [Withdrawn: Moved to ID.IM-04] [Withdrawn: Incorporated into ID.IM-02, ID.IM-04] [Withdrawn: Moved to GV.RR-04] [Withdrawn: Incorporated into ID.RA-01, PR.PS-02] [Withdrawn: Incorporated into ID.AM-08, PR.PS-02] [Withdrawn: Incorporated into PR.PS-04] [Withdrawn: Incorporated into PR.DS-01, PR.PS-01] [Withdrawn: Incorporated into PR.AA-06, PR.IR-01] [Withdrawn: Moved to PR.IR-03] [Withdrawn: Incorporated into PR.AT-01]

**SCF Controls:** CPL-01, GOV-01, GOV-01.1, RSK-01, RSK-09

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control PR.AA

> Identities and credentials for authorized users, services, and hardware are managed by the organization. Identities are proofed and bound to credentials based on the context of interactions. Users, services, and hardware are authenticated. Identity assertions are protected, conveyed, and verified. Access permissions, entitlements, and authorizations are defined in a policy, managed, enforced, and reviewed, and incorporate the principles of least privilege and separation of duties. Physical access to assets is managed, monitored, and enforced commensurate with risk. [Withdrawn: Incorporated into PR.AA-01, PR.AA-05] [Withdrawn: Moved to PR.AA-06] [Withdrawn: Incorporated into PR.AA-03, PR.AA-05, PR.IR-01] [Withdrawn: Moved to PR.AA-05] [Withdrawn: Moved to PR.AA-02] [Withdrawn: Moved to PR.AA-03] [Withdrawn: Incorporated into PR.AA-06, PR.IR-01]

**SCF Controls:** IAC-01, IAC-01.2, PES-01, PES-02, PES-03

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcIdentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System

Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory. Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline\_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with



downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

### **VMware vDefend (Contributes)**

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) implements authenticate, authorize, and audit (AAA) mechanisms for replication and recovery operations. Authentication uses VCF SSO. The PNR server acquires a holder-of-key SAML token from VCF SSO and presents it in a cryptographically signed envelope when establishing authenticated communication channels to remote services such as VMware vCenter. PNR uses service account authentication for server-to-vCenter communication, and a domain-level service account created by vCenter is used when PNR runs in an Enhanced Linked Mode environment. When connecting peer vCenter instances that reside in different or the same SSO domains, PNR also supports credential-based authentication. The PNR Appliance Management Interface requires authentication as the admin user for service management, network configuration, time zone settings, storage replication adapter configuration, and site unregistration workflows. The default admin password is set during initial deployment and is expected to be changed by the operator. PNR exposes Authentication APIs as part of its REST API gateway, including a REST endpoint to log out an authenticated session.

Authorization is enforced through PNR's privileges, roles, and permissions model. PNR performs operations using the user credentials supplied when the protected and recovery sites are connected, and permission checks apply at both sites for cross-site operations. The configuration import and export tool accepts the `--localAuthUseSA` and `--remoteAuthUseSA`



parameters, which select whether a Service Account file is used for authentication to the local or remote site. PNR and later supports Service Account authentication for importing or exporting configuration data.

Audit logging records replication and recovery operations and security-relevant events. PNR records operational information in log files that do not contain private keys or passwords. Authorization errors and certificate verification errors are written with timestamps and component information to security-related log files for audit trail purposes. Replication lifecycle events generate audit log entries, for example the AutoprotectEnabledRpEvent entry that indicates Automatic Protection has been activated for a replication provider.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and

classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

## Control PR.AA-01

> Identities and credentials for authorized users, services, and hardware are managed by the organization [Withdrawn: Incorporated into PR.AA-01, PR.AA-05]

**SCF Controls:** IAC-02, IAC-03, IAC-04, IAC-05

**Aggregate Coverage:** Meets

### VCF (Meets)

VCF provides centralized authentication, authorization, and auditing through VCF SSO, which acts as the identity broker for all VCF management components. All user and service authentication flows through VCF SSO, providing a single point of control for identity management across VMware vCenter, VMware ESX, NSX, VCF Operations, and VCF Automation. VCF SSO is configured via the VCF Operations console and provides a unified authentication source for VCF components.

VCF supports multiple authentication mechanisms for organizational users. VCF SSO issues SAML tokens for authenticated sessions and supports multiple authentication context methods, including PasswordProtectedTransport (password over HTTPS) and holder-of-key tokens that embed security artifacts for delegation scenarios. vCenter supports built-in identity source authentication using local domain credentials and basic authentication through the OAuth 2.0 Password grant type when federated to an external identity provider. VCF SSO also supports the use of SSPI (Security Support Provider Interface) for client authentication.

Identity federation with enterprise identity providers (via SAML or OIDC) enables organizations to extend their existing AAA infrastructure to VCF. Federating vCenter to an enterprise identity provider supports multifactor authentication and automatic registration and termination of users across services. vCenter has documented federation configurations for specific providers including Okta and PingFederate. VCF SSO also supports the System for Cross-domain Identity Management (SCIM) protocol for automating the exchange of user identity information between identity domains and external identity providers.

Organizations using Microsoft Active Directory can use user identities contained in a Windows Server domain controller or Active Directory service across their virtual infrastructure. VCF Automation allows each organization to define its own identity provider that it shares with other applications; users authenticate to the identity provider to obtain a token that they then use to log in to the organization. Every organization in VCF Automation has its own identity source for user import. The Supervisor component supports registration of external OIDC identity providers for authentication using Pinniped, which inspects upstream identity tokens from the external provider to determine user identity and group membership before passing that information to the Kubernetes API server. Supervisor can be configured with any OIDC-compliant provider, including Okta, Workspace ONE Access, and Dex, to authenticate users connecting to VMware Kubernetes Service (VKS) clusters. Custom ClusterClass configurations for VKS clusters can be used to authenticate developers using existing corporate identity systems. The Kubernetes API server also supports integration with organizational authentication infrastructure such as LDAP or Kerberos through authentication plugins, enabling Supervisor to participate in existing centralized identity management. An Identity API is available to programmatically authenticate and manage the authorization provider, supporting automated identity lifecycle management.

Authorization is enforced through role-based access control across all VCF components. vCenter maps authorization levels to groups and roles, providing consistent security controls regardless of operational context. VCF verifies what objects principals have access to as part of its authorization model. NSX has a set of built-in roles including Enterprise Admin, Auditor, Cloud Admin, Cloud Operator, Network Admin, Network Operator, Project Admin, Security Admin, and others. Local guest user accounts in NSX have the Auditor role by default, and only a user with the Enterprise Admin role can create new local guest user accounts. VCF Automation provides Organization Administrator, Organization Auditor (read-only), and Organization Owner roles, along with the ability to create custom roles scoped to an organization. Organization Administrators can view the rights associated with roles and create roles local to their organization. For Kubernetes workloads, vSphere Supervisor supports Namespace Owner, Edit, and View permission roles that allow consumers of vSphere Namespaces to provision VKS clusters and vSphere Pods using kubectl. Kubernetes RBAC evaluates Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings against the username, UID, group membership, and extra fields supplied by authenticator modules to determine whether a request is permitted. Users authenticated through external OIDC providers are referenced in

ClusterRoleBindings using the `oidc:user@example.com` naming convention; users authenticated through VCF SSO use the `ssso:<username>@<domain>` convention. The `AuthorizeWithSelectors` feature gate passes field and label selector information to authorization webhooks, supporting more granular per-resource authorization decisions. User impersonation is governed by Kubernetes RBAC: the "impersonate" verb on user, group, and ServiceAccount resources under authentication.k8s.io allows designated administrators to act on behalf of other principals in a traceable manner. Kubernetes also distinguishes human user accounts, whose identities are managed externally by the identity provider, from ServiceAccounts, which are namespace-scoped API objects used by automated workloads and processes; separating their lifecycle management supports differentiated audit strategies for each category. IAM role trust policies for VKS clusters can be scoped to specific service accounts and namespaces to enforce least privilege.

VCF provides role-based visibility into policy enforcements. The Organization Administrator and Organization Auditor roles can view policy enforcements within their organizations. VCF's logging infrastructure captures authentication and authorization events across management components. The Kubernetes API server records API server activity with structured per-event metadata. Audit annotations include `authorization.k8s.io/decision` and `authorization.k8s.io/reason`, which record each authorization decision and its human-readable justification in the audit log, providing per-request traceability of who performed what action and how the authorization decision was reached. An audit event is logged for each impersonation request, enabling tracking of how impersonation is used over time. Audit rules can be configured to alert on specific events, such as concurrent reading of multiple Secrets by a single user. Authentication context, including username and group memberships, can be retrieved and logged using `kubectl auth whoami` for verification purposes. Administrators can use `kubectl auth can-i` with user impersonation to determine what actions other users are permitted to perform.

Service-to-service authentication uses certificate-based Principal Identity users rather than password credentials. Principal identity user certificates must be SHA256-based and use RSA/DSA message algorithm with 2048 bits or above key size. Each VCF component registers with VCF SSO as a solution user. VCF Operations integrates with VCF SSO for centralized user and group authentication and management, and also supports LDAP authentication sources for additional monitoring and management access.

Additional Consumption-layer services extend the AAA model to workload infrastructure. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control for container image artifacts and artifact security policies. The Secret Store Supervisor Service enforces RBAC across administrators, DevOps engineers, and application tenants for access to secrets and credentials. Argo CD, deployable as a Supervisor Service, supports OIDC authentication with PKCE via the `enablePKCEAuthentication` field and defines access through global RBAC policies using policy rules and group mappings.

While VCF provides the technical mechanisms for authentication, authorization, and audit, centralizing these capabilities requires the organization to deploy and manage an external identity provider (such as Active Directory or an OIDC-compliant provider), define identity governance policies, and establish processes for user lifecycle management including provisioning, periodic access reviews, and de-provisioning. Role assignment procedures and access review processes are organizational responsibilities that fall outside VCF's direct control.

VMware Private AI Services (PAIS) integrates with an external OIDC identity provider to authenticate organizational users accessing AI infrastructure on VCF. The `PAISConfiguration` custom resource is configured with an OIDC authentication block specifying the issuer URL, the client ID (`'pais-authentication-id'`), and the scopes `'openid'`, `'groups'`, and `'offline_access'`. When a region is created for a supervisor in PAIS, an identity provider is automatically created in VMware vCenter for that supervisor, establishing a consistent authentication entry point for AI workloads. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator, who supplies the issuer URL and client ID.

Authorization for PAIS is enforced through OIDC group-based access control. The `'authorizedGroups'` setting in the `PAISConfiguration` restricts service access to user accounts that belong to designated OIDC groups (for example, `'group-for-pais-access-01'` or `'group-for-pais-access-02'`). The `'oidc-groups-claim'` setting names the claim used to identify group membership in the Access Token, and `'oidc-extra-audiences'` accepts additional OAuth 2.0 client IDs that PAIS will recognize when validating tokens. Grafana, used for PAIS metrics visualization, extends the same model through the `'grafana-oidc-role-`

mapping` configuration: users in a designated PAIS access group are assigned the Admin role automatically, while remaining authenticated users receive the Viewer role.

Harbor Registry imposes its own credential boundaries for AI artifact access. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. Processes that push artifacts to Harbor authenticate using the `oras login` command with username and password credentials. Knowledge Base integrations support per-source authentication: Confluence connections accept a user name and password or a personal access token, and SharePoint On-Premises connections use user name and password authentication. These mechanisms restrict access to organizational AI artifacts and reference data to authorized accounts.

### **VMware vDefend (Contributes)**

VMware vDefend contributes to this control through two mechanisms: management plane authentication for its Security Services Platform (SSP) and Identity Firewall (IDFW) for network policy enforcement.

SSP provides two built-in local user accounts configured during deployment: an admin account with the Enterprise Admin role, which has full privileges to deploy, manage, upgrade, and configure authentication and authorization settings, and an audit account with the Auditor role, which provides read-only visibility into system activity and API access for auditing without the ability to make configuration changes. The SSP License Hub implements role-based access control with three defined roles: Enterprise Admin, Auditor, and Support Bundle Collector. Roles can be assigned to individual users or groups defined in an external identity provider, allowing organizations to integrate Active Directory or LDAP group membership into access control for the platform.

SSP supports directory-backed authentication through Active Directory over LDAP and OpenLDAP in addition to local accounts. The platform uses Authelia, an open-source authentication and authorization server, to provide two-factor authentication and single sign-on capabilities for management access, allowing organizations to require multiple authentication factors for access to vDefend's security management functions.

Identity Firewall processes user identity at the source workload to enforce DFW and gateway firewall rules based on Active Directory user and group membership. This allows AD users and groups to be used as source criteria in firewall rules, enabling network access controls based on authenticated user identity rather than IP address. Security administrators are directed to distinguish between two primary administrative personas when managing vDefend access, maintaining security boundaries between different projects and the broader organization.

Centralized AAA for organizational users across the broader VCF environment, including single sign-on and multi-factor authentication for all users, is provided by VMware vCenter and VCF SSO and is outside vDefend's scope.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides cryptographic, replay-resistant authentication for its own inter-site components. When two sites are paired for recovery operations, PNR validates the identity of each peer through certificate-based authentication and supports importing certificate-authority-signed server certificates through the PNR Appliance Management Interface. Site pairing, site reconnection, and site pair break operations all require credential authentication, and the PNR Appliance Management Interface itself requires authentication as the admin user for service configuration, network configuration, hostname changes, and disconnection from the PNR Global Console.

For inter-site service authentication, PNR servers acquire a holder-of-key SAML token from VCF SSO using token-based authentication, then send cryptographically signed requests carrying that token to remote services. The remote service validates the token to establish the identity of the calling service before the connection proceeds, supplying bidirectional, replay-resistant authentication between PNR components without transmitting passwords across site boundaries. The VMware vCenter appliance handles authentication between the PNR server and vCenter at the VCF SSO level, and in an Enhanced Linked Mode environment the remote site reuses the same service account to authenticate to local services.

PNR also implements an OAuth 2.0 flow for remote site authentication, with a configurable authorization request lifetime through the `oauth2.authRequestLifetime` setting (default 60 seconds). The Cyber Recovery Connector authenticates with an OAuth app secret that Broadcom rotates every three months. Management communications are carried over TLS, with the

minimum protocol version configurable through the `envoy-proxy-config.json` file. The PNR user interface maintains logs that record certificate validation errors and connection failures during authentication attempts, supporting the audit dimension of AAA for PNR's own management traffic.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) addresses the authentication component of this control through a two-tier identity model. DSM supports both local user accounts and LDAPS-integrated directory service accounts, and administrators can configure one or both identity sources simultaneously. Local users are authenticated by matching their email address and validating their password directly within DSM. LDAPS users are authenticated by matching the email domain name against the registered LDAPS server and validating credentials against the directory service. DSM can be configured to use an LDAP server for both authentication and authorization of platform-level users.

Authentication for the managed databases is handled through database-native mechanisms that DSM exposes and configures. PostgreSQL databases use host-based authentication (HBA), with rules managed through DSM. The HBA configuration applies ordered matching rules where the first entry matching the connection type, client address, requested database, and user name is applied. The default final entry uses SCRAM-SHA-256, providing strong password-based authentication; an optional LDAP entry can also be included. MySQL databases support LDAPS integration using a simple authentication plug-in, with a unique LDAPS user entry per user and support for Active Directory authentication. PostgreSQL and MySQL databases also support LDAPS user accounts linked to organizational directory services, with LDAPS user creation managed through the DSM interface.

DSM adds SQL Server as a supported database engine. SQL Server clusters support two administrator identity types: SQL User credentials and Windows Principal accounts for clusters integrated with Active Directory. DSM's Active Directory integration supports Kerberos-based authentication for domain-joined SQL Server clients, allowing tools such as SQL Server Management Studio running on a Windows machine to authenticate using domain credentials. DSM maps the `dbo` user, the database object owner, to administrator-controlled identities for SQL Server database access. SQL Server clusters can also use contained database users, where each user authenticates directly against the database rather than a server-level login, keeping identity information self-contained within the database.

Authorization is handled through a role-based model. DSM provides two platform-level roles, DSM Admin and DSM User, which determine the capabilities available to each user within the DSM management interface and API. Custom user roles can be configured for directory service group members, providing scoped monitoring and management access. The Permissions view in DSM supports the creation, monitoring, and management of configured users, giving administrators visibility into who has access. Role assignments also affect behavior in database operations; DSM automatically establishes trust between primary and secondary PostgreSQL instances for Admin-role users, while User-role accounts require manual trust establishment.

DSM produces audit records covering both user-initiated and system-initiated actions. Audit events are generated for actions performed through the DSM UI and API, and each audit log entry includes a Source field identifying the initiating entity: either a user's email address or "System" when the action was initiated by DSM itself. Gateway Audit Logs provide visibility into gateway-level events, and the System Audit Events view is the designated location in the DSM UI for tracking nondatabase-related operations and tasks. For SQL Server clusters, DSM provides configurable server auditing with preset audits for login tracking and log retention; the Login Auditing option can automatically create a simple audit for login events.

In self-service consumption deployments, the DSM Consumption Operator authenticates with the DSM infrastructure using a dedicated authentication secret (`dsm-auth-creds`), providing a defined authentication path for Kubernetes-native database provisioning.

DSM's authentication, authorization, and audit capabilities are scoped to the DSM platform and its managed databases. Centralized AAA for the broader organizational user population, including account lifecycle management, privileged access governance, and enterprise-wide log aggregation, requires organizational identity governance programs and security tooling outside DSM's scope.



## VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) maintains its own administrative identity plane with mechanisms covering all three AAA elements: authentication, authorization, and audit. User accounts fall into two categories: local users and remote users. Remote users are authenticated through external AAA servers, with support for LDAP, TACACS+, and SAML-based authentication profiles. The product documentation recommends federated authentication as the preferred approach, delegating the authentication process to an organization's central identity provider rather than managing credentials locally within Avi.

For authorization, the Avi Controller evaluates authorization mapping rules on every user login, updating the user record with tenant and role pairs. Auth Mapping Profiles can map multiple user groups to different roles with tenant isolation, supporting both simple single-role assignments and multi-tenant configurations where a single user requires access across multiple administrative boundaries. The admin user is authorized and responsible for the highest-level configuration operations, including user creation and authorization and tenant management. The admin account is maintained as a locally authenticated account even in a system configured for remote authentication, providing a break-glass path for Controller access.

The Avi Controller License Hub provides dedicated role-based accounts for administration and auditing. The Admin account holds the `enterprise_admin` role with full access to deploy and manage security services, perform upgrades, and configure authentication and authorization. The Audit account holds the `auditor` role with full access to APIs and services for system auditing. LDAP can be configured as an identity provider for License Hub authentication, and the Admin user can reset the Audit user's password.

Avi also supports OAuth and OpenID Connect (OIDC) for client authentication at the application proxy layer. When configured, the Controller acts as a resource server and retrieves identity information from the OIDC `UserInfo` endpoint or from ID token claims, enabling per-user identity context to be associated with proxied application traffic. DataScript can check if a user ID is in an approved group list and redirect unauthenticated users to a login page, providing identity-based access control at the virtual service layer.

In the Avi for VCF Organization-Managed Mode, the organization administrator must be authenticated to edit Service Engine Groups and manage their own infrastructure configurations, reinforcing role-based access enforcement at the VCF integration layer.

The control asks whether the organization centrally manages AAA across its environment. Avi provides the mechanisms for its own administrative plane and supports integration with a central identity provider, but the organization must configure that integration, maintain the identity provider, and establish processes for reviewing audit log output.

## Control PR.AA-02

> Identities are proofed and bound to credentials based on the context of interactions [Withdrawn: Moved to PR.AA-02]

**SCF Controls:** IAC-28

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control PR.AA-03

> Users, services, and hardware are authenticated [Withdrawn: Incorporated into PR.AA-03, PR.AA-05, PR.IR-01]  
[Withdrawn: Moved to PR.AA-03]

**SCF Controls:** IAC-01.2, IAC-02, IAC-03, IAC-04, IAC-05

**Aggregate Coverage:** Meets

### VCF (Meets)

VCF provides built-in Authenticate, Authorize, and Audit (AAA) capabilities across its component stack, giving organizations a strong technical foundation for governing AAA within the platform.

For authentication, VCF SSO is the centralized identity broker. VMware vCenter can be federated with an external enterprise identity provider, which handles authentication in a federated model and enables flexible options such as multifactor authentication, automatic user registration, and termination of users across services. Named external identity providers supported for vCenter federation include Okta, with provider-specific configuration procedures available for each. NSX Manager supports local authentication, LDAP authentication, and OIDC authentication with configurable identity provider selection. VCF Automation allows organizations to define a shared identity provider and authenticate users through configurable authentication mechanisms, including redirections to external identity providers. The Identity API in VCF Automation provides programmatic management of authentication and authorization providers. The vCenter Client Credentials grant type also allows application-to-identity-provider authentication without a human user present, supporting machine-to-machine authentication scenarios. VMware ESX and vCenter validate user credentials against configured identity stores.

At the Kubernetes consumption layer, VMware Kubernetes Service (VKS) clusters support two authentication methods: VCF SSO and OIDC-compliant external identity providers. Administrators register an external provider by configuring the identity provider issuer URL, client credentials, and certificate authority through the Supervisor, enabling providers such as Okta. DevOps users then authenticate to the cluster using their identity provider credentials, keeping cluster authentication federated to a centrally managed identity store rather than relying on cluster-local accounts. Kubernetes hardening guidance recommends external authentication sources such as OIDC for production clusters with multiple users accessing the Kubernetes API directly. OIDC authentication is distributed to developer workstations through kubeconfig files, and custom ClusterClass configurations can be used to authenticate developers using existing corporate identity systems. Argo CD, when deployed as a Supervisor Service, supports PKCE-enabled OIDC authentication through the enablePKCEAuthentication field in the spec.oidc configuration, extending federated identity management to continuous delivery workflows. Infrastructure credentials, including service account tokens, can be configured to use short-lived certificates with automated rotation.

For authorization, VCF implements a permissions-based model across its components. Authenticated users on VMware ESX and vCenter can view objects or invoke operations depending on the permissions associated with their account. The vCenter authorization model provides consistent security control regardless of how users connect to the environment. NSX authentication best practices include defining access controls based on user roles and permissions and integrating with identity providers.

At the Kubernetes layer, the Supervisor exposes the full Kubernetes RBAC model through Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings, which control what authenticated principals can do within a cluster or namespace. The Node authorizer supports TokenReviews and SubjectAccessReviews for delegated authentication and authorization checks. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege across workloads. Kubernetes service accounts provide identity for Pods, allowing security software to group Pods into distinct security contexts. The Secret Store Supervisor Service enforces role-based access control for administrators, DevOps engineers, and application tenants managing and distributing sensitive data. Harbor Registry, deployable as a standard package on VKS clusters, secures container artifacts with policies and role-based access control, and its administrative interface allows administrators to verify authentication and access control configurations.

Audit capabilities are built into the platform at multiple levels. All API calls to NSX Manager are subject to authentication and authorization and generate audit logs. NSX supports audit data generation as a security functional requirement. NSX Manager and NSX Edge both include a dedicated audit role with separate credentials. The NSX Manager audit user has read-only privileges to the NSX environment and is not active by default; it must be explicitly activated after installation by an admin through the CLI. This separation of the audit role from administrative roles supports segregation of duties for audit functions. Within VCF SSO, NSX-related audit access is controlled through the NsxAuditors group, alongside NsxAdministrators and NsxViAdministrators, providing structured group-based assignments for NSX roles within the identity provider. NSX Manager exposes API endpoints (/api/v1/node/aaa/auth-policy and related paths) that return authentication policy settings, allowing administrators to validate authentication configuration across nodes programmatically. VCF Operations generates audit events across categories including access, access control, account management, configuration, data access, network, notification, permissions, session, system, policy, and firewall actions. These audit events are accessible through the Security menu and can be filtered, searched, and reviewed in detail.

The Kubernetes API server includes built-in audit logging. Audit events include an authenticationMetadata object that records how each request was authenticated, and when a request uses constrained impersonation the event includes an impersonationConstraint field that records which constrained impersonation verb authorized the request. Audit annotations capture authorization.k8s.io/decision and authorization.k8s.io/reason, recording authorization outcomes and their justifications in the audit log. ValidatingAdmissionPolicy objects emit audit annotations constructed from the policy name and a qualified key, with the annotation key included in the audit event, giving administrators a policy-level audit trail for admission control decisions. Separating service account creation from human user onboarding makes it easier to maintain distinct audit strategies for workloads and individuals.

Organizations looking to govern AAA within VCF should configure identity provider federation for vCenter and NSX Manager to centralize authentication through their enterprise identity provider. At the Kubernetes layer, configuring OIDC on VKS clusters and registering the same enterprise identity provider keeps workload cluster authentication aligned with the platform's identity governance. Enabling the NSX audit user and configuring audit logging across all components, including the Kubernetes API server, provides the audit leg of the AAA triad. The platform's support for multiple authentication methods (local, LDAP, OIDC) and its role-based authorization model give administrators the technical controls needed to enforce AAA policies. However, the governance policies themselves, including which AAA solutions to use, how to review and approve AAA configurations, and how to handle AAA for external service providers, must be established and maintained as organizational processes outside the platform.

VMware Private AI Services (PAIS) provides authentication and authorization mechanisms for its AI-specific services that organizations integrate into a broader AAA governance framework.

PAIS authentication uses OIDC. During service activation, an administrator configures the OIDC issuer URL, the client ID (pais-authentication-id), and the required scopes (openid, groups, offline\_access). The configuration also accepts the OIDC issuer certificate and supports an Extra Audiences setting that allows PAIS to accept access tokens minted for additional OAuth 2.0 clients when the OIDC provider requires it. PAIS requires HTTPS-based communication for the OIDC integration, and activation must be coordinated with the OIDC provider administrator to establish the identity and access management relationship.

Access to PAIS is governed by the authorizedGroups setting, which restricts service access to user accounts that are members of specified OIDC groups (for example group-for-pais-access-01). Group-based authorization routes identity decisions made in the OIDC provider directly into PAIS access control without separate per-service user provisioning.

PAIS supports CA trust bundle management to establish certificate-validated communication with the OIDC provider, Harbor registries, content management systems, and external knowledge base sources. The Grafana observability integration uses OIDC for metrics visualization access and should enable PKCE and refresh tokens for its own authentication flow. Harbor registry access uses credential-based authentication via oras login for artifact push and model pull operations, and PAIS is compatible with OCI-compliant registries from other vendors. Knowledge Bases that ingest from Confluence authenticate using either a username and password or a personal access token. Remote MCP servers connected to PAIS can optionally use

static authentication tokens. Air-gapped deployments require the self-hosted registry location and login credentials when the registry requires authentication.

Identity and access management for PAIS must be configured in coordination with an external OIDC provider administrator. PAIS provides the integration hooks and access enforcement mechanisms; the OIDC provider itself, including group lifecycle management and policy enforcement, is operated and governed separately by the organization.

### **VMware vDefend (Contributes)**

VMware vDefend contributes to AAA governance through built-in controls in Security Services Platform (SSP) and through network-layer enforcement capabilities in the Distributed Firewall.

SSP implements authentication using local accounts or directory-managed accounts. The platform uses Authelia, an open-source authentication and authorization server that provides two-factor authentication (2FA) and single sign-on (SSO) capabilities, alongside an Authserver that handles authentication requests and manages credentials. For directory integration, SSP supports Active Directory over LDAP or OpenLDAP, with only one identity source configured at a time. These capabilities apply across both the SSP platform itself and its License Hub component.

For authorization, SSP ships with two predefined local user accounts that enforce separation of duties: an admin user with the Enterprise Admin role for full management access, and an audit user with the Auditor role for read-only access to APIs and services for system auditing. These accounts are present in the SSP platform, the SSP Installer, and License Hub. The audit user's password must meet required criteria and can be reset by the admin user through the User Management interface.

For auditing, SSP provides a purpose-built audit user account scoped to compliance review and system inspection. All access events to License Hub are logged in audit logs that are enabled by default and cannot be disabled, providing a persistent access record for that management component.

At the network enforcement layer, vDefend microsegmentation policies restrict which systems can reach AAA infrastructure such as identity providers, directory services, and authentication servers, reducing the exposure of those services to lateral movement. Identity Firewall (IDFW) extends enforcement by using Active Directory user and group membership directly as the basis for firewall rule decisions. IDFW detects user logins by monitoring login events in domain controller event log servers, then applies security policies based on AD group membership. This allows network access rules to follow user identity across virtual desktops (VDI), Remote Desktop Sessions (RDSH), and physical machines. IDS/IPS profiles can detect attempts to exploit vulnerabilities in authentication services.

These controls do not replace organizational AAA governance policies or manage AAA solutions across the broader environment. They implement authentication, authorization, and audit mechanisms within the vDefend management layer and provide network-layer protection for AAA infrastructure that supports organizational governance objectives.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) implements authenticate, authorize, and audit (AAA) mechanisms for replication and recovery operations. Authentication uses VCF SSO. The PNR server acquires a holder-of-key SAML token from VCF SSO and presents it in a cryptographically signed envelope when establishing authenticated communication channels to remote services such as VMware vCenter. PNR uses service account authentication for server-to-vCenter communication, and a domain-level service account created by vCenter is used when PNR runs in an Enhanced Linked Mode environment. When connecting peer vCenter instances that reside in different or the same SSO domains, PNR also supports credential-based authentication. The PNR Appliance Management Interface requires authentication as the admin user for service management, network configuration, time zone settings, storage replication adapter configuration, and site unregistration workflows. The default admin password is set during initial deployment and is expected to be changed by the operator. PNR exposes Authentication APIs as part of its REST API gateway, including a REST endpoint to log out an authenticated session.

Authorization is enforced through PNR's privileges, roles, and permissions model. PNR performs operations using the user credentials supplied when the protected and recovery sites are connected, and permission checks apply at both sites for cross-site operations. The configuration import and export tool accepts the `--localAuthUseSA` and `--remoteAuthUseSA`

parameters, which select whether a Service Account file is used for authentication to the local or remote site. PNR and later supports Service Account authentication for importing or exporting configuration data.

Audit logging records replication and recovery operations and security-relevant events. PNR records operational information in log files that do not contain private keys or passwords. Authorization errors and certificate verification errors are written with timestamps and component information to security-related log files for audit trail purposes. Replication lifecycle events generate audit log entries, for example the AutoprotectEnabledRpEvent entry that indicates Automatic Protection has been activated for a replication provider.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) provides built-in authentication, authorization, and audit capabilities that support an organization's AAA governance requirements for the database-as-a-service layer.

For authentication, DSM supports two user authentication modes for access to the management interface: local user accounts and LDAPS-integrated accounts. Local users authenticate using an email address and password. LDAPS users authenticate with their directory service credentials at the DSM login screen, and DSM falls back to local user authentication when directory service credentials are non-functional. Organizations can integrate DSM with an LDAP or Active Directory server for both authentication and authorization, with the DSM appliance communicating with directory service servers for credential validation. This configuration is available under Managing LDAP Users in the DSM administration interface.

At the database level, DSM supports configurable host-based authentication (HBA) rules for PostgreSQL database instances. PostgreSQL instances use an ordered rule set in `pg_hba.conf` that matches connection type, client address, requested database, and user name to determine the authentication method applied. Custom HBA entries support the `scram-sha-256`, `reject`, and `cert` authentication methods; both a UI and an API are available for configuring these options. SQL Server databases use contained database users that authenticate directly against the database, with identity information stored within the database itself.

For authorization, DSM can be configured to use an LDAP server for both authentication and authorization, allowing role assignments and access decisions to be managed through the organization's existing directory infrastructure. Data service policies can be enforced consistently across different tenants, supporting a uniform security posture. Integration channels for metrics forwarding support configurable authentication: VCF Operations integration requires mutual TLS (mTLS) authentication, while Prometheus forwarding supports no authentication, certificate-only, basic authentication, or a combination of certificate and basic authentication. Webhook integrations support basic authentication with configurable Authorization User and Authorization Password credentials, so event notification channels can be secured. The DSM Consumption Operator uses a dedicated authentication secret (`dsm-auth-creds`) to authenticate with the DSM infrastructure for Kubernetes-native consumption paths.

For audit, DSM provides a System Audit capability on the Provider VM that monitors system audit events, accessible through the DSM administration interface. PostgreSQL database instances include the `pgaudit` extension, providing database-level audit logging of query and object access activity. SQL Server deployments include configurable server auditing with preset audits for login tracking and log retention; the Login Auditing option can automatically create an audit for login events.

Governing the use of these AAA mechanisms, establishing organizational policies for when LDAPS integration is required versus local accounts, defining retention and review requirements for audit logs, and extending governance to any External Service Provider hosting components of the AAA infrastructure remain organizational responsibilities. DSM provides the technical controls; organizational processes determine how strictly they are applied and monitored.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer provides AAA mechanisms at two layers: the administrative control plane for governing access to the Avi Controller itself, and the application delivery layer for governing client authentication to applications served through virtual services.

At the administrative control plane, Avi Load Balancer maintains user accounts in two categories: local users and remote users, with remote users authenticated through an external authentication, authorization, and accounting (AAA) server. User

accounts can be validated through a local database or a remote directory service such as LDAP, limited to a specific tenant, and assigned specific roles or access levels. LDAP authentication profiles are configured via **Templates > Security > Auth Profile** with Type set to LDAP. The documentation recommends federated authentication as the preferred pattern, delegating authentication to an external identity provider rather than managing it locally. OAuth 2.0 and OpenID Connect (OIDC) are supported for Controller client authentication, introducing an authorization layer that allows an identity provider to issue tokens to third-party applications with user approval without requiring direct credential sharing.

The Avi License Hub provides a distinct AAA surface for license management. It supports user authentication via Active Directory and OpenLDAP identity sources. The License Hub includes a dedicated Audit account with the auditor role that has full access to APIs and services for system auditing; the Admin user can reset the Audit account password. Passwords for License Hub accounts, including the audit user role, must meet specified complexity criteria.

Authorization at the administrative control plane is enforced through role-based access control. When remote authentication is configured, the Controller requires assignment of roles and tenants for every user login through authorization mapping rules configured in the Auth Mapping Profile. User accounts can be scoped to a specific tenant and assigned specific roles or access levels. The `allow_local_user_login` setting controls whether local login remains enabled alongside external authentication methods.

At the application delivery layer, virtual services can be configured with an access policy to enforce OAuth or OIDC authentication at the proxy boundary, configured under **Policies > Access** on a virtual service. The OAuth/OIDC flow uses an authorization server to authenticate the client, validate the authorization code, and issue access tokens. OIDC logout support includes RP-Initiated Logout, configurable per virtual service. Client LDAP authentication is also supported for virtual services, with client authorization enforced through OAuth access tokens that allow applications to act on behalf of users without direct credential sharing.

For audit logging, Avi Load Balancer requires that all external communication-related authentication failures, including those for SSH and TLS connections, be logged and persisted for auditing purposes. These records are accessible via **Application Monitoring > Audit Logging**.

## Control PR.AA-04

> Identity assertions are protected, conveyed, and verified

**SCF Controls:** IAC-01.2, IAC-02.2, IAC-03.5

**Aggregate Coverage:** Meets

### VCF (Meets)

VCF provides built-in Authenticate, Authorize, and Audit (AAA) capabilities across its component stack, giving organizations a strong technical foundation for governing AAA within the platform.

For authentication, VCF SSO is the centralized identity broker. VMware vCenter can be federated with an external enterprise identity provider, which handles authentication in a federated model and enables flexible options such as multifactor authentication, automatic user registration, and termination of users across services. Named external identity providers supported for vCenter federation include Okta, with provider-specific configuration procedures available for each. NSX Manager supports local authentication, LDAP authentication, and OIDC authentication with configurable identity provider selection. VCF Automation allows organizations to define a shared identity provider and authenticate users through configurable authentication mechanisms, including redirections to external identity providers. The Identity API in VCF Automation provides programmatic management of authentication and authorization providers. The vCenter Client Credentials grant type also allows application-to-identity-provider authentication without a human user present, supporting machine-to-machine authentication scenarios. VMware ESX and vCenter validate user credentials against configured identity stores.

At the Kubernetes consumption layer, VMware Kubernetes Service (VKS) clusters support two authentication methods: VCF SSO and OIDC-compliant external identity providers. Administrators register an external provider by configuring the identity provider issuer URL, client credentials, and certificate authority through the Supervisor, enabling providers such as Okta. DevOps users then authenticate to the cluster using their identity provider credentials, keeping cluster authentication federated to a centrally managed identity store rather than relying on cluster-local accounts. Kubernetes hardening guidance recommends external authentication sources such as OIDC for production clusters with multiple users accessing the Kubernetes API directly. OIDC authentication is distributed to developer workstations through kubeconfig files, and custom ClusterClass configurations can be used to authenticate developers using existing corporate identity systems. Argo CD, when deployed as a Supervisor Service, supports PKCE-enabled OIDC authentication through the `enablePKCEAuthentication` field in the `spec.oidc` configuration, extending federated identity management to continuous delivery workflows. Infrastructure credentials, including service account tokens, can be configured to use short-lived certificates with automated rotation.

For authorization, VCF implements a permissions-based model across its components. Authenticated users on VMware ESX and vCenter can view objects or invoke operations depending on the permissions associated with their account. The vCenter authorization model provides consistent security control regardless of how users connect to the environment. NSX authentication best practices include defining access controls based on user roles and permissions and integrating with identity providers.

At the Kubernetes layer, the Supervisor exposes the full Kubernetes RBAC model through Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings, which control what authenticated principals can do within a cluster or namespace. The Node authorizer supports TokenReviews and SubjectAccessReviews for delegated authentication and authorization checks. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege across workloads. Kubernetes service accounts provide identity for Pods, allowing security software to group Pods into distinct security contexts. The Secret Store Supervisor Service enforces role-based access control for administrators, DevOps engineers, and application tenants managing and distributing sensitive data. Harbor Registry, deployable as a standard package on VKS clusters, secures container artifacts with policies and role-based access control, and its administrative interface allows administrators to verify authentication and access control configurations.

Audit capabilities are built into the platform at multiple levels. All API calls to NSX Manager are subject to authentication and authorization and generate audit logs. NSX supports audit data generation as a security functional requirement. NSX Manager



and NSX Edge both include a dedicated audit role with separate credentials. The NSX Manager audit user has read-only privileges to the NSX environment and is not active by default; it must be explicitly activated after installation by an admin through the CLI. This separation of the audit role from administrative roles supports segregation of duties for audit functions. Within VCF SSO, NSX-related audit access is controlled through the `NsxAuditors` group, alongside `NsxAdministrators` and `NsxViAdministrators`, providing structured group-based assignments for NSX roles within the identity provider. NSX Manager exposes API endpoints (`/api/v1/node/aaa/auth-policy` and related paths) that return authentication policy settings, allowing administrators to validate authentication configuration across nodes programmatically. VCF Operations generates audit events across categories including access, access control, account management, configuration, data access, network, notification, permissions, session, system, policy, and firewall actions. These audit events are accessible through the Security menu and can be filtered, searched, and reviewed in detail.

The Kubernetes API server includes built-in audit logging. Audit events include an `authenticationMetadata` object that records how each request was authenticated, and when a request uses constrained impersonation the event includes an `impersonationConstraint` field that records which constrained impersonation verb authorized the request. Audit annotations capture `authorization.k8s.io/decision` and `authorization.k8s.io/reason`, recording authorization outcomes and their justifications in the audit log. `ValidatingAdmissionPolicy` objects emit audit annotations constructed from the policy name and a qualified key, with the annotation key included in the audit event, giving administrators a policy-level audit trail for admission control decisions. Separating service account creation from human user onboarding makes it easier to maintain distinct audit strategies for workloads and individuals.

Organizations looking to govern AAA within VCF should configure identity provider federation for vCenter and NSX Manager to centralize authentication through their enterprise identity provider. At the Kubernetes layer, configuring OIDC on VKS clusters and registering the same enterprise identity provider keeps workload cluster authentication aligned with the platform's identity governance. Enabling the NSX audit user and configuring audit logging across all components, including the Kubernetes API server, provides the audit leg of the AAA triad. The platform's support for multiple authentication methods (local, LDAP, OIDC) and its role-based authorization model give administrators the technical controls needed to enforce AAA policies. However, the governance policies themselves, including which AAA solutions to use, how to review and approve AAA configurations, and how to handle AAA for external service providers, must be established and maintained as organizational processes outside the platform.

VMware Private AI Services (PAIS) provides authentication and authorization mechanisms for its AI-specific services that organizations integrate into a broader AAA governance framework.

PAIS authentication uses OIDC. During service activation, an administrator configures the OIDC issuer URL, the client ID (`pais-authentication-id`), and the required scopes (`openid`, `groups`, `offline_access`). The configuration also accepts the OIDC issuer certificate and supports an `Extra Audiences` setting that allows PAIS to accept access tokens minted for additional OAuth 2.0 clients when the OIDC provider requires it. PAIS requires HTTPS-based communication for the OIDC integration, and activation must be coordinated with the OIDC provider administrator to establish the identity and access management relationship.

Access to PAIS is governed by the `authorizedGroups` setting, which restricts service access to user accounts that are members of specified OIDC groups (for example `group-for-pais-access-01`). Group-based authorization routes identity decisions made in the OIDC provider directly into PAIS access control without separate per-service user provisioning.

PAIS supports CA trust bundle management to establish certificate-validated communication with the OIDC provider, Harbor registries, content management systems, and external knowledge base sources. The Grafana observability integration uses OIDC for metrics visualization access and should enable PKCE and refresh tokens for its own authentication flow. Harbor registry access uses credential-based authentication via `oras login` for artifact push and model pull operations, and PAIS is compatible with OCI-compliant registries from other vendors. Knowledge Bases that ingest from Confluence authenticate using either a username and password or a personal access token. Remote MCP servers connected to PAIS can optionally use static authentication tokens. Air-gapped deployments require the self-hosted registry location and login credentials when the registry requires authentication.

Identity and access management for PAIS must be configured in coordination with an external OIDC provider administrator. PAIS provides the integration hooks and access enforcement mechanisms; the OIDC provider itself, including group lifecycle management and policy enforcement, is operated and governed separately by the organization.

### **VMware vDefend (Contributes)**

VMware vDefend contributes to AAA governance through built-in controls in Security Services Platform (SSP) and through network-layer enforcement capabilities in the Distributed Firewall.

SSP implements authentication using local accounts or directory-managed accounts. The platform uses Authelia, an open-source authentication and authorization server that provides two-factor authentication (2FA) and single sign-on (SSO) capabilities, alongside an Authserver that handles authentication requests and manages credentials. For directory integration, SSP supports Active Directory over LDAP or OpenLDAP, with only one identity source configured at a time. These capabilities apply across both the SSP platform itself and its License Hub component.

For authorization, SSP ships with two predefined local user accounts that enforce separation of duties: an admin user with the Enterprise Admin role for full management access, and an audit user with the Auditor role for read-only access to APIs and services for system auditing. These accounts are present in the SSP platform, the SSP Installer, and License Hub. The audit user's password must meet required criteria and can be reset by the admin user through the User Management interface.

For auditing, SSP provides a purpose-built audit user account scoped to compliance review and system inspection. All access events to License Hub are logged in audit logs that are enabled by default and cannot be disabled, providing a persistent access record for that management component.

At the network enforcement layer, vDefend microsegmentation policies restrict which systems can reach AAA infrastructure such as identity providers, directory services, and authentication servers, reducing the exposure of those services to lateral movement. Identity Firewall (IDFW) extends enforcement by using Active Directory user and group membership directly as the basis for firewall rule decisions. IDFW detects user logins by monitoring login events in domain controller event log servers, then applies security policies based on AD group membership. This allows network access rules to follow user identity across virtual desktops (VDI), Remote Desktop Sessions (RDSH), and physical machines. IDS/IPS profiles can detect attempts to exploit vulnerabilities in authentication services.

These controls do not replace organizational AAA governance policies or manage AAA solutions across the broader environment. They implement authentication, authorization, and audit mechanisms within the vDefend management layer and provide network-layer protection for AAA infrastructure that supports organizational governance objectives.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) implements authenticate, authorize, and audit (AAA) mechanisms for replication and recovery operations. Authentication uses VCF SSO. The PNR server acquires a holder-of-key SAML token from VCF SSO and presents it in a cryptographically signed envelope when establishing authenticated communication channels to remote services such as VMware vCenter. PNR uses service account authentication for server-to-vCenter communication, and a domain-level service account created by vCenter is used when PNR runs in an Enhanced Linked Mode environment. When connecting peer vCenter instances that reside in different or the same SSO domains, PNR also supports credential-based authentication. The PNR Appliance Management Interface requires authentication as the admin user for service management, network configuration, time zone settings, storage replication adapter configuration, and site unregistration workflows. The default admin password is set during initial deployment and is expected to be changed by the operator. PNR exposes Authentication APIs as part of its REST API gateway, including a REST endpoint to log out an authenticated session.

Authorization is enforced through PNR's privileges, roles, and permissions model. PNR performs operations using the user credentials supplied when the protected and recovery sites are connected, and permission checks apply at both sites for cross-site operations. The configuration import and export tool accepts the `--localAuthUseSA` and `--remoteAuthUseSA` parameters, which select whether a Service Account file is used for authentication to the local or remote site. PNR and later supports Service Account authentication for importing or exporting configuration data.



Audit logging records replication and recovery operations and security-relevant events. PNR records operational information in log files that do not contain private keys or passwords. Authorization errors and certificate verification errors are written with timestamps and component information to security-related log files for audit trail purposes. Replication lifecycle events generate audit log entries, for example the AutoprotectEnabledRpEvent entry that indicates Automatic Protection has been activated for a replication provider.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) provides built-in authentication, authorization, and audit capabilities that support an organization's AAA governance requirements for the database-as-a-service layer.

For authentication, DSM supports two user authentication modes for access to the management interface: local user accounts and LDAPS-integrated accounts. Local users authenticate using an email address and password. LDAPS users authenticate with their directory service credentials at the DSM login screen, and DSM falls back to local user authentication when directory service credentials are non-functional. Organizations can integrate DSM with an LDAP or Active Directory server for both authentication and authorization, with the DSM appliance communicating with directory service servers for credential validation. This configuration is available under Managing LDAP Users in the DSM administration interface.

At the database level, DSM supports configurable host-based authentication (HBA) rules for PostgreSQL database instances. PostgreSQL instances use an ordered rule set in `pg_hba.conf` that matches connection type, client address, requested database, and user name to determine the authentication method applied. Custom HBA entries support the `scram-sha-256`, `reject`, and `cert` authentication methods; both a UI and an API are available for configuring these options. SQL Server databases use contained database users that authenticate directly against the database, with identity information stored within the database itself.

For authorization, DSM can be configured to use an LDAP server for both authentication and authorization, allowing role assignments and access decisions to be managed through the organization's existing directory infrastructure. Data service policies can be enforced consistently across different tenants, supporting a uniform security posture. Integration channels for metrics forwarding support configurable authentication: VCF Operations integration requires mutual TLS (mTLS) authentication, while Prometheus forwarding supports no authentication, certificate-only, basic authentication, or a combination of certificate and basic authentication. Webhook integrations support basic authentication with configurable Authorization User and Authorization Password credentials, so event notification channels can be secured. The DSM Consumption Operator uses a dedicated authentication secret (`dsm-auth-creds`) to authenticate with the DSM infrastructure for Kubernetes-native consumption paths.

For audit, DSM provides a System Audit capability on the Provider VM that monitors system audit events, accessible through the DSM administration interface. PostgreSQL database instances include the `pgaudit` extension, providing database-level audit logging of query and object access activity. SQL Server deployments include configurable server auditing with preset audits for login tracking and log retention; the Login Auditing option can automatically create an audit for login events.

Governing the use of these AAA mechanisms, establishing organizational policies for when LDAPS integration is required versus local accounts, defining retention and review requirements for audit logs, and extending governance to any External Service Provider hosting components of the AAA infrastructure remain organizational responsibilities. DSM provides the technical controls; organizational processes determine how strictly they are applied and monitored.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer provides AAA mechanisms at two layers: the administrative control plane for governing access to the Avi Controller itself, and the application delivery layer for governing client authentication to applications served through virtual services.

At the administrative control plane, Avi Load Balancer maintains user accounts in two categories: local users and remote users, with remote users authenticated through an external authentication, authorization, and accounting (AAA) server. User accounts can be validated through a local database or a remote directory service such as LDAP, limited to a specific tenant, and assigned specific roles or access levels. LDAP authentication profiles are configured via `Templates > Security > Auth`

Profile with Type set to LDAP. The documentation recommends federated authentication as the preferred pattern, delegating authentication to an external identity provider rather than managing it locally. OAuth 2.0 and OpenID Connect (OIDC) are supported for Controller client authentication, introducing an authorization layer that allows an identity provider to issue tokens to third-party applications with user approval without requiring direct credential sharing.

The Avi License Hub provides a distinct AAA surface for license management. It supports user authentication via Active Directory and OpenLDAP identity sources. The License Hub includes a dedicated Audit account with the auditor role that has full access to APIs and services for system auditing; the Admin user can reset the Audit account password. Passwords for License Hub accounts, including the audit user role, must meet specified complexity criteria.

Authorization at the administrative control plane is enforced through role-based access control. When remote authentication is configured, the Controller requires assignment of roles and tenants for every user login through authorization mapping rules configured in the Auth Mapping Profile. User accounts can be scoped to a specific tenant and assigned specific roles or access levels. The `allow_local_user_login` setting controls whether local login remains enabled alongside external authentication methods.

At the application delivery layer, virtual services can be configured with an access policy to enforce OAuth or OIDC authentication at the proxy boundary, configured under Policies > Access on a virtual service. The OAuth/OIDC flow uses an authorization server to authenticate the client, validate the authorization code, and issue access tokens. OIDC logout support includes RP-Initiated Logout, configurable per virtual service. Client LDAP authentication is also supported for virtual services, with client authorization enforced through OAuth access tokens that allow applications to act on behalf of users without direct credential sharing.

For audit logging, Avi Load Balancer requires that all external communication-related authentication failures, including those for SSH and TLS connections, be logged and persisted for auditing purposes. These records are accessible via Application Monitoring > Audit Logging.

## Control PR.AA-05

> Access permissions, entitlements, and authorizations are defined in a policy, managed, enforced, and reviewed, and incorporate the principles of least privilege and separation of duties [Withdrawn: Incorporated into PR.AA-01, PR.AA-05] [Withdrawn: Incorporated into PR.AA-03, PR.AA-05, PR.IR-01] [Withdrawn: Moved to PR.AA-05]

**SCF Controls:** HRS-02, HRS-11, IAC-01, IAC-01.2, IAC-02, IAC-03, IAC-04, IAC-05, IAC-08, IAC-21

**Aggregate Coverage:** Meets

### VCF (Meets)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcIdentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID

Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory. Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline\_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is

automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

### **VMware vDefend (Contributes)**

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) supports least privilege through role-based access control with a defined set of predefined roles and the ability to clone and customize roles for narrower operational scope. The 9.1 release consolidates Site Recovery Manager and vSphere Replication management under a single permissions model where PNR augments vCenter roles and permissions with additional permissions that allow detailed control over PNR-specific tasks and operations. PNR also verifies permissions on the remote vCenter instance as part of its access control validation, so privilege assignments are evaluated at both sites.

By default, PNR restricts login access to vCenter administrators; other users must be explicitly granted access by an administrator through the PNR interface. Users or user groups assigned a PNR role who are not vCenter administrators do not obtain vSphere Replication privileges, because PNR roles do not include the privileges of vSphere Replication roles. A user who is not a vCenter administrator but requires privileges to perform both PNR and vSphere Replication operations should be added to two user groups, one for each role type, to avoid granting vCenter administrator privileges.

vSphere Replication uses role-based access control with predefined roles that can be cloned and customized by adding or removing privileges based on organizational needs. PNR supports role propagation to child objects in the inventory hierarchy, allowing administrators to extend privileges from parent objects such as folders to all virtual machines within them, or to assign permissions at specific inventory levels without propagation when narrower scope is required. When permissions are assigned without propagation, users must have at least Read-only permission on all parent objects in the vCenter inventory.

PNR for VCF Automation access is controlled through role-based permissions assigned to Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users, aligning RBAC with VCF Automation tenancy boundaries. Namespace unpair operations require Organization Administrator role authorization. In shared recovery site configurations, PNR restricts users from changing roles or assigning permissions for objects not dedicated to their own use, which helps prevent unauthorized privilege escalation across tenants, and the vCenter administrator manages PNR permissions so that each user has sufficient privileges to configure and use PNR but no user has access to resources belonging to other tenants.

PNR requires separate privilege assignment for testing a recovery plan and running a recovery plan, which helps prevent unintended changes at both sites that would require significant time and effort to reverse. PNR roles that allow users to run commands on PNR Server should be assigned to trusted administrator-level users only, and PNR server access should be limited to administrators to reduce the number of accounts available to an attacker. PNR administrators can assign `SrmAdministrator` or `SrmProtectionGroupsAdministrator` roles to the automatic protection user or user groups for managing automatic protection permissions.

For the 9.1 Clean Room Orchestrator, at least one user must be assigned the Organization Owner role to enable administrative access to all resources in the Organization, with additional roles available for narrower delegation. VCF Operations orchestrator workflows for PNR require administrator credentials to access and execute, which restricts non-administrative users from performing sensitive recovery operations through the orchestration interface.

### **VMware Data Services Manager (Meets)**

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

### **VMware Avi Load Balancer (Meets)**



VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

## Control PR.AA-06

> Physical access to assets is managed, monitored, and enforced commensurate with risk [Withdrawn: Moved to PR.AA-06]  
[Withdrawn: Incorporated into PR.AA-06, PR.IR-01]

**SCF Controls:** PES-01, PES-02, PES-02.1, PES-03

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control PR.AT

> Personnel are provided with awareness and training so that they possess the knowledge and skills to perform general tasks with cybersecurity risks in mind. Individuals in specialized roles are provided with awareness and training so that they possess the knowledge and skills to perform relevant tasks with cybersecurity risks in mind. [Withdrawn: Incorporated into PR.AT-01, PR.AT-02] [Withdrawn: Incorporated into PR.AT-02] [Withdrawn: Incorporated into PR.AT-01]

**SCF Controls:** SAT-01, SAT-02, SAT-03

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control PR.AT-01

> Personnel are provided with awareness and training so that they possess the knowledge and skills to perform general tasks with cybersecurity risks in mind [Withdrawn: Incorporated into PR.AT-01, PR.AT-02] [Withdrawn: Incorporated into PR.AT-01]

**SCF Controls:** SAT-02, SAT-03, SAT-03.6

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control PR.AT-02

> Individuals in specialized roles are provided with awareness and training so that they possess the knowledge and skills to perform relevant tasks with cybersecurity risks in mind [Withdrawn: Incorporated into PR.AT-01, PR.AT-02] [Withdrawn: Incorporated into PR.AT-02]

**SCF Controls:** SAT-03, SAT-03.5, SAT-03.6, SAT-03.7

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control PR.DS

> The confidentiality, integrity, and availability of data-at-rest are protected The confidentiality, integrity, and availability of data-in-transit are protected [Withdrawn: Incorporated into ID.AM-08, PR.PS-03] [Withdrawn: Moved to PR.IR-04] [Withdrawn: Incorporated into PR.DS-01, PR.DS-02, PR.DS-10] [Withdrawn: Incorporated into PR.DS-01, DE.CM-09] [Withdrawn: Incorporated into PR.IR-01] [Withdrawn: Incorporated into ID.RA-09, DE.CM-09] The confidentiality, integrity, and availability of data-in-use are protected Backups of data are created, protected, maintained, and tested [Withdrawn: Moved to PR.DS-11] [Withdrawn: Incorporated into PR.DS-01, PR.PS-01]

**SCF Controls:** DCH-01, DCH-01.1, DCH-01.2, DCH-01.3, DCH-01.4, DCH-02, DCH-03

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides multiple layers of data protection controls spanning encryption, storage resilience, backup and recovery, disaster recovery, centralized monitoring, and access management.

For data at rest, vSAN encryption protects data on storage devices so that if a device is physically removed from the cluster, the data remains unreadable. At the virtual machine level, VM encryption protects NVRAM, swap (VSWP), and snapshot (VMSN) files, providing per-VM granularity independent of the underlying storage encryption. For data in transit, vSAN data-in-transit encryption protects data as it moves between hosts and file service inter-host connections within a vSAN cluster, with forward secrecy enforced. TLS protects data in transit between other VCF components. Both vSAN and VM encryption integrate with external Key Management Server (KMS) infrastructure for key lifecycle management, requiring a trust relationship established through certificate and key file exchange. VCF components use FIPS-validated cryptographic modules: NSX cryptographic modules are validated to FIPS 140-3 standards, vSphere uses FIPS-validated cryptographic modules matching the FIPS 140-2 standard, and VCF Automation runs in FIPS-compliant mode by default using FIPS 140-3 validated modules.

vSAN implements erasure coding through RAID-5 storage policies, which split data into blocks with parity information to protect against component failures. vSAN includes failure indication and data rebuild mechanisms that detect storage failures and automatically reconstruct unavailable data. Virtual machines on vSAN datastores can be assigned storage policies that define specific data protection and performance characteristics, giving administrators granular control over how data is protected at the workload level.

VCF supports backup methods for its management components at multiple levels. VMware vCenter file-based daily backups are configured through the vCenter Management Interface for each vCenter instance. vCenter file-based backup supports optional password-based encryption of backup files, and backup files are stored off-appliance on servers accessible via FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB. When vSphere Native Key Provider is configured, vCenter backups contain the Key Derivation Key and must be stored in a secure, access-controlled location. VCF Operations backups support both file-based and image-based methods. NSX Manager backup is configured automatically during the bring-up process. For vSphere Supervisor environments, control plane backup and restore can be performed from the Workload Management UI, and Supervisor control plane backup can also be included as an option in vCenter file-based backup schedules. vSAN Data Protection uses native snapshots stored locally on vSAN Express Storage Architecture (ESA) clusters to help recover virtual machines from operational failure or ransomware attacks.

For Kubernetes workloads, VMware Kubernetes Service (VKS) provides dedicated data protection capabilities built into the VCF platform. VKS cluster node VMs are backed up through Supervisor state backup using the vCenter backup feature available in the vCenter Management Interface, so Supervisor state is covered by the same vCenter backup workflow used for the management plane. When data protection is activated for a VKS cluster, VKS cluster management installs the data protection extension, selected plugins, and Velero on the cluster; activation requires an Organization Administrator or Project Administrator role. Backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. Two backup methods are available: vSphere Plugin Snapshot performs block-level backup writing directly to object storage and is faster for workloads with large numbers of small files, while File System Backup operates at the file system level and supports incremental backups. The vSphere

Plugin Snapshot method performs full backups on each run since it does not support changed block tracking, so organizations that require incremental backups should use the File System Backup method. Both methods support stateless and stateful workloads. Backup scope is configurable to the entire cluster, selected namespaces, or specific resources identified by label, and VKS cluster backups include file system backups in the restore by default. Velero 1.17 supports scheduled backups, allowing organizations to configure automated backup cadences. Backup repositories support deduplication, compression, and encryption of backup data. The Velero Plugin for vSphere backs up and restores both stateless and stateful applications running on vSphere Pods in the Supervisor. VKS Backup and Restore Hooks enable execution of pre- and post-operation scripts for granular control over the data protection lifecycle, supporting application consistency and custom automation during recovery. Cross-cluster restore is available through the Restore from another cluster option in the Data Protection tab of the VCF Automation Tenant Portal. Data protection account credentials are scoped to users with Organization Administrator or Project Administrator roles, restricting who can configure backup target locations; VCF Automation enables platform teams to create target locations pointing to self-provisioned storage environments, supporting both cloud-hosted accounts and on-premises endpoints. VCF Automation also supports snapshotting VM groups, where each member VM receives a distinct snapshot, and restoring a VM group snapshot restores each member of the group.

Kubernetes cluster state is stored in etcd, and two backup methods are available for the etcd datastore: the built-in snapshot method and volume snapshot. The `etcdctl snapshot save` command creates a backup by specifying the endpoint, CA certificate, client certificate, and client key, providing authenticated access to the backup operation. Snapshots can be restored from a snapshot file or from a remaining data directory. During `kubeadm` upgrades, backup folders for etcd state and cluster manifests are written automatically to `/etc/kubernetes/tmp` with timestamped names, providing a recovery point in case of upgrade failure. Storage policy-based data management is available through Kubernetes StorageClass objects that reference vSphere storage policies via Storage Policy Based Management (SPBM); those policies may include encryption settings, allowing organizations to apply consistent encryption-at-rest requirements to persistent volumes through standard Kubernetes StorageClass configuration. CSI-based data protection for VKS requires a validated configuration between VKS and the underlying storage infrastructure.

VKS clusters on the Supervisor also support the Kubernetes VolumeSnapshot API, which provides `VolumeSnapshotContent` and `VolumeSnapshot` resources as a native point-in-time snapshot mechanism for persistent volumes. Volume snapshots can be provisioned dynamically from a `PersistentVolumeClaim` using a `VolumeSnapshotClass` that specifies storage provider parameters and the deletion policy for snapshot content. Restoring from a snapshot is performed by creating a new `PersistentVolumeClaim` with the target `VolumeSnapshot` as its `dataSource`, referenced via the `snapshot.storage.k8s.io` API group. Kubernetes `PersistentVolumes` have a configurable reclaim policy; setting the policy to `Retain` preserves volume data in a `Released` state after the associated `PersistentVolumeClaim` is deleted, allowing administrators to recover or migrate the data before the underlying storage is reclaimed.

Kubernetes Secrets provide a mechanism for storing sensitive configuration data separately from application code, reducing the risk of accidental exposure in container workloads. Applications consuming Secrets from environment variables or mounted volumes should avoid logging secret values in the clear or transmitting them to untrusted parties. Using short-lived Secrets helps limit the impact of accidental or intentional exposure. Kubernetes and applications can take additional precautions with Secrets, such as avoiding writing sensitive data to non-volatile storage.

vSphere APIs for Data Protection provide an integration point for third-party backup software to perform nondisruptive full, differential, and incremental image backups using VMFS snapshot capabilities, without requiring virtual machines to be powered off or placing backup processing overhead on VMware ESX hosts. For virtual machines running supported Microsoft Windows operating systems, these APIs integrate with Microsoft Volume Shadow Copy Services (VSS) to maintain application consistency during backup operations.

VMware Live Site Recovery extends data protection with orchestrated disaster recovery across sites. Replication can be configured with recovery point objectives as low as 60 seconds, with options for network compression, multiple point-in-time recovery, and automatic replication of new disks. vSphere Replication provides configurable RPO settings for VM-level replication to local or remote datastores. Application-level high availability and disaster recovery mechanisms combine real-

time availability with sitewide disaster recovery, with data replication to secondary sites providing recovery options in case of catastrophic failure.

VCF Operations Data and Site Resiliency Monitoring provides centralized visibility into data protection metrics across private clouds, enabling administrators to track the status of data protection controls from a single view. This monitoring layer helps organizations verify that their data protection configurations remain in place and functioning as expected.

For Kubernetes workloads on VKS clusters, volume health status is reported through `volumehealth.storage.kubernetes.io/messages` annotations on `PersistentVolumeClaims`, giving administrators granular visibility into whether individual persistent volumes are accessible.

Management of data protection settings is restricted through role-based access controls. VCF Operations uses privilege-based access controls that restrict visibility based on user roles, limiting which accounts can view sensitive operational data. For VKS clusters, managing data protection requires assignment of an Organization Administrator or Project Administrator role. VCF documentation includes storage security best practices covering securing access to storage devices, implementing storage encryption, and protecting virtual machine data as part of an overall data protection posture.

Selecting which of these data protection mechanisms apply to specific datasets, defining protection policies and recovery objectives, and configuring the relevant features to match those decisions remain organizational responsibilities. VCF supplies the technical mechanisms; organizations define what to protect, to what recovery point, and with which retention and access controls.

VMware Private AI Services (PAIS) contributes to data protection by applying access controls, authenticated connectivity, and credential management to AI workloads, model repositories, knowledge bases, and associated data assets that the platform handles.

The Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. PAIS is also compatible with OCI-compliant registries from other vendors, so organizations using an alternate backend can apply equivalent registry-level access controls.

Access to PAIS itself is gated by OIDC group-based authorization. Only user accounts that are members of the groups specified in the `authorizedGroups` configuration can access the service, and the OIDC group claim name is configurable to match the identity provider in use. PAIS uses a CA trust bundle for secure communication with external services and databases, and supports CA trust bundle management for secure connections with external registries and content management systems by uploading or referencing certificate files. VCF Automation Provider Management requires trusted certificate import for vCenter validation before integration with PAIS, restricting integration paths to validated endpoints.

For retrieval-augmented generation, PAIS Knowledge Bases link to external data sources through stored credentials, scoping indexed-data retrieval to defined service identities, and Data Indexing and Retrieval handles automatic collection and indexing of updates from those linked sources over time. Personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and data sources. SharePoint data sources for PAIS Knowledge Bases require user name and password authentication, with support limited to SharePoint On-Premises deployments.

PAIS observability also flows through authenticated paths: the Grafana integration uses OIDC provider authentication for metrics visualization, and LLM traces can be sent to an OpenTelemetry Collector for monitoring.

PAIS DSM database resource allocation is controlled through an infrastructure policy that defines the quality and quantity of resources the database can consume from vSphere clusters, with associated storage policies and VM classes. A default storage policy can be selected to define storage placement for the database in PAIS, and storage policy and VM class selections should be chosen to suit RAG workloads when the database supports RAG use cases.

Organizations connecting external data sources or registries to PAIS should examine the capabilities and parameters of those integrations and approve only those suitable for use, since unreviewed connectors can affect what data models access or expose.

### **VMware vDefend (Contributes)**

VMware vDefend (vDefend) contributes to data protection controls by providing network-level security mechanisms that protect data in transit and restrict unauthorized network access to systems where data is stored or processed.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level, restricting which workloads can communicate with data stores, databases, and application tiers. By segmenting the data center network into isolated security zones, vDefend limits the blast radius of a compromise and restricts lateral movement toward systems that hold sensitive data. Administrators define granular firewall rules based on workload identity, security tags, and application-level attributes, limiting access to data repositories to authorized services. Identity Firewall extends policy enforcement to user identity, allowing administrators to define access controls based on which authenticated user initiated the connection rather than solely the source workload, strengthening data access controls in environments with user-based authorization requirements. Security policies are defined, propagated, and enforced across Bare Metal servers through the Security Services Platform (SSP), extending microsegmentation protections beyond virtualized workloads to physical infrastructure connected to the environment.

The SSP includes Security Intelligence, which identifies risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP. This visibility allows administrators to detect and remediate unencrypted data flows that could expose sensitive information in transit. Security Intelligence administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment flows. Security Intelligence also enables administrators to generate policy recommendations and deploy them in monitor-before-enforcement mode, allowing observation of traffic patterns before applying restrictive rules. The SSP summary panel displays the number of services that are fully protected, partially protected, or not protected, giving administrators a dashboard view of segmentation coverage gaps across the environment.

IDS/IPS profiles attach to Distributed Firewall and Gateway Firewall rules to inspect east-west and north-south network traffic for signatures and behaviors associated with data theft, command-and-control communication, and exploitation of vulnerabilities in data-handling services. In vDefend, IDS/IPS signature rules support storing TLS/SSL certificates on disk for forensic analysis and threat investigation, providing durable artifacts for post-incident review of potential data exfiltration events.

Malware Prevention profiles attach to DFW and Gateway Firewall rules and can be configured to send files to the cloud for detailed analysis or to process files locally without cloud connectivity, accommodating environments with data-residency or air-gap requirements. Malware Prevention collects file analysis data including file hash submissions and assigns an Analyst UUID to each submission to track its analysis lifecycle. The Malware Prevention dashboard displays trends of malicious, suspicious, and suppressed file events across the data center, and file verdict filtering allows operators to focus on specific verdict categories such as malicious-only views.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to cloud services, providing a built-in data privacy mechanism for environments that enable cloud-assisted threat detection.

These network security controls complement the data-at-rest encryption, backup, replication, and access management capabilities provided by other VCF components. vDefend does not perform data encryption, classification, backup, or recovery itself, but it protects the network paths and access patterns through which data is stored, replicated, and retrieved.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides replication-based data protection for virtual machine workloads across sites. Protection groups allow administrators to organize virtual machines and datastores under consistent snapshot and replication policies at scale, covering both local recovery via vSAN snapshots and cross-site recovery via vSphere Replication or array-based replication. Protection group membership can be modified after creation, and virtual machines can be automatically enrolled for protection using storage tag selection on designated datastores, reducing manual overhead in maintaining protection coverage across a growing environment.

PNR introduces an immutability mode for protection groups that, when enabled, prevents the data protection group from being modified or deleted. This mechanism allows administrators to safeguard protection configurations against inadvertent or unauthorized changes. PNR Health monitoring provides consolidated visibility into data protection service health, operation issues for local and replication snapshots, storage utilization, and protection group membership changes, giving administrators a current view of protection posture across the environment.

Site Recovery Manager (SRM) integrates with vSphere Replication to provide orchestrated failover with configurable recovery point objectives, giving organizations control over acceptable data loss thresholds for protected workloads. PNR supports additional site topologies, including shared recovery site configurations where protected site resources are mapped to isolated datacenters, networks, folders, and datastores on the recovery site. Inventory mappings allow administrators to define resource configurations once and apply them consistently across protection groups.

vSAN Snapshots and Replication is a native, integrated snapshot-based backup capability for virtual machines running on vSAN datastores, managed through the vSphere Client. It provides VM restore and clone operations from existing snapshots, supporting both rapid recovery from operational failures and ransomware recovery scenarios. Test failover operations allow administrators to validate that recovery configurations are functional before an actual recovery event occurs.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) provides several mechanisms that support data protection for managed database instances, covering PostgreSQL, MySQL, and SQL Server databases.

The most direct contribution is DSM's automated backup framework, which administrators can enable on a per-database basis or through data service policies. When configured, DSM performs scheduled full and incremental backups of database content and stores them in S3-compatible object storage at a configurable backup location. Backup retention is configurable (backup-retention-period), and DSM retains backups of deleted databases until the configured retention period expires, supporting recovery from accidental deletion. For point-in-time recovery, DSM restores a backup to a newly created database VM with a user-specified name and datastore location, and can target the most recent timestamp or a specific point in time. DSM archives binary logs in backup storage as part of its backup protection mechanism. Administrators can also initiate manual on-demand backups of primary PostgreSQL databases to safeguard data before high-impact operations or as immediate protection after major changes. For PostgreSQL multi-site deployments, DSM performs a full backup automatically during a promotion event before resuming the regular schedule.

Data service policies give administrators control over backup behavior across all databases governed by a policy. Policies can require that databases have automated backups enabled, allow users to opt in, or disallow automated backups entirely. The allowed-backup-locations setting in the data service policy restricts users to selecting from approved backup locations, reducing the risk of backup misconfiguration. Policies can be enforced across multiple tenants and across different namespaces and namespace labels, supporting consistent data protection posture in multi-tenant deployments. A Compliance tab on data service policies displays compliance reports and allows administrators to expand each policy violation to view the noncompliant database, data service, and namespace, giving administrators visibility into where data protection requirements are not being met. In 9.1, data service policies extend to SQL Server databases in addition to MySQL and PostgreSQL.

DSM implements role-based access control that separates administrative and user-level database access. DSM Admins can create, monitor, and manage all data services in the environment; DSM Users can only manage and monitor the data services they own. This access model limits who can modify backup configurations and policy settings. Infrastructure policies govern which storage resources are available for database VMs, including CPU, memory, storage policies, IP pool, and VM classes, giving administrators control over the storage environment in which data resides.

Control plane recovery requires that a Provider Backup Repo has been configured at installation time. If the Provider VM fails, the restore-provider command restores it to the latest timestamp. In the VCF Automation context, tenants can perform point-in-time restores directly through the VCF Automation UI, broadening restore access to self-service scenarios.

One limitation applies: if an incremental backup in the backup chain is deleted, DSM cannot restore the full data; a successful restore from an incremental chain requires the last full backup and all following incremental backups. Organizations must protect the integrity of the backup chain through access controls on the backup storage.



DSM provides configurable backup, recovery, and policy enforcement mechanisms for managed database instances. The broader data protection program requires organizational decisions about backup schedules, retention periods, backup storage security, and off-site management that DSM does not prescribe on its own.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

## Control PR.DS-01

> The confidentiality, integrity, and availability of data-at-rest are protected [Withdrawn: Incorporated into PR.DS-01, PR.DS-02, PR.DS-10] [Withdrawn: Incorporated into PR.DS-01, DE.CM-09] [Withdrawn: Incorporated into PR.DS-01, PR.PS-01]

**SCF Controls:** CRY-01, CRY-01.1, CRY-05, DCH-01

**Aggregate Coverage:** Meets

### VCF (Meets)

VCF implements cryptographic protections across its component stack using publicly standardized, validated cryptographic modules and algorithms.

Multiple VCF components rely on cryptographic modules validated through the NIST Cryptographic Module Validation Program (CMVP) to FIPS 140-2 and FIPS 140-3 standards. NSX is configured to use FIPS 140-3 validated cryptographic modules by default, and NSX Manager uses FIPS 140 approved algorithms for authentication to its cryptographic module. Specific NSX validated modules include IKE with Rambus Safezone 2.0 (Certificate #4898), VMware OpenSSL 3.0.9 (Certificate #4861), VMware BouncyCastle 2.0.0 (Certificate #4986), and VMware BoringCrypto 6.0 (Certificate #4694). VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which holds FIPS 140-3 Certificate #4743. VCF Operations for Networks uses BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 with FIPS 140-2 Certificate #37009 as its validated cryptographic module. This consistent use of FIPS-validated modules across the platform means that organizations deploying VCF in regulated environments can rely on cryptographic implementations that have undergone independent validation against well-known public standards. The VMware Kubernetes Service (VKS) consumption layer also supports FIPS mode: VKS ClusterClass configurations include a `fips.enabled` variable that, when set, restricts cryptographic operations on cluster nodes to approved algorithm implementations. FIPS-enabled Kubernetes release images, identified by a `-fips` suffix in the release reference name, are available for organizations that require FIPS-validated cryptography across their containerized workloads.

At the protocol and algorithm level, VCF enforces modern cryptographic standards throughout. Starting in vSphere 9.0, all TLS profiles are FIPS compliant; the COMPATIBLE profile supports modern TLS cipher suites with standardized elliptic curves. Monitoring infrastructure such as Telegraf enforces a modern TLS minimum version for secure communication. The NSX L2 VPN FIPS compliance suite uses AES-GCM encryption with Perfect Forward Secrecy and Diffie-Hellman Group 20. NSX also supports ECDSA (Elliptic Curve Digital Signature Algorithm) encryption for environments with high-assurance cryptographic requirements. VCF Operations for Networks supports several encryption algorithms and ciphers for its data sources. VCF Operations provides a FIPS Security Mode that, when enabled, applies additional algorithm and cipher prerequisites across the management domain. All system management network communications are encrypted by default using standardized cipher suites. At the VKS layer, Kubernetes control plane components expose parameters for restricting permitted TLS configurations: the `kube-apiserver --tls-cipher-suites` parameter, the `kubelet tlsCipherSuites` configuration field, and the equivalent parameter on the `kube-scheduler` each restrict the set of permitted cipher suites, allowing administrators to exclude deprecated or weak algorithms. The `kubelet tlsMinVersion` field and the `--tls-min-version` parameter on the `kube-apiserver` enforce a minimum TLS protocol version floor for inbound connections. The Antrea networking component and vSphere Cloud Provider Interface on VKS clusters also support configurable TLS cipher suites for component-to-component communication. Kubernetes hardening guidance identifies specific preferred cipher suites and calls out cipher suite configuration on the `kube-scheduler` as a required hardening step. VKS clusters support the Istio service mesh package, which provides mutual TLS between workloads within the mesh; the `meshMTLS.minProtocolVersion` setting controls the minimum protocol version for inter-service communication, defaulting to TLS 1.2 with support for configuring TLS 1.3.

Data-in-transit protections using TLS have customizable PKI keypair and certificate options. These range from fully automated within VCF to semi-automated using certificates from enterprise PKI infrastructure or fully custom certificates installed manually. Automated certificate issuance is supported with Microsoft Active Directory Certificate Services. Trust establishment uses standard PKI management with multiple certificate options including Root CA certificates, CSR-based certificates, and direct certificate uploads. VCF Operations provides centralized certificate lifecycle management for all VCF components, enabling automated certificate renewal, monitoring, and replacement across the infrastructure. Organizations should be aware

that if self-signed certificates and private keys are generated using OpenSSL, those certificates and private keys are not FIPS-compatible. Environments operating under FIPS requirements should use certificate authorities and key generation methods that produce FIPS-compliant artifacts. For FIPS environments, certificates should use key sizes of 2048 or 3072 bits; key sizes greater than 3072 bits have not been tested with FIPS. At the VKS layer, the cert-manager package manages the lifecycle of certificates issued to workloads and ingress endpoints. VKS clusters maintain TLS certificates for component-to-component communication across their control and data planes. The Contour ingress package supports minimum TLS version configuration through the `tls.minimum-protocol-version` parameter. Harbor, when deployed as a Supervisor Service, accepts custom TLS certificate configuration through the `tlsCertificate.tls.crt` and `tlsCertificate.tls.key` fields, allowing organizations to supply certificates from their enterprise certificate authority rather than relying on self-signed certificates. The Supervisor secret injection agent automatically configures mutual TLS for communication with the vault-agent-injector service using auto-generated certificates.

Data-at-rest encryption uses vSAN cluster-based encryption or VM Encryption on non-vSAN storage. vSAN encryption uses AES-NI CPU offloading for efficient processing, and VMware ESX hosts encrypt vSAN disk data using the industry standard AES-256 XTS mode. Encryption keys are managed through KMIP 1.1-compatible external Key Management Servers (KMS) or vSphere Native Key Provider (NKP), which is included in all vSphere editions and does not require an external key server. VCF implements a three-element domain of trust comprising the key provider, VMware vCenter, and vSAN hosts. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK) for secure key management; ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

VCF Standard Key Providers have key wrapping capabilities that let organizations store a single wrapping key in their KMS, protecting multiple Key Encryption Keys within the VCF environment. This creates a three-tier key hierarchy: the Data Encryption Key encrypts object data, the Key Encryption Key protects the DEK, and the wrapping key protects the KEK. This approach reduces the number of keys stored in external KMS systems while maintaining cryptographic separation. Key wrapping includes automatic key rotation with configurable intervals from 30 days to 10 years.

With key persistence enabled, ESX hosts can persist encryption keys in the Trusted Platform Module (TPM) across reboots, allowing encryption operations to continue when the key server is unavailable. Each ESX host obtains the encryption keys initially and retains them in its key cache; if the ESX host has a TPM, the encryption keys are persisted in the TPM across reboots. Key persistence can be enabled using the `esxcli system security keypersistence enable` command.

VCF supports guest-level security features including virtual Trusted Platform Module (vTPM) 2.0 for VMs. This enables in-guest encryption capabilities such as Windows BitLocker, Linux disk encryption, and other operating system-native security features. Secure Boot provides UEFI verification to help ensure only signed and trusted code runs during the VM boot process. These features work independently of or in combination with infrastructure-level encryption, allowing organizations to implement defense-in-depth strategies.

vSAN offers Data-in-Transit (DIT) encryption as a cluster-wide setting that encrypts all data and metadata traffic as it transits across hosts. For vSAN Original Storage Architecture (OSA), data-at-rest encryption occurs at the Local Object Manager (LSOM) layer on the target host, making DIT encryption strongly recommended to restrict network-level interception. For vSAN Express Storage Architecture (ESA) in HCI mode, data is encrypted at the VM host before network transmission, making DIT encryption optional based on compliance requirements and risk tolerance. DIT encryption operates without requiring external key management servers and provides independent key rotation from data-at-rest encryption.

Encrypted vSphere vMotion secures confidentiality, integrity, and authenticity of data transferred during VM migrations. For encrypted VMs, vMotion always uses encryption. For unencrypted VMs, encrypted vMotion can be set to Disabled, Opportunistic (default), or Required. Cross-vCenter vMotion is supported when using shared key providers or backup/import of Native Key Provider. VCF uses one-time keys (nonces) for each migration session so that captured traffic cannot be replayed or decrypted after migration completes.

Memory Tiering encryption provides protection for tiered memory without requiring external key management. VCF generates random 256-bit AES-XTS keys at the kernel level during VM power-on, unique to each VM instance or per host depending on configuration.

VM Encryption provides protection across all datastore types including vSAN, iSCSI, NFS, and Fibre Channel. Disk encryption uses XTS-AES-256 keys as the disk encryption key. This encryption occurs before data reaches the storage layer, providing both data-at-rest and data-in-transit protection.

Kubernetes on VKS supports encryption at rest for data stored within the control plane. Operators configure the encryption provider and manage key access for control plane secrets; when relying on a managed key provider, administrators retain responsibility for access controls over the managed key material. The VCF Automation consumption layer includes VCF Encryption Management, which grants organization administrators the ability to use encryption keys from their own key providers for encryption of virtual machines and disks in their VCF environment, extending the platform's cryptographic key management to tenant-level operations.

For storage protocols, VCF provides varying levels of native encryption support. iSCSI includes CHAP for session authentication. Fibre Channel Gen 7 supports end-to-end encryption with secure HBAs. For NFS datastores, version 4.1 supports Kerberos authentication with three security levels: krb5 (authentication only), krb5i (authentication plus integrity checking), and krb5p (authentication plus privacy with full encryption).

ESX stores configuration data in encrypted form on boot devices. When the host has a TPM 2.0 enabled and configured, the configuration encryption key is stored in the TPM. The encryption mode can be configured using the `esxcli system settings encryption set` command with the `--mode=TPM` parameter.

Cryptographic operations are controlled through fine-grained privileges in vCenter. Only users assigned the Cryptographic Operations privileges can perform cryptographic operations. A dedicated No Cryptography Administrator role enables standard VM and infrastructure management while restricting unauthorized encryption changes. This role can be cloned and customized to grant only specific Cryptographic Operations privileges, such as allowing encryption but not decryption, supporting the principle of least privilege for encryption tasks. The `CryptoManager` and `CryptoManagerKmp` managed objects provide programmatic interfaces for handling cryptographic keys and integrating with key management server infrastructure. vSAN encryption key management requires specific permissions including `Cryptographer.ManageEncryptionPolicy`, `Cryptographer.ManageKeyServers`, and `Cryptographer.ManageKeys`.

vSAN includes secure disk wipe capabilities for proper media sanitization when decommissioning storage, supporting the Erase disks before use option during encryption configuration and disk management operations.

Defining the organization's cryptographic policy (algorithm selection, key strength, rotation schedules, KMS architecture, FIPS-mode activation decisions) and the key lifecycle management standards that govern key creation, distribution, storage, archive, and destruction sit with the organization above the platform. VCF supplies the validated cryptographic modules and protocol enforcement; the organizational cryptographic governance program determines how those mechanisms apply across the environment. Security Technical Implementation Guides (STIGs) for Supervisor and VKS releases are available to guide cryptographic hardening of the consumption layer.

VMware Private AI Services (PAIS) provides cryptographic controls across its AI infrastructure components, building on the cryptographic foundation of VCF.

GPU-accelerated VMware Kubernetes Service (VKS) clusters deployed for PAIS workloads use a FIPS-enabled Kubernetes runtime. The VKS cluster topology version applied to both control plane and worker deployments uses a FIPS-enabled VKR build running on Ubuntu 24.04, so AI workloads on PAIS VKS clusters operate within a FIPS-compliant Kubernetes runtime.

PAIS endpoints use TLS for service communication. The `PAISConfiguration` custom resource supports configurable CA bundle references through `spec.clientTls.caBundleRefs` for OIDC provider and Harbor registry authentication. The Supervisor endpoint communication for PAIS uses HTTPS on port 6443 with certificate-based authentication. The PAIS Prometheus metrics endpoint uses self-signed certificate authentication with TLS, where the CA certificate is retrieved from the `pais-ingress-default Secret` in the PAIS namespace and configured in base64-decoded form. Prometheus TLS client authentication and certificate validation are off by default; auditors should verify that client authentication is enabled in production deployments where mutual certificate validation is required.

PAIS requires CA trust bundles to be configured for all external HTTPS connections, including OIDC providers, Harbor registries, content management systems used as data sources in the Data Indexing and Retrieval service (such as Confluence or SharePoint), MCP servers that provide tools to agents, and the pgvector database server used for vector storage. Trust bundle material is obtained from each external system's administrator either as a certificate file or as a ConfigMap stored in the namespace where PAIS is deployed, and PAIS recommends maintaining separate trust bundles per application with periodic updates before certificate expiration. Administrators add trusted certificates through the VCF Automation Provider Management UI under Certificate Management and Trusted Certificates. The issuer certificate of the Harbor registry must also be added to the certificate trust store on Deep Learning VMs that pull models from the registry. When connecting to an MCP server over HTTPS, the MCP server issuer certificate must be added as a CA trust bundle.

The underlying cryptographic algorithms, cipher suites, and platform-level key management are provided by VCF and VKS. Organizations are responsible for selecting and enforcing approved cryptographic standards at the VCF and infrastructure level, while PAIS provides the certificate management and trust chain configuration mechanisms specific to AI service endpoints.

### **VMware vDefend (Contributes)**

VMware vDefend contributes to the implementation of cryptographic protection controls by using known public standards and trusted cryptographic technologies across its component stack for securing inter-component communications and providing cryptographic inspection capabilities for network traffic.

Security Services Platform (SSP), the control-plane component of vDefend, secures communications between vDefend product components using certificates and current TLS protocol versions with approved cipher suites. SSP and the SSP Installer deploy with the most current TLS version by default and also support the prior major TLS version. The TLS versions and cipher suites allowed on SSP Installer and SSP are fixed and cannot be modified, which enforces a consistent cryptographic baseline across deployments.

SSP components, including the SSP Installer and the NDR Sensor for vDefend, implement FIPS 140-2 and FIPS 140-3 cryptographic module standards. SSP uses the VMware BouncyCastle Module (NIST CMVP Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (NIST CMVP Certificate #4861) for its cryptographic operations. SSP actively enforces cryptographic hygiene by rejecting any certificate or TLS configuration that uses deprecated algorithms, short keys, or legacy protocol versions, returning a validation error rather than permitting degraded connections.

Certificate management within SSP provides lifecycle controls including certificate export, certificate signing request (CSR) generation, and CA-signed certificate replacement. SSP monitors and manages several certificate types used to identify client and host machines, establish trust between components, secure communications, and control access levels. Administrators can retrieve and validate LDAP certificates using standard tools to establish secure LDAPS connections for platform authentication. These capabilities allow organizations to integrate vDefend into their broader PKI infrastructure and follow standard certificate lifecycle practices.

vDefend provides TLS Inspection capabilities that allow the firewall to decrypt, inspect, and re-encrypt TLS-protected traffic. Without TLS Inspection, encrypted traffic cannot be examined or enforced against security policies even when other advanced security features are enabled. With TLS Inspection enabled, vDefend gains visibility into encrypted traffic flows, supporting more effective access control and threat detection. TLS Inspection also supports importing or generating trusted and untrusted proxy certificate authorities for external decryption profiles, giving administrators control over the CA chain used in inspection.

TLS Inspection includes a Crypto Enforcement option within decryption action profiles that allows administrators to set minimum and maximum protocol version and cipher suite constraints for both client and server connections. Profiles can be configured in Transparent or Enforce modes; the Enforce mode requires compliance with the configured cryptographic constraints.

vDefend IDS/IPS signature rules extend cryptographic visibility by supporting protocol version matching and certificate Subject field matching, enabling enforcement decisions based on certificate metadata in encrypted traffic. IDS/IPS rules also support storing TLS/SSL certificates to disk for forensic analysis and threat investigation. SSP guidance recommends that



organizations restrict or block protocols that carry data in cleartext and enforce minimum secure protocol versions as part of their network security practices.

vDefend does not itself provide the underlying key management infrastructure (KMS), platform-wide PKI lifecycle management, or the broader VCF platform's cryptographic controls; those responsibilities belong to VCF. However, vDefend's consistent use of approved cryptographic standards for its own operations and its ability to perform cryptographic inspection of network traffic contribute to an organization's overall implementation of cryptographic protection controls.

### **VCF Protection and Recovery (Meets)**

VCF Protection and Recovery (PNR) implements cryptographic protections for disaster recovery workflows using known public standards and trusted cryptographic technologies.

PNR uses modern TLS by default for all connections to the PNR server. The minimum TLS protocol version is configurable through the `envoy-proxy-config.json` file by editing the `tls_minimum_protocol_version` parameter. When the minimum protocol version is modified, PNR requires that the change be applied consistently across all relevant configuration occurrences in the system. Administrators can verify the TLS version in use on the Site Recovery Manager component using standard OpenSSL tooling.

The PNR Appliance requires an SSL/TLS certificate as the endpoint certificate for all TLS connections to the PNR server. PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. Custom SSL/TLS server endpoint certificates must meet specific requirements, including x509v3 Extended Key Usage indicating TLS Web Server Authentication. The Appliance Management Interface allows administrators to import CA-signed server certificates and custom root CA certificates, and to replace the appliance certificate. PNR uses TLS certificates and private keys to protect network communication and establish authentication with other servers. Certificate verification error messages are logged in security-related log files, and operational log files do not contain sensitive information such as private keys or passwords.

For encrypted virtual machine replication, PNR requires that the recovery and protected sites use a common Key Management Server (KMS) or that the KMS clusters at both sites share common encryption keys. Replication of encrypted virtual machines also requires Secure LWD support to be available on the virtual machine. This supports data-at-rest encryption continuity for virtual machines through the recovery lifecycle.

Defining the organization's cryptographic policy, including KMS architecture decisions, minimum TLS version selection, certificate management standards, and key lifecycle practices, sits with the organization above the DR layer. PNR supplies the cryptographic mechanisms needed for DR-specific traffic and operations; the organizational cryptographic governance program determines how those mechanisms apply across the environment.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) implements cryptographic protections across multiple layers of its architecture, applying standard cryptographic technologies for data in transit, certificate trust management, and credential storage.

Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms or parameters. Only RSA and ECDSA public key algorithms are accepted for certificates. The Ed25519 elliptic curve signature algorithm is rejected because it does not comply with FIPS 140-3. Custom trusted certificates should use ECDSA P-256 or P-384 algorithms; RSA certificates must meet a minimum key size of 2048 bits per FIPS requirements. DSM's latest certificate validation mode enforces strict cryptographic and KeyUsage validations across all DSM endpoints, including the Provider VM and data service clusters.

For connections to database clusters, DSM requires TLS for all client traffic. PostgreSQL database instances enforce a minimum TLS protocol version through the `ssl_min_protocol_version` setting. MySQL enforces minimum TLS versions on both the main connection interface and the administrative interface; these settings are fixed and cannot be modified by users, which helps maintain a consistent cryptographic baseline across deployments. MySQL also exposes the `group_replication_recovery_tls_version` setting to specify the TLS protocol used during distributed recovery connections. DSM supports SQL Server clusters, which use TLS to encrypt communication between clients and the cluster; the `network.tlsProtocols` custom engine setting defines the allowed TLS versions for client connections, and a minimum TLS

version must be included for the DSM operator to manage the cluster. DSM supports TLS verification during PostgreSQL database migration, covering replication traffic between source and target clusters.

DSM's certificate management capabilities support standard PKI practices. Administrators configure custom TLS certificates for database clusters through the DSM UI or API, providing certificates in PEM format with associated private keys and CA certificates. Supported private key algorithms are RSA and ECDSA with key sizes of 256 and 384 bits. When present, the X509v3 KeyUsage extension on a custom certificate must include the DigitalSignature capability; DSM also accepts certificates that omit the KeyUsage extension entirely, treating absent KeyUsage as permitting all usages in accordance with RFC 5280. To establish secure connections to database clusters and to the DSM Provider VM, clients add the CA to the operating system trust store or the trusted CA list. DSM's API provides a mechanism to retrieve the CA certificate from a custom certificate secret. The Consumption Operator, which enables self-service database provisioning, requires a TLS certificate for its communication with the DSM provider. Certificate management can also be handled through Kubernetes cert-manager, which manages various issuer types and outputs Kubernetes TLS Secrets in the format DSM requires.

DSM supports TLS for connections to external systems. When configuring log forwarding to an SMTP server, DSM supports Auto TLS to establish a secure connection. For private container registries, DSM supports CA certificate validation for untrusted registries.

For local user credential storage, DSM encrypts passwords using PGP symmetric encryption through the PGCrypto library, with dedicated encryption keys stored using the PGCRYPTO\_PASSWORD and PGCRYPTO\_ALGORITHM keys. MySQL has FIPS mode available on the client side through the `ssl_fips_mode` setting. PostgreSQL databases include the `pgcrypto` extension, which provides cryptographic functions that applications can use directly within the database. The DSM Provider Appliance includes virtual machine encryption, which activates when a Key Management Server is configured in the environment.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer provides configurable SSL/TLS profiles that control which cipher suites, protocol versions, and key exchange algorithms are permitted for application traffic termination. The SSL/TLS Profile, configured under Templates > Security > SSL/TLS Profile, contains the accepted protocol version list and a prioritized cipher suite list applied to virtual services. Administrators can create custom profiles or select from built-in templates; the documentation notes that the choice of accepted ciphers and protocol versions involves trade-offs between security, client compatibility, and computational expense. SSL profiles in 9.1 include a Post Quantum Cryptography section with support for modern cipher suites. Controller SSL/TLS certificates support elliptic curve (EC) or RSA algorithms, with EC recommended for new deployments.

For environments subject to cryptographic module validation requirements, Avi supports a FIPS mode backed by the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by the Cryptographic Module Validation Program (CMVP). When FIPS mode is activated on the Controller cluster, Avi restricts cryptographic operations to FIPS-compliant algorithms only. FIPS 140-3 also requires stricter handling of sensitive security parameters including keys, authentication data, and random number generation. FIPS mode is enabled at the Controller cluster level through the Controller settings. Note that FIPS mode does not support SSL Client Hello events in Avi DataScript, which may affect certain scripted traffic inspection use cases.

Avi Controller allows administrators to restrict specific key exchange algorithms and ciphers for management session access. The Allowed Ciphers field restricts management session ciphers to a specified subset, and the `kex_algorithm_exclude` field under Controller Settings excludes specific key exchange methods for SSH-based administrative access. Internal communications between the Avi Controller and Service Engines also use SSL/TLS, and custom certificates can be selected for this Secure Channel connection via the Access tab certificate field.

For certificate management, Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. The Controller is set up as an HSM client and can create keys and certificates directly on the HSM through client libraries, supporting high-availability HSM configurations. Automated certificate lifecycle management is available through Let's Encrypt integration using the ACME protocol. Avi's App Transport

Security feature supports integration with the Venafi Trust Protection Platform for certificate administration across tenants, with the Trust Protection Platform pushing signed certificates and required chain certificates to Avi Load Balancer.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports PKIProfile-based certificate validation and trust management for backend services. The PKIProfile, configured through custom resources, enables secure communication with backend services through certificate-based authentication and encryption. In VCF environments, the Avi PKI Profile defines the list of trusted certificate authorities permitted to sign client certificates and can be used to implement Zero Trust security between servers and clients.

Data-at-rest encryption for Avi Controller and Service Engine VMs is provided by VCF at the platform layer, not by Avi itself. Organizations must configure Avi SSL/TLS profiles, select appropriate cipher suites, and enable FIPS mode where cryptographic module validation requirements apply to activate these controls.



## Control PR.DS-02

> The confidentiality, integrity, and availability of data-in-transit are protected [Withdrawn: Incorporated into PR.DS-01, PR.DS-02, PR.DS-10]

**SCF Controls:** CRY-01, CRY-03, CRY-04, DCH-01

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF implements cryptographic protections across its component stack using publicly standardized, validated cryptographic modules and algorithms.

Multiple VCF components rely on cryptographic modules validated through the NIST Cryptographic Module Validation Program (CMVP) to FIPS 140-2 and FIPS 140-3 standards. NSX is configured to use FIPS 140-3 validated cryptographic modules by default, and NSX Manager uses FIPS 140 approved algorithms for authentication to its cryptographic module. Specific NSX validated modules include IKE with Rambus Safezone 2.0 (Certificate #4898), VMware OpenSSL 3.0.9 (Certificate #4861), VMware BouncyCastle 2.0.0 (Certificate #4986), and VMware BoringCrypto 6.0 (Certificate #4694). VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which holds FIPS 140-3 Certificate #4743. VCF Operations for Networks uses BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 with FIPS 140-2 Certificate #37009 as its validated cryptographic module. This consistent use of FIPS-validated modules across the platform means that organizations deploying VCF in regulated environments can rely on cryptographic implementations that have undergone independent validation against well-known public standards. The VMware Kubernetes Service (VKS) consumption layer also supports FIPS mode: VKS ClusterClass configurations include a `fips.enabled` variable that, when set, restricts cryptographic operations on cluster nodes to approved algorithm implementations. FIPS-enabled Kubernetes release images, identified by a `-fips` suffix in the release reference name, are available for organizations that require FIPS-validated cryptography across their containerized workloads.

At the protocol and algorithm level, VCF enforces modern cryptographic standards throughout. Starting in vSphere 9.0, all TLS profiles are FIPS compliant; the COMPATIBLE profile supports modern TLS cipher suites with standardized elliptic curves. Monitoring infrastructure such as Telegraf enforces a modern TLS minimum version for secure communication. The NSX L2 VPN FIPS compliance suite uses AES-GCM encryption with Perfect Forward Secrecy and Diffie-Hellman Group 20. NSX also supports ECDSA (Elliptic Curve Digital Signature Algorithm) encryption for environments with high-assurance cryptographic requirements. VCF Operations for Networks supports several encryption algorithms and ciphers for its data sources. VCF Operations provides a FIPS Security Mode that, when enabled, applies additional algorithm and cipher prerequisites across the management domain. All system management network communications are encrypted by default using standardized cipher suites. At the VKS layer, Kubernetes control plane components expose parameters for restricting permitted TLS configurations: the `kube-apiserver --tls-cipher-suites` parameter, the `kubelet tlsCipherSuites` configuration field, and the equivalent parameter on the `kube-scheduler` each restrict the set of permitted cipher suites, allowing administrators to exclude deprecated or weak algorithms. The `kubelet tlsMinVersion` field and the `--tls-min-version` parameter on the `kube-apiserver` enforce a minimum TLS protocol version floor for inbound connections. The Antrea networking component and vSphere Cloud Provider Interface on VKS clusters also support configurable TLS cipher suites for component-to-component communication. Kubernetes hardening guidance identifies specific preferred cipher suites and calls out cipher suite configuration on the `kube-scheduler` as a required hardening step. VKS clusters support the Istio service mesh package, which provides mutual TLS between workloads within the mesh; the `meshMTLS.minProtocolVersion` setting controls the minimum protocol version for inter-service communication, defaulting to TLS 1.2 with support for configuring TLS 1.3.

Data-in-transit protections using TLS have customizable PKI keypair and certificate options. These range from fully automated within VCF to semi-automated using certificates from enterprise PKI infrastructure or fully custom certificates installed manually. Automated certificate issuance is supported with Microsoft Active Directory Certificate Services. Trust establishment uses standard PKI management with multiple certificate options including Root CA certificates, CSR-based certificates, and direct certificate uploads. VCF Operations provides centralized certificate lifecycle management for all VCF components, enabling automated certificate renewal, monitoring, and replacement across the infrastructure. Organizations should be aware

that if self-signed certificates and private keys are generated using OpenSSL, those certificates and private keys are not FIPS-compatible. Environments operating under FIPS requirements should use certificate authorities and key generation methods that produce FIPS-compliant artifacts. For FIPS environments, certificates should use key sizes of 2048 or 3072 bits; key sizes greater than 3072 bits have not been tested with FIPS. At the VKS layer, the cert-manager package manages the lifecycle of certificates issued to workloads and ingress endpoints. VKS clusters maintain TLS certificates for component-to-component communication across their control and data planes. The Contour ingress package supports minimum TLS version configuration through the `tls.minimum-protocol-version` parameter. Harbor, when deployed as a Supervisor Service, accepts custom TLS certificate configuration through the `tlsCertificate.tls.crt` and `tlsCertificate.tls.key` fields, allowing organizations to supply certificates from their enterprise certificate authority rather than relying on self-signed certificates. The Supervisor secret injection agent automatically configures mutual TLS for communication with the vault-agent-injector service using auto-generated certificates.

Data-at-rest encryption uses vSAN cluster-based encryption or VM Encryption on non-vSAN storage. vSAN encryption uses AES-NI CPU offloading for efficient processing, and VMware ESX hosts encrypt vSAN disk data using the industry standard AES-256 XTS mode. Encryption keys are managed through KMIP 1.1-compatible external Key Management Servers (KMS) or vSphere Native Key Provider (NKP), which is included in all vSphere editions and does not require an external key server. VCF implements a three-element domain of trust comprising the key provider, VMware vCenter, and vSAN hosts. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK) for secure key management; ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

VCF Standard Key Providers have key wrapping capabilities that let organizations store a single wrapping key in their KMS, protecting multiple Key Encryption Keys within the VCF environment. This creates a three-tier key hierarchy: the Data Encryption Key encrypts object data, the Key Encryption Key protects the DEK, and the wrapping key protects the KEK. This approach reduces the number of keys stored in external KMS systems while maintaining cryptographic separation. Key wrapping includes automatic key rotation with configurable intervals from 30 days to 10 years.

With key persistence enabled, ESX hosts can persist encryption keys in the Trusted Platform Module (TPM) across reboots, allowing encryption operations to continue when the key server is unavailable. Each ESX host obtains the encryption keys initially and retains them in its key cache; if the ESX host has a TPM, the encryption keys are persisted in the TPM across reboots. Key persistence can be enabled using the `esxcli system security keypersistence enable` command.

VCF supports guest-level security features including virtual Trusted Platform Module (vTPM) 2.0 for VMs. This enables in-guest encryption capabilities such as Windows BitLocker, Linux disk encryption, and other operating system-native security features. Secure Boot provides UEFI verification to help ensure only signed and trusted code runs during the VM boot process. These features work independently of or in combination with infrastructure-level encryption, allowing organizations to implement defense-in-depth strategies.

vSAN offers Data-in-Transit (DIT) encryption as a cluster-wide setting that encrypts all data and metadata traffic as it transits across hosts. For vSAN Original Storage Architecture (OSA), data-at-rest encryption occurs at the Local Object Manager (LSOM) layer on the target host, making DIT encryption strongly recommended to restrict network-level interception. For vSAN Express Storage Architecture (ESA) in HCI mode, data is encrypted at the VM host before network transmission, making DIT encryption optional based on compliance requirements and risk tolerance. DIT encryption operates without requiring external key management servers and provides independent key rotation from data-at-rest encryption.

Encrypted vSphere vMotion secures confidentiality, integrity, and authenticity of data transferred during VM migrations. For encrypted VMs, vMotion always uses encryption. For unencrypted VMs, encrypted vMotion can be set to Disabled, Opportunistic (default), or Required. Cross-vCenter vMotion is supported when using shared key providers or backup/import of Native Key Provider. VCF uses one-time keys (nonces) for each migration session so that captured traffic cannot be replayed or decrypted after migration completes.

Memory Tiering encryption provides protection for tiered memory without requiring external key management. VCF generates random 256-bit AES-XTS keys at the kernel level during VM power-on, unique to each VM instance or per host depending on configuration.

VM Encryption provides protection across all datastore types including vSAN, iSCSI, NFS, and Fibre Channel. Disk encryption uses XTS-AES-256 keys as the disk encryption key. This encryption occurs before data reaches the storage layer, providing both data-at-rest and data-in-transit protection.

Kubernetes on VKS supports encryption at rest for data stored within the control plane. Operators configure the encryption provider and manage key access for control plane secrets; when relying on a managed key provider, administrators retain responsibility for access controls over the managed key material. The VCF Automation consumption layer includes VCF Encryption Management, which grants organization administrators the ability to use encryption keys from their own key providers for encryption of virtual machines and disks in their VCF environment, extending the platform's cryptographic key management to tenant-level operations.

For storage protocols, VCF provides varying levels of native encryption support. iSCSI includes CHAP for session authentication. Fibre Channel Gen 7 supports end-to-end encryption with secure HBAs. For NFS datastores, version 4.1 supports Kerberos authentication with three security levels: krb5 (authentication only), krb5i (authentication plus integrity checking), and krb5p (authentication plus privacy with full encryption).

ESX stores configuration data in encrypted form on boot devices. When the host has a TPM 2.0 enabled and configured, the configuration encryption key is stored in the TPM. The encryption mode can be configured using the `esxcli system settings encryption set` command with the `--mode=TPM` parameter.

Cryptographic operations are controlled through fine-grained privileges in vCenter. Only users assigned the Cryptographic Operations privileges can perform cryptographic operations. A dedicated No Cryptography Administrator role enables standard VM and infrastructure management while restricting unauthorized encryption changes. This role can be cloned and customized to grant only specific Cryptographic Operations privileges, such as allowing encryption but not decryption, supporting the principle of least privilege for encryption tasks. The `CryptoManager` and `CryptoManagerKmp` managed objects provide programmatic interfaces for handling cryptographic keys and integrating with key management server infrastructure. vSAN encryption key management requires specific permissions including `Cryptographer.ManageEncryptionPolicy`, `Cryptographer.ManageKeyServers`, and `Cryptographer.ManageKeys`.

vSAN includes secure disk wipe capabilities for proper media sanitization when decommissioning storage, supporting the Erase disks before use option during encryption configuration and disk management operations.

Defining the organization's cryptographic policy (algorithm selection, key strength, rotation schedules, KMS architecture, FIPS-mode activation decisions) and the key lifecycle management standards that govern key creation, distribution, storage, archive, and destruction sit with the organization above the platform. VCF supplies the validated cryptographic modules and protocol enforcement; the organizational cryptographic governance program determines how those mechanisms apply across the environment. Security Technical Implementation Guides (STIGs) for Supervisor and VKS releases are available to guide cryptographic hardening of the consumption layer.

VMware Private AI Services (PAIS) provides cryptographic controls across its AI infrastructure components, building on the cryptographic foundation of VCF.

GPU-accelerated VMware Kubernetes Service (VKS) clusters deployed for PAIS workloads use a FIPS-enabled Kubernetes runtime. The VKS cluster topology version applied to both control plane and worker deployments uses a FIPS-enabled VKR build running on Ubuntu 24.04, so AI workloads on PAIS VKS clusters operate within a FIPS-compliant Kubernetes runtime.

PAIS endpoints use TLS for service communication. The `PAISConfiguration` custom resource supports configurable CA bundle references through `spec.clientTls.caBundleRefs` for OIDC provider and Harbor registry authentication. The Supervisor endpoint communication for PAIS uses HTTPS on port 6443 with certificate-based authentication. The PAIS Prometheus metrics endpoint uses self-signed certificate authentication with TLS, where the CA certificate is retrieved from the `pais-ingress-default Secret` in the PAIS namespace and configured in base64-decoded form. Prometheus TLS client authentication and certificate validation are off by default; auditors should verify that client authentication is enabled in production deployments where mutual certificate validation is required.

PAIS requires CA trust bundles to be configured for all external HTTPS connections, including OIDC providers, Harbor registries, content management systems used as data sources in the Data Indexing and Retrieval service (such as Confluence or SharePoint), MCP servers that provide tools to agents, and the pgvector database server used for vector storage. Trust bundle material is obtained from each external system's administrator either as a certificate file or as a ConfigMap stored in the namespace where PAIS is deployed, and PAIS recommends maintaining separate trust bundles per application with periodic updates before certificate expiration. Administrators add trusted certificates through the VCF Automation Provider Management UI under Certificate Management and Trusted Certificates. The issuer certificate of the Harbor registry must also be added to the certificate trust store on Deep Learning VMs that pull models from the registry. When connecting to an MCP server over HTTPS, the MCP server issuer certificate must be added as a CA trust bundle.

The underlying cryptographic algorithms, cipher suites, and platform-level key management are provided by VCF and VKS. Organizations are responsible for selecting and enforcing approved cryptographic standards at the VCF and infrastructure level, while PAIS provides the certificate management and trust chain configuration mechanisms specific to AI service endpoints.

### **VMware vDefend (Contributes)**

VMware vDefend contributes to the implementation of cryptographic protection controls by using known public standards and trusted cryptographic technologies across its component stack for securing inter-component communications and providing cryptographic inspection capabilities for network traffic.

Security Services Platform (SSP), the control-plane component of vDefend, secures communications between vDefend product components using certificates and current TLS protocol versions with approved cipher suites. SSP and the SSP Installer deploy with the most current TLS version by default and also support the prior major TLS version. The TLS versions and cipher suites allowed on SSP Installer and SSP are fixed and cannot be modified, which enforces a consistent cryptographic baseline across deployments.

SSP components, including the SSP Installer and the NDR Sensor for vDefend, implement FIPS 140-2 and FIPS 140-3 cryptographic module standards. SSP uses the VMware BouncyCastle Module (NIST CMVP Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (NIST CMVP Certificate #4861) for its cryptographic operations. SSP actively enforces cryptographic hygiene by rejecting any certificate or TLS configuration that uses deprecated algorithms, short keys, or legacy protocol versions, returning a validation error rather than permitting degraded connections.

Certificate management within SSP provides lifecycle controls including certificate export, certificate signing request (CSR) generation, and CA-signed certificate replacement. SSP monitors and manages several certificate types used to identify client and host machines, establish trust between components, secure communications, and control access levels. Administrators can retrieve and validate LDAP certificates using standard tools to establish secure LDAPS connections for platform authentication. These capabilities allow organizations to integrate vDefend into their broader PKI infrastructure and follow standard certificate lifecycle practices.

vDefend provides TLS Inspection capabilities that allow the firewall to decrypt, inspect, and re-encrypt TLS-protected traffic. Without TLS Inspection, encrypted traffic cannot be examined or enforced against security policies even when other advanced security features are enabled. With TLS Inspection enabled, vDefend gains visibility into encrypted traffic flows, supporting more effective access control and threat detection. TLS Inspection also supports importing or generating trusted and untrusted proxy certificate authorities for external decryption profiles, giving administrators control over the CA chain used in inspection.

TLS Inspection includes a Crypto Enforcement option within decryption action profiles that allows administrators to set minimum and maximum protocol version and cipher suite constraints for both client and server connections. Profiles can be configured in Transparent or Enforce modes; the Enforce mode requires compliance with the configured cryptographic constraints.

vDefend IDS/IPS signature rules extend cryptographic visibility by supporting protocol version matching and certificate Subject field matching, enabling enforcement decisions based on certificate metadata in encrypted traffic. IDS/IPS rules also support storing TLS/SSL certificates to disk for forensic analysis and threat investigation. SSP guidance recommends that

organizations restrict or block protocols that carry data in cleartext and enforce minimum secure protocol versions as part of their network security practices.

vDefend does not itself provide the underlying key management infrastructure (KMS), platform-wide PKI lifecycle management, or the broader VCF platform's cryptographic controls; those responsibilities belong to VCF. However, vDefend's consistent use of approved cryptographic standards for its own operations and its ability to perform cryptographic inspection of network traffic contribute to an organization's overall implementation of cryptographic protection controls.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) implements cryptographic protections for disaster recovery workflows using known public standards and trusted cryptographic technologies.

PNR uses modern TLS by default for all connections to the PNR server. The minimum TLS protocol version is configurable through the `envoy-proxy-config.json` file by editing the `tls_minimum_protocol_version` parameter. When the minimum protocol version is modified, PNR requires that the change be applied consistently across all relevant configuration occurrences in the system. Administrators can verify the TLS version in use on the Site Recovery Manager component using standard OpenSSL tooling.

The PNR Appliance requires an SSL/TLS certificate as the endpoint certificate for all TLS connections to the PNR server. PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. Custom SSL/TLS server endpoint certificates must meet specific requirements, including x509v3 Extended Key Usage indicating TLS Web Server Authentication. The Appliance Management Interface allows administrators to import CA-signed server certificates and custom root CA certificates, and to replace the appliance certificate. PNR uses TLS certificates and private keys to protect network communication and establish authentication with other servers. Certificate verification error messages are logged in security-related log files, and operational log files do not contain sensitive information such as private keys or passwords.

For encrypted virtual machine replication, PNR requires that the recovery and protected sites use a common Key Management Server (KMS) or that the KMS clusters at both sites share common encryption keys. Replication of encrypted virtual machines also requires Secure LWD support to be available on the virtual machine. This supports data-at-rest encryption continuity for virtual machines through the recovery lifecycle.

Defining the organization's cryptographic policy, including KMS architecture decisions, minimum TLS version selection, certificate management standards, and key lifecycle practices, sits with the organization above the DR layer. PNR supplies the cryptographic mechanisms needed for DR-specific traffic and operations; the organizational cryptographic governance program determines how those mechanisms apply across the environment.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) implements cryptographic protections across multiple layers of its architecture, applying standard cryptographic technologies for data in transit, certificate trust management, and credential storage.

Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms or parameters. Only RSA and ECDSA public key algorithms are accepted for certificates. The Ed25519 elliptic curve signature algorithm is rejected because it does not comply with FIPS 140-3. Custom trusted certificates should use ECDSA P-256 or P-384 algorithms; RSA certificates must meet a minimum key size of 2048 bits per FIPS requirements. DSM's latest certificate validation mode enforces strict cryptographic and KeyUsage validations across all DSM endpoints, including the Provider VM and data service clusters.

For connections to database clusters, DSM requires TLS for all client traffic. PostgreSQL database instances enforce a minimum TLS protocol version through the `ssl_min_protocol_version` setting. MySQL enforces minimum TLS versions on both the main connection interface and the administrative interface; these settings are fixed and cannot be modified by users, which helps maintain a consistent cryptographic baseline across deployments. MySQL also exposes the `group_replication_recovery_tls_version` setting to specify the TLS protocol used during distributed recovery connections. DSM supports SQL Server clusters, which use TLS to encrypt communication between clients and the cluster; the `network.tlsProtocols` custom engine setting defines the allowed TLS versions for client connections, and a minimum TLS



version must be included for the DSM operator to manage the cluster. DSM supports TLS verification during PostgreSQL database migration, covering replication traffic between source and target clusters.

DSM's certificate management capabilities support standard PKI practices. Administrators configure custom TLS certificates for database clusters through the DSM UI or API, providing certificates in PEM format with associated private keys and CA certificates. Supported private key algorithms are RSA and ECDSA with key sizes of 256 and 384 bits. When present, the X509v3 KeyUsage extension on a custom certificate must include the DigitalSignature capability; DSM also accepts certificates that omit the KeyUsage extension entirely, treating absent KeyUsage as permitting all usages in accordance with RFC 5280. To establish secure connections to database clusters and to the DSM Provider VM, clients add the CA to the operating system trust store or the trusted CA list. DSM's API provides a mechanism to retrieve the CA certificate from a custom certificate secret. The Consumption Operator, which enables self-service database provisioning, requires a TLS certificate for its communication with the DSM provider. Certificate management can also be handled through Kubernetes cert-manager, which manages various issuer types and outputs Kubernetes TLS Secrets in the format DSM requires.

DSM supports TLS for connections to external systems. When configuring log forwarding to an SMTP server, DSM supports Auto TLS to establish a secure connection. For private container registries, DSM supports CA certificate validation for untrusted registries.

For local user credential storage, DSM encrypts passwords using PGP symmetric encryption through the PGCrypto library, with dedicated encryption keys stored using the PGCRYPTO\_PASSWORD and PGCRYPTO\_ALGORITHM keys. MySQL has FIPS mode available on the client side through the `ssl_fips_mode` setting. PostgreSQL databases include the `pgcrypto` extension, which provides cryptographic functions that applications can use directly within the database. The DSM Provider Appliance includes virtual machine encryption, which activates when a Key Management Server is configured in the environment.

### VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides configurable SSL/TLS profiles that control which cipher suites, protocol versions, and key exchange algorithms are permitted for application traffic termination. The SSL/TLS Profile, configured under Templates > Security > SSL/TLS Profile, contains the accepted protocol version list and a prioritized cipher suite list applied to virtual services. Administrators can create custom profiles or select from built-in templates; the documentation notes that the choice of accepted ciphers and protocol versions involves trade-offs between security, client compatibility, and computational expense. SSL profiles in 9.1 include a Post Quantum Cryptography section with support for modern cipher suites. Controller SSL/TLS certificates support elliptic curve (EC) or RSA algorithms, with EC recommended for new deployments.

For environments subject to cryptographic module validation requirements, Avi supports a FIPS mode backed by the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by the Cryptographic Module Validation Program (CMVP). When FIPS mode is activated on the Controller cluster, Avi restricts cryptographic operations to FIPS-compliant algorithms only. FIPS 140-3 also requires stricter handling of sensitive security parameters including keys, authentication data, and random number generation. FIPS mode is enabled at the Controller cluster level through the Controller settings. Note that FIPS mode does not support SSL Client Hello events in Avi DataScript, which may affect certain scripted traffic inspection use cases.

Avi Controller allows administrators to restrict specific key exchange algorithms and ciphers for management session access. The Allowed Ciphers field restricts management session ciphers to a specified subset, and the `kex_algorithm_exclude` field under Controller Settings excludes specific key exchange methods for SSH-based administrative access. Internal communications between the Avi Controller and Service Engines also use SSL/TLS, and custom certificates can be selected for this Secure Channel connection via the Access tab certificate field.

For certificate management, Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. The Controller is set up as an HSM client and can create keys and certificates directly on the HSM through client libraries, supporting high-availability HSM configurations. Automated certificate lifecycle management is available through Let's Encrypt integration using the ACME protocol. Avi's App Transport

Security feature supports integration with the Venafi Trust Protection Platform for certificate administration across tenants, with the Trust Protection Platform pushing signed certificates and required chain certificates to Avi Load Balancer.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports PKIProfile-based certificate validation and trust management for backend services. The PKIProfile, configured through custom resources, enables secure communication with backend services through certificate-based authentication and encryption. In VCF environments, the Avi PKI Profile defines the list of trusted certificate authorities permitted to sign client certificates and can be used to implement Zero Trust security between servers and clients.

Data-at-rest encryption for Avi Controller and Service Engine VMs is provided by VCF at the platform layer, not by Avi itself. Organizations must configure Avi SSL/TLS profiles, select appropriate cipher suites, and enable FIPS mode where cryptographic module validation requirements apply to activate these controls.

## Control PR.DS-10

> [Withdrawn: Incorporated into PR.DS-01, PR.DS-02, PR.DS-10] The confidentiality, integrity, and availability of data-in-use are protected

**SCF Controls:** CFG-02, CRY-01, DCH-01, IAC-21

**Aggregate Coverage:** Meets

### VCF (Meets)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce\_for\_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster



Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

### **VMware vDefend (Contributes)**

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

### **VMware Data Services Manager (Meets)**

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

## Control PR.DS-11

> Backups of data are created, protected, maintained, and tested [Withdrawn: Moved to PR.DS-11]

**SCF Controls:** BCD-11, BCD-11.1, BCD-11.5, BCD-11.6

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides built-in backup capabilities across its management components, workload layers, and storage subsystems, supporting organizations in meeting their Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).

#### Management component backups

VCF supports backup of all core management components. VMware vCenter supports both file-based and image-based backup methods, with file-based daily backups configured through the vCenter Management Interface of each vCenter instance. vCenter file-based backup and restore supports FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB as the backup server protocol. vCenter file-based backup optionally encrypts backup files using an encryption password that must be provided during restore; because vCenter backups contain the Key Derivation Key used for vSphere encryption, backup files should be stored on a secured backup server with appropriate access controls. VCF Operations similarly supports file-based and image-based backup methods. NSX Manager uses file-based backup, which VCF Operations configures automatically during the initial bring-up process. File-based backup jobs for VCF Operations and vCenter must be configured separately after deployment.

Scheduled backups should be implemented to prepare for critical failure scenarios, upgrade events, or certificate updates of management components. To capture a consistent state across related components, VCF requires creating a series of coordinated backup jobs that run simultaneously across component nodes. Simultaneous backups of component nodes help ensure that the backed-up state is logically consistent, reducing the need for integrity remediation during a restore. On-demand manual backups can be taken after a successful recovery operation or after a scheduled backup failure. VCF Operations backup is also configured to take a backup on state change, providing an additional layer of protection when configuration changes occur.

The backup file server stores backups from all NSX Manager or Global Manager nodes, and NSX includes a script to automatically delete old backups to manage storage consumption. NSX Global Manager backups should be periodically cleaned up to avoid excessive storage consumption on the backup file server. VCF Operations for Networks can store backups on local storage, retaining up to five backup files, or upload them to SSH or FTP servers. An initial on-demand backup should be performed after configuring VCF Operations to verify that backups complete successfully before relying on scheduled jobs. Sufficient storage capacity must be provisioned to accommodate backup data across all components.

#### Backup integrity and restore procedures

Backup integrity verification in VCF centers on version compatibility. When restoring a vCenter instance from a file-based backup, administrators must have a valid backup that matches the exact version of the vCenter appliance being restored to. VCF Operations must be available before restoring vCenter, and vCenter must be available before restoring VCF Operations, establishing a defined dependency order for restore operations. These dependencies require careful sequencing during recovery to restore the management plane to a consistent state.

#### Workload-level data protection

For workload-level data protection, VCF provides several mechanisms. Changed Block Tracking (CBT) tracks modified disk blocks on virtual machines, enabling incremental backups that reduce backup windows and storage requirements. VMware vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions to integrate with VCF. vSphere Supervisor supports backup of VM Service VMs through backup partner solutions based on VADP, and if a VADP-based backup solution is deployed on the default management cluster, the solution must be properly started and operational before starting up or shutting down VCF. Quiesced snapshots are appropriate for automated or periodic backups of VM Service virtual machines, as they capture a consistent state before the backup operation proceeds.



VCF Automation supports snapshotting a VM group to create an object that references distinct snapshots for each member VM; restoring a VM group snapshot restores each member of the group.

vSphere Supervisor control plane backup and restore can be performed using vCenter file-based backup and restore from the Workload Management UI. For applications that provide their own backup capabilities, VCF documentation recommends using application-specific backup methods rather than relying on filesystem backup alone.

#### vSAN data protection and snapshots

vSAN Data Protection allows snapshots to be managed through protection groups with configurable snapshot retention policies and scheduling intervals. The native Snapshot Service is supported by vSAN Express Storage Architecture (ESA) but not by vSAN Original Storage Architecture (OSA). Native snapshots in vSAN ESA are much faster than traditional vSphere snapshots because a base VMDK and its snapshots are contained in one vSAN object rather than being separate objects, allowing more frequent backups and faster recovery. In vSAN OSA, snapshots are separate vSAN objects. The vSAN Distributed File System Snapshot can be used by third-party backup vendors to copy changed files incrementally to a different physical location. The vSAN Snapshot Service API provides programmatic access for operations including creating linked clones from snapshots and restoring deleted virtual machines.

#### VMware Kubernetes Service backup

VMware Kubernetes Service (VKS) and the Supervisor layer extend VCF's backup capabilities to containerized workloads, cluster state, and persistent volume data. VKS Supervisor backup and restore for cluster node VMs is activated through the vCenter backup feature available in the vCenter Management Interface, integrating Kubernetes cluster state backup with the same management-plane backup infrastructure used for other VCF components.

For workload-level backup of VKS clusters, the platform supports three complementary methods: vSphere Plugin Snapshot (CSI Snapshot), File System Backup (FSB), and the Velero Plugin for vSphere. The vSphere Plugin Snapshot method produces crash-consistent, block-level backups of persistent volumes through the Container Storage Interface (CSI) layer and supports snapshot direct access and network traffic offload; it is faster and less resource-intensive than filesystem backup for complex filesystems with large numbers of small files, making it well-suited for production databases and high-IOPS applications. The File System Backup method operates at the filesystem level, supports NFS volumes and incremental backups where unchanged files are not re-transferred between runs, and offers backup repository features including deduplication, compression, and encryption; it is appropriate for legacy volumes with non-CSI storage. The Velero Plugin for vSphere can back up and restore both stateless and stateful applications running on vSphere Pods in the Supervisor. Platform teams can use both FSB and CSI Volume Snapshots within a single protection strategy to maximize data durability across workload types. VKS cluster backup supports opt-in and opt-out approaches for FSB volume backup, giving operators control over which volumes are included in filesystem-level operations. Third-party backup software can also integrate with VKS clusters using the standard Kubernetes CSI snapshot API: tools create a VolumeSnapshot object from the target PVC, materialize a temporary PVC from the snapshot, and use a Data Mover pod to transfer data to the backup destination. Kubernetes implements Persistent Volume Claim as Snapshot Source Protection, which blocks deletion of in-use API objects while a snapshot is in progress, reducing the risk of partial or inconsistent backup data. Kubernetes also supports provisioning a new PersistentVolumeClaim directly from a VolumeSnapshot by specifying the snapshot as the dataSource, enabling volume-level point-in-time recovery without requiring a full application restore workflow.

VKS cluster management provides a Create backup wizard that allows users to create backups immediately or schedule backups of specified data resources in a cluster. Backup scheduling supports immediate execution, recurring schedule formats with targeted start times, or custom cron expressions; automated backup scheduling can also be configured using the Velero CLI with the `velero schedule create` command, specifying the interval or cron expression for recurring backup operations. For on-demand backups outside a scheduled window, the `velero backup create` command backs up Kubernetes resources and persistent volume data for stateful workloads, with support for per-namespace targeting and volume snapshot inclusion. VKS cluster backups can retain a maximum of 720 backups per backup schedule; when high-frequency schedules are required, the retention period should be reduced to remain within this limit. Backup schedules can be edited, paused, or deleted through the management interface. File system backups are included in the restore by default, and snapshot data can be moved to a

separate backup storage location. Before defining a backup, a target location and credential must be created; if a data protection credential is deleted, scheduled backups relying on that credential will fail on their next execution, creating a detectable gap in backup execution history that administrators should monitor. Creating a backup schedule requires the Organization Administrator or Project Administrator role.

VKS cluster backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. The portal provides restore operations on specific backups, and a dedicated cross-cluster restore capability in the Data Protection tab enables restoring backups from a source cluster to a different target cluster. VKS cluster management supports backup and restore of an entire cluster, selected namespaces from the backup, or specific resources identified by a label. The CloneFromSnapshot CRD includes a status.phase field that tracks restore progress through multiple phases, providing operational visibility during restore operations.

For Kubernetes cluster state, etcd is the backing store for all Kubernetes objects, and clusters using etcd should have a backup plan. etcd backup can be performed using the built-in etcdctl snapshot save command by specifying the endpoint, CA certificate, and client credentials, or by taking a volume snapshot of the etcd storage volume when the underlying storage supports it. etcd snapshots can be restored from a previous snapshot file or from the remaining data directory, and cross-patch-version restores are supported. During kubeadm upgrades, automatic backup folders are written to /etc/kubernetes/tmp containing etcd data and manifests as a recovery point.

#### Backup automation through APIs

VCF exposes backup automation through its APIs, including the RecoveryBackupJobBackupRequest data structure for specifying backup location, protocol, authorization, and database scope, as well as the RecoveryBackupSchedulesUpdateSpec for programmatically managing backup schedules.

#### Disaster recovery planning

For disaster recovery planning, VCF supports application disaster recovery with data replication to a secondary site. Organizations should plan and test disaster recovery strategies regularly to meet their RTO and RPO targets. VCF Operations provides integration with VMware Live Recovery for periodic test runs to validate that existing recovery plans work with the underlying infrastructure and configured RPO limits. Application disaster recovery may result in some data loss during failover depending on the configured RPO.

VCF directly provides the mechanisms for creating recurring backups, managing retention, and supporting RTO/RPO requirements through multiple backup and snapshot methods. However, organizations must establish backup policies, define RTO/RPO targets, schedule regular restore testing, and maintain backup infrastructure such as external storage and third-party backup solutions to fully satisfy this control.

#### VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) provides backup and restore capabilities for the vDefend control plane, covering firewall rules, microsegmentation policies, IDS/IPS configurations, Bare Metal server information, tokens, and all associated security data managed by the platform. These backups protect against data loss from hardware or software malfunctions, data corruption, malware incidents, or unintentional deletion.

SSP supports recurring backup schedules configurable through the Backup Schedule interface, with frequency options ranging from 6 hours to 720 hours (30 days), as well as weekly scheduling by selecting the day and time. Recurring backups can be activated or deactivated by toggling the Recurring setting. Best practice guidance recommends scheduling backups during periods of low platform usage to minimize operational impact. A backup should also be performed before executing scale-out operations on the SSP cluster, to preserve the current configuration state before significant topology changes. Backup data is encrypted with a passphrase and transmitted to an SFTP server. Adequate storage must be verified on the backup server before activating recurring backups, and the platform must be in a healthy state for backup operations to proceed. Backup is also blocked if NSX is not onboarded to SSP.

SSP maintains a Backup History section that displays the status of each backup operation, showing "Completed" when the operation succeeds. When backup or restore operations enter a failed state, pod logs provide detailed error messages,



including database query failures and volume attachment errors, to support troubleshooting. Restoration supports deploying the backed-up configuration onto the same SSP instance or a new instance, enabling recovery when the current instance is in a non-recoverable state. Restoration requires that the same NSX instance that was onboarded at the time of backup be used, and that the platform be deployed on the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored environments must be maintained to avoid disruptions to NDR Sensor connectivity.

These capabilities address the backup component of this control for vDefend's own configuration and policy data. vDefend does not back up general workload data or application-level information; those responsibilities fall to the broader VCF platform's replication, snapshot, and backup mechanisms, including vSAN Data Protection, Protection and Recovery (PNR), and integration with third-party backup providers. vDefend's contribution is limited to protecting the security policy and configuration data that defines the network security posture of the environment.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides replication, snapshot, and recovery testing capabilities that support recovery point and recovery time objectives for protected workloads.

vSphere Replication delivers host-based continuous replication with RPO configurable from 1 minute to 24 hours, set via a slider during replication configuration. PNR uses the configured RPO to determine the most recent available state to which virtual machines are recovered during disaster recovery. vSAN snapshots and replication is a native, integrated snapshot-based backup solution for VMs running on vSAN datastores, managed through the vSphere Client, and supports RPO as low as 1 minute. Snapshot retention schedules support hourly, daily, weekly, and monthly snapshots with a maximum retention duration of three years. Predefined retention templates are available for quick configuration of RPO and snapshot retention parameters. Array-based replication supports configuring replication schedule, frequency, and RPO through VM storage policies, depending on the storage array's implementation.

PNR replication classes are preconfigured with an RPO that defines the acceptable amount of data loss after a disaster. In deployments using VCF Automation integration, replication classes can be assigned at the organization level.

Cyber Recovery, the cloud-based recovery component within PNR, uses incremental snapshots that transfer only modified or new data to cloud backup. This design enables detection of ransomware encryption by comparing entropy rates between normal snapshots and snapshots containing suspect data. Ransomware recovery plans in Cyber Recovery support predefined retention templates for configuring snapshot RPO and retention parameters.

PNR's own configuration is protected through backup settings that specify a datastore path, enable or disable the backup scheduler, set a retention period, and schedule backup frequency and time. PNR REST APIs can be configured to export and upload configuration data to a datastore on a daily basis. PNR also maintains internal database backups for audit and recovery purposes, covering the replication manager database (srmdb), recovery manager database (vrmsdb), and snapshot service database (snapservice).

Recovery plan testing is the integrity verification mechanism for protected data. During disaster recovery execution, PNR first attempts storage synchronization; if that succeeds, it uses the synchronized storage state to recover virtual machines to their most recent available state per the configured RPO. RPO violation dashboards in VCF Operations report violation counts for incoming and outgoing replications, enabling monitoring of whether replication is meeting defined targets.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) provides a built-in backup framework for managed PostgreSQL, MySQL, and SQL Server databases, giving administrators and database owners the tools to establish recurring backup schedules aligned with organizational recovery objectives.

Backup configuration is available at database creation and can be modified at any time through the database settings interface. Administrators activate automated backups using the Enable Automated Backups toggle (also exposed as Enable Backups in MySQL flows), specify a backup location pointing to S3-compatible object storage, and define a retention period. PostgreSQL databases support both full and incremental backups, and SQL Server databases support full and differential backup schedules. SQL Server adds a Log Backup Frequency setting in Advanced Settings with a maximum value of 30

minutes that is directly related to the Recovery Point Objective for that database. Backup schedules are expressed as cron expressions and can be customized per database or applied at the policy level.

Data Service Policies provide centralized backup governance for databases deployed within a namespace. A policy can include named backup jobs specifying backup type and schedule, and the policy backup requirement setting offers three options: Require Automated Backups (databases must have automated backups), Allow Automated Backups (users can choose to activate or deactivate automated backups), and Disallow. Allowed backup locations are defined in the policy via the `allowedBackupLocations` parameter, restricting where backups can be stored. When multiple policies apply, DSM aggregates the backup schedules into a single effective backup policy per database. High Availability clusters require automated backups to be enabled in order to provision databases, helping ensure that recoverable copies exist for replicated topologies.

DSM also supports on-demand backups for primary PostgreSQL databases, independent of the configured automated schedule, which is useful for capturing a point-in-time snapshot before a significant change. Backup storage is managed centrally through the Settings pane Storage Settings tab, which displays Database Backup Storage buckets and allows administrators to add or edit object storage targets. Provider-level control plane backups are stored in a designated Provider Backup Repo bucket configured during Provider VM setup, and recovery of the Provider VM from backup uses the `restore-provider` command with a `pgbackrest.conf` path to restore the appliance to the latest timestamp.

DSM retains automated backups of deleted databases until the configured retention period expires. When a database with configured backups is deleted, the system automatically creates an archive containing all collected backups that remains available in the Archives tab for the remainder of the retention period, allowing recovery of inadvertently deleted databases. Administrators can also manually delete retained backups of deleted databases when they are no longer needed.

Point-in-time recovery is supported from configured backup storage, restoring a backup at a specified date and time to a newly created database VM with a user-specified name and datastore location. The restore function is also accessible through the VCF Automation UI for tenant users. If any incremental backup in a chain is deleted, DSM cannot restore data to points in time that depended on that backup, and a restore from an incremental chain requires the last full backup plus all following incremental backups. Maintaining a balanced schedule of full and incremental backups reduces the risk of a gap in the recovery chain.

DSM provides operational validation of the backup target through the backup storage repository alert, which checks connection and operational status, bucket name, certificate expiration date, credentials, and sufficient available space in the repository. This helps surface configuration drift or storage failures that would otherwise compromise recoverability.

Satisfying this control fully requires that the organization define RTOs and RPOs for each database workload, configure backup policies accordingly, and periodically test restoration to verify that backup data is valid and recovery objectives are achievable. DSM provides the technical backup infrastructure and operational checks on the backup target; RTO and RPO definition and end-to-end backup integrity testing are organizational responsibilities.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) includes a built-in backup and restore capability for the Avi Controller configuration database. The configuration database defines all clouds, virtual services, users, tenants, and related entities. Protecting it is the primary mechanism for recovering the Avi control plane after a Controller failure.

Backup operations can be created on-demand or on a recurring schedule via the Controller web UI, CLI (using the `export` command), or REST API (using the `/api/scheduler/` endpoint). The scheduler supports configurable frequency units, including hourly, daily, and weekly intervals, with the run mode set to periodic. For single-node Controller deployments, enabling periodic external configuration backups is mandatory; the product documentation states that external backups are required to handle recovery from a complete VM or disk failure.

Avi supports multiple backup storage targets. Local backups are stored directly on the Controller with a configurable retention count, configured via the "Enable Local Backups (On Controller)" setting. Remote backups are transferred over Secure Copy Protocol (SCP) or Secure File Transfer Protocol (SFTP) to an off-Controller server, configured via the "Enable Remote Server Backup" setting. In 9.1, configuration backups can also be stored in Amazon S3 buckets as an additional remote storage

target. When deployed as part of VCF, Avi backups are stored by default on the same server used for VCF Operations appliance backups; the recommended best practice is to configure an external SFTP server as the backup destination. VCF Operations can be used to configure the external backup server and storage path for Avi backups. Product guidance also recommends storing backups with clear labeling that includes version and date information.

Before a restore proceeds, Avi performs a set of pre-restore checks to validate the backup image. In 9.1, these checks include verification of backup configuration version compatibility, presence of all file objects from the configuration on the Controller, FIPS mode consistency between the backup and the current Controller environment, Service Engine attachment verification, system configuration validation, and patch verification. All checks must pass before the restore operation is allowed to proceed.

Restore operations can be performed via the CLI (import command with the `keep_uuid` option to restore configuration to an empty Controller), the web UI, or the REST API restore endpoint. The API method accepts a configuration file and a passphrase parameter to decrypt an encrypted backup; the passphrase must match the one used when creating the backup. Restore operations generate system reports tracking operation state, start time, end time, duration, and total checks completed. The Controller metrics database can also be exported and imported separately to prevent loss of metrics data during version rollbacks. If all three nodes of a Controller cluster are permanently unavailable, recovery must be performed using a backup and restore procedure.

For multi-site deployments, Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling traffic redirection to a healthy site when a primary site fails. Avi GSLB adaptive replication mode also protects against configuration errors propagating across data centers by preventing faulty configuration objects from being replicated to follower sites.

The Avi backup and restore capability covers the Controller configuration plane. Application data, workload VM images, and the broader RTO/RPO framework depend on organizational process decisions and on the underlying VCF platform for VM-level data protection (see VCF Coverage).

## Control PR.IR

> [Withdrawn: Moved to PR.IR-04] [Withdrawn: Incorporated into PR.IR-01] Networks and environments are protected from unauthorized logical access and usage The organization's technology assets are protected from environmental threats Mechanisms are implemented to achieve resilience requirements in normal and adverse situations Adequate resource capacity to ensure availability is maintained [Withdrawn: Incorporated into PR.AA-03, PR.AA-05, PR.IR-01] [Withdrawn: Moved to PR.IR-02] [Withdrawn: Incorporated into PR.AA-06, PR.IR-01] [Withdrawn: Moved to PR.IR-03]

**SCF Controls:** GOV-01, GOV-01.1, RSK-01, SEA-01, SEA-01.1, SEA-01.2, SEA-02

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides several centralized management capabilities that support organization-wide implementation of cybersecurity and data protection controls, though it does not constitute a complete governance, risk, and compliance (GRC) platform on its own.

VCF Automation Organizations offer a centralized structure for access control and resource sharing across the platform. Organization administrators can distribute infrastructure and configure access management to groups within their organizations using the organization management functionality in VCF Automation. IT teams and cloud service providers can monitor resource usage, control permissions, and provide managed services through VCF Automation Organizations while maintaining security through network isolation. The Organization Administrator role can create and manage policies centrally, providing a single point of control for security policy definition and enforcement within the VCF environment. VCF Automation also supports role-based access control through group membership and role assignment management in its Access Control interface.

VCF SSO and the VCF Identity Broker provide centralized authentication and identity management across VCF components. The Identity Broker acts as a centralized authentication source, and VCF SSO integrates with it to manage authentication for VCF instance components. VCF Operations integrates with VCF SSO for centralized user and group authentication and management, and provides VCF SSO and centralized management of federated access through unified identity configuration. Role-based access control (RBAC) enforces consistent authorization policies across the stack: vCenter allows fine-grained control over authorization with permissions and roles by associating a role to a user or group on objects in the vCenter object hierarchy, and vSAN similarly supports RBAC and permissions management.

For network security management, NSX Manager provides centralized policy and grouping constructs. Security groups are defined and managed through NSX Manager, and in multi-site deployments, global security groups can be created on an NSX global manager and consumed by associated local managers, enabling consistent group definitions across geographically distributed environments. vDefend policies on Tier-0 and Tier-1 gateways are managed centrally from NSX Manager. For distributed firewall enforcement, microsegmentation, and advanced security policy at the vNIC level between workloads, VMware vDefend is a separate product that extends NSX networking; when deployed, its policies are managed from the same NSX Manager interface. PowerShell cmdlets such as InvokePatchSecurityPolicyForDomain are available for programmatic creation of security policies, supporting automation of security policy deployment at scale. The VCF distributed switch includes built-in security controls that help protect network traffic, providing baseline security capabilities that are centrally configured through vCenter.

VCF Operations provides continuous monitoring and operational visibility across the environment. Its configuration management capabilities include scheduled drift detection for vCenter and cluster objects, enabling proactive detection of configuration deviations from the desired state. Administrators can view and compare configuration drifts and identify settings that have changed. VCF Log Management provides centralized log aggregation that collects logs from all VCF components, including vCenter, ESX, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. The VCF Log Management cluster is the central point for log collection, aggregation, and analysis for all VCF instances within a given fleet.

VCF Operations is the lifecycle management layer, coordinating configuration and updates across VCF components from a single management plane. It simplifies provisioning new infrastructure, managing passwords, installing certificates, and patching or upgrading infrastructure components.

An auditor evaluating this control should verify that the organization has designated VCF Automation Organizations as the centralized structure for access control and policy management, that VCF SSO and Identity Broker are configured for centralized authentication across all components, that NSX Manager security policies are defined and applied consistently across all workload domains, that VCF Operations drift detection is scheduled and monitored, and that VCF Operations is used as the authoritative source for component lifecycle operations. The auditor should also confirm that these VCF-native capabilities are integrated into the organization's broader cybersecurity governance framework, as VCF addresses the technical control implementation layer but does not replace the need for organizational policies, risk management processes, and compliance monitoring tools.

### **VMware vDefend (Contributes)**

VMware vDefend contributes to centralized management of cybersecurity controls by providing a unified management plane for network security policy across the virtualized data center. vDefend's centralized capabilities span firewall policy, intrusion detection and prevention, malware prevention, and traffic analytics, all managed through a single interface or, for multi-site deployments, through Global Manager.

The vDefend distributed firewall (DFW) allows administrators to define, organize, and enforce microsegmentation policies from a central management plane. Policies are organized into pre-defined categories (Infrastructure, Environment, Application) that provide a logical structure for managing large rule sets. Administrators can create security groups based on VM attributes, IP sets, or dynamic criteria, and apply east-west firewall rules to those groups consistently. When rules are published, they are pushed from the management plane to every host in the targeted clusters, so enforcement is uniform across the environment without requiring per-host configuration. For multi-site or federated deployments, NSX Federation Security provides centralized management of security policies across all sites through Global Manager. Distributed and Gateway Firewall policies created from Global Manager are synchronized to Local Managers at each registered site. Administrators can define custom regions within a federated deployment and assign specific Security and Network policies to those regions, enabling policy scoping at geographic or administrative boundaries.

In 9.1, vDefend extends centralized policy management to VPC-scoped workloads in VCF Automation. Five system-defined security strategies are available for VPC security posture: VPC Isolation, VPC Isolation with essential services, VPC External Connectivity, VPC Secure Connection, and NONE. Project Administrators can select a pre-defined security posture that enforces Secure by Default principles, rather than manually configuring firewall rules for individual VPCs. The Distributed Firewall supports Organizations in VCF Automation for multi-tenant policy isolation, and the Organization Admin (Tenant Admin) role holds full access to manage Transit Gateway firewalls, distributed firewalls, and all VPC gateway firewalls within that tenant context.

Distributed IDS/IPS and Malware Prevention are centrally managed. IDS/IPS profiles and signature sets are configured centrally and distributed to hosts, and Distributed Malware Prevention rules follow the same publish model as firewall policies. In multi-site environments, IDS/IPS signature management is centralized through Global Manager, which distributes updates to multiple Local Managers and supports both automatic update and manual version control.

Security Services Platform provides centralized network security analytics and visibility through Security Intelligence, which analyzes traffic flows across the data center and generates policy recommendations, including recommended security policies and security groups, that administrators can review and publish as Distributed Firewall rules. The platform includes segmentation planning tools that help administrators design and implement microsegmentation strategies from a central vantage point. Security Services Platform also extends centralized policy management to bare metal servers, where security policies are defined, propagated, and enforced through the same centralized model as virtualized workloads.

Role-based access control within vDefend and Security Services Platform governs who can perform security operations. Security Services Platform defines five roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector, each with differentiated permissions for policy publishing, traffic visualization, and configuration changes.

Configuration of Distributed Firewall policies requires explicit DFW Manage/View rights and rights for Groups and Services, so access to centralized policy management is controlled at the permission level.

vDefend's centralized management is scoped to network security controls. Organization-wide centralized management of all cybersecurity and data protection processes, including identity management, compute hardening, compliance tracking, and governance, requires the broader VCF platform and external GRC systems.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) helps organizations achieve disaster recovery requirements for virtualized workloads by orchestrating virtual machine recovery at a secondary site. Recovery plans can be created with configurable properties to support disaster recovery operations, and replication classes are preconfigured with a Recovery Point Objective (RPO) that defines the acceptable amount of data loss after a disaster. PNR orchestrates both array-based replication and host-based replication.

Recovery plans run under both planned circumstances for migration and unplanned circumstances for disaster recovery. Operators can test recovery plans before using them in production to validate recovery procedures. Multi-region deployments with separate management domains can be designed to contain the impact of a disaster event to one region.

PNR exposes role-based access through specific roles such as SRM Recovery Plans Administrator and SRM Recovery Administrator, and role assignments must be configured on both the primary and secondary sites for consistent access control across the recovery environment. In Protection and Recovery for VCF Automation, Organization Administrators can perform multi-tenant disaster recovery operations on behalf of project administrators and project advanced users.

Operational visibility is provided through VCF Operations dashboards for Protection and Recovery. The Protection Groups dashboard surfaces a critical health status when a serious issue occurs with a protection group or its replication, and PNR classifies health findings into Error, Warning, and Info categories so operators can diagnose, troubleshoot, and remediate issues that affect resilience.

Cyber Recovery, part of the PNR suite, extends resilience to cyber incident scenarios. Integrated CrowdStrike vulnerability analysis applies the Exploitability and Predictive Risk Technology (ExPRT) rating to recommend immediate remediation of Critical vulnerabilities, timely remediation of Medium-severity vulnerabilities, and scheduled remediation of Low-severity findings. vSphere Replication supports point-in-time recovery for cyber resilience.

Recovery sites should be located in a facility that is unlikely to be affected by environmental, infrastructure, or other disturbances that affect the protected site. Decisions about acceptable RPO thresholds, recovery site selection, and operational processes for declaring and executing recovery remain organizational responsibilities outside the product.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) contributes to resilience through technical mechanisms at both the management plane and database levels, addressing both normal operations and adverse conditions such as node failures and site outages.

The DSM Provider Appliance, which hosts the management plane, relies on vSphere High Availability for its own resilience. DSM requires that HA be activated on VMware vCenter clusters hosting database workloads as a prerequisite for infrastructure policy compliance, making HA an enforced platform dependency rather than an optional configuration.

At the database level, DSM PostgreSQL deployments include a monitor node that orchestrates automatic failover. When the primary database node fails, the monitor node promotes the replica to primary without manual intervention. For environments requiring high availability across multiple failure domains, DSM provides a Cross vSphere Cluster HA topology that distributes PostgreSQL instances across multiple vSphere clusters, offering the highest availability and resilience for those configurations.

For cross-site resilience, DSM supports multi-site deployments for PostgreSQL databases. Before establishing a multi-site deployment, administrators must configure remote replication on the primary instance and retrieve the Certificate Authority from the primary instance to add it to the DSM Provider VM that will host the secondary. Users with the DSM User role must manually establish trust between primary and secondary instances. Secondary PostgreSQL instances support read-only connections while replication is active. DSM requires that the values of `max_connections`, `max_worker_processes`,



max\_wal\_senders, max\_prepared\_transactions, and max\_locks\_per\_transaction on the secondary database be equal to or greater than those on the primary. When a site fails, DSM provides a switchover workflow that promotes the secondary instance to primary. DSM also provides a failback workflow that reverses the roles and restores the system to a fully operational state. During a switchover, DSM validates trust of the new primary database certificate before redirecting secondary instances. DSM requires that organizations define disaster recovery requirements, including whether to enable multi-site replication, before creating a PostgreSQL database.

DSM extends high availability to MySQL deployments. DSM supports MySQL HA clusters and read replicas as distinct deployment topologies. A Cross vSphere Cluster HA configuration distributing a primary and two replicas across three vSphere clusters provides the highest availability for MySQL in multi-cluster environments. DSM requires that disaster recovery requirements be defined before creating a MySQL database.

For recovery operations, restoring a PostgreSQL cluster to a different DSM control plane should use resources equal to or greater than those of the source cluster to maintain stability.

DSM's technical mechanisms support but do not substitute for organizational resilience programs. Organizations must define recovery time and recovery point objectives, document and test disaster recovery procedures, and maintain runbooks for failover and failback operations.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer provides application-layer resilience mechanisms spanning the control plane, data plane, and geographic distribution layers. Organizations can use these mechanisms to satisfy resilience requirements for their application delivery infrastructure.

Control-plane resilience is achieved through the Avi Controller cluster. Production deployments use a Controller cluster that maintains quorum and fault tolerance, allowing the control plane to remain available when one node is unavailable. Controller clusters can be deployed across two availability zones, with documented failure scenarios and recovery actions for each topology. When running a single-node Controller, the Backup and Restore feature must be used for disaster recovery. After a storage failure event, the Controller is restored from a configuration archive, and at least one Service Engine controller IP must match a previous controller IP to enable Service Engines to reconnect to the Controller after restoration. The Controller's backup and restore capability also supports configuration migration across Controller instances.

For cross-site application failover, Avi Load Balancer includes Global Server Load Balancing (GSLB). Avi GSLB provides resilience when loss of a data center or network connection occurs, and supports an active disaster recovery deployment mode in which a geographically remote site receives application traffic when the primary site is unavailable. Where a deployment has only one active site, at least one geographically remote cloud should be designated as the GSLB disaster recovery target.

At the data plane, Service Engine distribution and scaling provide resilience at the workload level. A scaled-out virtual service experiences no more than performance degradation if a single Service Engine in the group fails, making the scaled-out model preferable to legacy high availability modes for resilience. Availability Zones can be configured within each Service Engine Group, with two or three zones recommended per group. Each Availability Zone should be defined around a distinct fault domain associated with shared power supplies, shared networking devices, or other common infrastructure, and maps specific VMware vCenter (vCenter) instances, hosts, and datastores that share that fault domain. In multi-vCenter deployments, this spreads data-plane capacity across multiple infrastructure failure boundaries.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) federation architecture supports designation of a leader cluster and multiple member clusters for disaster recovery and multi-cluster coordination. This extends Avi's resilience model to multi-cluster Kubernetes deployments, allowing application traffic management to continue across cluster failures.

In VCF deployments, the Cloud Console's Central Licensing feature maintains a global capacity pool that removes the need for duplicate licenses in disaster recovery scenarios, reducing licensing barriers to activating DR sites.

Achieving the resilience requirements in this control is an organizational process. The organization must define recovery objectives, validate failover procedures through testing, maintain configuration archives, and coordinate resilience activities across the underlying VCF platform. Avi's control-plane HA, GSLB, Availability Zone configuration, and AMKO multi-cluster federation capabilities directly support that process without substituting for it.



## Control PR.IR-01

> [Withdrawn: Incorporated into PR.IR-01] Networks and environments are protected from unauthorized logical access and usage [Withdrawn: Incorporated into PR.AA-03, PR.AA-05, PR.IR-01] [Withdrawn: Incorporated into PR.AA-06, PR.IR-01]

**SCF Controls:** NET-01, NET-02, SEA-01, SEA-02

**Aggregate Coverage:** Meets

### VCF (Meets)

VCF provides built-in mechanisms for implementing and governing network security controls across the infrastructure stack, spanning virtual switching, network segmentation, policy management, role-based access control, audit logging, and documented hardening procedures.

NSX, the networking component of VCF, delivers a hierarchical security policy framework organized around domains, security policies, and individual rules. Each rule can be configured with action, direction, IP protocol, source groups, destination groups, services, and scope, providing administrators a structured and repeatable model for defining network security posture. Security policies are organized into categories (Emergency, Infrastructure, Environment, Application) so that multiple administrators can create and manage policies without conflicts or overrides. Firewall rules within each category are organized into sections, supporting logical grouping and ordered evaluation. This hierarchical structure supports both centralized governance and delegated administration, allowing organizations to maintain consistent security standards while enabling application teams to manage policies within their assigned boundaries.

VCF's network security governance model is built on role-based access control (RBAC) that spans networking and security functions. NSX Projects and VPCs support scoped role assignments including VPC Admin, Security Admin, Network Admin, Security Operator, and Network Operator roles. These roles can be assigned at the project or VPC level, enabling least-privilege access to network security configuration. A VPC Admin has full access to networking and security objects within their assigned VPC, while Enterprise Admins retain overarching control. NSX Advanced Network Management extends RBAC to specific networking components including static routes, locale services, segments, segment profiles, IP address pools, forwarding policies, DNS, DHCP, load balancing, and NAT. This separation of duties allows organizations to delegate day-to-day network security operations while retaining centralized oversight.

The NSX VPC workflow provides a structured mechanism for implementing network security controls at the application level. Application owners can add subnets inside their assigned VPC and configure security policies to meet workload requirements without dependency on the Enterprise Admin. VPC Admins and Security Admins add security policies within the VPC to address the security requirements of connected workloads. Default East-West firewall rules are activated automatically when an appropriate security license is applied and can be adjusted as needed. This self-service model, bounded by RBAC, allows security policy implementation to scale across the organization while maintaining governance guardrails.

VCF includes multiple layers of network security controls. VMware vDefend, a separately licensed product that extends NSX, provides Distributed Firewall enforcement across deployment and operational scenarios, while its Gateway Firewall provides perimeter security. Context profiles and Layer 7 access profiles enable firewall rules with application-level and domain-based attributes for both distributed and gateway firewall enforcement. For containerized workloads, the Antrea Container Network Interface (CNI) plugin in VMware Kubernetes Service (VKS) enforces Kubernetes NetworkPolicy at the namespace and pod level. The AntreaPolicy feature gate enables AntreaNetworkPolicy and ClusterNetworkPolicy objects that extend standard NetworkPolicy with richer Layer 4 rule sets; traffic not explicitly permitted is blocked by default when a policy applies to a pod. The Antrea NetworkPolicyStats feature gate collects enforcement statistics, giving operators visibility into which policies are matching traffic and at what volume to support operational monitoring and periodic policy review. A Kubernetes cluster must provide and enforce NetworkPolicy for network security controls to be effective.

The VKS networking layer within VCF integrates directly with the broader NSX security framework. Supervisors using NSX VPC networking operate in the system VPC while VKS clusters reside in vSphere Namespace VPCs, providing topology-level isolation between the management plane and workload clusters. NSX VPC pod IP pools are configured as Private, restricting direct external accessibility of pod addresses. Antrea EgressSeparateSubnet allows egress traffic from specific workloads to

originate from a subnet distinct from the default node subnet, supporting more granular traffic segmentation. The Network Control Plane (NCP) component bridges Kubernetes networking objects with NSX, realizing VirtualNetwork, VirtualNetworkInterface, and LoadBalancer resources for the VKS control plane; communication between Supervisor and NSX is secured using TLS. Kubernetes control plane services communicate using certificates by default, and connections from nodes and pods to the control plane are secured by default and can run over untrusted networks. Supervisor networking architecture requires a deliberate deployment-time choice: NSX with embedded load balancer, or vSphere Distributed Switch with external load balancer. This choice determines which network security mechanisms are available downstream, and organizational procedures should reflect which path is in use. VKS Cluster Management Custom Policies provide a governance mechanism that should be reviewed and updated to ensure policy logic reflects current security and operational requirements. The Argo CD Supervisor Service deployment implements network segmentation and firewall rules to secure communication between its components. Organizations operating service meshes alongside VKS gain OSI Layer 7 network policies based on workload identity and mutual TLS encryption for pod-to-pod traffic, providing an additional isolation layer beyond namespace boundaries.

At the virtual infrastructure layer, vSphere Distributed Switches provide centralized management of virtual networking, handling traffic for all associated hosts in a data center. Distributed switches support network segmentation using Private VLAN (PVLAN) and VLAN-based SPAN for distributed port mirroring. Network segmentation is built into the VCF architecture: management traffic, vMotion, and storage traffic are isolated on separate networks. Network I/O Control allocates bandwidth to traffic types based on share values, and the Storage Traffic Separation network profile creates dedicated vSphere Distributed Switches with separate physical NICs for storage traffic isolation. NSX distributed port groups and uplink port groups support Traffic Filtering and Marking policies configurable at the port level, providing additional granularity for layer 2 security controls. ESX hosts also support IPsec for VMkernel network communication, with security associations and policies configurable via `esxcli network ip ipsec` commands, supporting both transport and tunnel mode with upper layer protocol filtering for tcp, udp, icmp6, or any traffic.

vSphere Lifecycle Manager enforces desired-state configuration for hosts and clusters, applying and remediating configuration to match the defined software specification. This helps detect and address configuration drift that could weaken network security posture, and the remediation process can be managed programmatically through the vSphere Automation API.

VCF publishes security baselines through the Security Configuration Guide and DISA STIGs. The NSX Security Configuration Guide provides documented procedures for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes. Recommendations cover configuring strong authentication, implementing RBAC, and securing administrative access. NSX security best practices address creating and managing security groups, implementing distributed firewalling, configuring security policies, and enforcing microsegmentation to control network traffic. Security Technical Implementation Guides for Supervisor and VMware Kubernetes Release (VKr) components are available to provide hardening guidance for VKS deployments, extending the documented security baseline to the containerized workload layer. These documented hardening procedures, aligned with industry-standard best practices, give organizations a baseline for developing and updating their network security control procedures.

Audit logging supports ongoing governance by recording security policy changes with full traceability. NSX firewall audit logs capture the user performing the operation, the module name, operation type, operation status, and modified resource details including the security policy display name, identifier, path, and rule configurations. This audit trail enables organizations to track who changed network security policies, what was changed, and when, supporting both compliance review and change management processes.

Programmatic management capabilities, including PowerCLI cmdlets such as `InvokePatchSecurityPolicyForDomain` for creating distributed firewall policies, support infrastructure-as-code approaches to network security governance, enabling version-controlled and repeatable policy deployment.

#### VMware vDefend (Meets)

VMware vDefend provides the technical enforcement layer that underlies Network Security Control (NSC) implementation, though the procedural and governance aspects of developing and updating NSC procedures remain organizational responsibilities.

Security Services Platform enables monitoring of traffic after publishing assets and security policies to NSX Manager, allowing administrators to refine policies and adjust security posture based on observed traffic behavior. Security Intelligence Policy Recommendations correlate observed traffic patterns within the NSX environment to assist with enforcing more dynamic security policies; these recommendations can be reviewed and published directly to the Distributed Firewall (DFW) rule set. The Security Intelligence infrastructure classification feature identifies compute entities providing network infrastructure services in the NSX environment, supporting structured policy development around infrastructure traffic categories.

Dynamic NSGroups enable DFW and Gateway Firewall (GFW) rules to update automatically as workloads are deployed or modified in the environment. Security Services Platform provides a workflow to import data center hierarchy from CSV, which translates IP addresses to virtual machines, tags those VMs, and creates NSX groups necessary for segmentation planning. This supports the initial development of network security control structures from existing IP-based inventories.

vDefend DFW security posture is applied to VPCs through system-defined Security Profiles accessible in NSX Manager. When a Security Profile is applied to a VPC in VCF Automation, the system automatically generates and realizes system-managed DFW rules within the NSX Project space. DFW policies extend to Bare Metal servers, with Bare Metal server groups, vDefend DFW policies, and rules defined in NSX Manager and managed through Security Services Platform. Malware Prevention Service is configured through the IDS/IPS & Malware Prevention Setup wizard, which provides a guided sequence of steps to prepare the data center.

NSX Federation Security provides centralized management of security policies across multiple sites through a Global Manager, supporting consistent policy enforcement in distributed and multi-site environments. The Security Overview dashboard in NSX Manager displays threat detection and response features, a visual summary of the overall security configuration, and the capacity of NSX objects, giving administrators visibility into the state of deployed network security controls.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) contributes to Network Security Controls implementation through its infrastructure policy framework, which governs how databases are placed on the network and which network resources they may access.

DSM's architecture requires that network connectivity be provided through vSphere Distributed Switches (VDS) or NSX Virtual Distributed Switches (N-VDS). During initial setup, administrators configure IP pools that define the address space available for database deployment. IP pools may be created either during infrastructure policy definition or in advance, with each pool specified using a Subnet Prefix in CIDR notation that controls network vs. host address allocation. The vSphere administrator is responsible for regulating database IP assignment through this mechanism, tying database network placement to explicitly defined, administrator-controlled address ranges rather than allowing ad-hoc assignment.

Infrastructure policies aggregate network configuration choices alongside compute and storage settings into named policies that govern how databases are provisioned. The DSM administrator UI provides an Infrastructure Policies view that displays all configured policies and their associated resources, including IP pools, VM classes, CPU, memory, and storage policies, giving administrators continuous visibility into how network resources are allocated across the environment. Defining infrastructure policies is advised to provide full visibility into infrastructure usage by DSM users.

DSM actively detects conflicting network configurations. When it detects overlap between Supervisor infrastructure policy IP ranges and system configuration networks, it generates a NetworkOverlapFound alert and requires resolution before provisioning operations can proceed. Infrastructure policies should be updated to remove overlapping networks that may cause provisioning failures.

DSM supports custom certificate management for the Provider VM, including an IP-inclusive certificate style where the Subject Alternative Name can list one or more IP addresses and optionally FQDNs, aligning certificate identity with the addresses assigned through IP pool management. For SQL Server databases, administrators can specify the allowed TLS versions for client connections using the network.tlsProtocols custom engine setting in the data service policy.

DSM is a database-as-a-service platform rather than a dedicated network security tool. It does not provide firewalls, intrusion detection, or network traffic inspection; those capabilities are provided by VMware vDefend, which is a separate product. Developing and updating organizational procedures for network security controls is an organizational responsibility that DSM does not fulfill. The network isolation and address management controls DSM exposes are implemented through the underlying VCF platform infrastructure, and the broader NSC governance framework must be established by the organization.

#### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer provides application-layer network security policy mechanisms that help organizations implement network access controls at the application delivery boundary. These Avi-native capabilities operate at the Virtual Service level and give administrators structured objects for defining, governing, and updating access rules as requirements change.

Avi's Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited. IP Group-based access control lists applied per Virtual Service are the most scalable method for implementing network-layer ACLs, allowing administrators to specify which source addresses may reach individual application services. Policies can be created and modified through the Avi Controller CLI using the `configure networksecuritypolicy` command, and updated programmatically through the REST API using the Modify Network Security ACL endpoint and IP Group UUID references.

Starting with Avi Load Balancer version 32.1, NSX security groups can be used directly in both HTTP Policies and Network policies. Security groups defined once in NSX are reused across Avi Virtual Service security policies, removing the need to manually maintain IP address lists in Avi. When an IP address changes in NSX, the update propagates automatically to Avi Load Balancer, keeping Virtual Service security policies current without manual intervention. This integration provides a unified governance model where network security group membership is managed centrally in NSX and reflected automatically in Avi policy enforcement.

Avi's DDoS Policy detects and mitigates Layer 4 through Layer 7 network attacks through the Network Security policy framework, providing additional network security control at the application delivery layer.

Within the broader VCF platform, NSX provides underlay routing and network infrastructure for Avi Service Engines. East-west firewall enforcement between application tiers is provided by VMware vDefend, a separate product that extends the platform's network security posture beyond what Avi provides at the application proxy boundary.

Satisfying this control fully requires the organization to document procedures for governing and updating network security controls across the Avi tier and the broader platform, assign ownership of Avi policy objects, and establish change management processes covering both Avi Network Security Policies and VCF-layer controls.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

## Control PR.IR-02

> The organization's technology assets are protected from environmental threats [Withdrawn: Moved to PR.IR-02]

**SCF Controls:** BCD-01, PES-01, PES-07, PES-07.5, PES-08, PES-09, SEA-01.2, THR-09

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations. HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

#### **VMware vDefend (Contributes)**

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

#### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting



both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) contributes to resilience through technical mechanisms at both the management plane and database levels, addressing both normal operations and adverse conditions such as node failures and site outages.

The DSM Provider Appliance, which hosts the management plane, relies on vSphere High Availability for its own resilience. DSM requires that HA be activated on VMware vCenter clusters hosting database workloads as a prerequisite for infrastructure policy compliance, making HA an enforced platform dependency rather than an optional configuration.

At the database level, DSM PostgreSQL deployments include a monitor node that orchestrates automatic failover. When the primary database node fails, the monitor node promotes the replica to primary without manual intervention. For environments requiring high availability across multiple failure domains, DSM provides a Cross vSphere Cluster HA topology that distributes PostgreSQL instances across multiple vSphere clusters, offering the highest availability and resilience for those configurations.

For cross-site resilience, DSM supports multi-site deployments for PostgreSQL databases. Before establishing a multi-site deployment, administrators must configure remote replication on the primary instance and retrieve the Certificate Authority from the primary instance to add it to the DSM Provider VM that will host the secondary. Users with the DSM User role must manually establish trust between primary and secondary instances. Secondary PostgreSQL instances support read-only connections while replication is active. DSM requires that the values of `max_connections`, `max_worker_processes`, `max_wal_senders`, `max_prepared_transactions`, and `max_locks_per_transaction` on the secondary database be equal to or greater than those on the primary. When a site fails, DSM provides a switchover workflow that promotes the secondary instance to primary. DSM also provides a fallback workflow that reverses the roles and restores the system to a fully operational state. During a switchover, DSM validates trust of the new primary database certificate before redirecting secondary instances. DSM requires that organizations define disaster recovery requirements, including whether to enable multi-site replication, before creating a PostgreSQL database.

DSM extends high availability to MySQL deployments. DSM supports MySQL HA clusters and read replicas as distinct deployment topologies. A Cross vSphere Cluster HA configuration distributing a primary and two replicas across three vSphere clusters provides the highest availability for MySQL in multi-cluster environments. DSM requires that disaster recovery requirements be defined before creating a MySQL database.

For recovery operations, restoring a PostgreSQL cluster to a different DSM control plane should use resources equal to or greater than those of the source cluster to maintain stability.

DSM's technical mechanisms support but do not substitute for organizational resilience programs. Organizations must define recovery time and recovery point objectives, document and test disaster recovery procedures, and maintain runbooks for failover and failback operations.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.



## Control PR.IR-03

> Mechanisms are implemented to achieve resilience requirements in normal and adverse situations [Withdrawn: Moved to PR.IR-03]

**SCF Controls:** BCD-01, SEA-01, SEA-01.2, SEA-02

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations.

HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

#### **VMware vDefend (Contributes)**

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

#### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) contributes to resilience through technical mechanisms at both the management plane and database levels, addressing both normal operations and adverse conditions such as node failures and site outages.

The DSM Provider Appliance, which hosts the management plane, relies on vSphere High Availability for its own resilience. DSM requires that HA be activated on VMware vCenter clusters hosting database workloads as a prerequisite for infrastructure policy compliance, making HA an enforced platform dependency rather than an optional configuration.

At the database level, DSM PostgreSQL deployments include a monitor node that orchestrates automatic failover. When the primary database node fails, the monitor node promotes the replica to primary without manual intervention. For environments requiring high availability across multiple failure domains, DSM provides a Cross vSphere Cluster HA topology that distributes PostgreSQL instances across multiple vSphere clusters, offering the highest availability and resilience for those configurations.

For cross-site resilience, DSM supports multi-site deployments for PostgreSQL databases. Before establishing a multi-site deployment, administrators must configure remote replication on the primary instance and retrieve the Certificate Authority from the primary instance to add it to the DSM Provider VM that will host the secondary. Users with the DSM User role must manually establish trust between primary and secondary instances. Secondary PostgreSQL instances support read-only connections while replication is active. DSM requires that the values of `max_connections`, `max_worker_processes`, `max_wal_senders`, `max_prepared_transactions`, and `max_locks_per_transaction` on the secondary database be equal to or greater than those on the primary. When a site fails, DSM provides a switchover workflow that promotes the secondary instance to primary. DSM also provides a failback workflow that reverses the roles and restores the system to a fully operational state. During a switchover, DSM validates trust of the new primary database certificate before redirecting secondary instances. DSM requires that organizations define disaster recovery requirements, including whether to enable multi-site replication, before creating a PostgreSQL database.

DSM extends high availability to MySQL deployments. DSM supports MySQL HA clusters and read replicas as distinct deployment topologies. A Cross vSphere Cluster HA configuration distributing a primary and two replicas across three vSphere clusters provides the highest availability for MySQL in multi-cluster environments. DSM requires that disaster recovery requirements be defined before creating a MySQL database.

For recovery operations, restoring a PostgreSQL cluster to a different DSM control plane should use resources equal to or greater than those of the source cluster to maintain stability.

DSM's technical mechanisms support but do not substitute for organizational resilience programs. Organizations must define recovery time and recovery point objectives, document and test disaster recovery procedures, and maintain runbooks for failover and failback operations.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

## Control PR.IR-04

> [Withdrawn: Moved to PR.IR-04] Adequate resource capacity to ensure availability is maintained

**SCF Controls:** CAP-01, CAP-02, CAP-03, CAP-04, CAP-05

**Aggregate Coverage:** Meets

### VCF (Meets)

VCF provides built-in capacity and performance management through VCF Operations, which delivers capabilities organized around three functional areas: assess, optimize, and plan. These capabilities allow administrators to evaluate whether physical capacity is sufficient to meet current or forecasted demand, balance supply against consumption, and manage production capacity as organizational requirements change.

The assess capability evaluates current and projected resource utilization across compute, storage, and networking. VCF Operations includes a capacity analytics engine that analyzes historical resource utilization data and generates projected utilization metrics. The engine computes and publishes metrics in the Capacity Analytics Generated group, including a capacityRemainingPercentage that tracks the most constrained resource relative to usable capacity. Capacity dashboards display key indicators including time remaining before capacity is projected to run out, the amount of remaining capacity, the number of virtual machines that can fit in remaining capacity, and reclaimable resources that can increase available capacity. The Capacity Summary dashboard provides details on available resources and what is currently running on those resources. The recommended approach for usable capacity is to maintain a green state by calculating total capacity minus high availability reservation for the time remaining.

The optimize capability helps administrators manage resources within the virtualized infrastructure to maintain performance and maximize resource utilization while keeping capacity within acceptable limits. The Workload Optimization screen lets administrators optimize workload placement based on policy settings, accessible via the Workload Placement tab under Capacity. Capacity Optimization allows forecasting the impact of adding workloads by modeling various scenarios to determine whether desired workloads can fit in targeted data centers. Administrators configure capacity policy settings by defining requirements and tolerances for their environment, such as CPU utilization thresholds, and then configure object groups and policies accordingly. At the vSphere layer, Distributed Resource Scheduler (DRS) continuously compares cluster and host-level metrics against an ideal resource usage given resource pool attributes, current demand, and a configurable imbalance target, automatically migrating virtual machines to maintain load balance. vSphere also applies admission control when creating or modifying resource pools, rejecting reservation requests that would exceed available capacity to prevent over-commitment of guaranteed resource allocations.

The plan capability uses historical resource utilization data and real-time predictive projections to forecast future capacity needs. The capacity engine uses an industry-standard statistical analysis model of demand behavior for its projections. Infrastructure Planning shows time remaining and the impact on CPU and memory when capacity changes, including graphical representations of whether removing capacity decreases the time remaining before resources run out. Committed scenarios allow capacity to be reserved so that operations teams do not perform ad hoc resource increases on workloads while a capacity manager is engaged in resource planning for new projects.

At the storage layer, vSAN provides storage-specific capacity and performance metrics. VCF Operations collects disk I/O and disk space metrics to monitor vSAN disk group performance, including read-cached hit rate, write-buffer free percentage, cache disk destage rate, congestion metrics, and outstanding I/O statistics. vSAN displays deduplication and compression savings information when these space efficiency features are enabled. vSAN also supports auto-policy management to optimize capacity utilization based on cluster size and type. The vSAN Performance Dashboard in VCF Operations provides a consolidated view of storage performance alongside compute and network resources.

The Consumption layer within VCF extends these capacity management capabilities to Kubernetes workloads running on VMware Kubernetes Service (VKS) and the vSphere Supervisor. At the namespace level, vSphere Namespace resource capacity can be configured with explicit limits on CPU, memory, storage, and storage policy consumption. When a vSphere Namespace is configured, a resource pool is created on VMware vCenter, and administrators can apply capacity and usage

quotas to bound what workloads in that namespace may consume; by default, this resource pool is created without capacity or usage quotas, requiring administrators to configure limits explicitly. The StoragePolicyQuota resource allows per-namespace limits on storage capacity allocated under a given storage policy, specified via the `spec.limit` parameter. VKS Cluster Management quota policies provide an additional boundary at the cluster management layer, with preconfigured templates (small, medium, and large) that define common limits on CPU and memory requests, or a custom template that allows specification of CPU and memory limits and request quantities for various resource types.

Within Kubernetes namespaces, ResourceQuota objects control resource allocation across pods and containers, allowing administrators to set per-namespace quotas on CPU, memory, and storage. ResourceQuota configuration can be enabled to protect system-critical priority classes, including system-node-critical and system-cluster-critical, from resource contention. LimitRange resources work alongside ResourceQuota to set default and maximum resource requests and limits at the pod level, reducing resource exhaustion from workloads that do not specify their own constraints; cluster administrators can use LimitRange to set per-claim storage request ceilings and ResourceQuota to cap total namespace storage consumption. Kubernetes pods can be configured with resource requests and limits at both pod-level and container-level, providing fine-grained control over CPU and memory allocation.

At the node level, Kubernetes nodes report capacity and allocatable resources including CPU, memory, ephemeral storage, hugepages, and pod count limits. The kubelet `systemReserved` configuration reserves CPU cores and memory for system processes, protecting node stability from workload interference. For workloads requiring stronger latency and performance guarantees, kubelet resource management policies can be configured. Node overprovisioning capacity reservation is configured by defining resource requests and limits for placeholder pods in a Deployment manifest, with total reserved resources calculated as the product of replica count and per-pod resource quantities, keeping headroom available for newly scheduled workloads.

The Kubernetes kube-scheduler manages availability, performance, and capacity through scheduler policies and profiles. Kube-scheduler metrics can be used to build capacity planning dashboards, assess current or historical scheduling limits, and identify workloads that cannot be scheduled due to resource shortfalls. Kubernetes Dynamic Resource Allocation allows consumable device capacity to be requested via ResourceClaimTemplate objects, with requestPolicy constraints controlling how those capacities are consumed across allocations; device capacity can define a default request policy value and valid range with step increments. The Supervisor Monitor tab under vSAN provides a Capacity view for tracking how much capacity stateful service objects are consuming.

VM classes in VKS support two reservation types: guaranteed, which fully reserves configured resources so that requests equal limits, and best effort, which does not hold resources in reserve. The choice of VM class reservation type affects how compute capacity is consumed under varying load conditions and is relevant to capacity planning for VM-based workloads on the platform. Kubernetes production cluster guidance recommends maintaining a capacity expansion plan based on expected pod and container counts, with additional capacity provisioned to allow critical workloads to reschedule in the event of node failures.

VMware Private AI Services (PAIS) provides several mechanisms that support capacity management for AI workloads. These mechanisms operate at multiple layers: organization quotas, region quotas, zone configurations, VM class and storage class reservations, infrastructure policies, and observability for capacity trending.

The foundation of capacity management in PAIS is the organization quota system. Organization region quotas in VCF Automation accept only finite CPU and memory limits and reservations; unlimited resources cannot be assigned. CPU and memory reservations cannot be over-provisioned, though CPU and memory limits and storage can be. VCF Automation creates a resource pool for the namespace in the clusters that correspond to the specified zones, applying the reservation and limit values to that resource pool so the platform enforces the quota at runtime.

Within organizations, capacity is allocated through region and zone quotas. Provider administrators use the VCF Automation Provider Management portal to configure a region and assign region quotas, with quotas based on the zones selected for one or multiple supervisors. For each zone, CPU and memory limits and reservations are specified along with reserved or non-reserved VM classes and storage classes; storage limits per storage class are configurable. Region quotas can include explicit



GPU resource counts by profile (for example, H100 and L40 vGPU profiles assigned per zone). The PAIS SupervisorNamespaceClassConfig captures these per-zone CPU limits, CPU reservations, memory limits, and memory reservations as a managed configuration object. When an organization quota spans multiple supervisors in the same region, a separate region quota is required for each supervisor, so administrators account for each physical boundary in their capacity plan.

VM class reservations provide another layer of capacity control designed specifically for AI workloads. Zone capacity is configured through reserved VM class instances, where each reservation specifies a VM class name and a count of reserved instances in the zone. VM class capacity is reserved in Supervisor zones to support resource availability for the workloads that run there. For workloads requiring GPU resources, VM classes with GPU reservations require capacity configuration using the `dcli` command, which sets reserved VM class instances with a count parameter per zone. Guaranteed VM classes are not permitted in a region quota with zero reservation, and guaranteed VM classes are not allowed in a quota unless CPU and memory reservations are provided to all zones, so resource availability commitments are tied to explicit capacity configuration. GPU-enabled workload domains receive license capacity allocation, while the management domain does not.

When AI catalog items are created in VCF Automation through the Private AI Services quickstart, an infrastructure policy is selected to define the quality and quantity of resources that the PAIS DSM database can consume from vSphere clusters; the policy also determines which storage policies and VM classes are available. A default storage policy can be selected to define storage placement and resources for the database. AI Kubernetes cluster deployments require selection of a storage class that defines storage placement and resources for the virtual machines, and the PAIS VKS control plane configuration requires specification of a VM class and storage class to represent the resources allocated to control plane nodes. PAIS model endpoints similarly use storage class policies that describe storage requirements and classes of service for the VMs created for the Kubernetes cluster nodes running the model. The containerd storage volume used by PAIS workloads is sized at 100 GiB and mounted at `/var/lib/containerd`, giving administrators a fixed local-image footprint to plan against.

PAIS also supports observability for capacity planning. A Prometheus server is deployed in the Private AI Services namespace with its own metrics database backed by a Persistent Volume; storage size for that database is inferred from the metrics retention property in the PAISConfiguration custom resource, allowing administrators to plan monitoring infrastructure capacity alongside AI workload capacity. The VCF Consumption CLI connects to the Supervisor endpoint and streams metrics from the PAIS controller pod, and PAIS metrics can be visualized in Grafana for monitoring and troubleshooting, including LLM completion API response times, inference engine tokens-per-second generation rate, and GPU compute and memory utilization. These signals feed the organizational capacity planning process that the control evaluates.

### **VMware vDefend (Contributes)**

VMware vDefend includes capacity and performance management capabilities specific to its security processing infrastructure through the Security Services Platform (SSP).

The SSP provides a Platform Host Capacity view that gives administrators visibility into resource utilization across the security processing cluster. This view tracks cluster data, unexported flow data, total flows, prioritized applications and groups, the average number of flows every five minutes, and the data collection status per cluster. The SSP also displays a time-series graph showing flow distribution over an hour and generates a warning notification when unexported flows affect the prioritized collection of applications and groups. SSP monitors which hosts are operating within capacity and which are capped when flows on the host exceed capacity. The system dashboard provides flow processing capacity analysis to display cluster sizing requirements.

When approaching capacity limits, vDefend provides actionable guidance: administrators can monitor specific metrics, add worker nodes, disable flow collection on certain hosts or clusters, or rebalance virtual machines across transport nodes to manage system performance. Resource reservation is enabled by default for SSP deployments, reserving the required CPU and memory at the resource pool level. The documentation advises against oversubscribing host CPU and memory, and recommends adjusting virtual machine allocations or migrating virtual machines when resources are insufficient.

SSP includes tools to manage license pool consumption for capacity reservations in mission-critical production sites and to set hard limits for development environments, supporting capacity planning across different environment tiers.

Host Transport Node Metrics monitoring helps detect capacity constraints within the Distributed Firewall processing layer, allowing administrators to optimize resource allocation and verify that security enforcement does not affect workload performance. DFW Resource Utilization Metrics provide a dedicated view for capacity planning and performance troubleshooting within the Distributed Firewall. For IDS/IPS deployments, administrators can assess current CPU and memory load on ESX hosts to identify hosts with unused capacity that can accommodate the IDPS engine without performance degradation.

Broader infrastructure capacity planning across compute, storage, and networking is handled by VCF Operations, which provides the full assess, optimize, and plan lifecycle for the overall VCF environment.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides several resource prioritization and protection controls that contribute to limiting and managing resource consumption across its services.

The DR REST API Gateway includes a multi-tier rate limiter designed to manage the risks of API resource exhaustion. At the IP address tier, the system enforces a default quota of 100 requests per IP address within a 60-second window. At the service tier, the system enforces a default quota of 1,000 requests per service name within a 60-second window, where service names include srm, vr, and configure. These thresholds are configurable, and administrators should evaluate the settings based on their deployment requirements.

Recovery plan execution uses a five-level priority system (priority 1 through priority 5) that controls the order in which virtual machines are powered on during failover or test recovery. Administrators assign virtual machines to priority groups so that business-critical workloads receive resources first. The Protection and Recovery server powers on groups of virtual machines according to priority, requiring all virtual machines in the next-higher priority group to recover or fail before the next priority group starts. Virtual machine dependencies must be placed in the same priority group, and the system tracks when a dependent virtual machine has a different priority than its dependency, flagging the status as Lower Priority or Higher Priority for administrator review. For large environments, PNR supports a configurable limit on the number of concurrent power-on and power-off operations, which helps prevent infrastructure overload and operation timeouts during recovery plan execution.

For recovered virtual machines at the target site, PNR supports resource pool mapping with reservations, limits, and affinity rules. Administrators configure resource pools on the recovery site and map them to source-site pools so that recovered workloads inherit appropriate resource allocations. The replication.createPlaceholderVmWithMinResources advanced setting, which defaults to false, can be set to true to have PNR use minimum CPU and memory resources when creating placeholder virtual machines, preventing recovered workloads from starting with insufficient resources.

PNR monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached, providing visibility into resource contention affecting the DR management infrastructure. The Protection and Recovery unified dashboard in VCF Operations displays a historical chart of bandwidth consumed by replication tasks relative to available capacity and tracks virtual machine utilization trends over time to identify machines with high utilization that may experience performance degradation. For replication traffic, administrators can manage bandwidth consumption by adjusting RPO targets, deactivating replication on high-change-rate virtual machines when bandwidth is constrained, or enabling data compression, which requires additional CPU resources on both the source site and the server managing the target datastore.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) contributes to capacity management through Infrastructure Policies, VM classes, IP pool sizing requirements, and per-database resource monitoring. These mechanisms give administrators the tools to plan for and constrain resource consumption within the database platform.

Infrastructure Policies are the primary capacity control mechanism in DSM. Administrators configure Infrastructure Policies to define and set limits on the specific compute, storage, and network resources that database workloads can consume from vSphere clusters. The DSM console displays all configured infrastructure policies, including their compute, storage, and



networking resource definitions and the VM classes each policy permits, giving administrators a view of the resource boundaries placed on DSM-managed workloads.

VM classes provide the per-database resource allocation unit. Each VM class specifies the vCPUs and memory in GiBs assigned to provisioned database VMs. When a user provisions a database, they select from the VM classes defined in the Infrastructure Policy. Administrators can adjust vCPU and memory allocations for database VMs at runtime without reprovisioning the database, supporting capacity adjustments as workload demands change. In DSM, enforcement of specific hardware allocations extends to SQL Server clusters to maintain their performance and stability within the containerized environment.

IP pool sizing is an explicit capacity planning requirement in DSM. IP pools must be sized to support the total number of database clusters expected to run simultaneously, plus reserve capacity for maintenance operations such as database engine upgrades and cluster topology changes, each of which temporarily requires additional IP addresses. DSM recommends monitoring IP pool utilization and expanding pool ranges or creating additional pools before capacity is reached. Global alerts are available to notify administrators when IP pool capacity approaches its limits.

The DSM Monitoring page provides visibility into database VM performance and resource consumption. Administrators can view metrics including Active Connections, Data Disk Usage, Write Throughput, Read Throughput, and Thread Resource Utilization for each database node VM. DSM also tracks system resource utilization metrics for CPU, memory, and data disk use through VCF Operations to help identify potential bottlenecks.

The Provider VM itself has sizing requirements tied to the volume of services it manages. Resources configured for a DSM Provider VM must be determined based on the type of environment in which it runs and the volume of services it manages, requiring upfront capacity planning when deploying the DSM management plane.

When DSM is deployed with VCF Automation as a provider, the Supervisor cluster must have sufficient CPU, memory, and storage resources available to schedule the DSM Consumption Operator pod. In this deployment model, infrastructure policies are created as cluster-scoped resources in the consumption cluster, and capacity planning for the Supervisor cluster is a prerequisite for successful scheduling.

Satisfying this control fully requires organizational processes for capacity forecasting and review that extend beyond what DSM provides at the platform level. DSM supplies the technical controls for constraining and monitoring database resource consumption; the broader organizational capacity management program, including demand forecasting, regular capacity reviews, and escalation processes, must be defined and operated by the organization.

### **VMware Avi Load Balancer (Meets)**

VMware Avi Load Balancer provides application-layer capacity management mechanisms across three areas: real-time capacity visibility through Pool and Service Engine metrics, proactive capacity management through elastic scaling and configurable resource controls, and multi-tenant capacity governance through the VCF organization-managed mode introduced in 9.1.

On the visibility side, the Pool Metrics system tracks both Estimated Capacity (the pool's maximum possible connections) and Available Capacity (currently open connections) at the pool level. Pool Metrics deliver specialized analytics and performance data representing the health and capacity of backend pool servers. At the individual server level, the `l4_server.avg_available_capacity` metric estimates connections-per-second capacity available for each server, calculated as the difference between maximum capacity and average load. The License Hub Platform Dashboard Resources tab visualizes hardware consumption overall and per controller and worker node, including System Load tracking of overall CPU demand against allocated vCPU capacity on a 15-minute average.

On the scaling and configuration side, each Service Engine has a maximum capacity for processing traffic measured in terms of traffic throughput or SSL transactions per second, which is a function of the SE VM size (number of vCPUs or memory), type of traffic, and deployment environment. CPU and memory reservations with limits set to unlimited are recommended for Service Engine virtual machines to achieve consistent and deterministic performance. Elastic HA N+M mode allows administrators to define a buffer expressed as M, an integer count of buffer Service Engines. When an N+M group is scaled

out to the maximum number of Service Engines, Avi Load Balancer permits additional virtual service placements into the spare capacity represented by M. Pool configuration allows setting the maximum number of connections per server on the Advanced tab to help prevent servers from being overloaded and to maintain optimal connection handling.

In the 9.1 Avi for VCF integration, organization-managed mode adds Service Unit quota enforcement per organization. Provider administrators can assign either a quota measured in Service Units or specific Service Engine Groups to organizations through the VCF Automation Provider Management portal, establishing resource governance to help prevent organizations from over-consuming shared Avi Load Balancer resources. In organization-managed mode, the provider or Load Balancer administrator manages resource assignments to enforce quotas and resource boundaries, and organization administrators can edit a Service Engine Group to scale the underlying performance (CPU and memory) or modify high-availability behaviors. Service Engine capacity provisioned on the Avi Controller is periodically reported, and the license quota reservation mechanism can be configured to keep a specific amount of capacity always available for a tier when a consumption ceiling is set.

These mechanisms give operations teams the metrics and controls needed to assess current application delivery capacity, monitor utilization trends, and adjust Service Engine group configuration or scale out in response to demand. The organizational processes for defining capacity plans, setting review cadences, acting on threshold alerts, and making scale decisions remain the responsibility of the organization.

## Control PR.PS

> [Withdrawn: Incorporated into ID.AM-08, PR.PS-03] Configuration management practices are established and applied Software is maintained, replaced, and removed commensurate with risk Hardware is maintained, replaced, and removed commensurate with risk Log records are generated and made available for continuous monitoring Installation and execution of unauthorized software are prevented Secure software development practices are integrated, and their performance is monitored throughout the software development life cycle [Withdrawn: Incorporated into PR.PS-01] [Withdrawn: Incorporated into ID.AM-08, PR.PS-06] [Withdrawn: Incorporated into PR.PS-01, ID.RA-07] [Withdrawn: Incorporated into ID.RA-01, PR.PS-02] [Withdrawn: Incorporated into ID.AM-08, PR.PS-02] [Withdrawn: Incorporated into PR.PS-04] [Withdrawn: Incorporated into PR.DS-01, PR.PS-01]

**SCF Controls:** CFG-01, CFG-02, CFG-02.1, CFG-02.5, MNT-01, MNT-02

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce\_for\_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKrs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. `AppArmor` and `SELinux` provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as `ConfigMaps` and `Secrets`.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references `ConfigMaps` containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per

application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

### **VMware vDefend (Contributes)**

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs, and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database



instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use scram-sha-256 as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support scram-sha-256, reject, and cert authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application

security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.



## Control PR.PS-01

> Configuration management practices are established and applied [Withdrawn: Incorporated into PR.PS-01] [Withdrawn: Incorporated into PR.PS-01, ID.RA-07] [Withdrawn: Incorporated into PR.DS-01, PR.PS-01]

**SCF Controls:** CFG-01

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides a layered configuration management capability spanning infrastructure state definition, drift detection, policy enforcement, and workload-level configuration automation.

VCF Operations includes a Configuration Templates feature that allows administrators to define a desired state as a set of configurations and then monitor the environment against those definitions. Configuration templates are created and managed through the Fleet Management > Configuration Drifts interface in VCF Operations, or through the Infrastructure Operations > Configurations > Policy Definition interface. VCF Operations supports managing global configuration templates across multiple vCenter instances, with the ability to assign templates to policies, activate them, and enforce them across the fleet.

The Configuration Drifts feature provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters, comparing the current vCenter value against the configuration template value for each instance. When a deviation from assigned template values occurs, a configuration drift notification alerts administrators. The Configuration Drift dashboard allows viewing and comparing drifts, and the Detect Drift function can be run across all configuration templates to display results in a consolidated drifts table. Drift detection can also be scheduled, enabling continuous detection of configuration deviations from the desired state without manual intervention.

Source control integration extends the configuration management program with version control, change tracking, and auditability. VCF Operations can synchronize configuration templates to and from a supported source control repository, enabling versioning, auditing, and controlled management of templates. This integration facilitates accurate configuration updates, supports change control with reviews, and enables continuous integration and continuous development workflows for automated testing and validation of configuration changes.

VCF Operations provides policy management capabilities through the Infrastructure Operations Configurations module, including the ability to add, edit, and remove policies. The Configure Host Security Config Data workflow allows selective enforcement of host security hardening rules by configuring enforcement options for individual configuration elements. VCF Operations also supports export of configuration content, including configuration files, policies, compliance scorecards, and global settings, enabling backup and portability of configuration baselines. The config polling interval can be adjusted to control how frequently configuration data is collected from data sources, allowing administrators to tune the monitoring cadence to their operational requirements.

vSphere Lifecycle Manager (vLCM) provides image-based lifecycle management for ESX hosts, maintaining consistency by defining and enforcing approved host images across the fleet. vLCM manages all hosts in a cluster collectively with a single image, and clusters are assigned a base image and optional vendor add-on to define the desired state. When hosts deviate from the defined image, the cluster reports a non-compliant status, and remediation installs the approved image across all hosts in the cluster. vSphere Lifecycle Manager images are created in the vSphere Client and then imported into VCF using VCF Operations.

vSphere Host Profiles provide a complementary mechanism that captures the configuration of a validated reference host, including memory, storage, networking, and advanced settings, stores it as a managed object, and enforces it against other hosts to detect and remediate configuration deviations. vSphere Configuration Profiles extend this to the cluster level through JSON configuration documents that can be downloaded, edited offline, and imported, with built-in alarm support to notify administrators of configuration drift via email or SNMP traps.

At the Kubernetes consumption layer, VMware Kubernetes Service (VKS) extends configuration management with a Kubernetes-native declarative model in which every cluster component, workload, and security policy is expressed as a YAML

manifest. Kubernetes recommends that object configuration be stored in a source control system such as Git to enable change review processes and audit trails. VKS cluster security configurations are immutable and persistent by design, moving away from manual node-level configuration. ClusterClass configuration variables expose granular control over cluster infrastructure across releases, and the VKS Add-on Management feature provides a declarative API for add-on installation and configuration across a fleet of workload clusters through AddonConfig resources. The Cluster API, which underlies VKS cluster creation and management, provides declarative, Kubernetes-style APIs for the full cluster lifecycle including creation, configuration, and ongoing management. StatefulSet controllers use ControllerRevision objects to track historical configuration changes, supporting rollback and version tracing. Kubernetes Operators extend the declarative model to custom resources by interacting with the API server to reconcile the actual state of complex stateful applications and services against a declared desired state, enabling management of domain-specific workloads beyond native Kubernetes primitives. Kubernetes ConfigMaps separate application configuration from container images by storing configuration data as key-value pairs; they can be updated at runtime to propagate changes to running pods without requiring a pod restart. The KubeletConfiguration API type, managed through kubeadm, centralizes kubelet configuration across cluster nodes.

The Argo CD Supervisor Service implements a GitOps model for the consumption layer: all infrastructure and application configurations are expressed declaratively in a Git repository, and Argo CD can automatically apply changes from the repository to the target environment. Argo CD also manages VKS cluster lifecycle, with applications defined in Git referencing cluster lifecycle management manifests that target a specific namespace and Kubernetes API server endpoint, extending configuration-as-code governance from workloads to the clusters themselves. Argo CD continuously monitors the live application state against the desired state in Git, tracks per-resource sync status and health state, and reports deviations as OutOfSync. It provides both a CLI and a web-based UI for defining applications and visualizing cluster configuration drift, paralleling the drift-detection capability at the VCF Operations layer. Kustomize, available as a Kubernetes-native configuration management tool, transforms base resource manifests through declarative patching, field customization, and resource composition, enabling environment-specific variation without modifying source manifests. VKS Cluster Management Policies use the open-source OPA Gatekeeper as the policy engine for Security, Registry, Mutation, and Custom policy types; custom Security Policy templates allow organizations to fine-tune security context parameters and governance controls to their specific requirements. Security Technical Implementation Guides (STIGs) for Supervisor and VMware Kubernetes Release (VKr) deployments are available through Tanzu STIG Hardening, providing a structured configuration baseline for organizations building a configuration management program across the full VCF stack.

VCF Automation extends configuration management to workloads through integration with Ansible Open Source, Ansible Automation Platform, and Puppet Enterprise. Ansible integration is configured through Infrastructure > Connections > Integrations > Add Integration > Ansible Tower, and allows automated configuration management of VM-based applications deployed on the platform. Puppet Enterprise integration requires establishing a connection between the external Puppet system and the VCF Automation instance and is available on all projects by default. VCF Automation policies apply to both current and new deployments, and the Provisioning Service API allows programmatic integration and centralization of configuration properties.

VMware Private AI Services (PAIS), formerly Private AI Services, provides structured, configurable mechanisms that organizations can apply as part of a configuration management program for AI infrastructure on VCF.

The PAISConfiguration Custom Resource Definition (CRD) is the central PAIS configuration artifact. Administrators define PAIS settings in a YAML file compliant with the PAISConfiguration CRD, with sections for storage policy, CA trust bundles, PostgreSQL database connection, OIDC provider integration, and ingress service type. Configuration is managed using kubectl to update or patch the PAISConfiguration custom resource. Client TLS configuration references CA bundles for OIDC provider and Harbor authentication, with trust bundles supplied through ConfigMap resources referenced in the spec.clientTls.caBundleRefs section. The documentation recommends organizing CA trust bundles per application and monitoring them for certificate expiration so renewals are applied before associated certificates expire. When a CA certificate is selected and added from the namespace, PAIS is updated with a new ConfigMap resource.

Harbor Registry integration provides configuration control points for AI model distribution and lifecycle management. PAIS deployment uses Harbor replication rules with configurable filters, target namespaces, and trigger mode controls, including

manual trigger mode for explicit replication runs. Disconnected (air-gapped) environments use a Bastion and Admin host pattern for PAIS setup, with replication configured to a destination registry aligned to organizational requirements.

The VCF Automation Provider Management surface manages region configuration and quotas for PAIS deployments. Provider administrators configure regions by selecting an NSX Manager instance integrated with the vCenter instances for the region, then assign region quota based on the zones selected for one or more supervisors. Regions are associated with supervisor clusters for PAIS deployment. VCF Automation aggregates zones with the same name across multiple supervisors in a region, combining their CPU, memory, and reserved VM class resources and presenting them as a single unit at the region level.

VCF Automation provides catalog items for provisioning AI workloads, including Deep Learning VMs and GPU-accelerated VMware Kubernetes Service (VKS) clusters, through a self-service catalog organizations configure to their deployment standards. The PAIS Quickstart generates blueprints that can be customized for deployment on VCF Automation. Passwords entered in the PAIS Quickstart, including the private container registry password and proxy password, are saved as secrets in VCF Automation rather than embedded in catalog item definitions. PAIS Data Services Manager (DSM) database resource allocation is controlled through an infrastructure policy that defines the quality and quantity of resources the database can consume from vSphere clusters, with associated storage policies and VM classes.

PAIS observability is configured through the same PAISConfiguration custom resource. Prometheus runtime metrics collection is activated by uncommenting the `spec.observability.prometheusRuntime` section and supplying a storage class and configurable metrics retention period; LLM traces can be exported to an OpenTelemetry Collector through the same configuration path. VI administrators can visualize PAIS controller pod operation metrics in VCF Operations, with Telegraf user configuration stored in a `telegraf-user-config` ConfigMap in the `vmware-system-monitoring` namespace. The VCF Consumption CLI provides a command-line interface for cluster management capabilities through a plugin installation command, giving administrators a scriptable surface for repeatable PAIS workload operations.

### VMware vDefend (Contributes)

VMware vDefend provides configuration management mechanisms for its network security policy infrastructure, contributing to an organization's broader configuration management program.

The vDefend distributed firewall (DFW) supports a draft configuration management workflow that separates policy authoring from activation. Administrators prepare and review firewall policy changes in draft form before publishing them to the enforcement plane. Draft configurations can be saved as a new configuration or as an update to an existing one, and can be locked with an optional comment requirement to enforce change control discipline. Auto drafts and manual drafts can be cloned and saved, with the option to edit the name and lock the configuration with a required comment. Export options include the published configuration, an auto-saved draft, or a manually saved draft. The Publish function commits a draft and makes it active; the Revert function returns the environment to the previous published configuration. Auto-drafts and saved manual drafts can be loaded and published at any time, giving administrators the ability to restore a prior policy state after a change.

In federated deployments, a Global Manager provides centralized configuration management across distributed Local Manager sites. IDS/IPS signatures, profiles, Distributed Firewall and Gateway Firewall policies, oversubscription settings, and syslog settings can all be managed centrally from the Global Manager and applied across all Local Managers. This enables consistent security policy baselines across geographically distributed environments.

The vDefend also supports full rollback capability, which deletes newly added policies and reverts the security configuration to its prior state in reverse order. This applies to broader policy migration and transition scenarios, beyond the draft-level Revert function.

Security Services Platform (SSP) extends configuration management to vDefend's detection and prevention services. The SSP deployment wizard conducts validations before implementing configuration changes to confirm that configurations are correct and compatible. The SSP Configuration Database is the storage layer for system settings and configurations. SSP also extracts all IDS policies, rules, and security profiles to support multiple remediations, clean up stale policies, and suggest policies that do not conflict with each other. IDS/IPS remediation policies can be verified by navigating to Security > IDS/IPS & Malware

Prevention > Emergency Threat Rules. Security policies defined within SSP are propagated and enforced across Bare Metal servers as well, extending policy management scope beyond virtual workloads.

Administrators can use flow inactivity data and Security Intelligence recommendations to identify and remove unused or outdated DFW policies and rules, supporting configuration lifecycle hygiene. Security Intelligence's segmentation posture assessment stores data in a Configuration Management Database (CMDB) within the Security Services Platform, maintaining application context and workload attributes. Segmentation planning supports importing workload context from flat files containing IP addresses, subnets, virtual machines, logical segments, and organizational roles, allowing administrators to establish a baseline for policy configuration decisions.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides several configuration management mechanisms specific to disaster recovery operations.

The Configuration Import/Export Tool allows administrators to export and import PNR configuration data, including inventory mappings, recovery plans, protection groups, and related objects, into XML files. This capability supports configuration versioning and backup by capturing the complete disaster recovery configuration state: server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array manager information with Storage Replication Adapter details. The tool provides schema support for programmatic configuration management and offers multiple export and import modes. Administrators can use a properties file (`srm_configuration.properties`) to simplify or automate the import process, invoke the `import-export.jar` utility interactively using the `--importInteractive` flag with parameters for the XML file path, delay, and retry count, or use a script-based method that exports configuration data without requiring credential entry. Exports can be integrated directly into recovery plans as callout steps, so configuration data is captured automatically during recovery operations.

The Protection and Recovery Appliance Management Interface allows administrators to configure network settings on the appliance after initial deployment. PNR upgrade procedures preserve advanced settings and configurations from the prior release, maintaining configuration continuity across version changes. Advanced settings can also be modified through the Site Pair > Configure > Advanced Settings interface in the product UI.

The DR IP Customizer tool provides structured management of network configuration for protected virtual machines. It generates CSV files describing the IP properties of protected VMs grouped by site and recovery plan, which administrators can modify with recovery-site-specific values and reapply. This structured approach supports repeatable and auditable network configuration changes during recovery operations.

Storage Replication Adapter (SRA) configuration management is supported through the Appliance Management Interface, which provides a Download Configuration Archive function for retrieving and importing SRA configurations. PNR also rescans storage arrays every 24 hours by default to detect configuration changes.

In deployments that integrate with VCF Automation, Provider Administrators install PNR in desired regions, pair regions together, and manage organizational access to PNR capabilities through the VCF Automation Provider Management UI. The VCF Operations Orchestrator Plugin for Protection and Recovery requires administrator login to access and execute workflows for managing site mappings and network configurations.

Access to PNR configuration changes is governed by role-based access control. Granular permissions restrict who can modify advanced settings, manage array managers, and create, modify, or execute protection groups and recovery plans, supporting separation of duties for configuration change management.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) supports configuration management by providing structured mechanisms for defining, applying, and monitoring the configuration of database infrastructure components. Administrators interact with DSM through two primary interfaces: the Provider UI for system-wide settings and the vSphere Client for infrastructure configuration. The Settings view in the Provider interface is the central location for managing system-wide settings, including LDAPS integration, SMTP configuration, and directory service settings. The Administrator Dashboard displays at-a-glance metrics covering the

number of configured users, their assigned roles, and the types and counts of provisioned database services, giving administrators a current view of deployment state.

Infrastructure configuration in DSM is governed by infrastructure policies. These policies define which VM classes are available for database VMs, which storage policies apply, and which vSphere clusters and namespaces are used during provisioning. Infrastructure policy configuration requires that placements, storage policies, VM classes, and IP ranges be correctly configured for valid policy status. Policies that are actively in use by a database cannot have their existing settings modified, though new compute resources with corresponding parameters can be added; unused policies can be changed at any time. VM classes are configurable resource profiles that specify vCPU cores and memory allocation, and can be defined to match organizational capacity standards. Infrastructure policies also establish guardrails that restrict the quantity and quality of resources DSM users can consume from vSphere clusters. Configuration tasks performed during initial deployment include configuring IP pools, defining VM classes, assigning user permissions, creating infrastructure policies, and selecting storage policies.

Database-level configuration is managed through the database instance settings. DSM allows configuration of database instances using either custom or default configuration profiles, with configuration properties varying by database type (PostgreSQL, MySQL, MinIO, or SQL Server). DSM automates provisioning, backups, and security patch application for managed database instances. After initial provisioning, database VM resource configuration can be adjusted at runtime. Optional database configuration parameters for PostgreSQL and MySQL databases can be added or removed after database creation. Maintenance windows can be configured to control when software updates and database option changes are applied, providing a mechanism for scheduled, controlled configuration changes.

DSM provides a Maintenance Policy editor, accessible from the Version & Upgrade section under the DSM System tab, for configuring automatic software updates of the DSM plug-in within defined maintenance windows. The DSM controller manages component and feature dependencies through status monitoring and automated remediation.

When integrated with VCF Automation, DSM supports data service policies that define and enforce configurations for each tenant or organization. These policies can be enforced across different namespaces and namespace labels to maintain a uniform configuration posture. The Consumption Operator automates database deployments based on predefined infrastructure and backup policies, reducing the scope for manual configuration drift.

DSM provides visibility into configuration activity through the Operations tab, which displays the progress of database configuration changes, resource changes, and disk extension tasks. A support bundle can be created and downloaded to collect diagnostic information for troubleshooting system configuration failures. DSM system configuration is also managed through a `dsmsystemconfig` Custom Resource within the gateway, which can be inspected via SSH access to the appliance VM to review directory service status and configuration details.

DSM's contribution to a configuration management program is at the platform level: it provides technical mechanisms for defining baseline configurations through policies and VM classes, enforcing them during provisioning, and tracking changes through operational visibility. The broader configuration management program, including change control processes, configuration baseline documentation and approval, configuration audits against external standards, and periodic review cycles, must be established and maintained by the organization.

### **VMware Avi Load Balancer (Contributes)**

Avi Load Balancer provides several mechanisms that support the implementation of configuration management controls across the application delivery layer.

The Controller maintains a centralized Configuration Database that stores all configuration information including tenants, virtual services, pools, policies, and accounts. This is the single source of truth for all system settings. When an administrator makes a change through the web interface, CLI, or REST API, that change is automatically propagated to all Controller cluster members, so any node can assume leadership with a complete and current configuration.

The Controller CLI provides direct access to the full configuration surface. The `configure systemconfiguration` command allows administrators to modify system-wide parameters including DNS, NTP, portal settings, and cryptographic algorithm

configuration, with changes synchronized to Service Engines. The `configure` command covers a broad range of objects including virtual services, pools, health monitors, authentication profiles, application profiles, and policy sets, and supports creation, modification, and deletion of those objects. The REST API exposes comparable capabilities programmatically, including the `PUT api/systemconfiguration` endpoint for system-wide settings and the `/api/cloud` endpoint for cloud configuration resources.

Configuration management in Avi can be automated through the Ansible `aviconfig` role, which allows configurations to be expressed as structured dictionaries and applied in a repeatable manner, reducing the need for multiple individual task definitions. The Controller supports on-demand configuration backup and restore, enabling disaster recovery and configuration migration across Controller instances.

In the 9.1 VCF integration, Avi distinguishes between two operational modes: Provider-Managed Mode, where the provider administrator manages Service Engine Group settings including scale-out, CPU, and memory configurations; and Organization-Managed Mode, where the organization administrator manages their own Service Engine Group configurations and infrastructure settings. This separation clarifies ownership and scope of configuration responsibilities within a shared VCF deployment. After upgrading Avi components, a drift check should be performed against VCF Operations, vCenter, and NSX Manager to verify configuration consistency across the stack.

For Kubernetes environments, the Avi Kubernetes Operator (AKO) configuration is customized through the `AddonConfig` resource, a Supervisor namespace-scoped resource that supports modification of parameters such as logging level and shard virtual service size.

The Config Events overlay in the Service Engine Analytics view allows operators to correlate configuration changes with observed traffic behavior, supporting investigation of the impact of individual changes. Avi Load Balancer events provide the building blocks for configuration automation workflows.

Organizations should define change control procedures, assign ownership of configuration baselines, and determine which changes require approval before these mechanisms can function within a formal configuration management program. Avi provides the technical instruments; the program structure requires organizational governance.



## Control PR.PS-02

> Software is maintained, replaced, and removed commensurate with risk [Withdrawn: Incorporated into ID.RA-01, PR.PS-02] [Withdrawn: Incorporated into ID.AM-08, PR.PS-02]

**SCF Controls:** MNT-01, MNT-02, MNT-03, MNT-03.1, PRM-07, SEA-07.1, TDA-17, VPM-01, VPM-01.1, VPM-02, VPM-05

**Aggregate Coverage:** Meets

### VCF (Meets)

VCF provides integrated lifecycle management capabilities for conducting controlled maintenance activities across the full infrastructure stack, spanning host servicing, component updates, and operational monitoring.

VCF Operations includes a maintenance mode capability that allows administrators to place managed objects into maintenance mode either manually or on a defined schedule. Manual maintenance mode can be applied indefinitely or for a specified duration in minutes, and it can be started or stopped independently of any assigned recurring schedule. For recurring maintenance windows, administrators can create maintenance schedules that place objects in maintenance mode at fixed intervals, such as from midnight until 3:00 a.m. on a specific night each week. These schedules are configured per policy through the Policy Definition interface in VCF Operations. When objects are in maintenance mode on schedule, VCF Operations suppresses alerts and status indicators for those objects, preventing misleading data that would otherwise result from objects being offline or in an unusual state during planned maintenance.

VCF Operations also supports automation of maintenance tasks through Automation Central, which allows administrators to create jobs that schedule actions to run automatically. Jobs can be configured with daily, weekly, or monthly recurrence and set to end after a specific date or number of occurrences. The VCF Operations orchestrator further supports scheduling of workflow runs at specified dates, times, and intervals. These capabilities allow maintenance tasks to run during defined windows without manual supervision.

Lifecycle management in VCF provides tools for planning and executing updates across the software stack. Starting with VCF 9, component lifecycle management is performed through the VCF Operations UI, which centralizes update and patch deployment for all VCF components. Administrators can schedule maintenance windows and coordinate changes to reduce disruption to services. Configuration updates are required to be performed during a maintenance window. VCF lifecycle management automates the process of applying updates and patches to software components within the stack, and it manages version compatibility across VCF components to maintain stability during and after updates.

VCF delivers maintenance releases as scheduled, cumulative updates focused on platform stability and support. These releases are synchronized among VCF components through a new Bill of Materials, which coordinates versioning across the stack so that components remain compatible after each update cycle. Patch releases, by contrast, are not synchronized among all components and do not require a new Bill of Materials.

For workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor, the platform provides structured lifecycle management procedures at both the cluster and workload levels. Cluster-level lifecycle operations are performed through the Cluster API resource, which manages provisioning, scaling, and upgrades of VKS clusters. Node maintenance follows a defined sequence: operators cordon a node to prevent new workload scheduling, then drain it using `kubectl drain` to safely evict running pods before performing maintenance. Maintenance should not begin until the drain command completes, and operators should select worker nodes rather than control plane nodes when performing tasks such as checking for updates, preserving control-plane stability during the maintenance window. On shared clusters, operators should verify that cordoning and draining a node will not adversely affect other tenants before executing the operation.

For application updates within VKS clusters, Kubernetes rolling update strategies on Deployments, DaemonSets, and StatefulSets allow workloads to be updated with maintained availability. The `kubectl rollout` command manages the rollout lifecycle, supporting pausing, resuming, and rolling back changes. StatefulSet controllers use `ControllerRevision` objects to track historical configuration changes and maintain a revision history that enables rollback when updates need to be reversed. StatefulSet pods retain their identity and persistent storage when rescheduled to available nodes during maintenance, allowing stateful applications to survive node maintenance events without losing state. The `DaemonSetUpdateSurge` feature

gate enables DaemonSet workloads to maintain per-node availability during updates. Declarative object management using kubectl apply with version-controlled configuration files provides a controlled change mechanism that supports tracking what changed and restoring prior state if needed.

Kubernetes Operators running on Supervisor extend these capabilities by automating lifecycle procedures for stateful applications, including snapshot creation, StatefulSet and volume management, backup scheduling, and version upgrade orchestration. Operators allow complex, application-specific lifecycle procedures to be codified and applied consistently across environments. The Kubernetes TTL controller automatically removes finished Jobs based on configurable time-to-live settings, supporting lifecycle hygiene for batch workloads without manual intervention. Finalizers provide an additional mechanism for controlling the lifecycle and cleanup of resources owned by deleted objects.

The VCF Automation self-service catalog allows consumers to deploy IT resources and independently manage workloads through day-2 actions including updates and patches. Catalog items are scoped to projects, and lifecycle and day-2 actions for custom resources in a deployment must be shared with all relevant projects to support continued management after a deployment moves between projects. VCF building-block services have independent lifecycles, enabling individual components to be updated or maintained without requiring a complete platform maintenance window.

For backup data lifecycle maintenance, Velero on VKS clusters includes a configurable maintenance job system through the backupRepository.maintenanceJobConfig setting, which supports both global configuration and per-backup-repository maintenance job configuration. The fullMaintenanceInterval defaults to normalGC, and resource limits for maintenance job pods are tunable.

Supervisor system components, including the vmware-system-tkg controller manager, state metrics, and webhook components, are deployed across multiple replicas for high availability. This design allows component-level updates to proceed without requiring a complete platform maintenance window. Cluster health visibility is available through Kubernetes cluster conditions, including a Remediating condition that surfaces details about ongoing remediation of controlled machines. Readiness probes run throughout a container's lifecycle and allow the platform to detect and respond to recovery from temporary faults during or after maintenance events.

For host-level maintenance, VMware ESX hosts support a formal maintenance mode with dedicated API methods (EnterMaintenanceMode\_Task and ExitMaintenanceMode\_Task) that allow hosts to be taken offline for servicing in a controlled manner. Maintenance mode can also be managed through the ESXCLI interface. Administrators can verify whether a host is in maintenance mode using ``esxcli --server=<server_name> system maintenanceMode get``, and access to maintenance mode operations is governed by the ``Host.Config.Maintenance`` privilege, which controls the ability to place a host in and out of maintenance mode and to shut down and restart the host. When remediating hosts through Update Manager, administrators can configure maintenance mode settings to control how hosts enter and exit maintenance mode during patching operations. For vSAN clusters, placing a host in maintenance mode requires selecting a data evacuation mode, such as Ensure accessibility, Full data migration, or No data migration.

At the network layer, routine maintenance tasks for NSX Manager appliances include running backups, adding licenses and certificates, and changing passwords, providing a defined set of maintenance activities for the networking infrastructure.

### **VMware vDefend (Contributes)**

VMware vDefend provides lifecycle management and operational visibility capabilities through its Security Services Platform (SSP) that support controlled maintenance activities for the vDefend security infrastructure.

SSP's Platform Inventory Monitor gives administrators status visibility across environments, regions, zones, and virtual machines, identifying assets in success, timeout, or out-of-sync states. Filtering by name and status allows administrators to assess operational health before and after maintenance activities. The View details of external rollouts option in SSP displays progress details for Refresh operations covering Bare Metal servers, NDR Sensors, and Service VMs at both the individual and overall feature status levels, providing granular visibility into rollout state.

SSP enforces sequencing constraints on maintenance operations: Bare Metal Service operations such as onboarding, offboarding, and upgrading Bare Metal servers should not be performed while a backup or restore is in progress. After



restoring a backup in either a disaster recovery or in-place scenario, agent health status must be confirmed as Up on Bare Metal servers before proceeding. The vDefend CLI provides a command to display the health of all services and agents running on a Bare Metal server, giving administrators a mechanism to verify service state before and after servicing. SSP also includes Depot and Registry services that run as systemd-managed services and can be restarted and monitored via systemctl commands.

SSP proactively manages its Platform CA certificate lifecycle. The certificate manager and security intelligence services within SSP can be queried for operational status to diagnose service availability issues during and after maintenance events.

NDR Sensor management operations, including activating or deactivating features and offboarding sensors, are restricted to the Enterprise Admin or Security Engineer role, limiting who can execute maintenance actions on detection infrastructure. Tokens, Bare Metal servers, and Bare Metal server interfaces are included in the full inventory backup, supporting recovery after maintenance activities.

When using vDefend Intelligent Assist or Network Detection and Response remediation workflows, objects that encounter errors during remediation require manual cleanup, which is a constraint administrators should account for in maintenance planning.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) supports controlled maintenance through two configurable policy mechanisms: a maintenance policy for the DSM plug-in software itself, and per-database maintenance windows for database engine upgrades.

For plug-in software updates, administrators configure a maintenance policy that specifies a start date, start time (in hours and minutes), and a permitted duration for applying updates. The policy is accessible from the Version & Upgrade section under the DSM System tab in the DSM UI, as well as from the vSphere Client. This policy governs automatic upgrades of the DSM Provider Appliance plug-in, allowing organizations to schedule maintenance during off-peak hours and bound the duration of any resulting downtime. The policy can be edited during the 10-minute interval between automatic update attempts, which cancels the next scheduled attempt and applies the revised settings. If an automatic upgrade fails, administrators can reconfigure the maintenance policy to reschedule or perform a manual update.

For database engines, each database supports an individually configurable maintenance window that controls when minor version upgrades are applied. The default schedule is Saturday at 23:59 UTC with a six-hour duration, adjustable through the Edit Maintenance Window dialog. MySQL databases include an Enable Maintenance Window toggle with the same default schedule. SQL Server databases support configurable maintenance windows for both software version upgrades and operating system patching. In 9.1, DSM adds a Monthly Occurrences setting that refines the maintenance schedule from a standard weekly cadence to specific weeks within a month, allowing selection of a particular day and one or more specific occurrences of that day. If no specific occurrence is selected, the maintenance window runs every week. Maintenance window settings, including Monthly Occurrences, are also configurable when provisioning databases through VCF Automation. Administrators are prompted to define maintenance window schedules during database creation alongside backup policies.

The DSM controller manages component dependencies through status monitoring and automated remediation. DSM also provides operational visibility into maintenance activity through the database Status indicator and the Operations tab, which display in-progress operations, configuration changes, disk extension tasks, and restore operations. This allows administrators to confirm that maintenance actions have been applied and to identify those that have failed.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) provides several mechanisms that support controlled maintenance activities across its application delivery infrastructure.

For back-end server pools, Avi's health monitoring framework includes maintenance mode detection. Health monitors can be configured so that when a back-end server enters maintenance mode (signaled by returning a designated response code or response string), Avi automatically changes the server's health status to "down for maintenance" and stops routing traffic to it. This behavior is supported across TCP, UDP, HTTP, HTTPS, HTTP/2, and POP3/POP3S health monitor types. TCP and UDP

monitors use the `tcp-udp-maintenance-mode-filters` setting; HTTP monitors use the `maintenance_response` and `maintenance_code` CLI parameters; HTTP/2 monitors use the `maintenance-server-response-data` setting; POP3/POP3S monitors match a configured string such as `MAINTENANCE_ACTIVE` against the health-check response body. The maintenance mode detection monitor must be associated with the pool the server belongs to. Administrators and application developers can inspect health-check responses directly to validate server maintenance state. When the maintenance string or code is no longer returned, subsequent health checks restore the server to active rotation.

For Global Server Load Balancing (GSLB) operations, Avi enforces a controlled pre-maintenance step before a manual leader change. The CLI command `gslb maintenancemode enabled` must be run in GSLB configuration mode to place the leader Controller into maintenance mode before the leader change proceeds; the corresponding `gslb no maintenancemode` command exits maintenance mode. Avi GSLB can also direct traffic to alternative endpoints during planned maintenance, supporting service continuity while primary endpoints are offline.

For cloud-level maintenance, the Avi Controller provides a CLI workflow to place an entire cloud into maintenance mode using `configure cloud <name>` followed by the `maintenance_mode` directive. This is used during Controller upgrades and patch operations. The cloud exits maintenance mode via the `no maintenance_mode` directive.

For Kubernetes deployments using the Avi Kubernetes Operator (AKO), maintenance mode detection is available through the HealthMonitor custom resource definition (CRD). AKO HealthMonitor TCP monitors support a `maintenance_response` value, enabling Kubernetes-native maintenance workflows where health-check responses trigger traffic drain before maintenance begins.

For bare-metal Linux Server Cloud deployments hosting both Controller and Service Engine components, Avi defines a sequential maintenance procedure: Service Engines must be deactivated before hardware maintenance, host OS upgrades, security patching, or kernel updates on the host. Controller cluster nodes must be serviced one at a time to preserve cluster quorum and availability throughout the maintenance window.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

## Control PR.PS-03

> [Withdrawn: Incorporated into ID.AM-08, PR.PS-03] Hardware is maintained, replaced, and removed commensurate with risk

**SCF Controls:** MNT-01, MNT-02, MNT-03, MNT-03.1, PRM-07, SEA-07.1, TDA-17

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides integrated lifecycle management capabilities for conducting controlled maintenance activities across the full infrastructure stack, spanning host servicing, component updates, and operational monitoring.

VCF Operations includes a maintenance mode capability that allows administrators to place managed objects into maintenance mode either manually or on a defined schedule. Manual maintenance mode can be applied indefinitely or for a specified duration in minutes, and it can be started or stopped independently of any assigned recurring schedule. For recurring maintenance windows, administrators can create maintenance schedules that place objects in maintenance mode at fixed intervals, such as from midnight until 3:00 a.m. on a specific night each week. These schedules are configured per policy through the Policy Definition interface in VCF Operations. When objects are in maintenance mode on schedule, VCF Operations suppresses alerts and status indicators for those objects, preventing misleading data that would otherwise result from objects being offline or in an unusual state during planned maintenance.

VCF Operations also supports automation of maintenance tasks through Automation Central, which allows administrators to create jobs that schedule actions to run automatically. Jobs can be configured with daily, weekly, or monthly recurrence and set to end after a specific date or number of occurrences. The VCF Operations orchestrator further supports scheduling of workflow runs at specified dates, times, and intervals. These capabilities allow maintenance tasks to run during defined windows without manual supervision.

Lifecycle management in VCF provides tools for planning and executing updates across the software stack. Starting with VCF 9, component lifecycle management is performed through the VCF Operations UI, which centralizes update and patch deployment for all VCF components. Administrators can schedule maintenance windows and coordinate changes to reduce disruption to services. Configuration updates are required to be performed during a maintenance window. VCF lifecycle management automates the process of applying updates and patches to software components within the stack, and it manages version compatibility across VCF components to maintain stability during and after updates.

VCF delivers maintenance releases as scheduled, cumulative updates focused on platform stability and support. These releases are synchronized among VCF components through a new Bill of Materials, which coordinates versioning across the stack so that components remain compatible after each update cycle. Patch releases, by contrast, are not synchronized among all components and do not require a new Bill of Materials.

For workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor, the platform provides structured lifecycle management procedures at both the cluster and workload levels. Cluster-level lifecycle operations are performed through the Cluster API resource, which manages provisioning, scaling, and upgrades of VKS clusters. Node maintenance follows a defined sequence: operators cordon a node to prevent new workload scheduling, then drain it using `kubectl drain` to safely evict running pods before performing maintenance. Maintenance should not begin until the drain command completes, and operators should select worker nodes rather than control plane nodes when performing tasks such as checking for updates, preserving control-plane stability during the maintenance window. On shared clusters, operators should verify that cordoning and draining a node will not adversely affect other tenants before executing the operation.

For application updates within VKS clusters, Kubernetes rolling update strategies on Deployments, DaemonSets, and StatefulSets allow workloads to be updated with maintained availability. The `kubectl rollout` command manages the rollout lifecycle, supporting pausing, resuming, and rolling back changes. StatefulSet controllers use `ControllerRevision` objects to track historical configuration changes and maintain a revision history that enables rollback when updates need to be reversed. StatefulSet pods retain their identity and persistent storage when rescheduled to available nodes during maintenance, allowing stateful applications to survive node maintenance events without losing state. The `DaemonSetUpdateSurge` feature

gate enables DaemonSet workloads to maintain per-node availability during updates. Declarative object management using kubectl apply with version-controlled configuration files provides a controlled change mechanism that supports tracking what changed and restoring prior state if needed.

Kubernetes Operators running on Supervisor extend these capabilities by automating lifecycle procedures for stateful applications, including snapshot creation, StatefulSet and volume management, backup scheduling, and version upgrade orchestration. Operators allow complex, application-specific lifecycle procedures to be codified and applied consistently across environments. The Kubernetes TTL controller automatically removes finished Jobs based on configurable time-to-live settings, supporting lifecycle hygiene for batch workloads without manual intervention. Finalizers provide an additional mechanism for controlling the lifecycle and cleanup of resources owned by deleted objects.

The VCF Automation self-service catalog allows consumers to deploy IT resources and independently manage workloads through day-2 actions including updates and patches. Catalog items are scoped to projects, and lifecycle and day-2 actions for custom resources in a deployment must be shared with all relevant projects to support continued management after a deployment moves between projects. VCF building-block services have independent lifecycles, enabling individual components to be updated or maintained without requiring a complete platform maintenance window.

For backup data lifecycle maintenance, Velero on VKS clusters includes a configurable maintenance job system through the backupRepository.maintenanceJobConfig setting, which supports both global configuration and per-backup-repository maintenance job configuration. The fullMaintenanceInterval defaults to normalGC, and resource limits for maintenance job pods are tunable.

Supervisor system components, including the vmware-system-tkg controller manager, state metrics, and webhook components, are deployed across multiple replicas for high availability. This design allows component-level updates to proceed without requiring a complete platform maintenance window. Cluster health visibility is available through Kubernetes cluster conditions, including a Remediating condition that surfaces details about ongoing remediation of controlled machines. Readiness probes run throughout a container's lifecycle and allow the platform to detect and respond to recovery from temporary faults during or after maintenance events.

For host-level maintenance, VMware ESX hosts support a formal maintenance mode with dedicated API methods (EnterMaintenanceMode\_Task and ExitMaintenanceMode\_Task) that allow hosts to be taken offline for servicing in a controlled manner. Maintenance mode can also be managed through the ESXCLI interface. Administrators can verify whether a host is in maintenance mode using ``esxcli --server=<server_name> system maintenanceMode get``, and access to maintenance mode operations is governed by the ``Host.Config.Maintenance`` privilege, which controls the ability to place a host in and out of maintenance mode and to shut down and restart the host. When remediating hosts through Update Manager, administrators can configure maintenance mode settings to control how hosts enter and exit maintenance mode during patching operations. For vSAN clusters, placing a host in maintenance mode requires selecting a data evacuation mode, such as Ensure accessibility, Full data migration, or No data migration.

At the network layer, routine maintenance tasks for NSX Manager appliances include running backups, adding licenses and certificates, and changing passwords, providing a defined set of maintenance activities for the networking infrastructure.

### **VMware vDefend (Contributes)**

VMware vDefend provides lifecycle management and operational visibility capabilities through its Security Services Platform (SSP) that support controlled maintenance activities for the vDefend security infrastructure.

SSP's Platform Inventory Monitor gives administrators status visibility across environments, regions, zones, and virtual machines, identifying assets in success, timeout, or out-of-sync states. Filtering by name and status allows administrators to assess operational health before and after maintenance activities. The View details of external rollouts option in SSP displays progress details for Refresh operations covering Bare Metal servers, NDR Sensors, and Service VMs at both the individual and overall feature status levels, providing granular visibility into rollout state.

SSP enforces sequencing constraints on maintenance operations: Bare Metal Service operations such as onboarding, offboarding, and upgrading Bare Metal servers should not be performed while a backup or restore is in progress. After

restoring a backup in either a disaster recovery or in-place scenario, agent health status must be confirmed as Up on Bare Metal servers before proceeding. The vDefend CLI provides a command to display the health of all services and agents running on a Bare Metal server, giving administrators a mechanism to verify service state before and after servicing. SSP also includes Depot and Registry services that run as systemd-managed services and can be restarted and monitored via systemctl commands.

SSP proactively manages its Platform CA certificate lifecycle. The certificate manager and security intelligence services within SSP can be queried for operational status to diagnose service availability issues during and after maintenance events.

NDR Sensor management operations, including activating or deactivating features and offboarding sensors, are restricted to the Enterprise Admin or Security Engineer role, limiting who can execute maintenance actions on detection infrastructure. Tokens, Bare Metal servers, and Bare Metal server interfaces are included in the full inventory backup, supporting recovery after maintenance activities.

When using vDefend Intelligent Assist or Network Detection and Response remediation workflows, objects that encounter errors during remediation require manual cleanup, which is a constraint administrators should account for in maintenance planning.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) supports controlled maintenance through two configurable policy mechanisms: a maintenance policy for the DSM plug-in software itself, and per-database maintenance windows for database engine upgrades.

For plug-in software updates, administrators configure a maintenance policy that specifies a start date, start time (in hours and minutes), and a permitted duration for applying updates. The policy is accessible from the Version & Upgrade section under the DSM System tab in the DSM UI, as well as from the vSphere Client. This policy governs automatic upgrades of the DSM Provider Appliance plug-in, allowing organizations to schedule maintenance during off-peak hours and bound the duration of any resulting downtime. The policy can be edited during the 10-minute interval between automatic update attempts, which cancels the next scheduled attempt and applies the revised settings. If an automatic upgrade fails, administrators can reconfigure the maintenance policy to reschedule or perform a manual update.

For database engines, each database supports an individually configurable maintenance window that controls when minor version upgrades are applied. The default schedule is Saturday at 23:59 UTC with a six-hour duration, adjustable through the Edit Maintenance Window dialog. MySQL databases include an Enable Maintenance Window toggle with the same default schedule. SQL Server databases support configurable maintenance windows for both software version upgrades and operating system patching. In 9.1, DSM adds a Monthly Occurrences setting that refines the maintenance schedule from a standard weekly cadence to specific weeks within a month, allowing selection of a particular day and one or more specific occurrences of that day. If no specific occurrence is selected, the maintenance window runs every week. Maintenance window settings, including Monthly Occurrences, are also configurable when provisioning databases through VCF Automation. Administrators are prompted to define maintenance window schedules during database creation alongside backup policies.

The DSM controller manages component dependencies through status monitoring and automated remediation. DSM also provides operational visibility into maintenance activity through the database Status indicator and the Operations tab, which display in-progress operations, configuration changes, disk extension tasks, and restore operations. This allows administrators to confirm that maintenance actions have been applied and to identify those that have failed.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) provides several mechanisms that support controlled maintenance activities across its application delivery infrastructure.

For back-end server pools, Avi's health monitoring framework includes maintenance mode detection. Health monitors can be configured so that when a back-end server enters maintenance mode (signaled by returning a designated response code or response string), Avi automatically changes the server's health status to "down for maintenance" and stops routing traffic to it. This behavior is supported across TCP, UDP, HTTP, HTTPS, HTTP/2, and POP3/POP3S health monitor types. TCP and UDP

monitors use the `tcp-udp-maintenance-mode-filters` setting; HTTP monitors use the `maintenance_response` and `maintenance_code` CLI parameters; HTTP/2 monitors use the `maintenance-server-response-data` setting; POP3/POP3S monitors match a configured string such as `MAINTENANCE_ACTIVE` against the health-check response body. The maintenance mode detection monitor must be associated with the pool the server belongs to. Administrators and application developers can inspect health-check responses directly to validate server maintenance state. When the maintenance string or code is no longer returned, subsequent health checks restore the server to active rotation.

For Global Server Load Balancing (GSLB) operations, Avi enforces a controlled pre-maintenance step before a manual leader change. The CLI command `gslb maintenancemode enabled` must be run in GSLB configuration mode to place the leader Controller into maintenance mode before the leader change proceeds; the corresponding `gslb no maintenancemode` command exits maintenance mode. Avi GSLB can also direct traffic to alternative endpoints during planned maintenance, supporting service continuity while primary endpoints are offline.

For cloud-level maintenance, the Avi Controller provides a CLI workflow to place an entire cloud into maintenance mode using `configure cloud <name>` followed by the `maintenance_mode` directive. This is used during Controller upgrades and patch operations. The cloud exits maintenance mode via the `no maintenance_mode` directive.

For Kubernetes deployments using the Avi Kubernetes Operator (AKO), maintenance mode detection is available through the HealthMonitor custom resource definition (CRD). AKO HealthMonitor TCP monitors support a `maintenance_response` value, enabling Kubernetes-native maintenance workflows where health-check responses trigger traffic drain before maintenance begins.

For bare-metal Linux Server Cloud deployments hosting both Controller and Service Engine components, Avi defines a sequential maintenance procedure: Service Engines must be deactivated before hardware maintenance, host OS upgrades, security patching, or kernel updates on the host. Controller cluster nodes must be serviced one at a time to preserve cluster quorum and availability throughout the maintenance window.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

## Control PR.PS-04

> Log records are generated and made available for continuous monitoring [Withdrawn: Incorporated into PR.PS-04]

**SCF Controls:** MON-01, MON-01.4, MON-03

**Aggregate Coverage:** Meets

### VCF (Meets)

VCF provides enterprise-wide monitoring through integrated tools that span infrastructure health, performance metrics, compliance assessment, log analysis, and alerting.

VCF Operations continuously monitors the operational state of all VCF components to detect conditions that may affect availability or compliance. It collects metrics across compute, storage, and networking resources, and correlates them over time to identify trends that may lead to potential failures. VCF Health, a component of VCF Operations, continuously monitors the operational state of VCF components to verify they are functioning as expected, giving platform operators a single view of operational status. Platform operators can configure alerts, perform log analysis, run infrastructure diagnostics, and review VCF health from a unified interface.

VCF Operations provides continuous compliance management by monitoring infrastructure against industry-standard benchmarks and custom policies. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the monitoring posture to organizational requirements. The platform assesses objects based on selected compliance policies and activates alert definitions associated with the current scorecard, providing ongoing visibility into compliance status. Compliance-related alerts are triggered on objects and displayed through a dedicated compliance alert subtype.

The alerting subsystem in VCF Operations supports the full lifecycle of alert management. Administrators can configure and manage alert definitions to monitor infrastructure events and conditions, including performance metrics, log events, and custom conditions configured through the Management Pack Builder. The Platform Health Alerts page provides a centralized view of all alerts related to overall system health, including alerts from data sources and infrastructure nodes. Health alerts are generated for conditions that affect the health of the environment and require immediate attention. Administrators can create policies to govern how alert definitions are evaluated, including which objects to monitor and what thresholds to apply, and can apply consistent practices to optimize alert behavior across monitored objects.

VCF Operations supports flexible grouping and scheduling to align monitoring with operational realities. Custom groups can be configured with automatic membership criteria to support monitoring strategies and achieve a high level of automation. Maintenance schedules can be assigned to objects undergoing planned downtime to keep monitoring data accurate and avoid false alerts when an object is offline for scheduled maintenance.

VCF Log Management provides centralized log collection and analysis. It ingests logs from VMware vCenter, VMware ESX hosts, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture. The platform provides dashboards and analytics for troubleshooting and security investigation. Log-based alert definitions allow administrators to trigger notifications when specific log patterns appear across monitored systems. Log forwarding to external SIEM or syslog targets is configurable, with support for TLS encryption to protect log data in transit. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols. NSX Manager syslog supports TLS and requires port 6514 for encrypted log transmission.

At the vSphere layer, the alarm infrastructure integrates with events and performance counters to provide real-time alerting. The MetricAlarmExpression data object allows administrators to set alarms on specific performance metrics with configurable monitoring intervals and aggregation functions for processing data points. The vSphere Client provides direct visibility into tasks and events for change tracking and troubleshooting. VCF ships with preconfigured vSphere alarms that are active by default and monitor specific components including the Identity Management Service, Message Bus Configuration Service, ESX Agent Manager, VMware Service Control Agent, vSphere HA host status, and host connection and power state. The vCenter Management Interface provides appliance-level health visibility through an Overall Health badge that reflects one of five states



(Good, Warning, Alert, Critical, or Unknown) across all vCenter components, and notifies administrators of available security patches through Critical or Alert badge indicators when automatic patch checks are enabled.

When VCF Automation is integrated with VCF Operations, the Insights dashboard and Alerts tab provide real-time capacity awareness and alert information for VCF Automation objects, giving IT teams visibility into resource usage across both provisioned workloads and the underlying infrastructure. The VCF Automation Monitor tab surfaces deployment health information sourced from VCF Operations, and deployment cards display Last Request Status information that tracks the most recent operation on each deployment (Create, Update, or Delete) and its outcome (Successful, In Progress, or Failed). The Management Pack Builder allows administrators to set up event definitions for integrated systems, monitoring specific conditions or thresholds and configuring alerts for proactive management. Management Packs extend monitoring to network devices, including sensor monitoring for devices such as switches and routers. Adapters can be installed on VCF Operations nodes to extend monitoring to additional systems and data sources beyond the core VCF components.

The VMware Kubernetes Service (VKS) layer of VCF extends enterprise monitoring to container workloads and Kubernetes infrastructure. VKS clusters support MachineHealthCheck objects for both control plane nodes and worker node deployments; administrators manage these through the VCF CLI `vcf cluster machinehealthcheck` command, which supports configuration of unhealthy-condition definitions, maximum unhealthy thresholds (expressed as an absolute number or a percentage), and label selectors to target specific machines. The VCF CLI `vcf cluster machinehealthcheck node get` and `vcf cluster machinehealthcheck control-plane get` commands retrieve node and control plane health status on demand. VKS cluster health conditions, including the Ready and ControlPlaneReady status indicators, reflect the operational state of each cluster and are accessible via `kubectl` and the VCF CLI. The VCF Automation Provider Management UI includes a Services overview interface that exposes VKS cluster management functions and the health status of all cluster elements, giving platform operators a centralized view of the VKS tier. The Kubernetes API server within VKS clusters exposes diagnostic and health check endpoints (`/healthz`, `/livez`, `/readyz`, `/statusz`, and `/metrics`) that external monitoring systems can scrape to track API server availability and readiness; the `kube-apiserver` also emits the `kubernetes_healthchecks_total` counter and `kubernetes_healthcheck` gauge metric, which report structured health check status for components including `etcd` and `autoregister-completion`. Access to these monitoring endpoints is governed by the built-in Kubernetes `system:monitoring` RBAC group, which grants read access to liveness, readiness, and metrics endpoints while restricting broader cluster access. The Kubernetes Watch API allows monitoring tools to track changes to any API object as a live stream, supporting event-driven monitoring without continuous polling. The Node Problem Detector monitors node health and surfaces node-level problems as Kubernetes events and node conditions that external monitoring systems can consume via the event stream.

For workload-level monitoring within VKS clusters, Prometheus Operator is available as a standard package and defines custom resource definitions to deploy and manage Prometheus and Alertmanager StatefulSets, enabling high-availability alerting configurations. The Prometheus Alertmanager custom resource definition configures alert grouping, inhibition, and routing to external notification systems. The Istio service mesh, also available as a standard package on VKS clusters, provides service-level monitoring alongside its traffic management capabilities. The Dynatrace Operator can be deployed on VKS clusters to automate the deployment, scaling, and maintenance of the Dynatrace monitoring stack. Historical analysis, dashboarding, and alerting on cluster-level metrics require a dedicated monitoring solution configured to scrape the VKS metrics endpoints and subscribe to the Kubernetes event stream. The `vcf cluster support-bundler create` command gathers diagnostic information from Supervisor and VKS clusters when troubleshooting is needed.

At the network layer, NSX provides monitored indicators including node uptime status, deployment status, management and controller connections, tunnel status, PNIC status, and uptime duration. NSX time series APIs allow viewing data such as VPN statistics, including metadata about the number of tunnels configured and how many are up or down at a given time.

VCF Operations also supports self-monitoring through the VCF Operations adapter, which collects internal metrics such as activity success counts. This allows administrators to verify that the monitoring platform itself is functioning correctly. The VCF Operations policy engine monitors conditions and generates events to react to changing states in the orchestrator server or connected technologies. The Adapter Instance monitoring interval is configurable, with intervals as granular as five minutes.

VMware Private AI Services (PAIS) includes a built-in observability stack that supplies monitoring data for AI infrastructure and AI workloads. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the `pais-controller-manager` service,



allowing collection by monitoring systems and visualization in observability platforms such as Grafana. Observability is activated by updating the PAISConfiguration custom resource with optional sections for Prometheus metrics collection and LLM trace forwarding. The Prometheus runtime can be configured with a specified storage class policy and a configurable metrics retention period, giving administrators control over how long monitoring data is stored. A Prometheus server pod must be in a ready and running state for observability to function.

LLM trace data from PAIS can be forwarded to an OpenTelemetry Collector endpoint over http/protobuf or gRPC, providing distributed tracing for AI model inference activity. The observability.llmTraces configuration governs trace forwarding and works alongside the Prometheus metrics pipeline to produce two signals: metrics for health and performance, and traces for inference-level behavior. PAIS Controller metrics include the Model Endpoint Controller and PAIS Configuration Controller, giving monitoring platforms component-level visibility into PAIS operations.

In 9.1, PAIS adds direct integration with VCF Operations. The controller-pod-metrics-streaming setting activates streaming of PAIS controller pod metrics from the Supervisor cluster to VCF Operations, allowing administrators to view PAIS metrics alongside other VCF infrastructure metrics. A Telegraf deployment in the vmware-system-monitoring namespace uses a telegraf-user-config ConfigMap to manage user-configured monitoring endpoints for PAIS. The VCF Consumption CLI connects to the Supervisor endpoint and enables VI administrators to stream metrics from the PAIS controller pod. DevOps engineers can visualize health and performance metrics for PAIS components running in a VCF Automation namespace using Grafana, and MLOps engineers and application developers can monitor the health, quality, and behavior of AI applications and the models used in agents through the same observability platforms.

PAIS supplies the technical monitoring mechanisms this control requires. Enterprise-wide orchestration of monitoring controls, including alert threshold definition, escalation procedures, and integration with a centralized monitoring or log management platform, remain organizational responsibilities.

### **VMware vDefend (Contributes)**

VMware vDefend (vDefend) supports network security monitoring through multiple integrated capabilities that contribute to enterprise-wide monitoring frameworks.

Security Intelligence, hosted on the Security Services Platform (SSP), provides continuous visibility into network traffic flows across protected workloads. It monitors flows between application pairs, updates the Policy Protection Status for each application to indicate that flows are being monitored, and continuously detects new flows between environment pairs, alerting administrators to unauthorized or unexpected traffic. The Monitor & Plan Overview page presents a consolidated view of pending actions, data collection activity status, network security posture, flow trends, and a summary of suspicious traffic. The Security Intelligence Recommendations monitoring capability checks for changes in the scope of monitored entities every hour when the Monitoring toggle is enabled, allowing administrators to keep policy recommendations current as environments evolve. Segmentation Monitoring provides dedicated views of application and infrastructure flows with configurable time ranges spanning from the last hour to the last month, and displays flows related to detected infrastructure servers in a specified time interval.

The Network Detection and Response (NDR) Sensor checks the status of activated detection features every 15 minutes and updates its configuration accordingly, supporting sustained threat detection coverage. NDR Sensor health status monitoring tracks whether key components, including network traffic capture, file analysis, and data transmission, are operating properly. The NDR Sensor also sends alerts notifying administrators of conditions such as services being down, high CPU, memory, or disk usage, packet drops, or missed heartbeats. NDR provides role-based access control covering triage operations such as viewing detections and campaigns, as well as SIEM configuration management.

The Security Services Platform monitors its own health, with Yellow or Red health status indicators displayed when issues occur in subcomponents. SSP monitoring tracks the status of the flow clustering job that runs every hour and reports suspicious traffic detector execution status after each run, with values such as SUCCESS, NOT\_ENOUGH\_BASELINE, and FAILURE.

The Security dashboard provides a consolidated view for monitoring and configuring security features across network workloads. In federated deployments, the Global Manager provides centralized event management and monitoring for malicious IP blocking activity across all Local Managers.

vDefend generates Unified Security Logs that VCF Log Management can collect and analyze. These logs cover Distributed Firewall, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering activity. Broader log aggregation and SIEM correlation for enterprise-wide monitoring remain the responsibility of the SIEM and logging infrastructure deployed alongside vDefend.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.

The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

### **VMware Data Services Manager (Meets)**

VMware Data Services Manager (DSM) contributes to enterprise-wide monitoring controls through a layered set of observability capabilities covering database health, infrastructure compliance, and event-driven alerting.

DSM provides a built-in monitoring framework that tracks database instance health across multiple dimensions. From the Monitoring tab in the DSM UI or the vSphere Client, administrators and authorized users can view real-time and historical metrics for database VMs, including CPU Health, Data Disk Health, System Disk Health, Max Connections, Active Connections, Write Throughput, Read Throughput, Thread Resource Utilization, Slow Queries per Second, InnoDB Buffer Usage, and InnoDB Reads and Writes. The Monitoring page defaults to the last three hours of aggregated metric data, with the time range adjustable through the Time Range Last dropdown. This visibility supports detection of resource contention, performance degradation, and connectivity anomalies at the database layer.

DSM's alert framework provides configurable thresholds for warning and critical conditions on key health indicators. Administrators and users can set separate warning and critical thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters. When thresholds are exceeded, DSM generates typed alerts such as Database Engine Health, Custom Config Health, and Backup Storage Health alerts. DSM monitors database replication status and raises an alert when a secondary database is not replicating data from the primary. DSM also raises an alert when metrics are no longer being received from a cluster, supporting detection of monitoring gaps. Alerts can be activated or deactivated per data service through the "Enable Alerts for DB Alert" setting, providing granular control over which databases are subject to active alerting. For each alert, DSM provides mitigation suggestions to help administrators resolve issues without disrupting database services.

In addition to database-level alerts, DSM generates global infrastructure alerts that surface vCenter integration and infrastructure policy issues. These include `INFRASTRUCTURE_POLICY_VC_ALARMS`, raised when vCenter resource alarms are active; `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, which reflect cluster compliance state; `VCENTER_CONNECTIVITY`, raised when vCenter connectivity fails and triggering troubleshooting steps that include verifying connectivity and checking authentication logs; and `LicensingNotUpdated` and `vCenterBinding` API status alerts that surface license and API integration conditions. A Global Alerts page in the DSM UI provides a centralized view of these alerts during and after installation and ongoing operation.

In 9.1, DSM integrates with VCF Operations to extend observability beyond the DSM UI. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state and displays a Data Services View dashboard showing active alerts and inventory items. VCF Operations presents performance data across three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for KPIs including Active Connections, Commits, Rollbacks, and Deadlocks. This integration requires configuring the connection between DSM and VCF Operations before use.

DSM also adds SQL Server as a supported database type, with dedicated monitoring through an integrated InfluxDB instance and Telegraf agents deployed across the provider appliance and SQL Server workload clusters. The monitoring framework supports metrics-based and status-condition-based alerts for SQL Server, covering database engine degradation, non-operational status, and automated or transaction log backup failure conditions.

DSM supports event notification to external systems through a webhook integration. Webhooks transmit alert notifications containing the triggered date, triggered time, triggered user email, task status, previous status, and task type. This allows DSM alerts to feed into centralized monitoring or incident management platforms maintained by the organization. DSM generates plug-in registration logs that administrators can review for vCenter connectivity errors, and DSM's troubleshooting guidance directs administrators to review active vCenter infrastructure alarms and resolve underlying issues identified through the alert system.

Enterprise-wide monitoring requires organizational decisions about monitoring architecture, log aggregation platforms, alerting policies, and operational response procedures that lie outside DSM's scope. DSM provides the data and integration points; the organization must determine how those signals are collected, correlated, and acted upon across the broader environment.

### **VMware Avi Load Balancer (Meets)**

VMware Avi Load Balancer (Avi) contributes to enterprise-wide monitoring through application-delivery-layer mechanisms built into the Avi Controller and Service Engines.

The Avi Controller monitors Service Engine metrics and sends alarms and notifications to administrators when resource utilization data exceeds defined thresholds. Administrators configure custom thresholds on Service Engine groups through the Resource Events tab in the Avi UI. The Alert feature processes system events and metrics against user-defined rules and generates alerts that trigger configured actions, including sending an email, a syslog message, or an SNMP trap. Alert notifications can be forwarded to remote syslog servers for integration with centralized log management and monitoring platforms.

ControlScripts extend this event-response capability: a ControlScript can alter Avi configuration or communicate to external systems, including through webhook integrations with external monitoring tools, in response to defined system events. This supports dynamic responses including resource scaling or automated notifications based on health scores from monitoring data.

The Avi Controller and Service Engines track health score changes and SSL certificate expiration events. Avi integrates with external monitoring tools such as Prometheus for metrics collection and analysis. User-Defined Metrics allow administrators to define and extract customized telemetry data for specific compliance or reporting needs through the API. Real-time metrics are available via API but deactivate by default after 30 minutes to conserve resources and must be reactivated when sustained real-time visibility is required.

At the data plane, Avi health monitors track the status of backend servers and Service Engines continuously. Service Engine health monitoring records detailed server operational status, including health monitor name, type, last transition timestamps, rise count, fall count, total checks, and total failed checks. Each health monitor can be assigned its own threshold and timeout period for server health validation. Monitors support HTTP, HTTPS, TCP, and UDP health-check protocols with configurable success and failure thresholds, send intervals, and receive timeouts.

In Kubernetes environments managed by the Avi Kubernetes Operator (AKO), the HealthMonitor custom resource definition (CRD) allows users to define custom health monitoring configurations for backend services with fine-grained control over health check parameters. The Avi Multi-Cluster Kubernetes Operator (AMKO) GlobalDeploymentPolicy supports health monitor references for consistent monitoring across multi-cluster deployments. Within VCF Automation, a HealthMonitor custom resource can create monitors for tracking backend pool member status using TCP, PING, and HTTP check types.

## Control PR.PS-05

> Installation and execution of unauthorized software are prevented

**SCF Controls:** CFG-01, CFG-02, CFG-03, CFG-03.2, CFG-05, END-03

**Aggregate Coverage:** Meets

### VCF (Meets)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the `Security.PasswordQualityControlPwquality` setting on ESX hosts, including parameters such as `minlen=15`, `maxrepeat=3`, `maxclassrepeat=4`, `difok=4`, and `enforce_for_root`. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. `AppArmor` and `SELinux` provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as `ConfigMaps` and `Secrets`.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references `ConfigMaps` containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.



Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

### VMware vDefend (Meets)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,



and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

## Control PR.PS-06

> Secure software development practices are integrated, and their performance is monitored throughout the software development life cycle [Withdrawn: Incorporated into ID.AM-08, PR.PS-06]

**SCF Controls:** TDA-01, TDA-01.1, TDA-06, TDA-06.1, TDA-06.2, TDA-06.3, TDA-09

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control RC

> The recovery portion of the incident response plan is executed once initiated from the incident response process. Recovery actions are selected, scoped, prioritized, and performed. The integrity of backups and other restoration assets is verified before using them for restoration. Critical mission functions and cybersecurity risk management are considered to establish post-incident operational norms. The integrity of restored assets is verified, systems and services are restored, and normal operating status is confirmed. The end of incident recovery is declared based on criteria, and incident-related documentation is completed [Withdrawn: Incorporated into RC.CO-04]. Recovery activities and progress in restoring operational capabilities are communicated to designated internal and external stakeholders. Public updates on incident recovery are shared using approved methods and messaging [Withdrawn: Incorporated into ID.IM-03, ID.IM-04] [Withdrawn: Incorporated into ID.IM-03]

**SCF Controls:** BCD-01, BCD-12

**Aggregate Coverage:** Meets

### VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental

backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations. HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

### **VMware vDefend (Contributes)**

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

## **VCF Protection and Recovery (Meets)**

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

## **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) provides several mechanisms that support the secure recovery and reconstitution of database services to a known state following a disruption, compromise, or failure.

For backup-based recovery, DSM supports point-in-time recovery (PITR), which restores a backup to a newly created database VM. During the restore operation, the administrator can specify the database name, choose the target datastore location, and configure management settings. DSM supports restoring backups from either local or cloud-compatible (S3-compatible) storage, with restoration permitted to any point in time within the configured backup retention period. When restoring a deleted database, DSM's Archives tab allows users to access databases with retained backups and create a new database VM from a selected restore point, including options to restore to the most recent available timestamp or a custom point in time. PITR coverage extends across PostgreSQL, MySQL, and SQL Server database engines. For SQL Server, DSM automatically manages the database recovery model based on backup status, using Full Recovery for databases with automated backups enabled and Simple Recovery otherwise. Cloning a MySQL or PostgreSQL database is functionally equivalent to PITR to the latest available time, giving operators an additional path for rebuilding a known-good database instance. For failed clusters, DSM supports restoration to a different cluster with the option to target either the latest available time or a specific custom restore point.

For active recovery and failover of PostgreSQL databases, DSM provides a multi-site disaster recovery deployment model in which a secondary instance replicates from the primary across sites. When a failover is needed, DSM provides a switchover workflow that reverses the roles of instances, redirecting the secondary to become the new primary and restoring the database service to a fully operational state. DSM also provides a switchover workflow for failback, allowing operators to reverse instance roles again after the primary site is restored. DSM requires trust validation of the new primary database



certificate when redirecting secondary instances during disaster recovery switchover, and operators with the DSM user role must manually establish trust between primary and secondary instances by retrieving the Certificate Authority from the primary and adding it to the Provider VM that will host the secondary. For backup-location certificates, DSM supports a Trust On First Use (TOFU) configuration that extracts and trusts certificates for specific backup locations, and at least one backup location must be configured with a trusted root certificate when a data service policy requires or allows automated backups. DSM also preserves the backing virtual machines of removed database nodes in an idle state until an instance is promoted again, maintaining infrastructure capacity for disaster recovery operations.

The resiliency of the DSM Provider Appliance itself is supplied by the underlying VCF platform (see VCF Coverage); DSM relies on vSphere High Availability to restart the appliance on another host in the event of a host failure, and does not add a separate management-plane HA mechanism. If a DSM provider restore fails for any reason, the documented procedure is to re-deploy the appliance and then follow the recovery procedure again rather than re-attempting the restore workflow on the same appliance.

DSM tracks recovery operations through its audit and operations interfaces. Event logs record Provider Restore Success events with timestamps, allowing operators to verify that recovery operations completed. Restore operation progress is visible in the Operations tab and Operations view, and a new entry appears in the Databases view table when a restore completes. To support integrity of recovery artifacts, the DSM Consumption Operator deployment includes Signature Verification of packages.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

## Control RC.CO

> [Withdrawn: Incorporated into RC.CO-04] Recovery activities and progress in restoring operational capabilities are communicated to designated internal and external stakeholders. Public updates on incident recovery are shared using approved methods and messaging.

**SCF Controls:** BCD-01.1, BCD-01.2

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides planning, dependency visualization, and scenario analysis capabilities through VCF Operations that support an organization's ability to coordinate contingency plan development across teams, though the formal coordination of contingency plans with internal and external stakeholders is an organizational responsibility.

VCF Operations models infrastructure as a set of related objects with one-to-many, many-to-one, and one-to-one relationships defined at horizontal, vertical, and diagonal levels. When objects are related, a problem with one object surfaces as an anomaly on related objects, giving contingency planners visibility into cascading failure paths and helping teams identify which components are affected by a specific failure. The Object Relationship widget displays parent-child relationships in graph, tree, or hexagon views, while the Relationship view diagram provides two modes: an Application View showing the same relationship diagram as the Business Application page, and an Infrastructure View displaying a graph of virtual machines and their vSphere infrastructure. These dependency maps allow contingency planners to trace the blast radius of a component failure and coordinate recovery priorities accordingly.

The Business Application feature in VCF Operations allows administrators to define application-to-application relationships, grouping workloads and their underlying infrastructure into logical units. The Relationship view table lists each object's name, type, capacity remaining, and active alerts within a business application, giving recovery planners a consolidated view of application health and resource availability. The Geo Widget displays object locations on a world map when Geo Location tags are configured, providing a geographic view of infrastructure distribution that supports site-level contingency planning. The Topology Graph widget displays the topology of a selected object, helping teams understand the structural relationships between infrastructure components.

VCF Operations includes infrastructure planning and capacity scenario tools that facilitate cross-team visibility into current and future resource requirements. The Committed Scenarios feature, accessible through the Plan menu under Capacity, allows organizations to model future infrastructure states and share those projections across teams. In organizations with separate capacity management and operations teams, committing a scenario helps stakeholders understand current capacity and upcoming capacity requirements. The team responsible for infrastructure expansion receives actionable insights into future scenarios, which helps account for capacity needs when developing contingency and recovery strategies.

The What-If analysis capability within VCF Operations Infrastructure Planning allows administrators to define and evaluate multiple scenarios for physical infrastructure planning. Scenarios can be saved for later execution and run cumulatively, allowing planners to model different contingency conditions and assess resource availability under various failure or recovery situations. Because these scenarios do not require immediate implementation, they function as a planning tool that teams can use to evaluate options before committing to a course of action.

VCF design guidance provides structured documentation covering supported design options, decision points, justifications, implications, and considerations for each component of the platform. Cloud architects and infrastructure administrators can use this documentation as a reference when developing contingency plans, helping planners understand the dependencies and relationships between VCF components and identify which elements require coordinated recovery procedures.

VCF's API framework supports integration with third-party backup providers, storage replication solutions, and configuration management databases, enabling infrastructure, security, and business continuity teams to build coordinated recovery workflows that span multiple tools and platforms.

To satisfy this control in a VCF environment, an auditor should verify that the organization has established a formal process for coordinating contingency plan development with all relevant internal teams (infrastructure operations, capacity management, application owners, security) and external parties (service providers, cloud partners, support vendors). The auditor should confirm that VCF Operations planning tools are being used to model contingency scenarios, that dependency mapping and business application groupings reflect the actual environment, and that the results are shared with stakeholders responsible for related recovery and continuity plans.

#### **VCF Protection and Recovery (Contributes)**

Recovery plans in VCF Protection and Recovery (PNR) are the shared technical artifact around which teams coordinate contingency planning. Each plan is created with a specified direction of protection between paired sites, and that direction cannot be changed after creation, requiring upfront agreement between protected-site and recovery-site teams on the scope and direction of each plan before it goes into service.

Recovery plan states are driven by the states of the protection groups within the plan, and the plan state determines which operations are permitted. This state model gives coordinating teams real-time visibility into whether dependent plans are ready for test or execution. The VCF Operations Orchestrator Plug-In for Protection and Recovery includes an Initiate Test Recovery Plan workflow that can be run on the recovery site, giving multiple stakeholder teams a shared validation point without requiring direct access to the DR management interface.

Each recovery plan runs a series of steps in a specific order for workflows such as planned migration or reprotect. The fixed order of built-in steps cannot be changed, but custom steps can be added to the sequence; custom steps can display messages and run commands, accommodating site-specific or team-specific coordination actions. Recovery plan steps can be exported in various formats for future reference or to maintain a hard copy backup, making the planned procedure reviewable by stakeholders outside the DR management interface.

PNR emits structured lifecycle events that provide an audit trail for plan changes: a PlanEdit event is raised when an existing plan is edited, and PlanDelete and PlanDestroy events are raised when a plan is removed. These events can be used to create alarms and monitor plan modifications across coordinating teams.

The VCF Operations Orchestrator Plug-In for PNR supports additional recovery plan management workflows, enabling integration of DR plan organization with external orchestration tools and cross-team workflows that link DR plans to broader business continuity efforts.

Not applicable for this control: VMware vDefend, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control RC.CO-03

> Recovery activities and progress in restoring operational capabilities are communicated to designated internal and external stakeholders

**SCF Controls:** BCD-01.6

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides technical mechanisms for tracking recovery operations, generating status telemetry, and forwarding notifications to stakeholders, though the organizational processes for defining communication plans, escalation paths, and stakeholder contact lists must be established outside the platform.

VCF includes built-in disaster recovery capabilities at multiple levels of the stack. Application Disaster Recovery enables failover to a secondary site to maintain operations during major disruptions, with data replication providing recovery options in case of catastrophic failure. Disaster recovery may also be implemented for fleet-level components. NSX Federation supports both planned and unplanned disaster recovery scenarios for Global Manager, and the Global Manager detects loss of connection to a Local Manager and prompts administrators to perform Network Recovery, providing real-time awareness of component status during a disruption. NSX Federation Global Manager and Local Manager VMs can be recovered using VMware Live Site Recovery for high availability of the management plane.

These recovery operations follow structured recovery plans that define execution priority groups, giving recovery teams a sequenced view of which steps have completed and which remain pending. For example, recovery plans for VCF Operations for Networks require the primary platform node to be placed in a higher priority group than other platform nodes, providing a defined sequence whose completion status can be tracked and reported. VMware Live Site Recovery orchestrates recovery plan execution across sites, with role-based access controlling who can create and execute recovery plans on the recovery site. Recovery plan creation for host-based replication involves initialization of a protection group specification, creation of the protection group task, and monitoring of task progress. The `Invoke-SrmGetTaskInfo` cmdlet monitors task progress in Live Site Recovery, and `Invoke-SrmGetRecoveryPlan` retrieves recovery plans by pairing and plan identifiers.

During recovery operations, VCF components report detailed status information at multiple levels. VMware vCenter restore jobs report state with progress percentage tracking until completion. The `com.vmware.appliance.recovery.restore.job.get` appliance shell API command retrieves the current status of a vCenter restore job. After restoration completes, the `service-control --status --all` command confirms that vCenter services have restarted successfully. VCF Operations restore tasks return a task ID that can be monitored through a REST API endpoint to track status. Recovery reconciliation jobs in vCenter include a `RecoveryReconciliationJobInfo` data structure containing description, status, progress, error details, start time, and end time, accessible through the management API with possible states of `NONE`, `RUNNING`, `FAILED`, and `SUCCEEDED`. Administrators should verify that there is no running or failed reconciliation job before initiating a new restore operation.

VCF Operations tracks recent task status with states including `Completed`, `In Progress`, `Failed`, `Maximum Time Reached`, `Not Dispatched`, `Started`, and `Unknown`, and provides a Recent Tasks tile in the Administration Control Panel for monitoring. VCF Operations also monitors recovery-related metrics, such as recovery status indicators for database components, which show whether recovery is enabled or disabled. Once a planned migration or disaster recovery operation finishes successfully, the recovered system becomes operational, and VCF Operations reflects that restored state in its health monitoring. VCF Operations dashboards provide real-time, interactive views of infrastructure health, alerts, and operational status, and are recommended over static reports for timely situational awareness during recovery activities.

VCF Operations supports multiple outbound notification methods for forwarding recovery-related alerts and status to external systems. Alert notifications can be sent via email, webhook, SNMP trap, and Slack integrations. The Slack plug-in forwards pre-formatted alert details to Slack channels and supports configuration of multiple notification rules with different channels. The webhook notification plugin supports integration with any REST API endpoint, allowing recovery status data to be forwarded to incident management platforms, communication tools, or custom dashboards. Alert notifications include details such as alert definition name, description, object name, alert impact, alert state, symptoms with metric details, and

recommended actions. Notification rules can be configured to trigger on specific alert status changes, so stakeholders receive updates as conditions evolve. Alerts can be assigned to specific users through ownership management (Take/Release Ownership), so team members know who is working on a given recovery issue.

Simultaneous backups of VCF Operations fleet management component nodes help ensure that restored components are logically consistent with each other, reducing the need for additional remediation steps that could delay recovery communications. Organizations should plan and test disaster recovery strategies regularly to meet recovery time objectives (RTO) and recovery point objectives (RPO), establishing clear benchmarks against which recovery progress can be measured and communicated.

While VCF provides the technical telemetry, dashboards, alerting integrations, and structured recovery plans needed to track and report on recovery status, the organizational processes for communicating that information to designated internal and external stakeholders, including establishing communication plans, defining escalation paths, identifying stakeholder contact lists, and selecting communication channels, must be established outside the platform.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides recovery status visibility mechanisms that support communication of recovery progress to stakeholders, though the organizational communication process for reaching external stakeholders is outside its scope.

Recovery plan state management gives operators visibility into recovery progress throughout the recovery lifecycle. The state of a recovery plan is determined by the states of the protection groups within that plan, and the plan state determines which operations are allowed at each stage. PNR recovery plans can be configured with message prompt steps that pause execution until an operator closes the prompt, creating explicit checkpoints where status can be assessed and communicated before the plan continues. The reprotect process passes through observable states visible within the recovery plan interface, extending status visibility into post-recovery operations.

PNR signals key recovery milestones through structured events and alarms. When a recovery is initiated, PNR generates a PlanExecBeginEvent on the recovery site. When a recovery plan finishes executing a command callout, PNR sends a RecoveryPlanServerCommandEndTrap that includes the protection and recovery site name, recovery plan name, and recovery type. PNR also generates alarms when connectivity issues are encountered or when protection groups and recovery plans enter an error state, providing signals that operators can use as the basis for stakeholder communication.

The Recovery Plans Details Dashboard in VCF Operations tracks recovery plan status including protection group associations, execution history, failover and reprotection status, and cleanup completion. This dashboard gives administrators a consolidated view of recovery activity that can inform status reporting to stakeholders.

Role-based access controls separate recovery plan management from recovery execution. PNR defines specific roles including the SRM Recovery Plans Administrator role, which permits managing and testing recovery plans, and the SRM Recovery Administrator role, which permits running recoveries. This separation allows organizations to designate specific individuals as responsible for communicating recovery status based on their operational role.

Not applicable for this control: VMware vDefend, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control RC.CO-04

> [Withdrawn: Incorporated into RC.CO-04] Public updates on incident recovery are shared using approved methods and messaging

**SCF Controls:** IRO-16

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control RC.RP

> The recovery portion of the incident response plan is executed once initiated from the incident response process. Recovery actions are selected, scoped, prioritized, and performed. The integrity of backups and other restoration assets is verified before using them for restoration. Critical mission functions and cybersecurity risk management are considered to establish post-incident operational norms. The integrity of restored assets is verified, systems and services are restored, and normal operating status is confirmed. The end of incident recovery is declared based on criteria, and incident-related documentation is completed.

**SCF Controls:** BCD-01, BCD-01.4, BCD-02, BCD-02.1

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations. HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

#### **VMware vDefend (Contributes)**

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

#### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable

BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) provides technical mechanisms that support an organization's ability to meet defined Recovery Time Objectives and Recovery Point Objectives for database workloads.

Point-in-time recovery. DSM supports point-in-time recovery (PITR) for PostgreSQL, MySQL, and SQL Server databases, allowing administrators to restore data to a specific moment within the configured backup retention period. When initiating a restore, administrators identify a restore point and choose either the most recent timestamp or a user-specified date and time, and the restored database is created as a new database instance. The granularity of recovery is bounded by the configured backup schedule and retention settings, and PITR can only restore data from within the configured retention period. PITR requires the source database to be operational, the required backup to be available, and connectivity to the S3 storage repository. SQL Server PITR can restore onto the same or a different SQL Server cluster. PostgreSQL restore can also target a different DSM control plane by specifying a time value; if the time field is omitted, DSM restores the latest available state. For SQL Server, DSM automatically manages the recovery model based on backup status, using Full Recovery Model when automated backups are enabled and Simple Recovery Model otherwise. PITR may fail or be incomplete if binary log files are missing from the source database, which administrators should account for in operational procedures.

Log backup frequency and RPO. DSM exposes a Log Backup Frequency setting in Advanced Settings with a maximum value of 30 minutes. The log backup frequency is directly related to the achievable RPO for both PostgreSQL and SQL Server databases, and administrators should configure this value based on their RPO requirements.

Database cloning. DSM can clone a MySQL or PostgreSQL database to create an identical database. Cloning is functionally equivalent to PITR to the latest available time and can act as a recovery mechanism when the most recent consistent state is the desired recovery target.

Provider VM recovery and restore duration. DSM documents a recovery procedure for a single Provider VM failure, and the Provider VM restoration must complete fully before proceeding to subsequent recovery steps. This is a relevant consideration

for control plane RTO planning. Database restoration duration depends on data volume and underlying infrastructure performance, and administrators should account for this when planning restore operations against an RTO target.

Defining and formally documenting RTO and RPO targets is an organizational process outside DSM's scope. DSM provides the backup, restore, and cloning mechanisms that technical teams configure and test against those targets. Organizations must establish their RTO and RPO requirements, configure DSM backup policies accordingly, test recovery procedures, and verify operational results align with those targets.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

## Control RC.RP-01

> The recovery portion of the incident response plan is executed once initiated from the incident response process

**SCF Controls:** BCD-01.5, BCD-12

**Aggregate Coverage:** Meets

### VCF (Contributes)

VCF provides built-in capabilities for secure recovery and reconstitution of infrastructure and workloads to a known state after a disruption, compromise, or failure. These capabilities span compute-level high availability, storage-level data protection, structured backup and restore workflows for management components, and disaster recovery across sites.

At the compute layer, vSphere High Availability (HA) automatically restarts virtual machines on surviving hosts following a physical machine failure, restoring workloads to their prior operational state. vSphere Fault Tolerance provides continuous availability for individual workloads in the event of a hardware failure with no data loss or downtime. Proactive HA supports maintenance mode as a remediation method, allowing the platform to respond to hardware degradation indicators. On TPM-equipped hosts, VMware ESX supports a Secure ESX Configuration recovery key that is required to restore the host configuration following TPM failure, TPM reset, motherboard replacement, or TPM device replacement; administrators can retrieve and store this key using `esxcli system settings encryption recovery list` and should keep it in a secure, off-host location.

At the storage layer, vSAN fault domains distribute data according to storage policy so that it remains available even when hardware failures occur. vSAN stretched clusters extend a cluster across two availability zones, providing site-level resiliency against the loss of an entire availability zone. When one site becomes unavailable, the surviving site continues operations, and with local fault protection enabled, the cluster can perform repairs on missing or broken components in the available site. vSAN Data Protection uses native snapshots stored locally on a vSAN Express Storage Architecture (ESA) cluster to support point-in-time recovery from operational failures or ransomware attacks. Changed Block Tracking (CBT) tracks changes on disk sectors, enabling incremental backups through VADP-integrated partner backup solutions.

For large-scale disruptions, Application Disaster Recovery enables failover to a secondary site, with data replication so recovery options exist in the event of catastrophic failure. Disaster recovery can also be implemented for fleet-level components, covering the management plane itself. VCF documentation recommends planning and testing disaster recovery strategies regularly to validate that recovery time objectives (RTO) and recovery point objectives (RPO) can be met.

VCF includes structured backup and restore workflows for its management components. Administrators create a series of backup jobs that capture the state of related components, including VCF Operations, NSX Manager, and VMware vCenter, at a common point in time. VCF Operations backup is configured to take a backup on state change. VMware vCenter supports both file-based and image-based backup methods. The file-based restore procedure is a two-stage operation: stage 1 deploys a new vCenter appliance, and stage 2 transfers data from the backup location to that appliance; the restored appliance operates in non-HA mode, so vCenter High Availability must be reconfigured after recovery completes. Simultaneous backups of VCF Operations fleet management component nodes support restoring the nodes to a logically consistent state, so further integrity remediation is not required after a restore. The platform also recommends backing up the management domain vCenter and VCF Identity Broker appliance following any substantial modifications to the identity source configuration, such as a VCF SSO reset, to preserve a known-good recovery point.

For VMware vCenter specifically, the vCenter Management API provides a unified restore process that handles multiple vCenter components in a single operation. After a file-based or image-based restore, the reconciliation API checks whether vCenter partners in embedded linked mode are available, synchronizes vCenter data and services with the partners, and runs vCenter services. The appliance recovery API exposes a restore client interface for programmatic restore operations, supporting automation of recovery workflows.

VCF Operations supports image-based backup and restore as a recovery process for single node, primary node, replica node, data node, and collector failures. VCF Operations for Networks supports backup and restore of its deployment data to enable recovery when the existing setup is unrecoverable. VCF Operations HCX provides backup and restore operations through its

appliance management interface, and its Mobility Groups support workload migration with state tracking, retry capabilities, and reverse migration from destination back to the original source.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS), vSphere namespaces, and VCF Services consumption, extends recovery and reconstitution capabilities to containerized workloads and self-service deployments. At the Kubernetes control-plane level, ReplicaSets and Deployment controllers continuously monitor pod health and reschedule workloads to healthy nodes when pods or nodes fail. Liveness probes detect application-level failures and trigger container restarts; readiness probes gate traffic until a workload recovers from transient faults or overloads. These self-healing mechanisms operate without manual intervention for transient failures. Pod Disruption Budgets allow administrators to define minimum availability constraints that the platform respects during voluntary disruptive actions such as node upgrades or certificate rotations, so those operations proceed without taking down an entire service.

VKS clusters support structured backup and restore through VKS Cluster Management and Velero-based mechanisms. VKS Cluster Management backup operations can capture an entire cluster or a subset of data resources, and restore operations allow the operator to specify the scope of resources to recover. Restore operations include file system backups by default; CSI volume snapshots can be optionally selected for restoration. CSI Volume Snapshots deliver crash-consistent backups with support for block mode and file system mode, incremental backups, deduplication, compression, and encryption, and provide a resilient safety net for VKS clusters when primary storage infrastructure fails. CloneFromSnapshot custom resources expose a status.phase field that tracks restore progress through multiple phases, giving operators visibility into the state of ongoing recovery operations. The Velero plugin for vSphere supports backup and restore of vSphere pods, and VADP-based backup partner solutions can perform backup, full restore, and registration of VM Service VMs on a Supervisor.

Deploying workloads across multiple failure zones using the Cluster API defines worker nodes across multiple failure domains with automatic healing rules that reschedule workloads when a zone becomes unavailable. Replicating control plane components across at least three failure zones limits the impact of a single-zone failure on the Kubernetes control plane itself. For VM Service workloads, the IaaS Services Console and Local Consumption Interface provide a Resources tab where users can create snapshots with optional memory capture and guest file system quiescence, and can revert a VM to a prior snapshot to restore it to a known state.

Deployment rollback is available natively in Kubernetes through Deployments with revision history, allowing administrators to return to a previous known-good revision when a newly deployed version fails. The Harness CI/CD Supervisor Service extends this with automated rollback capabilities that can revert to a previous stable state when deployment failures are detected.

Immutable infrastructure patterns supported by Kubernetes, combined with infrastructure-as-code stored in version control, provide a reproducible mechanism for reconstituting a cluster to a known, authorized state. Every change to the declared state is recorded in version control, and the cluster can be rebuilt from that record after a compromise or failure. VKS Cluster Management Policy Insights expose Sync signals that indicate when policy definitions fail to propagate from the management plane to the targeted VKS cluster estate, helping operators detect and remediate policy drift before it affects recovery posture.

Restore operations require that the target infrastructure be in place before a restore can proceed. VCF documentation recommends implementing a consistent backup strategy to safeguard the infrastructure against unforeseen disruptions and to support effective disaster recovery.

### **VMware vDefend (Contributes)**

VMware vDefend contributes to secure recovery and reconstitution through backup and restore capabilities for its own security infrastructure, and through disaster recovery features that maintain security policy continuity across site failover events.

The Security Services Platform provides backup and restore functionality, accessible through the System > Backup and Restore interface, that allows recovery of a platform instance to its previous configuration when the current instance is in a non-recoverable state. The backup scope includes the full system inventory: tokens, Bare Metal servers, and Bare Metal server interfaces are captured as part of inventory backup, and required certificates from the backup server are restored automatically during the restore process. The platform must be in a healthy state to perform backup operations; backup and



restore cannot proceed when the platform is unhealthy. Certificate consistency between backup and restored Security Services Platform environments must be maintained to avoid NDR Sensor disruptions. Backup and restore operations enter a failed state after 30 minutes if internal services are restarted manually or due to failure. Administrators should back up the Security Services Platform before performing scale-out operations, and Bare Metal Service operations (onboarding, offboarding, or upgrading Bare Metal servers) should not be performed while backup or restore is in progress.

The Security Services Platform can be deployed on vSAN stretched configurations, which supports recovery from site failures and reduces recovery time at the infrastructure level.

For disaster recovery scenarios, NSX Federation maintains security posture during workload migration and site failover by propagating Distributed Firewall rules, security groups, and microsegmentation policies across multiple sites. When workloads fail over from a protected site to a recovery site, the vDefend security policies governing east-west traffic at the destination site are already in place. vSphere HA can be configured to handle host-level failures affecting Security Services Platform appliances.

The broader recovery of compute infrastructure, storage, virtual machines, and application workloads to a known state is handled by other VCF components such as Protection and Recovery, vSAN Data Protection, vSphere Replication, and vCenter backup and restore.

### **VCF Protection and Recovery (Meets)**

VCF Protection and Recovery (PNR) provides mechanisms for secure recovery and reconstitution of virtual machine workloads to a known state after a disruption, compromise, or failure.

Recovery is organized through protection groups and recovery plans. Protection groups define which virtual machines are protected, while recovery plans orchestrate the sequence of steps required to recover those workloads at the recovery site. The state of a recovery plan is determined by the states of the protection groups within it, and the plan state governs which operations are permitted at each stage of the DR lifecycle. Recovery plans support two primary modes: planned migration for orderly, scheduled failover, and disaster recovery for unplanned site failures. A single recovery plan can also be configured to serve both disaster recovery and cyber recovery operations, allowing organizations to maintain consistent recovery procedures across different incident types.

Recovery plan testing is a built-in capability. Recovery plans should be tested before use for planned migration or disaster recovery to validate their functionality. This confirms that the recovery process will bring protected virtual machines online at the recovery site and that inventory mappings correctly place workloads on the appropriate networks, storage, and compute resources.

Cyber Recovery extends reconstitution capabilities with an Isolated Recovery Environment (IRE) designed for compromise scenarios such as ransomware incidents. The IRE provides a dedicated, isolated segment of the recovery environment that blocks direct private network connections from production, allowing compromised workloads to be analyzed and validated before being returned to production. Cyber Recovery transitions virtual machines through a controlled sequence of states, including Entering validated, Validated, Staging, and Staged, to prepare them for recovery. This state-based workflow supports data integrity validation prior to production restoration.

Recovery plan compliance checks verify that protection groups are actively replicating, that sufficient point-in-time snapshots are available for each virtual machine in the plan, and that all workflow steps can execute without conflict. Continuous compliance monitoring provides warnings when VM configuration status deviates from expected state.

The Configuration Import/Export Tool enables administrators to export PNR server configuration data, including inventory mappings, placeholder datastores, advanced settings, array manager configurations, and protection group definitions. This capability supports configuration backup and reconstitution of the PNR environment itself after a failure or migration.

PNR integrates with VCF Operations for recovery plan lifecycle visibility. The Recovery Plans Details dashboard shows the current phase of the DR lifecycle, including whether a plan is ready, whether a test is in progress, and whether incomplete recovery or cleanup operations require attention. PNR also supports recovery of VCF Automation and VCF Operations



services: when a disaster event affects the management domain containing these services, PNR enables service recovery in another management domain.

All communications between PNR and VMware vCenter instances use TLS certificates and private keys. The PNR Appliance supports importing server certificates signed by a certificate authority to establish secure communications across both protected and recovery sites.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) provides several mechanisms that support the secure recovery and reconstitution of database services to a known state following a disruption, compromise, or failure.

For backup-based recovery, DSM supports point-in-time recovery (PITR), which restores a backup to a newly created database VM. During the restore operation, the administrator can specify the database name, choose the target datastore location, and configure management settings. DSM supports restoring backups from either local or cloud-compatible (S3-compatible) storage, with restoration permitted to any point in time within the configured backup retention period. When restoring a deleted database, DSM's Archives tab allows users to access databases with retained backups and create a new database VM from a selected restore point, including options to restore to the most recent available timestamp or a custom point in time. PITR coverage extends across PostgreSQL, MySQL, and SQL Server database engines. For SQL Server, DSM automatically manages the database recovery model based on backup status, using Full Recovery for databases with automated backups enabled and Simple Recovery otherwise. Cloning a MySQL or PostgreSQL database is functionally equivalent to PITR to the latest available time, giving operators an additional path for rebuilding a known-good database instance. For failed clusters, DSM supports restoration to a different cluster with the option to target either the latest available time or a specific custom restore point.

For active recovery and failover of PostgreSQL databases, DSM provides a multi-site disaster recovery deployment model in which a secondary instance replicates from the primary across sites. When a failover is needed, DSM provides a switchover workflow that reverses the roles of instances, redirecting the secondary to become the new primary and restoring the database service to a fully operational state. DSM also provides a switchover workflow for failback, allowing operators to reverse instance roles again after the primary site is restored. DSM requires trust validation of the new primary database certificate when redirecting secondary instances during disaster recovery switchover, and operators with the DSM user role must manually establish trust between primary and secondary instances by retrieving the Certificate Authority from the primary and adding it to the Provider VM that will host the secondary. For backup-location certificates, DSM supports a Trust On First Use (TOFU) configuration that extracts and trusts certificates for specific backup locations, and at least one backup location must be configured with a trusted root certificate when a data service policy requires or allows automated backups. DSM also preserves the backing virtual machines of removed database nodes in an idle state until an instance is promoted again, maintaining infrastructure capacity for disaster recovery operations.

The resiliency of the DSM Provider Appliance itself is supplied by the underlying VCF platform (see VCF Coverage); DSM relies on vSphere High Availability to restart the appliance on another host in the event of a host failure, and does not add a separate management-plane HA mechanism. If a DSM provider restore fails for any reason, the documented procedure is to re-deploy the appliance and then follow the recovery procedure again rather than re-attempting the restore workflow on the same appliance.

DSM tracks recovery operations through its audit and operations interfaces. Event logs record Provider Restore Success events with timestamps, allowing operators to verify that recovery operations completed. Restore operation progress is visible in the Operations tab and Operations view, and a new entry appears in the Databases view table when a restore completes. To support integrity of recovery artifacts, the DSM Consumption Operator deployment includes Signature Verification of packages.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) provides application-layer recovery and reconstitution mechanisms at the load balancing and application delivery tier.

The Avi Controller cluster can be deployed across two availability zones, with defined failure scenarios and documented recovery actions for each zone-loss case. Availability zones should be configured based on fault domains associated with shared power supplies, shared networking devices, or other common infrastructure to reduce the risk of virtual service unavailability. When the cluster enters manual recovery state following a failure or compromise, Avi automatically revokes all Service Engine secure channel credentials and causes Service Engines to reboot themselves, halting all application traffic delivery. This returns the data plane to a controlled, known state. Service Engines that subsequently re-establish connectivity to a recovered Controller node reconfigure themselves automatically to connect only to that node.

If all three Controller cluster nodes are permanently unavailable, recovery must be performed using a backup and restore procedure. When a Controller node fails but is not permanently lost, it can be recovered by bringing the existing node back online, which is transparent to existing data traffic, or by rebuilding a new Controller node, which is disruptive to existing connections. Factory reset recovery is irreversible and deletes all Controller configuration, requiring the database to be recreated from the configuration archive. When a Service Engine is compromised or rebooted independently, all configurations including private keys and public certificates are wiped from the Service Engine, providing a clean starting state for reconstitution.

Elastic High Availability (Elastic HA) provides fast recovery for individual virtual services following the failure of a Service Engine, redistributing workloads to surviving Service Engines without requiring a full cluster-level recovery event. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, so application services are restored in a defined sequence.

Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling global-level recovery and reconstitution for applications served across multiple sites.

Avi provides configuration backup and restore capabilities for the Controller. A remote backup destination should be specified to protect against non-recoverable Controller cluster failures. The Controller checks and obtains user consent prior to performing a restore operation. After a storage failure requiring a full restore, the Controller is restored from the configuration archive. The restore process follows a defined sequence: cloud discovery, post-restore validation, configuration unblocking, and placement resumption. Post-restore validation verifies the count of restored configuration objects, including clouds and Service Engine groups, confirming that the reconstituted state matches the backup. Restore operations report state information including the operation type, image version, and cluster node name. The Controller logs restore completion events with timestamps, node IP addresses, task status, and success or failure messages for audit trail purposes.

Avi's recovery mechanisms address the application delivery tier. VM-level backup and restore for the Controller and Service Engine VMs, storage-level recovery, and infrastructure reconstitution depend on the underlying VCF platform. See VCF Coverage for those mechanisms.

## Control RC.RP-02

> Recovery actions are selected, scoped, prioritized, and performed

**SCF Controls:** BCD-01, BCD-01.4, BCD-02, BCD-02.1

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations. HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

#### **VMware vDefend (Contributes)**

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

#### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting

both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

#### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) provides technical mechanisms that support an organization's ability to meet defined Recovery Time Objectives and Recovery Point Objectives for database workloads.

Point-in-time recovery. DSM supports point-in-time recovery (PITR) for PostgreSQL, MySQL, and SQL Server databases, allowing administrators to restore data to a specific moment within the configured backup retention period. When initiating a restore, administrators identify a restore point and choose either the most recent timestamp or a user-specified date and time, and the restored database is created as a new database instance. The granularity of recovery is bounded by the configured backup schedule and retention settings, and PITR can only restore data from within the configured retention period. PITR requires the source database to be operational, the required backup to be available, and connectivity to the S3 storage repository. SQL Server PITR can restore onto the same or a different SQL Server cluster. PostgreSQL restore can also target a different DSM control plane by specifying a time value; if the time field is omitted, DSM restores the latest available state. For SQL Server, DSM automatically manages the recovery model based on backup status, using Full Recovery Model when automated backups are enabled and Simple Recovery Model otherwise. PITR may fail or be incomplete if binary log files are missing from the source database, which administrators should account for in operational procedures.

Log backup frequency and RPO. DSM exposes a Log Backup Frequency setting in Advanced Settings with a maximum value of 30 minutes. The log backup frequency is directly related to the achievable RPO for both PostgreSQL and SQL Server databases, and administrators should configure this value based on their RPO requirements.

Database cloning. DSM can clone a MySQL or PostgreSQL database to create an identical database. Cloning is functionally equivalent to PITR to the latest available time and can act as a recovery mechanism when the most recent consistent state is the desired recovery target.

Provider VM recovery and restore duration. DSM documents a recovery procedure for a single Provider VM failure, and the Provider VM restoration must complete fully before proceeding to subsequent recovery steps. This is a relevant consideration for control plane RTO planning. Database restoration duration depends on data volume and underlying infrastructure performance, and administrators should account for this when planning restore operations against an RTO target.

Defining and formally documenting RTO and RPO targets is an organizational process outside DSM's scope. DSM provides the backup, restore, and cloning mechanisms that technical teams configure and test against those targets. Organizations must

establish their RTO and RPO requirements, configure DSM backup policies accordingly, test recovery procedures, and verify operational results align with those targets.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.



## Control RC.RP-03

> The integrity of backups and other restoration assets is verified before using them for restoration

**SCF Controls:** BCD-13, BCD-13.1

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides built-in backup and restoration capabilities for its management components, with access controls, encryption, integrity checks, and platform-level protections that help protect the security of backup operations. Physical hardware protection, environmental controls for backup storage locations, offsite media handling, and network-level controls for backup storage remain organizational responsibilities.

VCF supports file-based and image-based backup methods for its core management components, including VMware vCenter, VCF Operations, and NSX Manager. NSX Manager backup is automatically configured during the VCF bring-up process, while file-based backup jobs for VCF Operations and vCenter must be configured separately. vCenter file-based daily backups are configured through the vCenter Management Interface of each vCenter instance. vCenter file-based backup and restore supports FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB protocols to transfer backup files to and from backup servers. NSX treats backup and restore operations as specific to each appliance, whether it is the Global Manager or the Local Manager, providing isolation between backup datasets. Scheduled backups should be configured to prepare for critical failure of a management component, an upgrade, or a certificate update.

File-based backups of management components, including VCF Operations, vCenter, and VCF Identity Broker, are restored onto newly deployed appliances, providing a clean recovery path. It is advisable to perform a backup of the VCF Identity Broker appliance following any substantial modifications to the identity source configuration, such as when resetting VCF SSO. VCF Operations supports backup and restore of custom and out-of-the-box content, and administrators should use recent backups to restore content or import content to a different environment if incorrect edits occur or data recovery is needed. VCF Operations for Networks supports backup and restore of deployment data for recovery when an existing setup is unrecoverable.

VCF enforces several integrity protections for backup and restoration operations. When restoring a vCenter instance from file-based backup, the administrator must have a valid backup file that matches the same version as the vCenter appliance being restored, and the version retrieved from VCF Operations must be verified against the backup file. Proper sequencing and verification of component restoration is required to maintain dependencies and system integrity. For example, vCenter must be available before proceeding with a restore of VCF Operations, and VCF Operations must be available before restoring vCenter. These dependency checks help protect against incomplete or corrupted restorations.

Role-based access control restricts who can perform backup and recovery operations. Only Admin and Console users can configure backup and restore through public APIs and CLI commands respectively. The No Cryptography Administrator role supports all Administrator privileges except for Cryptographic Operations privileges, which restricts unauthorized changes to encryption settings that protect backup data. The No Cryptography Administrator role can be cloned to create custom roles with only specific Cryptographic Operations privileges, providing granular control over encryption-related backup operations.

VCF provides backup encryption to protect backup data at rest. When backup encryption is enabled, a password must be supplied that is then required to decrypt the file during restoration. The backup process offers the option to encrypt the compressed file before transmission to the backup storage location. vCenter file-based backup files contain the Key Derivation Key, so access controls on the backup storage location are critical to protect both backup integrity and encryption key material. vSAN data-at-rest encryption encrypts everything in the vSAN datastore, including all files, virtual machines, and their corresponding data, which protects data stored in snapshots and replicated copies. vSAN data-in-transit encryption protects data as it moves across hosts and file service inter-host connections in the cluster, securing replication and backup traffic between sites and components.



vSAN Data Protection provides snapshot-based data protection with configurable retention policies and scheduling intervals. Protection groups contain snapshot policies that define retention duration and snapshot scheduling, keeping backup data managed with automated lifecycle policies.

For workload-level backup protection, VMware Kubernetes Service (VKS) includes a data protection capability that installs the data protection extension, selected plugins, and Velero on clusters to enable backup and restore operations. Disabling data protection on a cluster does not remove backups that have already been created, which helps protect against accidental deletion of backup data. For virtual machine workloads, partners and customers can develop backup applications using the Virtual Disk Development Kit (VDDK), and VM Service VMs can be backed up through partner solutions that use VMware vSphere Storage APIs for Data Protection.

### **VMware vDefend (Contributes)**

The Security Services Platform (SSP) component of VMware vDefend enforces a set of pre-restoration compatibility requirements that must be satisfied before a backup can be used for restoration. The SSP version and build number of the target environment must exactly match those used when the backup was taken; a version or build mismatch blocks restoration. Service and messaging FQDNs must also match between the backup environment and the restoration target. Certificate consistency between the backup and restored SSP environments is required to avoid disruption to SSP services and to the NDR Sensors that depend on those certificates. In 9.1, the same NSX instance that was onboarded at the time of the backup must be present at restoration, and the platform must be deployed on the same vSAN datastore as the initial installation using the same build version. Adequate storage capacity on the SFTP server must be verified before activating recurring backups.

SSP Backup History displays backup status and shows "Completed" when a backup operation succeeds, providing visibility into whether a valid backup is available before a restore is attempted. When restore operations fail, SSP surfaces the failure state for troubleshooting. Specific failure modes include inability to locate disk objects referenced by the backup (which prevents restore pods from attaching required volumes), database schema dependency violations such as foreign key constraints referencing tables that do not exist, and permission or data integrity issues surfaced by `pg_restore` during database restoration.

VMware vDefend does not perform cryptographic hash verification or digital signature validation of backup file contents. Organizations requiring cryptographic assurance of backup data integrity must implement those controls at the SFTP server or storage layer.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) contributes to protecting backup and restoration software through access controls, configuration backup, encrypted communications, and data separation capabilities.

Role-based access control restricts who can manage protection groups, recovery plans, and replication configurations. Predefined roles limit the operations each user can perform on the backup and recovery infrastructure. Certain roles that allow running commands on the PNR Server should be assigned only to trusted administrator-level users.

All communications between PNR and VMware vCenter instances are secured over TLS connections. The appliance management interface verifies certificates during configuration, protecting the recovery infrastructure from unauthorized access and man-in-the-middle attacks during management operations.

PNR backup configuration supports setting a datastore path, enabling or disabling the backup scheduler, configuring the retention period, and scheduling backup frequency and time. Administrators should take regular backups of PNR services so that the service can be restored into another management domain if needed. The PNR Configuration Import/Export Tool backs up and transfers protection and recovery settings including protection groups, recovery plans, and site mappings. For configuration import and export, PNR supports service account authentication as an alternative to remote vCenter credentials, with the service account path stored at a configurable file location such as `/opt/vmware/etc/dr-backup/secrets/file`.

vSAN snapshots and replication provides a native, integrated snapshot-based protection solution for VMs running on vSAN datastores, managed through the vSphere Client. Snapshot-based protection enables recovery from operational failures or

ransomware attacks using locally stored snapshots, while replication to a peer site through PNR protects against site-level failures. PNR allows administrators to manage protection groups, view available snapshots, and perform VM operations including restore and clone from existing snapshots. vSphere Replication can be configured to create and retain point-in-time snapshots on the recovery site, maintaining protected copies separate from the source environment.

Physical protection of backup and restoration hardware, environmental controls for storage locations, and offsite media handling are organizational responsibilities outside PNR's scope.

### **VMware Avi Load Balancer (Contributes)**

Avi Load Balancer provides mechanisms to protect both its backup software and the configuration backup data produced for the Avi Controller.

Backup data is protected through passphrase-based encryption. The `backup_passphrase` parameter in the Controller's backup configuration encrypts all sensitive fields in the backup file. The Controller also stores sensitive information encrypted in a local database, with encryption keys protected during backups when a passphrase is included. The passphrase is required at restore time to decrypt the file. Avi documentation recommends storing backups in a safe external location and labeling them clearly with version and date.

Backup files transferred to remote storage use Secure Copy Protocol (SCP), providing encrypted transport for data in transit. Remote server authentication uses SSH user credentials. Backups can also be sent to S3-compatible object storage, with authentication via access key and secret key credentials or an attached IAM role. The Controller supports independent configuration for local backups, stored on the Controller with a configurable retention count, and remote server backups. For single-node Controller deployments and for recovery from complete VM or disk failure, enabling periodic external configuration backups is mandatory. The documentation recommends designating a remote backup destination to protect against non-recoverable Controller cluster failures.

In VCF-integrated deployments, VCF Operations is used to configure the external backup server and storage path for Avi Load Balancer backups. By default, Avi backups are stored on the same server where VCF Operations appliance backups are stored. When restoring a Controller cluster from backup, the new instance must remain synchronized with the VCF Operations lifecycle.

The Controller's backup scheduler automates backup operations. On-demand backups are available via the CLI export command or the REST API. The CLI `show backups` command lists available backup files for verification. Prior to any upgrade operation, the Controller verifies that a backup has been taken.

Before applying a configuration backup, the Avi Controller performs pre-restore checks: validation of the backup configuration, verification of Service Engine attachment, system configuration validation, patch verification, backup configuration version compatibility with the current Controller version, confirmation that all file objects referenced in the backup are present on the Controller, FIPS mode verification (the FIPS mode of the backup configuration must match the controller environment), and available cluster disk space. The Controller also obtains user consent before proceeding with a restore operation. Both CLI (`import` command with `keep_uuid` option) and REST API restore methods are available, each requiring the backup passphrase. After restore, the Controller performs post-restore validation that verifies the successful restoration of configuration objects, including counts of restored Clouds and ServiceEngineGroups.

The hardware infrastructure hosting the Avi Controller VMs and Service Engine VMs is protected by VCF platform mechanisms, including vSphere High Availability, which provides failover protection against hardware and operating system outages. Protection of the underlying compute, storage, and network hardware is addressed by VCF.

Organizations must define backup storage policy, establish off-site or remote custody arrangements for backup media, and conduct periodic restore testing. These organizational governance processes are outside Avi's scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

## Control RC.RP-04

> Critical mission functions and cybersecurity risk management are considered to establish post-incident operational norms

**SCF Controls:** BCD-01, BCD-01.4, BCD-02, BCD-02.1

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations. HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

### **VMware vDefend (Contributes)**

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting

both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) provides technical mechanisms that support an organization's ability to meet defined Recovery Time Objectives and Recovery Point Objectives for database workloads.

Point-in-time recovery. DSM supports point-in-time recovery (PITR) for PostgreSQL, MySQL, and SQL Server databases, allowing administrators to restore data to a specific moment within the configured backup retention period. When initiating a restore, administrators identify a restore point and choose either the most recent timestamp or a user-specified date and time, and the restored database is created as a new database instance. The granularity of recovery is bounded by the configured backup schedule and retention settings, and PITR can only restore data from within the configured retention period. PITR requires the source database to be operational, the required backup to be available, and connectivity to the S3 storage repository. SQL Server PITR can restore onto the same or a different SQL Server cluster. PostgreSQL restore can also target a different DSM control plane by specifying a time value; if the time field is omitted, DSM restores the latest available state. For SQL Server, DSM automatically manages the recovery model based on backup status, using Full Recovery Model when automated backups are enabled and Simple Recovery Model otherwise. PITR may fail or be incomplete if binary log files are missing from the source database, which administrators should account for in operational procedures.

Log backup frequency and RPO. DSM exposes a Log Backup Frequency setting in Advanced Settings with a maximum value of 30 minutes. The log backup frequency is directly related to the achievable RPO for both PostgreSQL and SQL Server databases, and administrators should configure this value based on their RPO requirements.

Database cloning. DSM can clone a MySQL or PostgreSQL database to create an identical database. Cloning is functionally equivalent to PITR to the latest available time and can act as a recovery mechanism when the most recent consistent state is the desired recovery target.

Provider VM recovery and restore duration. DSM documents a recovery procedure for a single Provider VM failure, and the Provider VM restoration must complete fully before proceeding to subsequent recovery steps. This is a relevant consideration for control plane RTO planning. Database restoration duration depends on data volume and underlying infrastructure performance, and administrators should account for this when planning restore operations against an RTO target.

Defining and formally documenting RTO and RPO targets is an organizational process outside DSM's scope. DSM provides the backup, restore, and cloning mechanisms that technical teams configure and test against those targets. Organizations must

establish their RTO and RPO requirements, configure DSM backup policies accordingly, test recovery procedures, and verify operational results align with those targets.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.



## Control RC.RP-05

> The integrity of restored assets is verified, systems and services are restored, and normal operating status is confirmed

**SCF Controls:** BCD-12

**Aggregate Coverage:** Meets

### VCF (Contributes)

VCF provides built-in capabilities for secure recovery and reconstitution of infrastructure and workloads to a known state after a disruption, compromise, or failure. These capabilities span compute-level high availability, storage-level data protection, structured backup and restore workflows for management components, and disaster recovery across sites.

At the compute layer, vSphere High Availability (HA) automatically restarts virtual machines on surviving hosts following a physical machine failure, restoring workloads to their prior operational state. vSphere Fault Tolerance provides continuous availability for individual workloads in the event of a hardware failure with no data loss or downtime. Proactive HA supports maintenance mode as a remediation method, allowing the platform to respond to hardware degradation indicators. On TPM-equipped hosts, VMware ESX supports a Secure ESX Configuration recovery key that is required to restore the host configuration following TPM failure, TPM reset, motherboard replacement, or TPM device replacement; administrators can retrieve and store this key using `esxcli system settings encryption recovery list` and should keep it in a secure, off-host location.

At the storage layer, vSAN fault domains distribute data according to storage policy so that it remains available even when hardware failures occur. vSAN stretched clusters extend a cluster across two availability zones, providing site-level resiliency against the loss of an entire availability zone. When one site becomes unavailable, the surviving site continues operations, and with local fault protection enabled, the cluster can perform repairs on missing or broken components in the available site. vSAN Data Protection uses native snapshots stored locally on a vSAN Express Storage Architecture (ESA) cluster to support point-in-time recovery from operational failures or ransomware attacks. Changed Block Tracking (CBT) tracks changes on disk sectors, enabling incremental backups through VADP-integrated partner backup solutions.

For large-scale disruptions, Application Disaster Recovery enables failover to a secondary site, with data replication so recovery options exist in the event of catastrophic failure. Disaster recovery can also be implemented for fleet-level components, covering the management plane itself. VCF documentation recommends planning and testing disaster recovery strategies regularly to validate that recovery time objectives (RTO) and recovery point objectives (RPO) can be met.

VCF includes structured backup and restore workflows for its management components. Administrators create a series of backup jobs that capture the state of related components, including VCF Operations, NSX Manager, and VMware vCenter, at a common point in time. VCF Operations backup is configured to take a backup on state change. VMware vCenter supports both file-based and image-based backup methods. The file-based restore procedure is a two-stage operation: stage 1 deploys a new vCenter appliance, and stage 2 transfers data from the backup location to that appliance; the restored appliance operates in non-HA mode, so vCenter High Availability must be reconfigured after recovery completes. Simultaneous backups of VCF Operations fleet management component nodes support restoring the nodes to a logically consistent state, so further integrity remediation is not required after a restore. The platform also recommends backing up the management domain vCenter and VCF Identity Broker appliance following any substantial modifications to the identity source configuration, such as a VCF SSO reset, to preserve a known-good recovery point.

For VMware vCenter specifically, the vCenter Management API provides a unified restore process that handles multiple vCenter components in a single operation. After a file-based or image-based restore, the reconciliation API checks whether vCenter partners in embedded linked mode are available, synchronizes vCenter data and services with the partners, and runs vCenter services. The appliance recovery API exposes a restore client interface for programmatic restore operations, supporting automation of recovery workflows.

VCF Operations supports image-based backup and restore as a recovery process for single node, primary node, replica node, data node, and collector failures. VCF Operations for Networks supports backup and restore of its deployment data to enable recovery when the existing setup is unrecoverable. VCF Operations HCX provides backup and restore operations through its



appliance management interface, and its Mobility Groups support workload migration with state tracking, retry capabilities, and reverse migration from destination back to the original source.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS), vSphere namespaces, and VCF Services consumption, extends recovery and reconstitution capabilities to containerized workloads and self-service deployments. At the Kubernetes control-plane level, ReplicaSets and Deployment controllers continuously monitor pod health and reschedule workloads to healthy nodes when pods or nodes fail. Liveness probes detect application-level failures and trigger container restarts; readiness probes gate traffic until a workload recovers from transient faults or overloads. These self-healing mechanisms operate without manual intervention for transient failures. Pod Disruption Budgets allow administrators to define minimum availability constraints that the platform respects during voluntary disruptive actions such as node upgrades or certificate rotations, so those operations proceed without taking down an entire service.

VKS clusters support structured backup and restore through VKS Cluster Management and Velero-based mechanisms. VKS Cluster Management backup operations can capture an entire cluster or a subset of data resources, and restore operations allow the operator to specify the scope of resources to recover. Restore operations include file system backups by default; CSI volume snapshots can be optionally selected for restoration. CSI Volume Snapshots deliver crash-consistent backups with support for block mode and file system mode, incremental backups, deduplication, compression, and encryption, and provide a resilient safety net for VKS clusters when primary storage infrastructure fails. CloneFromSnapshot custom resources expose a status.phase field that tracks restore progress through multiple phases, giving operators visibility into the state of ongoing recovery operations. The Velero plugin for vSphere supports backup and restore of vSphere pods, and VADP-based backup partner solutions can perform backup, full restore, and registration of VM Service VMs on a Supervisor.

Deploying workloads across multiple failure zones using the Cluster API defines worker nodes across multiple failure domains with automatic healing rules that reschedule workloads when a zone becomes unavailable. Replicating control plane components across at least three failure zones limits the impact of a single-zone failure on the Kubernetes control plane itself. For VM Service workloads, the IaaS Services Console and Local Consumption Interface provide a Resources tab where users can create snapshots with optional memory capture and guest file system quiescence, and can revert a VM to a prior snapshot to restore it to a known state.

Deployment rollback is available natively in Kubernetes through Deployments with revision history, allowing administrators to return to a previous known-good revision when a newly deployed version fails. The Harness CI/CD Supervisor Service extends this with automated rollback capabilities that can revert to a previous stable state when deployment failures are detected.

Immutable infrastructure patterns supported by Kubernetes, combined with infrastructure-as-code stored in version control, provide a reproducible mechanism for reconstituting a cluster to a known, authorized state. Every change to the declared state is recorded in version control, and the cluster can be rebuilt from that record after a compromise or failure. VKS Cluster Management Policy Insights expose Sync signals that indicate when policy definitions fail to propagate from the management plane to the targeted VKS cluster estate, helping operators detect and remediate policy drift before it affects recovery posture.

Restore operations require that the target infrastructure be in place before a restore can proceed. VCF documentation recommends implementing a consistent backup strategy to safeguard the infrastructure against unforeseen disruptions and to support effective disaster recovery.

### **VMware vDefend (Contributes)**

VMware vDefend contributes to secure recovery and reconstitution through backup and restore capabilities for its own security infrastructure, and through disaster recovery features that maintain security policy continuity across site failover events.

The Security Services Platform provides backup and restore functionality, accessible through the System > Backup and Restore interface, that allows recovery of a platform instance to its previous configuration when the current instance is in a non-recoverable state. The backup scope includes the full system inventory: tokens, Bare Metal servers, and Bare Metal server interfaces are captured as part of inventory backup, and required certificates from the backup server are restored automatically during the restore process. The platform must be in a healthy state to perform backup operations; backup and

restore cannot proceed when the platform is unhealthy. Certificate consistency between backup and restored Security Services Platform environments must be maintained to avoid NDR Sensor disruptions. Backup and restore operations enter a failed state after 30 minutes if internal services are restarted manually or due to failure. Administrators should back up the Security Services Platform before performing scale-out operations, and Bare Metal Service operations (onboarding, offboarding, or upgrading Bare Metal servers) should not be performed while backup or restore is in progress.

The Security Services Platform can be deployed on vSAN stretched configurations, which supports recovery from site failures and reduces recovery time at the infrastructure level.

For disaster recovery scenarios, NSX Federation maintains security posture during workload migration and site failover by propagating Distributed Firewall rules, security groups, and microsegmentation policies across multiple sites. When workloads fail over from a protected site to a recovery site, the vDefend security policies governing east-west traffic at the destination site are already in place. vSphere HA can be configured to handle host-level failures affecting Security Services Platform appliances.

The broader recovery of compute infrastructure, storage, virtual machines, and application workloads to a known state is handled by other VCF components such as Protection and Recovery, vSAN Data Protection, vSphere Replication, and vCenter backup and restore.

### **VCF Protection and Recovery (Meets)**

VCF Protection and Recovery (PNR) provides mechanisms for secure recovery and reconstitution of virtual machine workloads to a known state after a disruption, compromise, or failure.

Recovery is organized through protection groups and recovery plans. Protection groups define which virtual machines are protected, while recovery plans orchestrate the sequence of steps required to recover those workloads at the recovery site. The state of a recovery plan is determined by the states of the protection groups within it, and the plan state governs which operations are permitted at each stage of the DR lifecycle. Recovery plans support two primary modes: planned migration for orderly, scheduled failover, and disaster recovery for unplanned site failures. A single recovery plan can also be configured to serve both disaster recovery and cyber recovery operations, allowing organizations to maintain consistent recovery procedures across different incident types.

Recovery plan testing is a built-in capability. Recovery plans should be tested before use for planned migration or disaster recovery to validate their functionality. This confirms that the recovery process will bring protected virtual machines online at the recovery site and that inventory mappings correctly place workloads on the appropriate networks, storage, and compute resources.

Cyber Recovery extends reconstitution capabilities with an Isolated Recovery Environment (IRE) designed for compromise scenarios such as ransomware incidents. The IRE provides a dedicated, isolated segment of the recovery environment that blocks direct private network connections from production, allowing compromised workloads to be analyzed and validated before being returned to production. Cyber Recovery transitions virtual machines through a controlled sequence of states, including Entering validated, Validated, Staging, and Staged, to prepare them for recovery. This state-based workflow supports data integrity validation prior to production restoration.

Recovery plan compliance checks verify that protection groups are actively replicating, that sufficient point-in-time snapshots are available for each virtual machine in the plan, and that all workflow steps can execute without conflict. Continuous compliance monitoring provides warnings when VM configuration status deviates from expected state.

The Configuration Import/Export Tool enables administrators to export PNR server configuration data, including inventory mappings, placeholder datastores, advanced settings, array manager configurations, and protection group definitions. This capability supports configuration backup and reconstitution of the PNR environment itself after a failure or migration.

PNR integrates with VCF Operations for recovery plan lifecycle visibility. The Recovery Plans Details dashboard shows the current phase of the DR lifecycle, including whether a plan is ready, whether a test is in progress, and whether incomplete recovery or cleanup operations require attention. PNR also supports recovery of VCF Automation and VCF Operations

services: when a disaster event affects the management domain containing these services, PNR enables service recovery in another management domain.

All communications between PNR and VMware vCenter instances use TLS certificates and private keys. The PNR Appliance supports importing server certificates signed by a certificate authority to establish secure communications across both protected and recovery sites.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) provides several mechanisms that support the secure recovery and reconstitution of database services to a known state following a disruption, compromise, or failure.

For backup-based recovery, DSM supports point-in-time recovery (PITR), which restores a backup to a newly created database VM. During the restore operation, the administrator can specify the database name, choose the target datastore location, and configure management settings. DSM supports restoring backups from either local or cloud-compatible (S3-compatible) storage, with restoration permitted to any point in time within the configured backup retention period. When restoring a deleted database, DSM's Archives tab allows users to access databases with retained backups and create a new database VM from a selected restore point, including options to restore to the most recent available timestamp or a custom point in time. PITR coverage extends across PostgreSQL, MySQL, and SQL Server database engines. For SQL Server, DSM automatically manages the database recovery model based on backup status, using Full Recovery for databases with automated backups enabled and Simple Recovery otherwise. Cloning a MySQL or PostgreSQL database is functionally equivalent to PITR to the latest available time, giving operators an additional path for rebuilding a known-good database instance. For failed clusters, DSM supports restoration to a different cluster with the option to target either the latest available time or a specific custom restore point.

For active recovery and failover of PostgreSQL databases, DSM provides a multi-site disaster recovery deployment model in which a secondary instance replicates from the primary across sites. When a failover is needed, DSM provides a switchover workflow that reverses the roles of instances, redirecting the secondary to become the new primary and restoring the database service to a fully operational state. DSM also provides a switchover workflow for failback, allowing operators to reverse instance roles again after the primary site is restored. DSM requires trust validation of the new primary database certificate when redirecting secondary instances during disaster recovery switchover, and operators with the DSM user role must manually establish trust between primary and secondary instances by retrieving the Certificate Authority from the primary and adding it to the Provider VM that will host the secondary. For backup-location certificates, DSM supports a Trust On First Use (TOFU) configuration that extracts and trusts certificates for specific backup locations, and at least one backup location must be configured with a trusted root certificate when a data service policy requires or allows automated backups. DSM also preserves the backing virtual machines of removed database nodes in an idle state until an instance is promoted again, maintaining infrastructure capacity for disaster recovery operations.

The resiliency of the DSM Provider Appliance itself is supplied by the underlying VCF platform (see VCF Coverage); DSM relies on vSphere High Availability to restart the appliance on another host in the event of a host failure, and does not add a separate management-plane HA mechanism. If a DSM provider restore fails for any reason, the documented procedure is to re-deploy the appliance and then follow the recovery procedure again rather than re-attempting the restore workflow on the same appliance.

DSM tracks recovery operations through its audit and operations interfaces. Event logs record Provider Restore Success events with timestamps, allowing operators to verify that recovery operations completed. Restore operation progress is visible in the Operations tab and Operations view, and a new entry appears in the Databases view table when a restore completes. To support integrity of recovery artifacts, the DSM Consumption Operator deployment includes Signature Verification of packages.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) provides application-layer recovery and reconstitution mechanisms at the load balancing and application delivery tier.

The Avi Controller cluster can be deployed across two availability zones, with defined failure scenarios and documented recovery actions for each zone-loss case. Availability zones should be configured based on fault domains associated with shared power supplies, shared networking devices, or other common infrastructure to reduce the risk of virtual service unavailability. When the cluster enters manual recovery state following a failure or compromise, Avi automatically revokes all Service Engine secure channel credentials and causes Service Engines to reboot themselves, halting all application traffic delivery. This returns the data plane to a controlled, known state. Service Engines that subsequently re-establish connectivity to a recovered Controller node reconfigure themselves automatically to connect only to that node.

If all three Controller cluster nodes are permanently unavailable, recovery must be performed using a backup and restore procedure. When a Controller node fails but is not permanently lost, it can be recovered by bringing the existing node back online, which is transparent to existing data traffic, or by rebuilding a new Controller node, which is disruptive to existing connections. Factory reset recovery is irreversible and deletes all Controller configuration, requiring the database to be recreated from the configuration archive. When a Service Engine is compromised or rebooted independently, all configurations including private keys and public certificates are wiped from the Service Engine, providing a clean starting state for reconstitution.

Elastic High Availability (Elastic HA) provides fast recovery for individual virtual services following the failure of a Service Engine, redistributing workloads to surviving Service Engines without requiring a full cluster-level recovery event. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, so application services are restored in a defined sequence.

Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling global-level recovery and reconstitution for applications served across multiple sites.

Avi provides configuration backup and restore capabilities for the Controller. A remote backup destination should be specified to protect against non-recoverable Controller cluster failures. The Controller checks and obtains user consent prior to performing a restore operation. After a storage failure requiring a full restore, the Controller is restored from the configuration archive. The restore process follows a defined sequence: cloud discovery, post-restore validation, configuration unblocking, and placement resumption. Post-restore validation verifies the count of restored configuration objects, including clouds and Service Engine groups, confirming that the reconstituted state matches the backup. Restore operations report state information including the operation type, image version, and cluster node name. The Controller logs restore completion events with timestamps, node IP addresses, task status, and success or failure messages for audit trail purposes.

Avi's recovery mechanisms address the application delivery tier. VM-level backup and restore for the Controller and Service Engine VMs, storage-level recovery, and infrastructure reconstitution depend on the underlying VCF platform. See VCF Coverage for those mechanisms.

## Control RC.RP-06

> The end of incident recovery is declared based on criteria, and incident-related documentation is completed

**SCF Controls:** IRO-02, IRO-09

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as `callerId`, `propagateAlertUpdates`, `retrieveIncidentUpdates`, and `incidentReopenState`, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

### **VMware vDefend (Contributes)**

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.



Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

#### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) provides audit logging and alerting capabilities that support situational awareness during cybersecurity and data protection incidents. The System Audit Events view, accessible through the DSM administrative interface, records administrative actions with structured fields: Source (the user identifier or "System" when DSM initiates the operation), Event Type (the category of audited operation), Status (the outcome), Component (the DSM subsystem involved), Event Time (UTC), and Event Details (operation-specific context). These records give administrators a traceable account of actions within DSM that can be reviewed during an incident investigation to establish what occurred, when it occurred, and who or what initiated it. Audit event data can be exported from DSM in CSV or XLSX format using the ACTIONS drop-down menu in the System Audit Events view, supporting the documentation and reporting requirements of an incident response process.

DSM generates alerts for specific categories of security-relevant events, including authentication failures, backup and restore corruptions, and certificate errors. Administrators can enable or disable alerts for database operation failures through the "Enable Alerts for DB Operation Failure" setting. DSM also raises metrics-based alerts when resource thresholds are exceeded, and surfaces resolution suggestions alongside active database alerts in the UI to support investigation and remediation. Alerts are classified at multiple severity levels, including CRITICAL and WARNING. When alerts fire, DSM transmits notifications to configured webhooks with structured data including the alert name, alert level, trigger timestamp, current service status, and database cluster identifier and name.

Webhook configuration in DSM includes direct integration with ServiceNow. DSM populates the ServiceNow short\_description, description, close\_code, and close\_notes fields with alert and cluster context, allowing DSM alert data to be routed into an existing incident management workflow without additional middleware. This reduces the manual steps required to open and populate incident tickets when DSM detects a security-relevant event.

DSM can also be monitored using VCF Operations for troubleshooting and status visibility, extending operational awareness beyond the DSM interface.

DSM's contribution to this control is through audit trail visibility, configurable alerting with severity classification, external notification forwarding, and ServiceNow integration. The broader requirement to document incident status end-to-end, assign incidents to responsible parties, track them through resolution, and formally report outcomes to stakeholders requires an organizational incident response process and dedicated case management tooling. DSM provides the data feeds, event notifications, and ServiceNow integration that support that process but does not replace it.



## VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER\_HEALTH\_DEGRADED, POOL\_HEALTH\_DEGRADED, and VS\_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

## Control RS

> The incident response plan is executed in coordination with relevant third parties once an incident is declared. Incident reports are triaged and validated. Incidents are categorized and prioritized. Incidents are escalated or elevated as needed. The criteria for initiating incident recovery are applied. [Withdrawn: Incorporated into RS.MA-02] [Withdrawn: Incorporated into RS.MA-02, RS.MA-03, RS.MA-04] Analysis is performed to establish what has taken place during an incident and the root cause of the incident. [Withdrawn: Moved to RS.MA-03] [Withdrawn: Moved to ID.RA-08] Actions performed during an investigation are recorded, and the records' integrity and provenance are preserved. Incident data and metadata are collected, and their integrity and provenance are preserved. An incident's magnitude is estimated and validated. [Withdrawn: Incorporated into PR.AT-01] Internal and external stakeholders are notified of incidents. Information is shared with designated internal and external stakeholders. [Withdrawn: Incorporated into RS.MA-01, RS.MA-04] [Withdrawn: Incorporated into RS.CO-03] Incidents are contained. Incidents are eradicated. [Withdrawn: Incorporated into ID.RA-06] [Withdrawn: Incorporated into RS.MA-01] [Withdrawn: Incorporated into ID.IM-03, ID.IM-04] [Withdrawn: Incorporated into ID.IM-03]

**SCF Controls:** IRO-01, IRO-02, IRO-04, IRO-07, IRO-09, IRO-10

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as `callerId`, `propagateAlertUpdates`, `retrieveIncidentUpdates`, and `incidentReopenState`, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic

access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

### **VMware vDefend (Contributes)**

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) provides audit logging and alerting capabilities that support situational awareness during cybersecurity and data protection incidents. The System Audit Events view, accessible through the DSM administrative interface, records administrative actions with structured fields: Source (the user identifier or "System" when DSM initiates the operation), Event Type (the category of audited operation), Status (the outcome), Component (the DSM subsystem involved), Event Time (UTC), and Event Details (operation-specific context). These records give administrators a traceable account of actions within DSM that can be reviewed during an incident investigation to establish what occurred, when it occurred, and who or what initiated it. Audit event data can be exported from DSM in CSV or XLSX format using the ACTIONS drop-down menu in the System Audit Events view, supporting the documentation and reporting requirements of an incident response process.

DSM generates alerts for specific categories of security-relevant events, including authentication failures, backup and restore corruptions, and certificate errors. Administrators can enable or disable alerts for database operation failures through the "Enable Alerts for DB Operation Failure" setting. DSM also raises metrics-based alerts when resource thresholds are exceeded, and surfaces resolution suggestions alongside active database alerts in the UI to support investigation and remediation. Alerts are classified at multiple severity levels, including CRITICAL and WARNING. When alerts fire, DSM transmits notifications to configured webhooks with structured data including the alert name, alert level, trigger timestamp, current service status, and database cluster identifier and name.

Webhook configuration in DSM includes direct integration with ServiceNow. DSM populates the ServiceNow short\_description, description, close\_code, and close\_notes fields with alert and cluster context, allowing DSM alert data to be routed into an existing incident management workflow without additional middleware. This reduces the manual steps required to open and populate incident tickets when DSM detects a security-relevant event.

DSM can also be monitored using VCF Operations for troubleshooting and status visibility, extending operational awareness beyond the DSM interface.

DSM's contribution to this control is through audit trail visibility, configurable alerting with severity classification, external notification forwarding, and ServiceNow integration. The broader requirement to document incident status end-to-end, assign incidents to responsible parties, track them through resolution, and formally report outcomes to stakeholders requires an organizational incident response process and dedicated case management tooling. DSM provides the data feeds, event notifications, and ServiceNow integration that support that process but does not replace it.

### **VMware Avi Load Balancer (Contributes)**

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER\_HEALTH\_DEGRADED, POOL\_HEALTH\_DEGRADED, and VS\_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

## Control RS.AN

> [Withdrawn: Incorporated into RS.MA-02] [Withdrawn: Incorporated into RS.MA-02, RS.MA-03, RS.MA-04] Analysis is performed to establish what has taken place during an incident and the root cause of the incident [Withdrawn: Moved to RS.MA-03] [Withdrawn: Moved to ID.RA-08] Actions performed during an investigation are recorded, and the records' integrity and provenance are preserved Incident data and metadata are collected, and their integrity and provenance are preserved An incident's magnitude is estimated and validated

**SCF Controls:** IRO-02, IRO-08

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.



For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

### **VMware vDefend (Contributes)**

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.



### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

### **VMware Avi Load Balancer (Contributes)**

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER\_HEALTH\_DEGRADED, POOL\_HEALTH\_DEGRADED, and VS\_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

### Control RS.AN-03

> Analysis is performed to establish what has taken place during an incident and the root cause of the incident

**SCF Controls:** IRO-13

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control RS.AN-06

> Actions performed during an investigation are recorded, and the records' integrity and provenance are preserved

**SCF Controls:** IRO-02, IRO-08, IRO-09

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as `callerId`, `propagateAlertUpdates`, `retrieveIncidentUpdates`, and `incidentReopenState`, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

### **VMware vDefend (Contributes)**

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

#### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) provides audit logging and alerting capabilities that support situational awareness during cybersecurity and data protection incidents. The System Audit Events view, accessible through the DSM administrative interface, records administrative actions with structured fields: Source (the user identifier or "System" when DSM initiates the operation), Event Type (the category of audited operation), Status (the outcome), Component (the DSM subsystem involved), Event Time (UTC), and Event Details (operation-specific context). These records give administrators a traceable account of actions within DSM that can be reviewed during an incident investigation to establish what occurred, when it occurred, and who or what initiated it. Audit event data can be exported from DSM in CSV or XLSX format using the ACTIONS drop-down menu in the System Audit Events view, supporting the documentation and reporting requirements of an incident response process.

DSM generates alerts for specific categories of security-relevant events, including authentication failures, backup and restore corruptions, and certificate errors. Administrators can enable or disable alerts for database operation failures through the "Enable Alerts for DB Operation Failure" setting. DSM also raises metrics-based alerts when resource thresholds are exceeded, and surfaces resolution suggestions alongside active database alerts in the UI to support investigation and remediation. Alerts are classified at multiple severity levels, including CRITICAL and WARNING. When alerts fire, DSM transmits notifications to configured webhooks with structured data including the alert name, alert level, trigger timestamp, current service status, and database cluster identifier and name.

Webhook configuration in DSM includes direct integration with ServiceNow. DSM populates the ServiceNow short\_description, description, close\_code, and close\_notes fields with alert and cluster context, allowing DSM alert data to be routed into an existing incident management workflow without additional middleware. This reduces the manual steps required to open and populate incident tickets when DSM detects a security-relevant event.

DSM can also be monitored using VCF Operations for troubleshooting and status visibility, extending operational awareness beyond the DSM interface.

DSM's contribution to this control is through audit trail visibility, configurable alerting with severity classification, external notification forwarding, and ServiceNow integration. The broader requirement to document incident status end-to-end, assign incidents to responsible parties, track them through resolution, and formally report outcomes to stakeholders requires an organizational incident response process and dedicated case management tooling. DSM provides the data feeds, event notifications, and ServiceNow integration that support that process but does not replace it.

## VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER\_HEALTH\_DEGRADED, POOL\_HEALTH\_DEGRADED, and VS\_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.



## Control RS.AN-07

> Incident data and metadata are collected, and their integrity and provenance are preserved

**SCF Controls:** IRO-08

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides technical capabilities that support digital forensic investigations and evidence preservation, though the organization retains responsibility for chain-of-custody procedures, legal compliance, and formal forensic processes.

VCF Operations includes a Forensics Widget that can be added to custom dashboards for operational analysis during investigations. The widget displays data based on configurable filter sections, where each section progressively filters objects and passes the results to the next section. Administrators can search for and select specific objects in the environment on which to base the widget data, using text filters and tag-based filtering to narrow scope. The widget supports comparing data across two time periods, which is useful when investigating changes in environment behavior around a suspected incident. After adding the Forensics Widget to a dashboard, administrators should configure its options to tailor the output to the specific investigative needs of the dashboard users.

For evidence capture, VMware vCenter supports VM snapshots that record the memory, disk, and settings state of a virtual machine at a specific point in time. Reverting to a snapshot returns all of these to the exact state they were in when the snapshot was taken, making snapshots useful for preserving system state during an investigation. VM files (VMDKs, memory snapshots, log files) can also be collected and copied without powering down the workload, allowing incident responders to capture volatile and non-volatile evidence without altering the running state of the original workload. vSAN extends snapshot capabilities with immutable snapshots through its data protection service. An immutable vSAN snapshot is a read-only copy of data that cannot be modified or deleted, even by an attacker with administrative privileges. Once immutability mode is enabled on a protection group, it cannot be disabled by an administrator. This property helps protect forensic evidence from tampering. The `vmkfstools` command on VMware ESX hosts supports a `--chainConsistent` option that checks the entire virtual disk snapshot chain for corrupted links or invalid parent-child relationships, allowing investigators to verify the structural integrity of snapshot evidence before relying on it. VCF Automation exposes day-2 resource actions (Suspend, Create Snapshot, Delete Snapshot, Power On) through its API, allowing forensic preservation steps to be invoked programmatically as part of an incident response workflow. Day-2 action policies can be configured to entitle specific roles to perform snapshot actions and can be scoped at the organization level.

Audit logging across VCF components provides the evidentiary foundation that forensic investigators rely on. VCF Operations audit events capture operational details that facilitate security and compliance audits and provide information for conducting security forensics. The audit log feature in VCF Operations for Networks is always on and captures CRUD operations, login/logout events, and actions from the API, UI, and CLI. VCF Automation creates audit logs for reportable actions including catalog deployments, template operations, and day-2 actions. NSX audit logs use structured syslog fields with an `audit="true"` marker to identify security-related events, and a separate `nsx-audit-write.log` captures modification events. These audit records, combined with event logs from vCenter, ESX hosts, and VCF Operations, create a detailed trail of administrative actions, configuration changes, authentication events, and system state transitions. ESX hosts maintain audit records as a separately configurable logging feature from general event logs; these audit records must be explicitly activated and are not enabled by default, a step auditors should verify when assessing the forensic readiness of the platform.

For centralized evidence preservation, VCF components support log forwarding to external SIEM platforms via syslog. NSX remote logging supports TLS-encrypted transport with certificate verification. vSphere Supervisor similarly supports TLS-encrypted syslog forwarding with CA-based certificate verification. Forwarding logs to external systems with their own retention and integrity controls helps organizations maintain an independent, tamper-resistant record of events for forensic analysis.

Organizations deploying VCF should establish documented forensic procedures that define how to collect, handle, and preserve digital evidence from the virtualized environment. This includes defining who has authority to initiate evidence

collection, how VM snapshots and log exports are stored to maintain integrity, and how the chain of custody is recorded from initial collection through analysis and potential legal proceedings. VCF provides the raw technical capabilities for evidence capture, audit logging, and secure log forwarding, but the procedural controls, trained personnel, legal chain-of-custody documentation, evidentiary handling procedures, and specialized forensic tooling required to maintain a legally defensible chain of custody are organizational responsibilities.

### **VMware vDefend (Contributes)**

VMware vDefend provides several technical capabilities that support digital forensic investigations by capturing, preserving, and exporting network-level evidence. While vDefend does not manage chain-of-custody documentation or legal evidentiary procedures, it generates and retains the forensic artifacts that investigators rely on during incident analysis.

vDefend IDS/IPS captures and stores packet capture (PCAP) files associated with detected intrusion events, which can be exported in TAR format for detailed analysis and forensic investigation. IDS/IPS also provides a filestore capability that stores matched files to disk when a signature rule is triggered, and stores TLS/SSL certificates on disk for forensic analysis and threat investigation. These artifacts preserve the raw network traffic, file evidence, and certificate data surrounding a security event. The NDR Sensor extends this by recording raw network packets associated with detected intrusion events through its IDS Packet Capture capability.

Malware Prevention generates detailed analysis reports for both file-based and process-based (fileless) malware detections. The File Analysis Report and Process Analysis Report each support downloading screenshots and PCAP files from the inspection analysis. These artifacts document the behavior observed during sandboxing and can serve as evidence of malicious activity during a forensic investigation.

Network Detection and Response (NDR) correlates individual detections into campaigns using correlation rules that link related events across workloads. Campaign data includes detection types, identified threats, affected workloads, and mapped MITRE ATT&CK tactics. This correlated view helps investigators reconstruct the sequence and scope of an attack, connecting individual events into a coherent narrative. NDR campaign correlation rules link file transfer detections with command-and-control events, IDS drive-by events with subsequent malicious file transfers, and custom IDS signature events sharing the same signature ID on the same workload. Security Intelligence also detects and categorizes suspicious events using MITRE tactics and techniques, recording the number of occurrences during the selected time period.

The Distributed Firewall (DFW) and Gateway Firewall both support per-rule logging. Administrators can attach log labels to firewall rules, which tag matched traffic in log output for easier parsing in a log aggregator. These timestamped, attributable records of firewall rule hits provide evidence of network access patterns during and around a security incident. Security Explorer tracks compute entities that were in the inventory during the selected time period and separately identifies entities deleted from inventory, helping investigators establish a forensic timeline of asset activity.

The Security Services Platform supports role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The Auditor role allows forensic investigators to review security data without the ability to modify it, supporting the integrity of the evidence under review. The Security Operator role monitors security systems and responds to security incidents.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) supports forensic investigation and evidence preservation through event logging, security-related audit trails, and protection group state tracking. PNR records operational information in log files that exclude sensitive information such as private keys and passwords, making these logs suitable for sharing with forensic investigators or external auditors without exposing credentials. PNR also logs certificate verification error messages in security-related log files, providing an audit trail of authentication events relevant to incident investigation.

PNR captures Info-level events when users include or remove datastores in protection groups, recording protection group membership changes that contribute to a chronological record of administrative activity. PNR tracks collection state for each protection group to indicate which operational phase the group is in, including modifying, testing, replicating, or recovering,

which gives investigators context for reconstructing administrative actions during an incident. The VCF Operations Recovery Plans Dashboard exposes PNR operational state for monitoring and after-action review.

Organizations performing forensic investigation should forward PNR log files to a centralized log aggregation system such as VCF Log Management to preserve evidence integrity beyond the appliance's local log retention. Chain of custody documentation, evidence handling procedures, and integration with broader incident response workflows remain organizational responsibilities outside PNR's scope.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control RS.AN-08

> An incident's magnitude is estimated and validated

**SCF Controls:** IRO-02.4

**Aggregate Coverage:** Contributes

### VMware vDefend (Contributes)

VMware vDefend provides structured classification and prioritization mechanisms for security detection events within the network security domain.

Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help security teams prioritize response actions. Security Intelligence also categorizes detected events by MITRE adversarial tactics and techniques, recording occurrence counts during the selected time period, which provides additional context for classification decisions.

Network Detection and Response (NDR) assigns impact scores to campaigns, with higher scores indicating higher priority for triage and response. Detection events are classified into impact levels; events with an impact score from 1 to 24 are classified as Informational, indicating the detected activity is not essentially malicious. NDR calculates impact scores from Confidence and Severity values, and contextual scoring logic may promote some Informational detections to a higher impact level. NDR also provides filtering of the unified event list by detection impact score using checkboxes, which allows security teams to focus investigation on higher-priority detections.

The Security Services Platform (SSP) Campaign view includes a Blueprint tab that visualizes correlated security events and key actors, supporting investigation of multi-stage incidents. Security teams can investigate individual threat events and correlated campaigns through the SSP interface to assess impact, identify root causes, and take appropriate mitigation actions.

VMware vDefend includes an Intelligent Assist triage capability: when responding to security incidents, security teams can select a Targeted Strategy for surgical, safer remediation with potentially lower effectiveness, or a Comprehensive Strategy for broader remediation with potentially lower safety. This capability helps match remediation scope to assessed incident severity.

IDS/IPS events are classified by severity level (Informational, Low, Medium, High, and Critical), and vDefend IDS/IPS follows a prioritized event-handling approach under memory pressure, dropping non-critical severity data (Low and Informational) first, followed by Medium, then High and Critical severity events, with packet captures dropped only as a last resort. This built-in severity hierarchy reflects the product's internal classification model.

The broader incident classification process, including establishing organizational incident categories, defining triage protocols, and coordinating business continuity actions, remains an organizational function that extends beyond network-layer detection capabilities.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control RS.CO

> [Withdrawn: Incorporated into PR.AT-01] Internal and external stakeholders are notified of incidents. Information is shared with designated internal and external stakeholders. [Withdrawn: Incorporated into RS.MA-01, RS.MA-04] [Withdrawn: Incorporated into RS.CO-03]

**SCF Controls:** IRO-02, IRO-02.5, IRO-06.1, IRO-09, IRO-10, IRO-10.2, IRO-10.4

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as `callerId`, `propagateAlertUpdates`, `retrieveIncidentUpdates`, and `incidentReopenState`, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require

zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

### **VMware vDefend (Contributes)**

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) provides audit logging and alerting capabilities that support situational awareness during cybersecurity and data protection incidents. The System Audit Events view, accessible through the DSM administrative interface, records administrative actions with structured fields: Source (the user identifier or "System" when DSM initiates the operation), Event Type (the category of audited operation), Status (the outcome), Component (the DSM subsystem involved), Event Time (UTC), and Event Details (operation-specific context). These records give administrators a traceable account of actions within DSM that can be reviewed during an incident investigation to establish what occurred, when it occurred, and who or what initiated it. Audit event data can be exported from DSM in CSV or XLSX format using the ACTIONS drop-down menu in the System Audit Events view, supporting the documentation and reporting requirements of an incident response process.

DSM generates alerts for specific categories of security-relevant events, including authentication failures, backup and restore corruptions, and certificate errors. Administrators can enable or disable alerts for database operation failures through the "Enable Alerts for DB Operation Failure" setting. DSM also raises metrics-based alerts when resource thresholds are exceeded, and surfaces resolution suggestions alongside active database alerts in the UI to support investigation and remediation. Alerts are classified at multiple severity levels, including CRITICAL and WARNING. When alerts fire, DSM transmits notifications to configured webhooks with structured data including the alert name, alert level, trigger timestamp, current service status, and database cluster identifier and name.

Webhook configuration in DSM includes direct integration with ServiceNow. DSM populates the ServiceNow short\_description, description, close\_code, and close\_notes fields with alert and cluster context, allowing DSM alert data to be routed into an existing incident management workflow without additional middleware. This reduces the manual steps required to open and populate incident tickets when DSM detects a security-relevant event.

DSM can also be monitored using VCF Operations for troubleshooting and status visibility, extending operational awareness beyond the DSM interface.



DSM's contribution to this control is through audit trail visibility, configurable alerting with severity classification, external notification forwarding, and ServiceNow integration. The broader requirement to document incident status end-to-end, assign incidents to responsible parties, track them through resolution, and formally report outcomes to stakeholders requires an organizational incident response process and dedicated case management tooling. DSM provides the data feeds, event notifications, and ServiceNow integration that support that process but does not replace it.

#### **VMware Avi Load Balancer (Contributes)**

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER\_HEALTH\_DEGRADED, POOL\_HEALTH\_DEGRADED, and VS\_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

## Control RS.CO-02

> Internal and external stakeholders are notified of incidents

**SCF Controls:** IRO-02, IRO-10, IRO-10.2, IRO-10.4

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as `callerId`, `propagateAlertUpdates`, `retrieveIncidentUpdates`, and `incidentReopenState`, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

### **VMware vDefend (Contributes)**

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

#### **VMware Avi Load Balancer (Contributes)**

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER\_HEALTH\_DEGRADED, POOL\_HEALTH\_DEGRADED, and VS\_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

## Control RS.CO-03

> Information is shared with designated internal and external stakeholders [Withdrawn: Incorporated into RS.CO-03]

**SCF Controls:** IRO-02, IRO-10, IRO-10.2, IRO-10.4

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

### **VMware vDefend (Contributes)**

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.



Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

#### **VMware Avi Load Balancer (Contributes)**

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER\_HEALTH\_DEGRADED, POOL\_HEALTH\_DEGRADED, and VS\_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

## Control RS.MA

> The incident response plan is executed in coordination with relevant third parties once an incident is declared. Incident reports are triaged and validated. Incidents are categorized and prioritized. Incidents are escalated or elevated as needed. The criteria for initiating incident recovery are applied. [Withdrawn: Incorporated into RS.MA-02] [Withdrawn: Incorporated into RS.MA-02, RS.MA-03, RS.MA-04] [Withdrawn: Moved to RS.MA-03] [Withdrawn: Incorporated into RS.MA-01, RS.MA-04] [Withdrawn: Incorporated into RS.MA-01]

**SCF Controls:** IRO-02, IRO-04, IRO-07

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

### **VMware vDefend (Contributes)**

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

### **VMware Avi Load Balancer (Contributes)**

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER\_HEALTH\_DEGRADED, POOL\_HEALTH\_DEGRADED, and VS\_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

## Control RS.MA-01

> The incident response plan is executed in coordination with relevant third parties once an incident is declared [Withdrawn: Incorporated into RS.MA-01, RS.MA-04] [Withdrawn: Incorporated into RS.MA-01]

**SCF Controls:** IRO-02, IRO-02.5, IRO-04, IRO-07, IRO-10

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require



zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

### **VMware vDefend (Contributes)**

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

#### **VMware Avi Load Balancer (Contributes)**

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER\_HEALTH\_DEGRADED, POOL\_HEALTH\_DEGRADED, and VS\_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

## Control RS.MA-02

> Incident reports are triaged and validated [Withdrawn: Incorporated into RS.MA-02] [Withdrawn: Incorporated into RS.MA-02, RS.MA-03, RS.MA-04]

**SCF Controls:** IRO-02, IRO-04

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require

zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

### **VMware vDefend (Contributes)**

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

#### **VMware Avi Load Balancer (Contributes)**

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER\_HEALTH\_DEGRADED, POOL\_HEALTH\_DEGRADED, and VS\_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.



## Control RS.MA-03

> Incidents are categorized and prioritized [Withdrawn: Incorporated into RS.MA-02, RS.MA-03, RS.MA-04] [Withdrawn: Moved to RS.MA-03]

**SCF Controls:** IRO-02.4

**Aggregate Coverage:** Contributes

### VMware vDefend (Contributes)

VMware vDefend provides structured classification and prioritization mechanisms for security detection events within the network security domain.

Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help security teams prioritize response actions. Security Intelligence also categorizes detected events by MITRE adversarial tactics and techniques, recording occurrence counts during the selected time period, which provides additional context for classification decisions.

Network Detection and Response (NDR) assigns impact scores to campaigns, with higher scores indicating higher priority for triage and response. Detection events are classified into impact levels; events with an impact score from 1 to 24 are classified as Informational, indicating the detected activity is not essentially malicious. NDR calculates impact scores from Confidence and Severity values, and contextual scoring logic may promote some Informational detections to a higher impact level. NDR also provides filtering of the unified event list by detection impact score using checkboxes, which allows security teams to focus investigation on higher-priority detections.

The Security Services Platform (SSP) Campaign view includes a Blueprint tab that visualizes correlated security events and key actors, supporting investigation of multi-stage incidents. Security teams can investigate individual threat events and correlated campaigns through the SSP interface to assess impact, identify root causes, and take appropriate mitigation actions.

VMware vDefend includes an Intelligent Assist triage capability: when responding to security incidents, security teams can select a Targeted Strategy for surgical, safer remediation with potentially lower effectiveness, or a Comprehensive Strategy for broader remediation with potentially lower safety. This capability helps match remediation scope to assessed incident severity.

IDS/IPS events are classified by severity level (Informational, Low, Medium, High, and Critical), and vDefend IDS/IPS follows a prioritized event-handling approach under memory pressure, dropping non-critical severity data (Low and Informational) first, followed by Medium, then High and Critical severity events, with packet captures dropped only as a last resort. This built-in severity hierarchy reflects the product's internal classification model.

The broader incident classification process, including establishing organizational incident categories, defining triage protocols, and coordinating business continuity actions, remains an organizational function that extends beyond network-layer detection capabilities.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control RS.MA-04

> Incidents are escalated or elevated as needed [Withdrawn: Incorporated into RS.MA-02, RS.MA-03, RS.MA-04]  
[Withdrawn: Incorporated into RS.MA-01, RS.MA-04]

**SCF Controls:** IRO-02, IRO-04, IRO-07

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require

zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

### **VMware vDefend (Contributes)**

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

#### **VMware Avi Load Balancer (Contributes)**

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER\_HEALTH\_DEGRADED, POOL\_HEALTH\_DEGRADED, and VS\_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

## Control RS.MA-05

> The criteria for initiating incident recovery are applied

**SCF Controls:** BCD-01, BCD-01.5

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations. HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

### **VMware vDefend (Contributes)**

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting



both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

#### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

## Control RS.MI

> Incidents are contained Incidents are eradicated [Withdrawn: Incorporated into ID.RA-06]

**SCF Controls:** IRO-01, IRO-02, IRO-04

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

### **VMware vDefend (Contributes)**

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

#### **VMware Avi Load Balancer (Contributes)**

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER\_HEALTH\_DEGRADED, POOL\_HEALTH\_DEGRADED, and VS\_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

## Control RS.MI-01

> Incidents are contained

**SCF Controls:** IRO-02

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as `callerId`, `propagateAlertUpdates`, `retrieveIncidentUpdates`, and `incidentReopenState`, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.



VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

### **VMware vDefend (Contributes)**

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

#### **VMware Avi Load Balancer (Contributes)**

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER\_HEALTH\_DEGRADED, POOL\_HEALTH\_DEGRADED, and VS\_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

## Control RS.MI-02

> Incidents are eradicated

**SCF Controls:** IRO-02

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as `callerId`, `propagateAlertUpdates`, `retrieveIncidentUpdates`, and `incidentReopenState`, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

### **VMware vDefend (Contributes)**

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

### **VMware Avi Load Balancer (Contributes)**

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER\_HEALTH\_DEGRADED, POOL\_HEALTH\_DEGRADED, and VS\_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.



